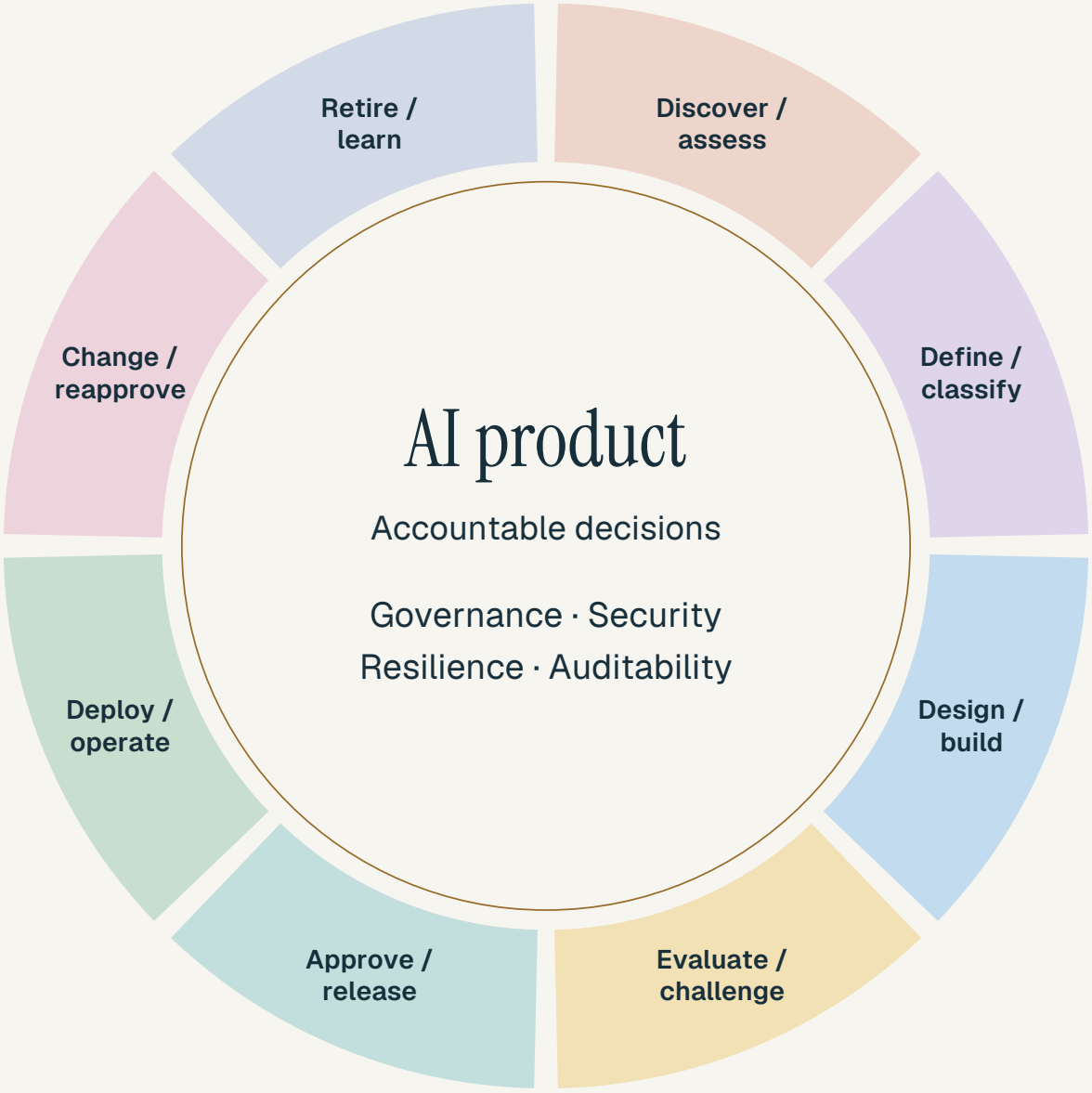
The AI Software Development Lifecycle for Banking

Engineering Governed, Secure,
Resilient, and Auditable AI Products



Re-enter at the affected decision

Navigation is not a mandatory waterfall.

Imitiyaz Basha K M

The AI Software Development Lifecycle for Banking

Engineering Governed, Secure, Resilient, and Auditable AI Products

First Edition

Imitiyaz Basha K M

© 2026 Imitiyaz Basha K M. All rights reserved.

First Edition

All Fictional Bank cases and numerical results are constructed teaching examples. They do not report an actual bank, customer, deployment, test, financial benefit or regulatory outcome.

Companion resources: https://github.com/Imitiyaz/ai-sdlc

Author profile: https://www.linkedin.com/in/imitiyaz

About the Author

Imitiyaz Basha K M is a technology engineering leader with more than 18 years of experience in banking. He has delivered digital banking, cloud, API and DevSecOps initiatives for financial institutions including Standard Chartered, Citi, Credit Suisse, DBS and Affin Bank.

His work spans the software development lifecycle, from requirements and solution architecture through engineering, security, testing and release to production operations. He has led cross-functional teams across regional banking programmes, managing complex delivery commitments and relationships with stakeholders and vendors. He has also led an AI/ML proof of concept exploring enterprise use cases.

This book draws on that experience. It reflects his practical approach to building AI products in banking: bringing engineering, security and delivery discipline together, with clear accountability for how those products are governed and operated.

Imitiyaz holds a master’s degree in Computer Applications from Anna University, India. His professional certifications include Project Management Professional (PMP), TOGAF Enterprise Architecture Practitioner, Certified Cloud Security Professional (CCSP) and AWS Certified AI Business Strategist.

Preface: Why This Book Exists

Artificial intelligence is often introduced through a model demonstration. Banking institutions must operate something larger: a product with purpose, users, data, software, permissions, providers, people, controls, evidence, and consequences. The challenge is not to add an AI approval form to a conventional project. It is to extend software engineering and technology-risk management so learned behavior and delegated authority remain governable across a complete lifecycle.

This book offers that lifecycle. It begins with strategy and an intended use, moves through architecture, data, models, retrieval, agents, engineering, evaluation, security, release, and operation, and ends with change, assurance, transformation, and retirement. Its central framework is the **evidence bundle**: the connected record that shows what the institution intended, built, evaluated, approved, operated, observed, changed, and learned.

The treatment is global rather than tied to one jurisdiction. Selected EU, UK, U.S., Singapore, and international sources are used as bounded examples. Their applicability depends on entity, activity, model or system, date, and jurisdiction. Readers must obtain qualified local advice and apply their own policies, risk appetite, delegations, thresholds, and records obligations.

The Reader Promise

By the end of this book, a reader should be able to take a proposed banking AI use case and produce a bounded purpose statement, risk and authority assessment, architecture boundary, evaluation plan, approval evidence bundle, operating-control plan, and change or retirement decision. The book is designed to help an institution answer not only “Can this model perform?” but also “Should this product operate, under whose authority, with what evidence, and what will cause it to stop or re-enter review?”

Executive Brief: Decisions Before Scale

The governing idea

The bank does not operate a model in isolation. It operates a product: a purpose, workflow, people, software, data, knowledge, models, tools, providers, permissions, controls, operations and consequences. The product—not the model—is therefore the primary unit of accountability.

Every material release should be represented by an evidence bundle. The bundle connects what the institution intended, built, evaluated, approved, deployed, operated, observed, changed and ultimately retired. It is not one large document. It is a controlled set of linked records with an identifiable product and release.

Every change is a change to a claim. A new model, prompt, corpus, data source, tool, permission, population, jurisdiction, action, provider or fallback can change what the bank believes the product will do. Change control asks which claim changed and which evidence must be refreshed.

Eight executive decisions

- **Purpose and value:** Which service problem is being addressed, what credible alternative exists, and what evidence would justify continued investment or scale?
- **Use boundary:** Which users, populations, data, outputs, actions, channels and jurisdictions are permitted or prohibited?
- **Authority:** Is the product informing, recommending, preparing, deciding, acting or orchestrating—and where is institutional authorization enforced?
- **Consequence and control intensity:** What can happen to customers, employees, money, records, markets or critical services, and how reversible is the effect?
- **Evidence:** Can the bank identify the exact operating release and reconstruct its purpose, dependencies, evaluation, approval, incidents and changes?
- **Operation and resilience:** Can the underlying service continue, contain harm, reconcile state, remediate affected parties and exit a provider dependency?
- **Accountability:** Who owns the product, operating service, data, controls, review, residual-risk decision and customer remedy?
- **Re-entry or stop:** Which event, drift, incident, exception, provider change or accumulated change requires restriction, renewed review or retirement?

What must be true before scale

Scale is not justified by a successful demonstration. Decision-makers should see evidence that the purpose remains bounded; the intended and prohibited uses are enforceable; the product/release inventory is accurate; severe evaluation failures are resolved or explicitly conditioned; operational and customer-impact measures are defined; fallback and remediation have realistic capacity; provider concentration and exit have been tested; review capacity is available; and conditions can be enforced technically and monitored.

When a necessary fact is unavailable, the decision should identify the evidence gap. It may lead to narrower scope, a conditional pilot, more research, another design or stop. A blank field is not evidence, and an approval meeting does not make it so.

Board question set

- Which operating products have material customer, financial, conduct, security or resilience consequence?
- Which products can act, transact, communicate externally or materially influence a decision?
- Are any high-consequence releases operating with expired conditions, overdue findings or unavailable evidence?
- Can management trace each operating product to an accountable owner, approved release, evaluation conclusion and non-AI fallback?
- Which providers, base models, clouds, regions, data services or specialist teams create correlated exposure?
- Can affected populations and records be reconstructed and remediated after an incident?
- Do reported benefits include defined denominators, costs, adverse outcomes and uncertainty?
- Is reviewer and operational capacity sufficient for the portfolio?
- Which products should be narrowed, paused or retired?
- What material change since the last report requires a new decision?

Illustrative risk-appetite pattern

An institution can state the purposes and authorities it is willing to permit, the consequences or data classes that require escalation, the activities it will not undertake, the minimum evidence before pilot and scale, the authority and duration for exceptions, the concentration and resilience boundaries it will accept, and the customer-remediation standard it expects. This book does not provide numeric thresholds or delegations; they require institutional and jurisdictional decisions.

Executive dashboard—what to request

Request a portfolio view of exposure; exact operating releases; decisions due; severe findings and incidents; evidence gaps; exception age; third-party concentration; fallback and exit readiness; value and customer outcomes; and review/operations capacity. Each tile should reveal its definition, denominator, owner, uncertainty and underlying record. Avoid unexplained composite “AI trust” or maturity scores.

Five leadership questions, linked to the eight decisions

The one-page brief below condenses the eight executive decisions into five questions for a leadership discussion. It does not replace those decisions, the board question set or the evidence model. Read each question through the underlying product and release records; a summary cannot supply a missing authorization or prove that the service is ready.

Table P.1 — Leadership question and existing executive decisions

Leadership question	Existing executive decisions	Records to bring to the discussion
X1: Why this product, and within which boundaries?	E1 purpose/value; E2 use boundary; E3 authority; E4 consequence/control intensity	Purpose, alternative, permitted use and control-intensity assessment
X2: What supports an accountable release?	E3 authority; E5 evidence	Exact release, evaluation/challenge conclusion, permission boundary and decision conditions
X3: Can the service operate and recover safely?	E6 operation/resilience; E7 accountability	Operating observations, contingency exercise, capacity assumptions, reconciliation and remediation owners
X4: When must we reapprove, exit or retire?	E8 re-entry/stop, with the continuity/exit decisions	Changed claim, qualification of alternatives, exit exercise, cutover and residual duties
X5: Are legal rights and accountability protected?	E7 accountability, with the scoped legal/complaints treatment	Applicability and duty record, complaint/claims links, lawful evidence custody and actual decision authority

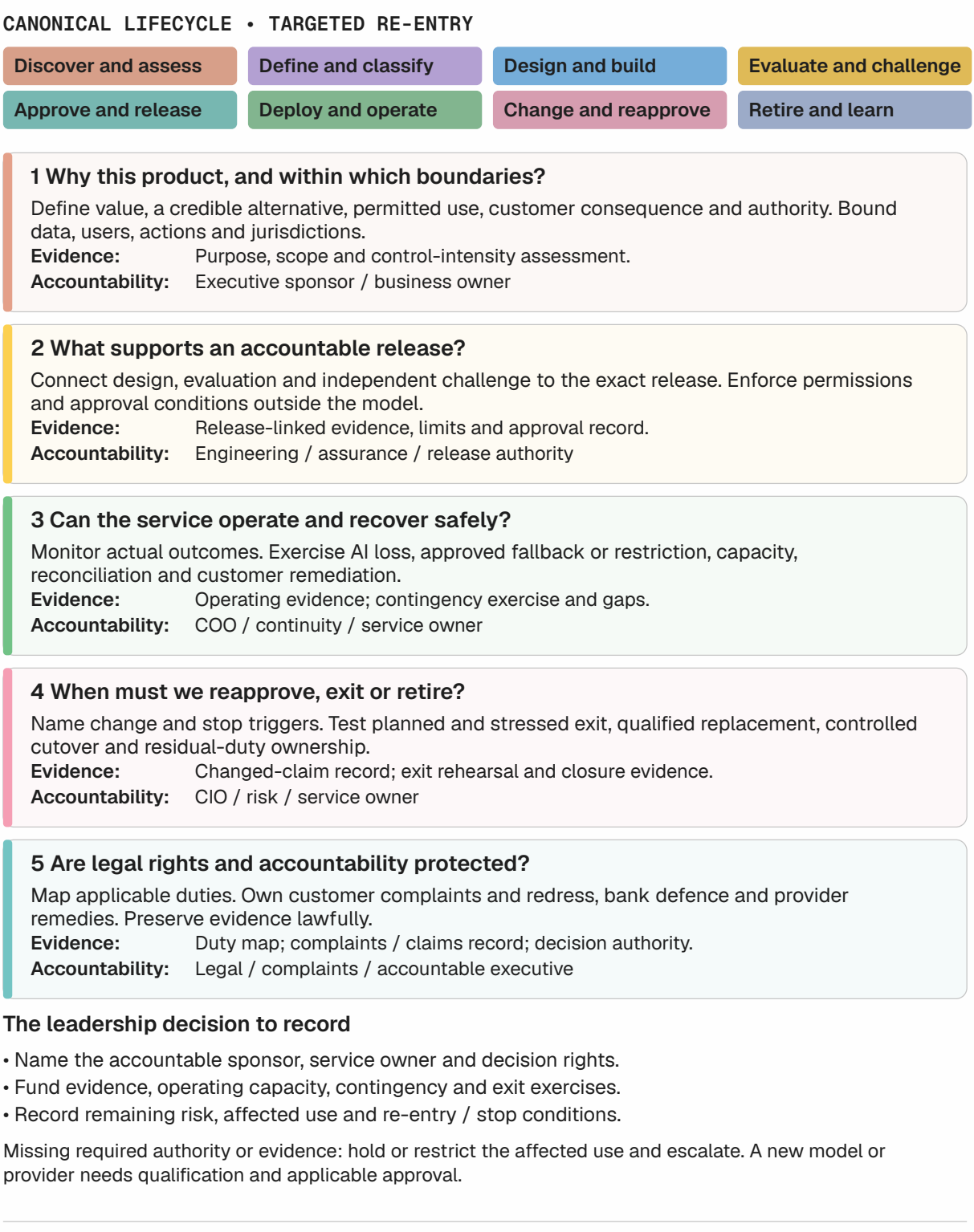
E1–E8 refer to the eight decisions above; X1–X5 refer to the five questions in the brief. This is a descriptive reading aid, not a scored crosswalk or an additional artifact taxonomy. The C-level and functional titles in the diagram are illustrative. Local delegations determine who actually decides, prepares or challenges a particular use.

Leadership must resource the capability it expects. A continuity route needs credible staffing, controls and service capacity; an exit option needs qualification, rights, technical work and exercises. Request the resource assumptions, unresolved constraints and decision required alongside the plan. Keep planned arrangements, authorized scope, exercise observations and actual operating outcomes distinct. When evidence or authority is missing, record whether the affected use is held, narrowed, restricted or retired; the brief does not transfer approval to a new model or provider.

The operating detail is in §§24.9 and 25.5–25.6; the legal-review method is in §8.4, rights and provider capability in §25.4, and customer review/remediation in §§19.6 and 23.6. §28.5 and Appendix I explain how to present the supporting evidence without turning the portfolio into a composite readiness score. See Figure P.1.

Figure P.1 — AI SDLC: the leadership decisions

A one-page brief for banking executives and accountable service leaders. Govern the banking product and its consequences. Link every operating release to its purpose, evidence, authority and accountable owner.



Five leadership questions connect to the eight executive decisions. Roles and ownership are illustrative; local delegations determine authority. No readiness result is claimed. Figure P.1. AI SDLC: the leadership decisions. Author synthesis. Role titles are illustrative; they do not assign authority or establish compliance or readiness.

The First-Hour Path

Use this short route to prepare one bounded decision. The timings are reading estimates, not a claim that governance can be completed in an hour.

- **10 minutes:** §§1.1 and 1.8 — identify the product boundary and the decision phases.

The single lifecycle in §1.8 has eight decision phases: discover/assess, define/classify, design/build, evaluate/challenge, approve/release, deploy/operate, change/reapprove and retire/learn. Chapters follow those decisions; Appendix F supplies the detailed crosswalk. A phase does not necessarily create a distinct permission state.

- **15 minutes:** §§2.2 and 2.7 — follow one filled evidence trail and its failed condition.
- **10 minutes:** §4.4 — assess the six factors, especially action authority and reversibility.
- **10 minutes:** §20.5 — decide whether a condition is enforceable before exposure.
- **15 minutes:** §23.10 or §25.8 — inspect one incident or disruption decision; use Appendix A to record the next question, owner and evidence due.

Follow-up reading depends on the use. Read Chapters 5–8 before an investment or scope decision; Chapters 9–20 for design and assurance; Chapters 21–26 for operation and recovery; and Chapters 27–30 for portfolio and domain responsibilities. Appendices A–J contain the minimum record fields; no companion pack is needed to start.

How to Use This Book

The book follows a bank's decision path.

- **Parts I–II** frame the governed product, value, use, risk, and accountability.
- **Part III** designs architecture, data, knowledge, models, prompts, tools, and agents.
- **Part IV** builds, evaluates, challenges, secures, and validates the product.
- **Part V** releases, observes, responds, sustains, changes, and retires it.
- **Part VI** embeds the lifecycle in operating model, assurance, transformation, and domain playbooks.

Readers may follow the whole sequence or use a pathway. The chapters identify the decisions leaders must make and the evidence practitioners need to support them.

Audience Pathways

Table P.2 — Reader and recommended route

Reader	Recommended route	Primary decision
Board and executive leadership	1–5, 7–8, 20, 25, 27–30	What exposure, accountability, value, and evidence should the institution accept?
Business and product owners	1–8, 16, 19–23, 26, 30	What use is authorized, and how will it deliver and recover?
Architecture and engineering	1–2, 4, 6, 9–18, 21–26	How should the complete product be built and operated?
Data, model, and evaluation teams	2, 6–7, 10–12, 16–20, 22, 26	What claim, data, method, and evidence support the use?
Security, privacy, legal, compliance, and risk	2–4, 6–8, 10–14, 17–20, 23, 25, 28, 30	Which boundaries and obligations require challenge or escalation?
Operations, resilience, and service management	2, 8–9, 14, 18, 21–26, 28	How will the service be observed, contained, recovered, and retired?
Validation and audit	2, 6–8, 12, 16–20, 22–23, 25–28	Can the claim and material decisions be independently reconstructed?

Evidence Labels and Reading Conventions

Author synthesis identifies a framework or pattern developed for this book. Sources may support constituent concepts without validating the framework. **Illustrative scenario** identifies a fictional composite. **Proposed control** describes a design option, not evidence that a control is implemented or effective. **Evidence gap** identifies information that cannot be supplied responsibly without local data, lawful source access, or specialist judgment. **Jurisdiction-specific** material must be read within its stated scope and date.

Chapter endnotes cite primary sources and peer-reviewed research where factual or high-risk propositions require them. The consolidated bibliography records source status and limitations. No source converts an illustrative framework into a universal mandate.

Disclaimer and Jurisdictional Boundaries

This book is educational and does not provide legal, regulatory, accounting, investment, cybersecurity, privacy, model-validation, audit, or other professional advice. It does not establish compliance, safety, security, fairness, resilience, or control effectiveness. Laws, regulations, supervisory expectations, standards, provider services, and technical practices change. Readers must verify current sources, determine applicability, use qualified professionals, and follow their institution’s approvals.

References to regulations and supervisory materials are selective. They do not cover every amendment, implementing act, local rule, interpretation, or transition. References to voluntary frameworks and community guidance do not make them binding. Fictional scenarios are not recommendations to deploy a described system.

Figure P.2 provides the compact overview; Figure P.3 provides the full lifecycle map.

Contents

About the Author 4
Preface: Why This Book Exists 5
The Reader Promise 6
Executive Brief: Decisions Before Scale 7
The First-Hour Path 12
How to Use This Book 13
Audience Pathways 13
Evidence Labels and Reading Conventions 14
Disclaimer and Jurisdictional Boundaries 14
List of Figures 17
List of Tables 18
Part I — Why AI Changes the Lifecycle 24
Chapter 1 — Why AI Changes the Software Development Lifecycle 25
Chapter 2 — The AI System as an Evidence Bundle 48
Chapter 3 — Banking Context: Value, Trust, and Consequence 71
Chapter 4 — AI Types, Autonomy, and Control Intensity 83
Part II — Strategy, Use, Risk and Accountability 100
Chapter 5 — Strategy and the Business Value Hypothesis 101
Chapter 6 — Intended Use, Prohibited Use, and Acceptance Criteria 124
Chapter 7 — Risk Classification, Criticality, and Materiality 136
Chapter 8 — Governance, Accountability, and Decision Rights 147
Part III — Architecture and Design 163
Chapter 9 — Enterprise Architecture and Platform Foundations 164
Chapter 10 — Data Engineering and Data Governance for AI 174
Chapter 11 — Knowledge Engineering and Retrieval-Augmented Generation 184
Chapter 12 — Model Selection, Sourcing, and the Model Supply Chain 193
Chapter 13 — Prompt, Context, Workflow, and Tool Design 205
Chapter 14 — Agentic Systems and Delegated Authority 215
Part IV — Engineering, Evaluation and Assurance 225
Chapter 15 — Software Engineering for AI-Enabled Products 226
Chapter 16 — Evaluation Strategy and Quality Engineering 236
Chapter 17 — Red Teaming, Abuse Testing, and Safety Validation 246
Chapter 18 — Security Engineering and Threat Modeling 254
Chapter 19 — Privacy, Fairness, Explainability, and Human Oversight 263

Chapter 20 — Quality Gates, Independent Review, and Model Validation 276
Part V — Release, Operation and Change 285
Chapter 21 — Release, Deployment, Rollback, and Fallback 286
Chapter 22 — Runtime Observability and Continuous Evaluation 294
Chapter 23 — AI Incident Response and Customer Remediation 303
Chapter 24 — Performance, Cost, Reliability, Capacity, and Sustainability 312
Chapter 25 — Operational Resilience and Third-Party Dependencies 319
Chapter 26 — Change, Continuous Improvement, and Retirement 338
Part VI — Institutionalization and Domain Use 347
Chapter 27 — The AI SDLC Operating Model 348
Chapter 28 — Auditability, Assurance, and Executive Oversight 357
Chapter 29 — Maturity and Transformation Roadmap 368
Chapter 30 — Domain Playbooks and Decision Patterns 375
Appendix A — AI Product Intake and Value Hypothesis 389
Appendix B — Intended-Use and Prohibited-Use Specification 391
Appendix C — AI Product Classification and Control-Intensity Worksheet 393
Appendix D — Architecture and Trust-Boundary Review 395
Appendix E — Evaluation Plan and Result Record 397
Appendix F — Release Manifest, Gate, and Exception Record 399
Appendix G — Runtime, Incident, and Remediation Record 409
Appendix H — Third-Party and Exit Assessment 411
Appendix I — Executive Oversight and Assurance View 417
Appendix J — Domain Playbook Canvas 419
Illustration Descriptions 421
Glossary 471
Bibliography 475
Index 483

List of Figures

Figure P.1 AI SDLC: the leadership decisions 11
Figure P.2 AI SDLC in a nutshell 22
Figure P.3 AI SDLC: the full lifecycle 23
Figure 1.1 A lifecycle of accountable decisions 41
Figure 2.1 One release identity, federated evidence 54
Figure 2.2 Five evidence classes; eight artifact families 64
Figure 4.1 Where can this product have consequences? 84
Figure 4.2 Six factors that shape control intensity 89
Figure 4.3 Put enforcement outside the model 95
Figure 5.1 Evidence must bridge each benefit claim 105
Figure 5.2 Qualified impact and effort matrix 114
Figure 5.3 Initiative investment verdicts 121
Figure 6.1 A specified use has an explicit boundary 125
Figure 7.1 Classification determines the review route 140
Figure 8.1 Separate preparation, challenge and authority 150
Figure 8.2 Legal review across the AI lifecycle 154
Figure 10.1 Entitlement must precede context assembly 180
Figure 12.1 A manifest for the model-supply decision 202
Figure 13.1 Authorize the exact action candidate 208
Figure 14.1 Agent autonomy stays inside granted authority 219
Figure 15.1 Permission bands are separately granted 232
Figure 16.1 An evaluation conclusion needs an argument 237
Figure 18.1 Locate the control; record the observed test 258
Figure 19.1 Oversight must be capable of changing an outcome 270
Figure 20.1 Say precisely which status the evidence supports 281
Figure 21.1 Approval, deployment and operation are different states 287
Figure 22.1 Make every operating signal actionable 299
Figure 23.1 Restore service and remedy harm on separate tracks 307
Figure 25.1 Different services can share one failure domain 321
Figure 25.2 Legal rights, provider terms and exit capability 324
Figure 25.3 AI disruption and business continuity 327
Figure 25.4 Planned and stressed AI exit readiness 329
Figure 26.1 A change must remain inside an approved envelope 344
Figure 27.1 Accountability stays with named roles 350
Figure 28.1 Build the dossier from one challenged event 358
Figure 28.2 An executive view should lead to a decision 366
Figure 30.1 Carry the policy assistant’s evidence through change 382

List of Tables

Table P.1 Leadership question and existing executive decisions 10
Table P.2 Reader and recommended route 13
Table 1.1 Working term and meaning in this book 26
Table 1.2 Existing discipline or lifecycle and primary concern 28
Table 1.3 Conventional engineering and AI-specific extensions 29
Table 1.4 Evaluation layer and example claim 32
Table 1.5 Phase and decision 43
Table 1.6 Figure description and controlled record meaning 45
Table 1.7 Stage and authority and data boundary 46
Table 2.1 Field and purpose 50
Table 2.2 Evidence classes and the questions they answer 52
Table 2.3 Evidence class and a1 charter 59
Table 2.4 Phase and decision 61
Table 2.5 Condition and authorized evidence route 62
Table 2.6 Role and action and record 63
Table 2.7 Artifact family and fictional release evidence 67
Table 2.8 Record and version and evidence 69
Table 3.1 Banking domain and illustrative ai pattern 73
Table 3.2 Domain / consequence and primary review questions 76
Table 3.3 Lens and status and scope 78
Table 3.4 Provision and actor/use to screen 79
Table 4.1 Authority and control-intensity questions 88
Table 4.2 Factor and guiding question 90
Table 4.3 Threat or failure class and entry point 93
Table 5.1 Decision and illustrative value evidence 103
Table 5.2 Cost category and monthly amount 106
Table 5.3 Use-case intake checklist 108
Table 5.4 Gate and decision question 109
Table 5.5 Investment gate and canonical phase relation 110
Table 5.6 Dimension and assessment question 111
Table 5.7 Portfolio position and suggested investment treatment 113
Table 5.8 Dimension and synthetic assessment 116
Table 5.9 Portfolio field and decision-ready content 118
Table 5.10 Verdict and meaning and required rationale 119
Table 5.11 Proposed scale claim and evidence required 123
Table 6.1 Misuse or adversarial condition and what the assessment should examine 127
Table 6.2 Request class and policy-assistant example 128
Table 6.3 Criterion class and illustrative criterion with an explicit failure condition 129

Table 6.4 Concise intended-use record 131
Table 6.5 Situation and required behavior 133
Table 7.1 Illustrative band and typical route—not a universal classification 141
Table 7.2 Proposed use and illustrative classification observations 143
Table 7.3 Variant and permitted capability 143
Table 7.4 Field and fictional bank pa-draft candidate 145
Table 8.1 Illustrative line or role type and contribution to the decision system 149
Table 8.2 AI product accountability map 152
Table 8.3 Question and record and implementation link 157
Table 8.4 Decision and accountable authority 161
Table 9.1 Layer and primary responsibility 165
Table 9.2 Contract and decision-relevant measure / check 166
Table 9.3 Record and minimum content 169
Table 9.4 Zone and principal components 170
Table 9.5 Option and when it may fit 171
Table 9.6 Pattern and suitable use 172
Table 10.1 Data domain and purpose 175
Table 10.2 Field and illustrative bounded record 179
Table 10.3 Data issue and predictive-product question 181
Table 11.1 Stage and material failure 185
Table 11.2 Illustrative policy-assistant condition and required check 187
Table 11.3 Knowledge technique and useful for 190
Table 11.4 Field and example for the policy assistant 191
Table 12.1 Strategy and potential advantage 194
Table 12.2 Route and contribution and delivery pattern 195
Table 12.3 Decision and provider or internal evidence sought 201
Table 12.4 Changed fact and supplier assertion 204
Table 13.1 Context element and design concern 206
Table 13.2 Control point and question 209
Table 13.3 Output destination and material risk 211
Table 14.1 Pattern and appropriate use 217
Table 14.2 Boundary and approved design 221
Table 14.3 Trajectory state and evidence and action 223
Table 15.1 Boundary and contract concern 227
Table 15.2 Band and capability 230
Table 15.3 Field and fictional value 234
Table 16.1 Layer and example question 238
Table 16.2 Element and filled record 241
Table 16.3 Result layer and synthetic result 242
Table 17.1 Scenario family and example path 247
Table 17.2 Threat path and challenge objective 251

Table 17.3 Risk route and typical challenge pattern 252
Table 17.4 Chain field and record to preserve 253
Table 18.1 Threat family and illustrative attack path 259
Table 18.2 Threat and asset and attacker access 261
Table 19.1 Group / threshold and true positive 265
Table 19.2 Metric and events / denominator 266
Table 19.3 Audience and needed understanding 267
Table 19.4 Illustrative role and task and evidence to record 268
Table 19.5 Method and useful question 272
Table 19.6 Field and constructed record 274
Table 20.1 Risk route and typical gate depth 280
Table 20.2 Element and required content 282
Table 20.3 Status and what may be asserted 283
Table 21.1 Dependency or action and rollback question 289
Table 21.2 Pipeline decision and evidence produced 291
Table 21.3 Transition and evidence and decision 293
Table 22.1 Signal family and examples 295
Table 22.2 Signal and threshold meaning 298
Table 22.3 Signal and interpretation question 300
Table 22.4 Field and required definition 301
Table 23.1 Incident field and fictional record content 308
Table 23.2 Population question and constructed result 310
Table 24.1 Objective and boundary to define 313
Table 24.2 Component/state and recovery question 316
Table 24.3 Workload stress and safe-route decision 317
Table 25.1 Product route and direct supplier 320
Table 25.2 Observation and constructed evidence 332
Table 25.3 Source context and bounded example 334
Table 26.1 Change class and example 338
Table 26.2 Review element and question 342
Table 26.3 Change ledger item and claim affected 345
Table 27.1 Capability and enterprise role 349
Table 27.2 Pattern and shared versus product accountability 353
Table 27.3 Role group and minimum capability outcome 354
Table 28.1 Oversight question and possible evidence 360
Table 28.2 Oversight question and first-line evidence 363
Table 28.3 Tile and decision-oriented definition 364
Table 28.4 Field and pa-r1 dashboard entry 367
Table 29.1 State and observable behavior 369
Table 29.2 Dimension and reactive evidence 372
Table 29.3 State and transition evidence to inspect 374

Table 30.1 Domain and distinct decision boundary 377
Table 30.2 Question and required decision 379
Table 30.3 Existing trace and bounded authority 380
Table A.1 Field and what to enter 390
Table B.1 Field and what to enter 392
Table C.1 Field and what to enter 394
Table D.1 Field and what to enter 396
Table E.1 Field and what to enter 398
Table F.1 Field and what to enter 400
Table F.2 Crosswalk field and phase record 401
Table F.3 Crosswalk field and phase record 402
Table F.4 Crosswalk field and phase record 403
Table F.5 Crosswalk field and phase record 404
Table F.6 Crosswalk field and phase record 405
Table F.7 Crosswalk field and phase record 406
Table F.8 Crosswalk field and phase record 407
Table F.9 Crosswalk field and phase record 408
Table G.1 Field and what to enter 410
Table H.1 Field and what to capture 412
Table H.2 Field and what to capture 413
Table H.3 ID and scenario 414
Table H.4 Field and what to enter 416
Table I.1 Field and what to enter 418
Table J.1 Field and what to enter 420

Figure P.2 — AI SDLC in a nutshell

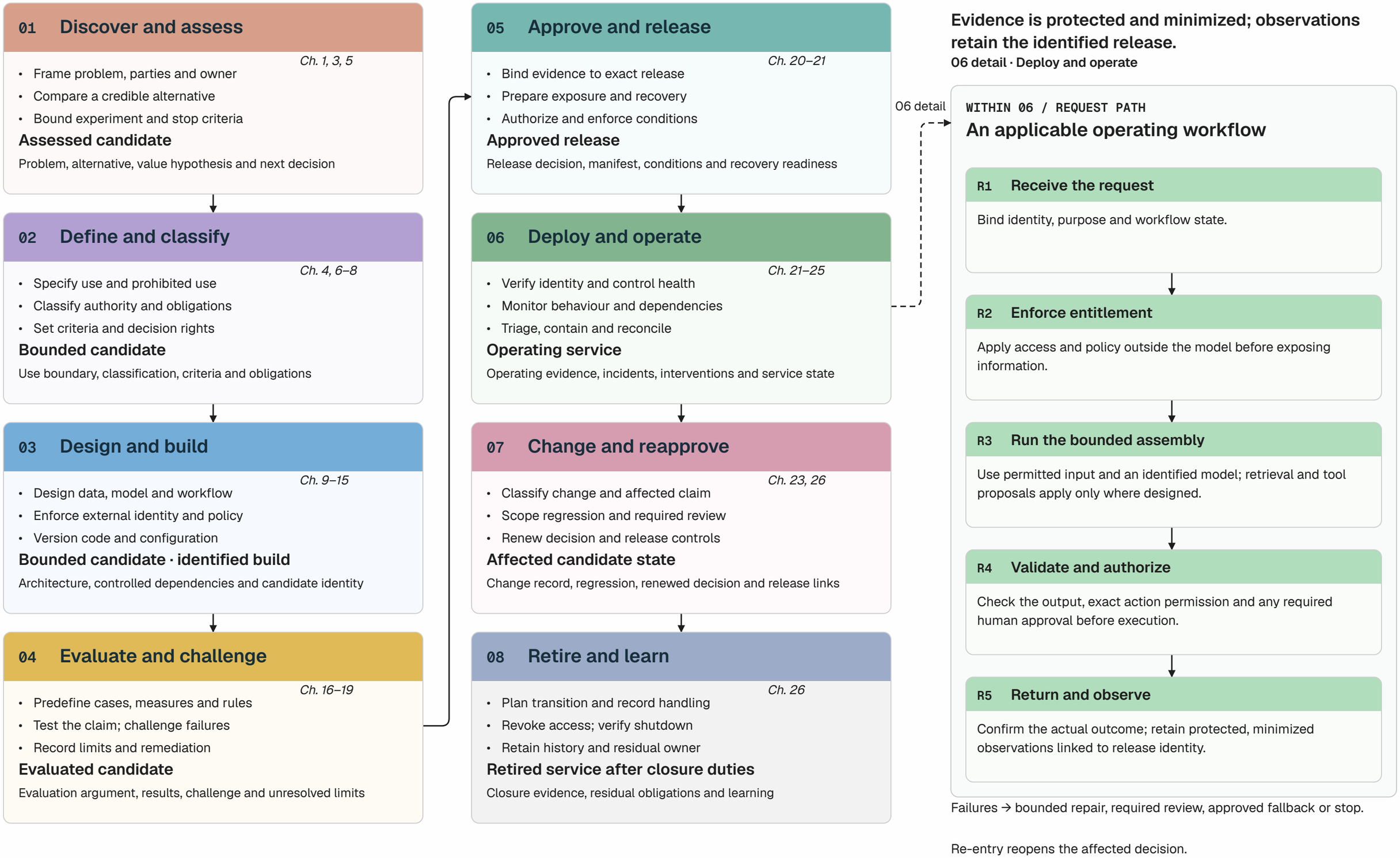
A compact route from assessed candidate to retirement; approval and effectiveness remain distinct.



AI SDLC in a nutshell: navigation from assessed candidate to retirement, with targeted re-entry.

Figure P.3 — AI SDLC: the full lifecycle

Read 01–04 down the left; follow the connector to 05–08 down the middle. Exact identity links decisions to operation.



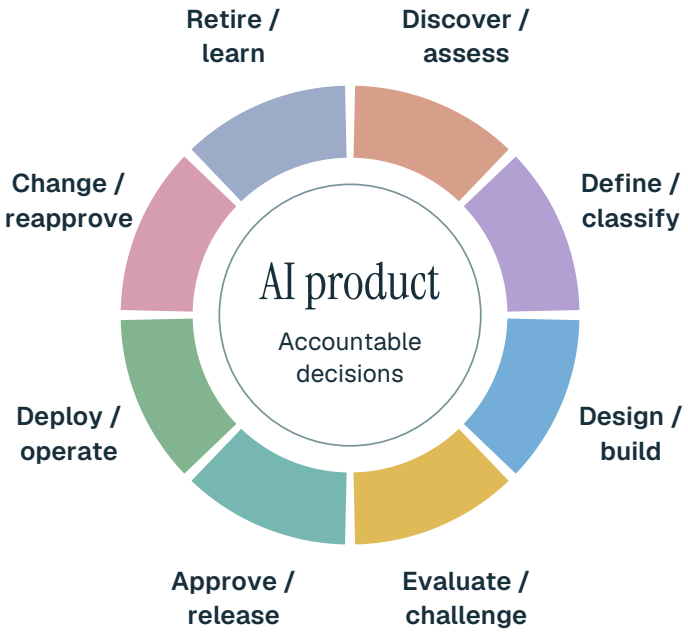
Navigation, not a mandatory waterfall · evaluated candidate → approval candidate when evidence is submitted · approved ≠ effective

Part

I

Why AI Changes the Lifecycle

Establishes the governed product, evidence bundle, banking consequence and authority/control-intensity model. The outcome is a common language for deciding what is being governed.



Emphasis: Discover / assess; Define / classify; Design / build; Evaluate / challenge; Approve / release; Deploy / operate; Change / reapprove; Retire / learn.

Other phases remain part of the lifecycle.

Re-enter at the affected decision.

Chapter

1 Why AI Changes the Software Development Lifecycle

In the following constructed example, Fictional Bank first proposes an assistant that drafts answers for employees from approved policy. A later request would let the same assistant submit a service request. The language model has not changed, but the bank's decision has: the product now crosses an action boundary. It needs a defined operation, accountable authority, fresh permission checks and a way to recover when execution is uncertain. This is why the unit of governance in this book is the banking product.

1.1 The Product Is Not the Model

When a financial institution approves an AI initiative, it is not approving an abstract model in isolation. It is authorizing a product and an operating process: a defined purpose, users, data flows, software components, human responsibilities, external dependencies, and actions that may affect customers, employees, accounts, or regulated records. The model matters, but it is one dependency inside that larger decision boundary.

In this book, an **AI/ML model** is a learned component that transforms inputs into outputs. An **AI application** combines one or more models with software that prepares inputs, supplies instructions or context, validates outputs, enforces permissions, presents results, and connects to other services. An **AI system** includes that application and its surrounding technical and human arrangements. The **AI product** is the governed unit: the system, intended use, operating workflow, owners, authority, and affected parties considered together. These working terms support the book's analysis; legal and supervisory definitions may differ and must be applied within their own scope.

In this book, the **AI software development lifecycle (AI SDLC)** is the institution's existing software-delivery and risk lifecycle extended so that every stage can govern learned behavior, data and knowledge dependencies, behavioral evaluation, delegated authority, and the evidence needed for accountable decisions. It is an overlay and extension, not a replacement process. It covers AI-enabled products that a bank builds, buys, configures, or operates. AI-assisted software engineering is a related but distinct use of AI inside the delivery process and is treated in Chapters 15 and 30.

Table 1.1 — Working term and meaning in this book

Working term	Meaning in this book	Boundary note
Model	A learned predictive or generative component	Not the complete governed product
Application	Software that integrates models, rules, interfaces, data, context, and tools	May contain several models or no user-facing model interface
AI system	The application plus technical and human arrangements needed for its intended operation	Regulatory definitions may differ
AI product	The governed unit: system, use, workflow, owners, authority, dependencies, and affected parties	Primary unit for lifecycle decisions in this book
Release	A named, evaluated, and approved configuration of behavior-shaping components	Defined operationally in Chapter 2

This wider boundary is operational, not merely editorial. NIST's AI Risk Management Framework treats AI risk as socio-technical and lifecycle-wide rather than as a property of model weights alone. Peer-reviewed work on machine-learning systems shows how data dependencies, feedback loops, configuration, and surrounding software can shape system behavior and technical debt. Research on retrieval-augmented generation and model-directed tool use adds further examples of components outside the model that can influence what a system knows or does.[1]

Approval therefore cannot stop at "Which model are we using?" Leadership also needs to know what outcome is intended, whose work or decisions will be influenced, which information the product can access, what authority it has, how failure will be detected, and who remains accountable. A capable model inside an unsuitable workflow can produce a weak product. A well-bounded model can still be unsafe if ownership, monitoring, or escalation is unclear.

Trace the dependencies that can change the product's behavior: model/configuration, code, data/instructions, runtime context, retrieval, tools, policy enforcement, people and infrastructure. Set the boundary for this use, distinguish machine enforcement from procedure, and identify users, reviewers, operators and the accountable owner. The component list is a design aid, not a universal taxonomy.

The model cannot serve as the sole unit of approval, testing, release, or accountability. Evidence must eventually connect intended use and ownership to controlled versions, evaluations, approvals, deployment state, operational observations, incidents, and changes. Chapter 2 develops that evidence model. The starting point is simpler: govern the product that will operate, not only the model inside it.

Product, application and component boundaries

The terms nest. The **AI product** is the governed banking service: purpose, users, workflow, decisions, people, software, data, dependencies, operations and evidence. The **application** is the software assembly that implements the user and workflow behavior. A **model** is one learned component within that application; a retrieval index, policy service or tool broker is another component. In the Fictional Bank policy assistant, the employee support service is the product, the retrieval-and-drafting application is the application, and the language model is one dependency. Changing the model does not necessarily change the purpose; changing the product's authority can be material even when the model is unchanged.

1.2 What Remains the Same

AI changes important parts of delivery, but it does not cancel the disciplines that make software dependable. Requirements, architecture, secure development, identity and access management, testing, configuration control, release management, observability, resilience, incident response, and clear ownership remain necessary. NIST's final Secure Software Development Framework v1.1 is one authoritative cross-sector reference for integrating secure practices across the software lifecycle. NIST SP 800-218A augments that framework with AI-model development practices for generative AI and dual-use foundation models. The Version 1.2 revision material remained an initial public draft as of 22 September 2026 and is not treated here as an adopted requirement. The broader list in this section is the book's engineering synthesis, not a claim that the SSDF family alone defines every discipline.[2]

Weak conventional engineering does not become acceptable when a model is added. An AI-enabled service still needs authenticated identities, controlled access, protected secrets, managed dependencies, repeatable deployment, change approval, capacity management, health monitoring, recoverable state, fallback or rollback, and an incident process. It still needs accountable product, system, and operational ownership. Adding model evaluation or an AI committee does not repair an unreliable product underneath.

The comparison requires care. Conventional software is not always simple, predictable, or deterministic at system level. Concurrency, distributed state, asynchronous events, networks, time-dependent logic, and external services already create variable outcomes. The useful distinction is not that ordinary software is certain while AI is uncertain. It is

that conventional application behavior is primarily specified through code, configuration, inputs, and state, while learned components must also be evaluated statistically across representative cases and operating conditions.[3]

The practical response is to extend the institution's delivery and risk model rather than create an isolated "AI process." Existing decision rights, security standards, release authorities, service ownership, resilience obligations, and incident accountability should remain in force. The organization then asks where learned behavior, changing data, generated content, retrieval, or delegated tool use adds new evidence and challenge requirements.

Table 1.2 — Existing discipline or lifecycle and primary concern

Existing discipline or lifecycle	Primary concern	What the AI SDLC adds
Conventional SDLC	Requirements, design, construction, testing, release, and maintenance	Behavioral claims, data and knowledge dependencies, and authority-aware evidence
DevSecOps	Integrated delivery automation, security, and operational feedback	Evaluation and control of non-code behavior-shaping assets
MLOps	Model, data, training, evaluation, deployment, and monitoring workflows	Product-level decisions, customer and banking consequence, and institutional accountability
LLMOps	Prompts, context, retrieval, foundation-model configuration, evaluation, serving, and operational feedback	Full workflow authority, source governance, content risk, and institutional accountability
Model-risk lifecycle	Model identification, validation, use controls, monitoring, and change	Coverage of the full AI product, including retrieval, tools, workflow, software, and operations

These practices overlap. The comparison is a navigation aid, not a claim that every institution uses the labels or draws their boundaries in the same way.

For delivery teams, extension means revisiting each familiar discipline with the complete AI system in view. Requirements must describe intended use and unacceptable outcomes, not only features. Architecture must include data, model, context, retrieval, and tool boundaries where they exist. Testing still verifies code and integration, while behavioral evaluation covers defined cases and conditions. Release control must version the dependencies that materially affect behavior. Observability must cover service

health and signals of changing or unacceptable outcomes. Incident response must address conventional failures and AI-specific behavior without splitting accountability between teams.

These extensions do not prove that every institution's current SDLC is deficient, and they do not establish one universal control set. Baseline maturity differs across organizations, products, and jurisdictions. The principle is additive: retain the practices that manage software and operational risk, then extend them where the product introduces new behavioral, data, evaluation, or authority surfaces.

Table 1.3 — Conventional engineering and AI-specific extensions

Retained discipline	Additional question for an AI-enabled product	Evidence to connect
Requirements	Which task, context and unacceptable behaviors define the use?	Intended use and evaluation criteria
Configuration management	Which data, model, prompt and retrieval versions shape behavior?	Released dependency identities and lineage
Testing	Does the assembled product behave acceptably across relevant conditions?	Cases, results, uncertainty and limitations
Access control	What may the application or agent read, prepare or execute?	Identity, permissions and authorization records
Operations	Which behavioral changes matter alongside service health?	Observations linked to thresholds and intervention
Change management	Which dependencies or authority changes require re-evaluation?	Impact analysis, approval and rollback limits

Conventional systems can also be data-dependent, distributed or variable. The table highlights additional AI-product questions; it does not establish control effectiveness.

The comparison describes typical emphases, not capabilities absent from mature organizations. Established SDLC, DevSecOps, model-risk and product-management practices already address accountability and change. The AI SDLC connects those practices around an assembled behavior and authority boundary whose dependencies can change independently.

1.3 What Changes When Behavior Is Learned

In conventional development, teams often reason from specification to implementation: define a rule, implement it, and test whether the implementation follows the rule. Learned behavior changes that relationship. A team selects an objective, data, representation, training or adaptation process, model family, parameters, and evaluation method; the resulting behavior is then observed across cases. The code can run exactly as written while the product still performs poorly for a population, a boundary condition, or a changed operating context.

This does not mean learned systems are unknowable. It means that assurance depends on evidence about distributions and conditions, not only on inspection of program logic. The team needs to know which cases were represented, which were absent, how labels or feedback were produced, what metrics conceal, how uncertainty is handled, and where performance changes materially. The relevant unit is often a set of behaviors under specified conditions rather than a single expected output.

Data also becomes part of the implementation. Its provenance, permitted use, quality, representativeness, timeliness, and transformation can affect the result. A schema change, new customer segment, revised upstream process, or altered feedback loop may change behavior without a line of model-serving code being edited. Configuration matters too: thresholds, prompts, sampling controls, feature logic, routing, and fallback rules can determine what the user experiences.

Evaluating three layers of behavior

A practical evaluation strategy separates three related questions.

At the **component layer**, the team asks whether the learned component performs the defined task across relevant cases. The answer may include aggregate measures, but averages are not enough. Error type, severity, affected group, confidence behavior, and performance at important boundaries can matter more than a single summary result. A component result is useful only when its test conditions and transfer limits are known.

At the **application layer**, the team evaluates the assembled behavior: preprocessing, instructions, retrieval, rules, model calls, output checks, interface, and fallback. An application can improve a weak component result by constraining the task or routing uncertain cases. It can also degrade a strong component result through poor context, stale retrieval, inappropriate thresholds, or misleading presentation.

At the **workflow layer**, the team examines what happens when people and downstream systems use the output. Does the product change how work is prioritized? Can a reviewer identify an error? Does the interface encourage over-reliance? Does an upstream omission become a downstream action? This layer is where a statistically acceptable output can still create an unacceptable institutional process.

The three layers are an author-developed explanatory structure, not a prescribed standard. Their value is diagnostic: when an evaluation fails, the team can ask whether the issue lies in the learned component, the assembled application, or the operating workflow. When an evaluation passes, the same separation prevents the institution from treating a narrow component result as evidence for a broader workflow claim.

Table 1.4 — Evaluation layer and example claim

Evaluation layer	Example claim	Decision supported	Typical evidence owner	Example failure
Component	The learned component performs a bounded task under stated test conditions	Whether the component is suitable for integration or further experiment	Model or evaluation owner	Aggregate performance conceals a consequential boundary failure
Application	The assembled software retrieves, constrains, validates, and presents output as designed	Whether the candidate configuration is suitable to advance toward release	Product and engineering owners	Correct model output is paired with stale or unauthorized context
Workflow	People and downstream systems can use, challenge, and recover from the output safely	Whether the complete service is suitable for the approved operating use	Business process and service owners	Review becomes routine acceptance rather than meaningful challenge

The evidence at one layer cannot silently stand in for a broader claim at another.

Evaluation cases should therefore follow the product's claims and failure pathways. A representative set may need ordinary cases, rare but consequential conditions, ambiguous inputs, missing information, changed context, adversarial or misuse cases where relevant, and cases that should be refused or escalated. The composition is use-case specific. This chapter does not prescribe a universal sample size, error tolerance, or acceptance threshold.

For executives, the consequence is that approval must include an evidence claim: this system is suitable for this purpose, these users, these conditions, and this level of consequence. "The model passed testing" is incomplete unless the testing represents the product's intended use and the limits are intelligible to decision-makers. The owner must also decide what changes require renewed evaluation or approval.

For practitioners, the delivery system needs traceability from intended use to data and model versions, evaluation cases, acceptance decisions, release state, and runtime signals. Monitoring should not be reduced to infrastructure uptime. It may need to detect changes in input mix, retrieval behavior, refusal behavior, error types, escalation patterns, or other use-case-specific indicators. What is monitored, and at what threshold, is not universal; it must follow the risk and the limits established before release.

Machine-learning systems research has long highlighted hidden dependencies, feedback loops, and configuration debt, while NIST frames risk management across the AI lifecycle and its socio-technical context. These sources support the need for lifecycle evaluation; they do not prescribe one bank-wide metric set or prove that monitoring eliminates risk.[4]

Learned behavior also changes the meaning of a release. A code commit may be unchanged while the effective product changes because data, a provider model, an embedding model, a corpus, a threshold, or a feature transformation changes. In this book, the operational lifecycle distinguishes a **candidate** assembled for assessment, an **evaluated** candidate with recorded results, an **approved** release identity authorized for a stated use, a **deployed** configuration placed into an environment, and an **operating** service whose runtime condition is being observed. These states must not be inferred from one another. The release record should identify which behavior-shaping dependencies were evaluated together. Change control should then distinguish editorial or operational updates from changes that can alter an approved claim and therefore require renewed evaluation.

The shift is therefore from "Does the code do what we specified?" to a larger question: "Does the assembled product behave acceptably for its approved purpose, across the conditions that matter, and can the institution detect when that answer changes?"

1.4 Generative AI Adds Context and Content Risk

Generative AI turns model output into content—text, code, images, summaries, explanations, or structured responses—whose surface fluency can exceed its reliability. A coherent answer may be unsupported, incomplete, stale, or inappropriate for the user's purpose. That creates a control challenge: presentation quality is not the same as factual quality, and user confidence is not evidence of correctness.

The behavior depends on more than model weights. System instructions, user input, conversation history, retrieved material, tool results, sampling configuration, content filters, output formatting, and application logic can all shape what is produced. Some of these dependencies change more frequently than a traditional software release. Others are controlled by a provider or external service. The institution therefore needs a release and change model that reflects the dependencies it can control, the ones it can only monitor, and the ones that require contractual or operational safeguards.

Content risk is use-case specific. An imperfect internal draft that a trained employee must verify is different from a customer-facing explanation, a recommendation used in a financial decision, or content that triggers a system update. The same base model can sit inside each design, but the consequence and evidence burden are not the same. Evaluation must therefore cover the task, users, context, instructions, connected knowledge, workflow, and human action—not only a general model benchmark.

Generative evaluation begins with the product claim

A generative product should be tested against what it promises, not against fluency in the abstract. If it promises to summarize a policy, evaluation should ask whether the summary preserves controlling conditions, exceptions, effective dates, and uncertainty. If it promises to draft a customer response, the test should consider factual support, completeness, tone, prohibited content, required disclosures where applicable, and whether the employee can verify the result. If it promises to produce structured data, syntactic validity is only the first question; semantic accuracy and downstream handling still matter.

Evaluate the dimensions that matter to the task: adherence, relevance, groundedness, completeness, consistency, refusal, provenance, privacy/security and escalation. Keep consequential weaknesses visible rather than averaging them away. A relevant answer can be poorly grounded; a valid structure can omit a material condition.

Evaluation should also distinguish **reference-based** and **judgment-based** evidence. Some cases have a controlled expected answer or a set of required properties. Others require structured human judgment because several responses could be acceptable. Human evaluation needs defined criteria, qualified reviewers, disagreement handling, and a record of limitations. Model-based evaluation may support scale or triage, but it

introduces another model, prompt, and calibration dependency that must be understood rather than treated as an independent oracle.

Repeated testing matters because generation is variable. The number of repetitions and the acceptable variability depend on the claim and consequence; this chapter establishes no universal value. The team should know whether a passing result reflects stable behavior, a favorable sample, or an evaluation that does not stress the conditions most likely to expose failure.

NIST's Generative AI Profile identifies risks and suggested actions for generative systems, while peer-reviewed research illustrates how text-generation behavior depends on decoding choices. Those sources support a cautious, test-in-context approach; they do not establish that one provider setting, refusal test, or accuracy score is sufficient for a banking use.[5]

The operating question is not whether a system produces what is variously called a hallucination or confabulation in the abstract. This book uses **unsupported output** as the operational term: content whose material proposition is not adequately supported for the approved task. The institution must ask what unsupported or inappropriate output can occur in the workflow, how it will be detected or contained, what a user is expected to verify, and what happens when verification is infeasible. Controls may include constraining the task, grounding the response, limiting accessible data and tools, requiring citations or source display, validating structure, routing uncertain cases, or prohibiting direct action. These are design options, not proof of safety.

The acceptance record should connect each important product claim to evidence, open limitations, and an owner. A claim such as "answers are grounded in approved policy" is broader than "the response includes a citation." The evidence needs to address whether the cited source is authoritative, whether the response accurately reflects it, whether decisive exceptions were omitted, and what happens when approved material is unavailable or contradictory. This is why generative evaluation is a product exercise rather than a one-time model benchmark.

Executives should focus on the promise being made to the user. If the product is called an assistant, what assistance is actually reliable? If it creates a draft, who verifies it and with what information? If it explains a decision, is the explanation grounded in the actual decision process? Practitioners then translate that promise into testable requirements, failure cases, instrumentation, and release conditions.

Generative capability expands the space of possible outputs. The SDLC response is to narrow the approved purpose, make context and dependencies visible, and produce evidence that the complete workflow behaves acceptably within stated limits.

1.5 RAG Expands the Governed System Boundary

Retrieval-augmented generation, or RAG, connects generation to an external knowledge source. A typical pattern accepts a request, searches or ranks material, adds selected passages to the model's context, and generates a response. This can improve grounding and make current institutional content available without retraining the model. It also introduces a knowledge system whose behavior must be governed.

The product can fail even when the generator behaves as designed. The corpus may omit the controlling policy, include superseded guidance, expose material the user is not entitled to see, or contain conflicting versions. Chunking may separate a condition from its exception. Search may retrieve a plausible but irrelevant passage. Ranking may prefer the wrong source. Context limits may omit decisive material. A generated response may then combine retrieved and learned content in a way that makes provenance difficult to see.

Research on RAG establishes the technical pattern; NIST's generative-AI guidance provides a broader risk-management context. The exact control set described here is the book's architecture synthesis, not a universally adopted standard.[6]

Governance must cover at least the questions that affect the intended use: Who owns the corpus? Which source is authoritative when materials conflict? How are access rights enforced during retrieval? How are publication date, effective date, jurisdiction, and supersession represented? How quickly must changes appear? Can the response identify the material it used? What happens when no adequate source is found? Which query and retrieval details may be logged without creating an unnecessary privacy or security exposure?

These questions cross organizational boundaries. A policy owner may approve content; records or legal functions may determine status; data or knowledge teams may build ingestion; security may enforce access; application teams may configure retrieval; and operations may monitor failures. If no one owns the end-to-end answer, each component can be locally well managed while the product remains unreliable.

For leadership, RAG is not merely a feature that "connects the model to our documents." It is an operating commitment to maintain an authoritative, access-controlled, timely knowledge path. For practitioners, it is a versioned architecture with ingestion, indexing, ranking, authorization, context construction, output behavior, and observability. Changes to any of those elements may require evaluation.

RAG can reduce some failure modes and introduce others. The correct conclusion is neither "retrieval solves accuracy" nor "retrieval is unsafe." It is that the retrieved knowledge path becomes part of the governed product boundary and its evidence.

An output can fail in more than one way. An unsupported proposition lacks adequate evidence; a contradicted proposition conflicts with it; stale authority uses a superseded source; material incompleteness omits an exception that changes the answer; unauthorized disclosure crosses a permission boundary. Test each separately. A citation to the main rule can be accurate while the answer remains materially incomplete because the exception was not retrieved.

1.6 Agents Add Delegated Authority

An AI application becomes more consequential when it can select or invoke tools, update state, or carry work across several steps. Research systems such as Toolformer and ReAct demonstrate patterns in which language models use external tools or interleave reasoning with action. NIST's NCCoE is exploring identity and authorization for software and AI agents, but that work remains an emerging concept-paper project rather than final guidance.[7]

The essential change is delegated authority. A system that drafts text proposes information. A system that queries customer data crosses an access boundary. A system that prepares a case update changes the workflow even if a person must submit it. A system that sends a message, changes a limit, moves funds, deploys code, or closes an alert can create effects that are difficult to reverse.

An agent should therefore not be governed only by how well it interprets instructions. The architecture must define identity, allowed tools, permitted resources, action scope, limits, validation, state, logging, interruption, fallback, and recovery outside the model. A model instruction such as "do not exceed this amount" is not equivalent to an enforced transaction limit. A request for confirmation is not meaningful authorization if the reviewer lacks context, time, competence, or the ability to stop the action.

The book's position is that consequential authority must be explicit and bounded. Per-action human authorization is the default for high-impact or difficult-to-reverse actions unless a different operating pattern is deliberately approved. Some banking functions use **bounded automation**: limits, monitoring, override, recourse, recovery, and accountable intervention are approved in advance rather than applied through a person confirming every event. That pattern must be justified for the use and operating conditions; it is not a blanket exception. Human-in-the-loop, human-on-the-loop, and bounded automation are distinct designs whose adequacy depends on jurisdiction, task, consequence, feasibility, and evidence.

Decision-makers should ask what the product can perceive, recommend, invoke, change, or transact; how much work it can perform before another authority intervenes; and what happens when it encounters ambiguity or failure. Delivery teams should translate those answers into machine-enforced permissions, scoped credentials, policy checks,

input and output validation, rate or value limits, idempotency where needed, audit events, and recovery paths. Detailed implementation belongs in later chapters.

Agentic capability is not automatically inappropriate. It changes the burden of proof. The more authority a product can exercise, the stronger the evidence must be that its permissions, decisions, interventions, and recovery mechanisms match the approved purpose.

1.7 Banking Raises the Consequence of Error

Banking does not require a different physics of software, but it can make failure more consequential. AI-enabled products may influence customer communications, fraud or financial-crime work, credit or servicing processes, operations, regulated records, market activity, or services on which customers and other institutions depend. The significance of an error follows the use and operating context, not the presence of an AI label.

The Financial Stability Board identifies potential benefits from AI in finance alongside vulnerabilities involving third-party dependencies and concentration, market correlations, cyber risk, model risk, data quality, and governance. Its analysis is system-level and non-binding; it does not establish that every use case creates each vulnerability.[8]

BCBS operational-resilience principles provide another important context. Where an AI-enabled product supports a critical operation, a bank needs to understand tolerances, dependencies, continuity, response, and recovery. The principles are not AI-specific, and implementation varies by jurisdiction. Their relevance is the reminder that an AI failure can become an operational event if the product sits in the path of an important service.[9]

Consequences can propagate. A poor internal suggestion may increase rework. The same suggestion, if presented to a customer, may create confusion or unfair treatment. If used at scale, it may create systematic rather than isolated errors. If it depends on one external provider, a provider change or outage may affect multiple services. If an output is used without a viable challenge path, nominal human involvement may fail to contain the risk.

This is why materiality cannot be inferred from the model alone. The institution must consider who is affected, what decision or action follows, the value and sensitivity involved, scale, duration, reversibility, redress, and the product's role in critical operations. Chapter 3 develops the banking context, and Chapter 4 develops the book's proposed control-intensity factors.

The governance implication is not that every banking AI system must carry the maximum control burden. It is that proportionality must be defensible. A

low-consequence internal aid and a system that can influence customer outcomes should not pass through the same evidence and authority path merely because both use a similar model.

1.8 The Lifecycle Must Produce Evidence

A lifecycle is governable only when it produces evidence about its decisions and behavior. Policies and process diagrams are necessary, but they do not show which purpose was approved, which versions were evaluated, what limits were accepted, what entered production, how the system behaved, or what changed afterward.

NIST's AI RMF and Playbook organize risk work across Govern, Map, Measure, and Manage and offer voluntary actions and documentation practices. The EU AI Act provides more specific documentation and logging examples for covered high-risk systems. These sources support lifecycle traceability within their scope; neither adopts the book's exact evidence-bundle categories, and EU provisions are not globally applicable.[10]

This book proposes five connected evidence classes:

- **Decision evidence** explains purpose, ownership, alternatives, affected parties, materiality, risk acceptance, and approval.
- **Implementation evidence** identifies the architecture, data, model, prompts or instructions, retrieval sources, tools, configurations, policies, and versions that make up the released product.
- **Assurance evidence** records evaluation design, test cases, results, limitations, challenge, exceptions, and the basis for readiness decisions.
- **Operating evidence** covers deployment state, access, observations, escalations, incidents, interventions, service conditions, and control operation.
- **Change evidence** relates proposed and actual changes to affected components, renewed evaluation, approval, release, rollback, and retirement.

Use these record categories to expose broken links. An approval must identify the evaluated version; a model card must relate to the operating application; monitoring must tie to purpose and thresholds; and incidents must inform change and re-evaluation. The categories do not prescribe a universal records schedule.

Executives need enough evidence to make and revisit accountable decisions. Practitioners need evidence that can be produced without reconstructing the system manually after a challenge. Audit, risk, validation, and oversight functions need traceability and access appropriate to their roles. Retention, privacy, legal privilege, and regulated-record duties vary; Chapter 2 treats those as bounded design questions rather than prescribing one universal period.

The goal is not documentation volume. It is a connected explanation of what was intended, what was built, what was evaluated, what was approved, what operated, and what changed. See Figure 1.1.

Figure 1.1 — A lifecycle of accountable decisions

Chapter 1 §1.8 · candidate, evidence, permission and operating status remain distinct.

PHASE		CONTROLLED DESCRIPTION
01	Discover / assess	**Assessed candidate** Investigation scope; no operating permission.
02	Define / classify	**Bounded candidate** Intended use, rights and review route; no automatic permission.
03	Design / build	**Bounded candidate; identified build** An identified configuration; build completion is not approval.
04	Evaluate / challenge	**Evaluated candidate** Scoped results; approval candidate when evidence is submitted.
05	Approve / release	**Approved release** Exact release and conditions; deployment remains separate.
06	Deploy / operate	**Operating service** Verify deployed configuration and continuing conditions.
07	Change / reapprove	**Affected candidate state** Reopen affected decisions; prior approval is not inherited.
08	Retire / learn	**Retired service after closure duties** Verify closure; retain residual records and duties.

Re-enter at the affected decision

Incident, drift, complaint, provider change or accumulated change reopens affected claims and decisions. Navigation is not a mandatory waterfall; a phase need not create a new permission state.

A lifecycle of accountable decisions. Each phase has a decision purpose and expected evidence; phase descriptions do not confer permission.

Text alternative: Eight decision phases link assessed and bounded candidates to evidence, release, operation, affected re-entry and retirement. Each phase has a decision purpose and expected evidence; phase descriptions do not confer permission. Incidents, drift, complaints, provider change and accumulated change reopen the affected decision; no automatic permission increase or complete restart is implied.

Author synthesis. Each phase has a decision purpose and expected evidence. A phase need not create a new permission state. The state transitions below identify eligibility for the next decision; material change reopens affected claims.

For chapter navigation, four compact bands group the discussion: Strategy and Scope (Chapters 1, 3, and 5–8), Design and Build (Chapters 9–15), Assure and Release (Chapters 16–21), and Operate and Renew (Chapters 22–30). These reading bands do not replace the eight decision phases in Figure 1.1.

The canonical lifecycle used throughout this book

The book uses eight decision phases as its canonical operating model: **discover and assess; define and classify; design and build; evaluate and challenge; approve and release; deploy and operate; change and reapprove; retire and learn**. Figure 1.1 presents those eight phases and their decision states; the four prose bands above provide compact chapter navigation. The five evidence classes describe *why* evidence exists; the eight artifact families describe *how readers package it*; gates are attributable decisions at phase boundaries; and re-entry triggers reopen a prior claim. These are linked views, not competing lifecycles.

The state vocabulary is also controlled. A product may be a proposed idea, assessed candidate, bounded candidate, evaluated candidate, approval candidate, approved release, deployed configuration, operating service, restricted service, or retired service. **Approved** never means **effective**. Designed, implemented, tested, independently challenged, approved, deployed, operating, and effective-for-an-assessed-period are separate propositions.

The book’s eight-phase lifecycle draws on SDLC/DevSecOps, NIST AI RMF Govern–Map–Measure–Manage, release engineering and resilience. The exact evidence-bundle and re-entry arrangement is the author’s synthesis, rather than an inspected standard; expert review remains required.

Reader view of the eight decision phases

Table 1.5 — Phase and decision

Phase	Decision	State / identity	Exit condition
PH-01 Discover and assess	Fund a bounded question or stop	Proposed idea → assessed candidate	Credible problem, alternatives, sponsor and proportionate investigation scope; no operating permission
PH-02 Define and classify	Bound permitted use and route authority/risk	Assessed candidate → bounded candidate	Intended/prohibited use, route, rights, controls, owners and acceptance claims sufficiently specified
PH-03 Design and build	Construct the bounded candidate and enforce boundaries	Bounded candidate with identified build/configuration; no new named approved state	Traceable dependencies, authorized data/tools, enforceable contracts, secure build and test target identity
PH-04 Evaluate and challenge	Decide whether evidence supports defined claims	Bounded candidate → evaluated candidate → approval candidate when evidence submitted	Layer-specific results, hard failures, uncertainty, independence, limitations and unresolved exceptions visible
PH-05 Approve and release	Accept, condition, reject or hold an identified release	Approval candidate → approved release, or recorded hold/rejection	Authorized delegate records exact release, scope, conditions, residual risk, expiry and rollback/fallback readiness

Table 1.5 (continued)

Phase	Decision	State / identity	Exit condition
PH-06 Deploy and operate	Verify deployment and decide continued authorized service	Approved release → deployed configuration → operating service; restricted service if necessary	Identity and enforceable conditions verified; operating acceptance, observability, capacity and tested safe route
PH-07 Change and reapprove	Assess affected claims and route a changed candidate	Operating/restricted service → affected candidate state; renewed approval/deployment only after relevant decisions	Change envelope, cumulative effect, regression and condition closure assessed; no automatic inherited approval
PH-08 Retire and learn	Close service and preserve residual obligations	Operating/restricted service → retired service after verified closure	Access/ credentials/ indexes/ queues/ contracts closed or transferred; records/ holds/ customer obligations and learning owned

Section 2.6 gives the compact phase overview; Appendix F retains the complete role, evidence, artifact, template and re-entry reference. Product is the accountable service; release is its controlled configuration/permission identity; evidence bundle is the linked record supporting decisions about that identity. Authority level is an attribute assessed within a phase, and maturity is evidence of institutional capability. Neither creates another lifecycle.

Reading the figure and the controlled record together

Figure 1.1 uses short descriptions of work at each phase. The controlled record distinguishes evidence status from permission. Its labels have the following meanings; none confers authority by itself.

Table 1.6 — Figure description and controlled record meaning

Figure description	Controlled record meaning	Permission boundary
Assessed idea	Assessed candidate linked to the proposed idea	Investigation scope only
Bounded candidate	Candidate with intended use, rights and review route	No automatic operating permission
Assembled candidate	Identified build/configuration of that bounded candidate	Build completion is not approval
Evaluated candidate	Candidate with scoped results; approval candidate when submitted for a decision	Tests and independent conclusions remain evidence
Approved release	Exact configuration and use authorized by the delegate	Deployment and operating acceptance remain separate
Operating service	Verified deployment processing within permitted exposure	Continuing conditions and intervention apply
Renewed candidate	Changed candidate routed to the affected earlier decisions	Previous approval is not inherited
Closed service	Retired service after operating closure, with residual records and duties owned	Closure does not extinguish lawful retention or remedy

The product ID persists through those decisions. Candidate versions identify proposed changes; release IDs identify authorized configurations; per-request effective source versions identify permitted knowledge refreshes. A change in one does not silently change the others.

1.9 Illustrative Scenario: The Expanding Copilot

Illustrative scenario — fictional composite. Fictional Bank is considering a customer-service copilot. The scenario contains no achieved benefit, real incident, customer outcome, or completed control.

Table 1.7 — Stage and authority and data boundary

Stage	Authority and data boundary	New dependency or consequence	What must be re-evidenced
Restricted drafting	Drafts from employee notes; no customer-record access or outbound communication	Employee verification and topic boundary	Intended use, evaluation cases, user task, data handling, escalation
Policy retrieval	Reads an approved, permission-aware corpus	Source ownership, currency, retrieval, and provenance	Corpus and index identity, retrieval quality, access tests, answer support
Customer-context recommendation	Uses permitted customer context to recommend a next step	Customer consequence and reliance	Data purpose, affected population, recommendation limits, challenge path
Prepared record update	Produces a structured change for human review and submission	Institutional records and recovery	Field permissions, validation, preview, bound confirmation, rejection and recovery
Bounded execution proposal	Requests authority to execute within approved limits	Direct action, scale, reversibility, and recourse	Reclassification, architecture, assurance, approval, monitoring, intervention, and redress

For each proposed stage, ask which information or action boundary changes and what must be re-evidenced. Chapters 3 and 4 route the changed use and consequence; Chapters 9 and 13 test the trust and action boundaries. A similar model can therefore require a different product decision.

1.10 Decision Summary and Practitioner Checklist

Before funding the next step, the sponsor should identify the complete product and its authority boundary. The team should bring one claim and the evidence needed to decide it; a model demonstration alone cannot answer that question.

Source scope and limitations

- The end-to-end component list, five evidence classes, six control-intensity factors, and checklist are author synthesis, not universal standards.
- No universal time or workload threshold for meaningful human oversight was identified.
- NIST AI RMF and the Playbook are voluntary and under revision; SSDF v1.2 remains draft. NIST agent identity work is an emerging concept-paper project, not final guidance.
- FSB and BCBS sources are non-binding/international and do not establish firm-specific facts or universal legal duties.
- EU AI Act references apply only within the relevant actor, system, classification, territorial, and temporal scope.
- No Singapore-specific proposition is made from unavailable MAS FEAT material.
- Fictional Bank is a teaching setting. Later chapters use explicitly constructed metrics, incidents and decision records to explain the method; none reports observed bank results, customer outcomes or completed institutional controls.

Notes

1. NIST, AI RMF 1.0 (B01); Sculley et al., “Hidden Technical Debt in Machine Learning Systems” (B19); Lewis et al., “Retrieval-Augmented Generation” (B20); Schick et al., “Toolformer” (B21). Return to text

2. NIST, Secure Software Development Framework Version 1.1 (B04); NIST, Secure Software Development Practices for Generative AI and Dual-Use Foundation Models (B28); the Rev. 1 initial public draft is used only for status context (B05). Return to text

3. NIST, AI RMF 1.0 (B01); Sculley et al. (B19). Return to text

4. Sculley et al. (B19); NIST, AI RMF 1.0 (B01). Return to text

5. NIST, Generative Artificial Intelligence Profile (B02); Holtzman et al., “The Curious Case of Neural Text Degeneration” (B22). Return to text

6. Lewis et al. (B20); NIST, Generative Artificial Intelligence Profile (B02). Return to text

7. Schick et al. (B21); Yao et al., “ReAct” (B23); NIST NCCoE, Software and AI Agent Identity and Authorization (B17). Return to text

8. Financial Stability Board, The Financial Stability Implications of Artificial Intelligence (B14) and Monitoring Adoption of Artificial Intelligence and Related Vulnerabilities in the Financial Sector (B15). Return to text

9. Basel Committee on Banking Supervision, Principles for Operational Resilience (B11). Return to text

10. NIST, AI RMF 1.0 (B01) and AI RMF Playbook (B03); European Union, consolidated Regulation (EU) 2024/1689 (B07). Return to text

Chapter

2 The AI System as an Evidence Bundle

This chapter presents an author-developed evidence-bundle framework. It is not a universal records schedule, audit standard, legal conclusion, or compliance schema.

2.1 From Model Documentation to Product Evidence

A model description can be valuable without being sufficient. It may explain intended use, evaluation results, limitations, or ethical considerations for a learned component. The operating institution still has to answer a larger set of questions: Which product uses the model? For what purpose? With which data, prompts, retrieval sources, tools, and permissions? Which version was evaluated and approved? What entered production? What has happened since?

The distinction follows directly from Chapter 1. If the governed unit is an AI-enabled product and operating process, the evidence must describe that unit. A model card that cannot be related to an application release leaves an identity gap. An application approval that cannot identify its knowledge corpus leaves a configuration gap. A test result that cannot be related to the released version leaves a traceability gap. A monitoring alert without an approved purpose, limit, or owner leaves a decision gap.

NIST's AI RMF treats risk management as lifecycle-wide and socio-technical. Its Playbook provides voluntary actions and documentation prompts across Govern, Map, Measure, and Manage. Model-card research provides a model-centered documentation practice. Together they support the need for structured evidence, but none adopts the exact framework proposed in this chapter.[1]

For executives, the problem is accountability over time. An approval is made at one point, but the product changes: a model version moves, a corpus is updated, an instruction changes, a tool is added, a user group expands, or a threshold is revised. The institution needs to know whether the approved proposition still describes the operating product.

For practitioners, the problem is evidence by design. If teams wait until an audit, incident, or regulatory request to reconstruct purpose, versions, tests, decisions, and

runtime state, the evidence will be slow, incomplete, and contested. Delivery mechanisms should produce and relate useful evidence as part of normal work.

2.2 What an Evidence Bundle Contains

This book defines an **AI product evidence bundle** as the connected body of evidence that supports accountable decisions about an AI-enabled product across its lifecycle. The product is the governed unit; the evidence bundle is the linked record of what was intended, built, evaluated, approved, operated, and changed. “Bundle” does not mean a single folder, file, or new centralized repository. It is a logical evidence view that may relate records held in engineering, model inventory, change, configuration, governance-risk-compliance, ticketing, data catalog, records, security, observability, and validation systems.

The five classes answer different evidence questions:

- **Decision evidence** — purpose, scope, affected parties, value hypothesis, ownership, classification, risk acceptance, conditions, exceptions, and approval.
- **Implementation evidence** — architecture, interfaces, data, model, instructions, retrieval, tools, policies, infrastructure, dependency and configuration versions.
- **Assurance evidence** — evaluation design, test data or cases, results, limitations, challenge, security tests, validation, findings, exceptions, and readiness rationale.
- **Operating evidence** — deployed state, access, observations, alerts, human interventions, service events, incidents, complaints or escalations where applicable, and control operation.
- **Change evidence** — change intent, impact analysis, affected dependencies, renewed testing, approvals, release, rollback, remediation, and retirement.

These categories are author synthesis. They are useful only if adapted to the institution’s products, records, laws, and assurance model. A small internal assistant should not be forced to produce the same volume of evidence as a product with material customer or operational consequences. Proportionality should change depth and review, not erase identity, ownership, purpose, or the basis for release.

An evidence bundle also needs a subject. At minimum, an institution needs a stable way to identify the governed product, its intended purpose, responsible owners, approved environments, and relevant versions. A **release identity** names the evaluated-and-approved configuration of every behavior-shaping component material to the product claim. A **release manifest** records that configuration and is fixed once approved; later correction should append a new record or explicit correction rather than erase the historical state. A change inside a documented approved envelope may proceed under standing authority. A change that alters a claim, authority boundary,

consequential dependency, or control assumption requires renewed evaluation or a new release decision.

Illustrative minimum evidence record. The field names below are a proposed implementation pattern, not a universal schema.

Table 2.1 — Field and purpose

Field	Purpose	Minimum treatment
Product ID	Identifies the governed AI product	Stable across releases
Purpose and use statement	Defines the approved task, users, affected parties, and exclusions	Versioned and owned
Release ID and manifest	Identifies the evaluated configuration	Immutable after approval, with append-only correction
Authority boundary	States what the product may read, recommend, prepare, decide, or execute	Machine-enforced where consequence requires it
Claim and acceptance criteria	States what suitability proposition is being decided	Linked to cases, results, limits, and owner
Approval and conditions	Records authority, scope, conditions, exceptions, and expiry	Linked to the exact release
Operating state	Identifies what is deployed and material observations or interventions	Time-bounded and retrievable
Revisit triggers	Identifies changes that reopen classification, evaluation, or approval	Includes model, corpus, data, tool, population, provider, and authority changes

2.3 Decision, Implementation, Assurance, Operating, and Change Evidence

The five classes answer different questions.

Decision evidence answers **why and under whose authority**. It should make the approved purpose and boundary visible, including exclusions and conditions. It should identify who may be affected, what authority the product receives, which risks are

accepted, and which open items remain. A decision record without clear conditions cannot guide engineering or later change.

Implementation evidence answers **what was assembled**. For an AI-enabled product, this may include model and configuration, application code, data transformations, prompts or system instructions, retrieval sources and indexing, tools, access policies, infrastructure, and user interface. Not every component belongs in every use case. The bundle should identify what materially affects behavior and authority.

Assurance evidence answers **why the institution believed the product was ready for the approved purpose**. It relates claims and failure modes to evaluation cases, expected results, actual results, limitations, independent challenge where required, and the release decision. A high score without a clear population, use, threshold, or error analysis is difficult to govern. A passed test also remains historical evidence; it does not prove that future operation will remain acceptable.

Operating evidence answers **what was deployed and what occurred**. It may include deployment and configuration state, access events, monitoring outputs, escalations, overrides, incidents, fallback, service conditions, and evidence that key controls executed. The appropriate content is use-case specific. Collecting everything can create privacy, security, and cost problems; collecting too little can make investigation or challenge impossible.

Change evidence answers **how the product moved from one approved state to another**. It should relate the change request to affected components, risk and impact analysis, renewed evaluation, approvals, deployment, rollback readiness, and any post-change observation. This closes the loop between development and operation.

Table 2.2 — Evidence classes and the questions they answer

Evidence class	Design evidence	Execution or behavior evidence	Accountable meaning owner
Decision	Decision criteria, authority, conditions	Decision made, conditions applied, exception or expiry triggered	Decision owner
Implementation	Architecture, configuration, policies, versions	Build and release manifest for the operating configuration	Product or system owner
Assurance	Evaluation and review design	Results, findings, limitations, challenge, and conclusion	Assurance or validation owner
Operating	Monitoring, intervention, and recovery design	Deployed state, observations, control events, incidents, and responses	Service or operations owner
Change	Change classification, impact, and re-entry rules	Approved change, renewed evidence, deployment, rollback, and closure	Change and product owners

Completeness asks whether expected records and relationships exist. Sufficiency asks whether they support this decision. A complete bundle can still be insufficient; document count establishes neither.

2.4 Evidence Lineage Across the Lifecycle

Evidence lineage is the relationship among these records. It allows an institution to move from a business purpose to an operating release and back again. A useful lineage can answer questions such as:

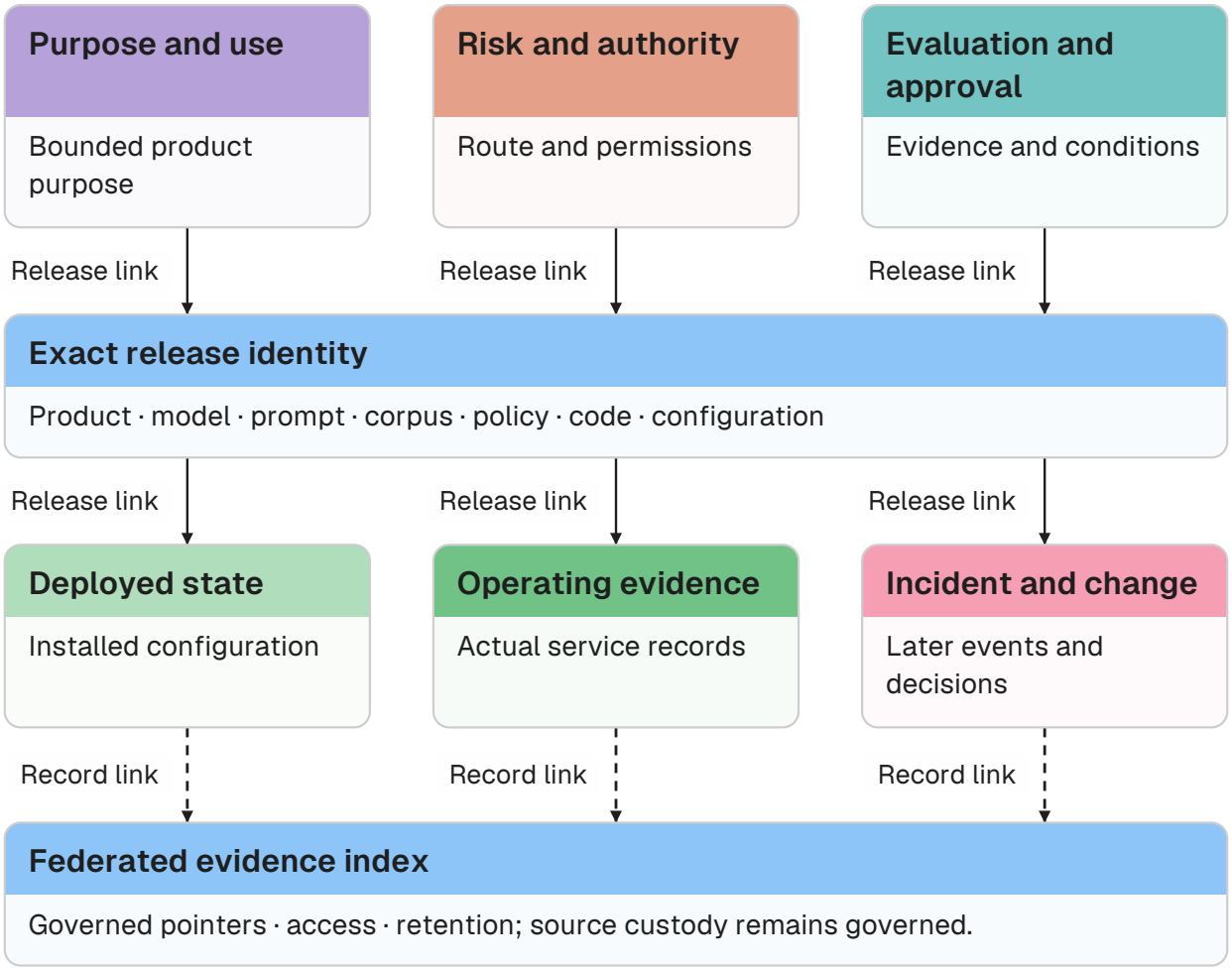
- Which approval authorized this use and user population?
- Which architecture, data, model, prompt, corpus, tool, and policy versions were evaluated?
- Which evaluation results and limitations supported release?
- Which exceptions were open, who accepted them, and when do they expire?
- Which configuration is operating now?

- Which observations or incidents relate to that state?
- Which change altered the state, and what renewed evaluation occurred?

The EU AI Act illustrates that, for covered high-risk systems within its scope, technical documentation, record-keeping, provider documentation retention, and deployer obligations can be legally significant. That bounded example supports the importance of traceability; it does not make the Act's exact records or retention periods universal.[2]

The lineage should also preserve time. An evidence bundle is not overwritten whenever a release changes. Decision-makers may need to know what the institution believed, what evidence was available, and what configuration operated at a past point. That creates design questions about immutable events, corrected records, effective dates, access, and retention. Those questions require records, legal, privacy, security, and architecture input; they cannot be settled by this book alone. See Figure 2.1.

Figure 2.1 — One release identity, federated evidence



Solid: release relationships. Dashed: governed record pointers.

Purpose and use, risk and authority, and evaluation and approval link to an exact release identity. Solid lines show release relationships; dashed lines connect records to the federated evidence index, with governed access, retention and source custody.

Text alternative: A product purpose and stable product identity lead to a release manifest. The manifest links behavior-shaping dependencies to evaluation claims, approval conditions, deployment state, operating observations, incidents, and subsequent changes. A material incident or change can reopen purpose, classification, evaluation, or approval.

The recommended record pattern is append-only for material decisions and operating events. Corrections should preserve both **valid time**—when the statement applied to the product—and **record time**—when the institution recorded or corrected it. Integrity techniques may include controlled repositories, signed attestations, hashes, or write-once event stores, selected according to consequence and the institution's architecture. This is an architectural recommendation, not a claim that one technology is required.

Durable history without retaining every sensitive payload

Keep an integrity-protected event record containing product/release IDs, event type, valid and record times, authorized decision and a protected payload reference. Store sensitive prompts or case content separately under their own access, retention and legal-hold rules. When lawful disposal is due, delete the payload or its permitted decryption material and retain only metadata justified by the records rule. A deletion marker identifies the authority, time and affected reference; it does not preserve the deleted content in a hidden log.

Reconstruction can establish that an event and a lawful deletion occurred while reporting that the original payload is unavailable. Backups, derived indexes and replicas follow the same disposition; a replay must not recreate disposed content. The records owner decides what metadata may survive, rather than treating append-only storage as a reason for indefinite personal-data retention.

2.5 Documentation Is Not Operating Effectiveness

A well-written document can describe a control that never operated. A log can show that a process ran without showing that it was well designed. A dashboard can display a metric without establishing that its threshold is appropriate. A signature can show approval without proving that the approver had adequate evidence.

This chapter therefore separates **design evidence**, **execution evidence**, **behavior evidence**, and **assurance conclusions**. Design evidence explains what should happen. Execution evidence shows that a defined activity occurred. Behavior evidence shows what the product or workflow did under specified conditions. An assurance conclusion records what a qualified reviewer concluded from the available evidence, including scope, limitations, unresolved findings, and independence. None is sufficient alone, and a conclusion should not be confused with the underlying evidence.

This is an author interpretation grounded in lifecycle risk management and the distinction between pre-release documentation, logs, monitoring, and ongoing management. It is not a formal audit definition attributed to NIST or EU law.[3]

Operating effectiveness also cannot be inferred from evidence volume. Thousands of logs may be irrelevant if they cannot identify a release or an affected action. A concise set of linked records may be more probative if it shows purpose, version, control execution, exception, and response. Evidence quality depends on relevance, integrity, completeness for the decision, timing, and interpretability.

Ask what would show that a control worked for this product and period. Capture the events and relationships needed to answer, while limiting unnecessary surveillance.

Common evidence anti-patterns

Use these diagnostic prompts to inspect the evidence chain. They are not institutional findings or a substitute for an audit method.

- **Artifact without decision:** a document exists, but the proposition it supported, the decision-maker, conditions, and date are unclear.
- **Version orphan:** a test result, approval, or incident record cannot be connected to the model, data, instructions, corpus, code, policy, or configuration that it describes.
- **Screenshot as proof:** a captured interface is treated as sufficient evidence even though provenance, configuration, completeness, and repeatability are unknown.
- **Log volume without meaning:** large event collections exist, but they cannot answer which material control operated, which exception occurred, or which response followed.
- **Approval without conditions:** a status says “approved,” but its permitted purpose, population, authority, limits, open findings, and expiry or review triggers are absent.
- **Evidence warehouse without ownership:** records are centralized, but no accountable role governs their meaning, quality, access, correction, retention, or use in decisions.
- **Retrospective reconstruction:** purpose, versions, tests, and rationale are assembled after a challenge because the delivery process did not preserve them when the decision was made.

Repair the missing identity, relationship, accountable owner or decision-specific evidence. Capture provenance and timing close to the activity. Sufficiency still depends on the decision, applicable obligations and competent judgment.

2.6 Evidence Architecture, Ownership, and Retention

Evidence needs an architecture even when it is distributed across delivery, model, data, ticketing, approval, monitoring, and records systems. A practical design should address:

- **Identity:** the governed product, component, release, environment, decision, and event can be identified.
- **Provenance:** evidence has a known producer, source, time, and transformation history appropriate to its use.
- **Relationships:** approvals, versions, tests, releases, observations, incidents, and changes can be connected.
- **Integrity:** unauthorized alteration can be prevented or detected.
- **Access:** people and services receive appropriate access, including separation for independent challenge.
- **Availability:** evidence can be retrieved within the time needed for operation, investigation, review, or a lawful request.
- **Minimization and protection:** collection and retention do not create avoidable privacy, confidentiality, or security exposure.
- **Lifecycle:** supersession, correction, expiration, legal hold, archival, and disposal follow applicable requirements.

These are architecture principles, not a tooling specification. The evidence may remain in systems that already own the source record, provided relationships and retrieval are dependable. Copying everything into a central store can introduce synchronization and access risk. Leaving everything distributed can make traceability fragile. The choice should follow the product's consequence, the institution's control environment, and applicable records obligations.

A practical implementation commonly uses a federated pattern: source systems retain authoritative records, while an evidence index stores stable identifiers, relationships, handling metadata, and retrieval pointers. The index should not become an ungoverned duplicate of sensitive evidence. The product or system owner is accountable for bundle completeness at a decision gate; designated challengers assess sufficiency for their domain; custodians preserve access and integrity without inheriting the decision accountability.

Retention cannot be set by a universal table in this book. It varies by jurisdiction, actor, system classification, record type, contract, litigation or investigation needs, privacy law, and institutional policy. The EU AI Act contains specific documentation and log provisions for defined covered systems and actors; those provisions require qualified legal interpretation before application.[4]

Ownership should distinguish who produces a record, who is accountable for its content, who administers the system, who may challenge it, and who decides retention or access. One team should not silently become the owner of every evidence class merely because it operates a platform.

Separating ownership roles

For a material evidence item or evidence class, an institution may need to distinguish several roles:

- the **evidence producer**, which creates or emits the record;
- the **content owner**, accountable for the record's meaning and accuracy within its defined use;
- the **control owner**, accountable for the control whose design or execution the evidence is meant to support;
- the **decision owner**, who uses the evidence to approve, reject, condition, or escalate a proposition;
- the **custodian or platform operator**, which stores, protects, and makes the record available;
- the **reviewer or challenger**, who assesses sufficiency with appropriate independence; and
- the **records authority**, which interprets applicable retention, disposal, legal-hold, and archival rules with qualified legal and privacy input.

These are author-developed role distinctions, not a prescribed organization chart. One person or function may hold more than one role where policy and independence allow. The important point is to prevent custody from being mistaken for accountability, production from being mistaken for approval, and approval from being mistaken for independent challenge. Material conflicts or gaps should be recorded and resolved through the institution's governance model.

Five evidence classes and eight artifact families

The five evidence classes answer *what proposition is being supported*; the eight artifact families answer *where a reader can find the connected record*. One artifact can contain several evidence classes, and one class can be distributed across artifacts.

Table 2.3 — Evidence class and a1 charter

Evidence class	A1 Charter	A2 Use	A3 Risk/authority	A4 Architecture	A5 Manifest	A6 Evaluation	A7 Approval/release	A8 Operate/change
decision evidence	primary	primary	primary	supporting	supporting	conclusion	primary	primary
implementation evidence	supporting	supporting	supporting	primary	primary	test target	release identity	operating identity
assurance evidence	limitation	acceptance	challenge	review	provenance review	primary	independent conclusion	periodic assurance
operating evidence	outcome hypothesis	boundary signal	reclassification signal	control health	dependency state	production sample	condition status	primary
change evidence	purpose change	use change	route change	design change	version change	regression	reapproval	primary

Read each matrix cell as the relationship to the artifact family: primary = principal home; supporting = context; conclusion/challenge/review = assessment; identity/test target/provenance = examined object; and hypothesis/signal/status/sample/change/regression/reapproval = the named link. These descriptive links are neither scores nor exclusive allocations. Map them to the institution's systems and authorities. Appendix F holds the detailed crosswalk.

Evidence-index security and resilience

The federated index is a high-value evidence-index control capability. It connects authoritative records; the architecture control plane in Chapter 9 enforces product policy and permissions. The two capabilities interact but have distinct responsibilities. Its threat model should cover pointer manipulation, privilege escalation through metadata, stale or divergent identifiers, duplicate evidence, search-result leakage, loss of availability, unauthorized bulk discovery, and false completeness. Baseline controls include source-system authorization, least-privilege indexing, immutable event history, identifier reconciliation, integrity monitoring, protected administration, availability objectives, and recovery tests. Risk-triggered controls include independent reconciliation, dual authorization for sensitive metadata changes, segregated search domains, and incident population reconstruction.

Index status must remain distinct from source-record status. A valid pointer does not prove the record is sufficient or truthful; a broken pointer can make an otherwise sound decision unauditable. Evidence health therefore has its own owner, tests, incident route, and re-entry trigger.

The authoritative phase and evidence crosswalk

Table 2.4 — Phase and decision

Phase	Decision	State produced
Discover and assess	Fund a bounded question or stop	Proposed idea → assessed candidate
Define and classify	Bound permitted use and route authority/risk	Assessed candidate → bounded candidate
Design and build	Construct the bounded candidate and enforce boundaries	Bounded candidate with identified build/configuration; no new named approved state
Evaluate and challenge	Decide whether evidence supports defined claims	Bounded candidate → evaluated candidate → approval candidate when evidence submitted
Approve and release	Accept, condition, reject or hold an identified release	Approval candidate → approved release, or recorded hold/rejection
Deploy and operate	Verify deployment and decide continued authorized service	Approved release → deployed configuration → operating service; restricted service if necessary
Change and reapprove	Assess affected claims and route a changed candidate	Operating/restricted service → affected candidate state; renewed approval/deployment only after relevant decisions
Retire and learn	Close service and preserve residual obligations	Operating/restricted service → retired service after verified closure

The complete role/evidence/artifact/template and re-entry fields are in Appendix F's lifecycle reference. The compact view is a navigation aid; the filled PA-01 record in §2.7 shows a decision trail.

This is an author-developed descriptive mapping. Institutions adapt functional role names to their delegations. Lists of artifact families and evidence classes identify linked records; they do not rate connections or establish sufficiency. "Assembled," "renewed" and "closed" on companion visuals describe a configured bounded candidate, a candidate reopened by change, and a retired service. They do not add controlled approval states.

Evidence access during degraded operation

Table 2.5 — Condition and authorized evidence route

Condition	Authorized evidence route	Decision boundary	Owner and recovery evidence
Index unavailable	Integrity-checked recovery snapshot or authorized direct-source retrieval; state age and gaps	Continue only where identity, authorization and required evidence remain established; hold affected new release/authority decisions	Custodian restores access; service/incident owner records restriction and retrieval tests
Index integrity doubtful	Isolate affected index and preserve investigation records; validate bindings against trusted source systems	A working pointer does not establish truthful evidence or an authorized configuration	Security/content owners scope tampering; decision owner assesses affected approvals
Snapshot stale or permission revoked	Check effective source and entitlement state with the authority that owns it	Snapshot availability does not revive withdrawn knowledge, expired approval or revoked access	Content/access owner records withdrawal and negative-access tests
Challenge access unavailable	Restore protected reviewer route or record decision hold	Custodian does not substitute its own approval for independent challenge	Reviewer and decision owner record missing evidence/conflict and restoration
Recovery and replay	Reconcile buffered event IDs, duplicate records and source links before reopening affected use	Evidence recovery, operating restoration, customer remedy and reapproval remain separate decisions	Custodian/ service/ records owners preserve replay, sample reconstruction and residual gaps

Define recovery priority by evidence needed for containment, safe service, affected-population reconstruction and lawful requests. Set retrieval targets, snapshot age/cadence, protected access, dependency order, buffering and reconciliation locally against service tolerances. Exercise unavailable, corrupt, stale and access-revoked

conditions; do not prescribe one universal recovery time. Chapter 25 links this capability to continuity and Chapter 23 to incident decisions.

Role-to-decision handoff

Table 2.6 — Role and action and record

Role	Action and record	Boundary / handoff
Producer	Create event/test/configuration record with identity and time	Content owner assesses meaning; production does not imply approval
Content owner	Attest scope, accuracy and effective version	Decision owner uses the record; custodian preserves it
Control owner	Own control design/operation and failure response	Provide evidence to challenger; resolve or escalate findings
Decision owner	Hold, reject, condition or approve the stated proposition	Bind delegation, scope, conditions, expiry and re-entry to a record
Custodian	Protect, retrieve and reconcile evidence links	Does not inherit content accountability or independent review
Independent challenger	Record supported conclusion, limitations and conflicts	Escalate insufficiency without delivery-owner substitution
Records authority	Determine applicable retention/hold/disposal with legal/privacy input	Give custodians an authorized record-handling rule

Record conflicting roles, delegates and emergency expiry rather than treating custody or attendance at a forum as decision authority. Existing emergency-containment reasoning in §§4.7 and 7.7 applies to the affected decision. See Figure 2.2.

Relationship key and runtime dependencies

Figure 2.2 — Five evidence classes; eight artifact families

Family	Decision evidence	Implementation evidence	Assurance evidence	Operating evidence	Change evidence
A1	primary	supporting	limitation	outcome hypothesis	purpose change
A2	primary	supporting	acceptance	boundary signal	use change
A3	primary	supporting	challenge	reclassification signal	route change
A4	supporting	primary	review	control health	design change
A5	supporting	primary	provenance review	dependency state	version change
A6	conclusion	test target	primary	production sample	regression
A7	primary	release identity	independent conclusion	condition status	reapproval
A8	primary	operating identity	periodic assurance	primary	primary

Artifact family key

A1 — AI Product Charter

A2 — Intended and Prohibited Use Record

A3 — Risk, Criticality, Materiality and Authority Assessment

A4 — System and Trust-Boundary Architecture Record

A5 — Data, Knowledge, Model, Prompt, Tool and Dependency Manifest

A6 — Evaluation and Acceptance Record

A7 — Approval, Exception and Release Record

A8 — Operating, Incident, Change and Retirement Record

The approved five classes and eight family names retain their descriptive crosswalk. No Primary, Supporting or Conditional figure edge has been inferred.

The nearby matrix legend applies to these artifact relationships as well. “Operating evidence” is also called “operation evidence” in the preserved source treatment.

Runtime authorization is a separate dependency from evidence discovery. The service needs authenticated identity, authoritative permission and source-authority checks before protected retrieval or action. It can use a verified release manifest and an approved, bounded evidence snapshot where policy permits; the snapshot cannot restore revoked authority. Material decisions stop when their required evidence cannot be established, even if low-consequence permitted work continues. The evidence index supports retrieval and investigation; it is not automatically a synchronous dependency for every request.

2.7 Illustrative Scenario: Tracing the Expanding Copilot

Illustrative scenario — fictional composite. Fictional Bank’s customer-service copilot is used only to show hypothetical evidence relationships. The scenario does not represent implemented controls or achieved outcomes.

For the internal drafting stage, decision evidence describes the permitted task and users. Implementation evidence identifies the application, model and configuration, instructions, and data boundary. Assurance evidence records the approved test cases and known limits. Operating evidence identifies the deployed state and permitted feedback or escalation events. Change evidence records material modifications.

When retrieval is added, the bundle must also identify corpus ownership, approved source collections, effective versions, access rules, indexing and ranking configuration, and the retrieval-aware evaluations that supported release. The evidence does not need to duplicate every source document, but it must make the evaluated knowledge state identifiable.

When customer context is introduced, the bank must revisit purpose, access, privacy, evaluation populations, human review, and escalation. A previous approval does not automatically cover the expanded boundary. If the product begins preparing a structured system update, the evidence must distinguish preparation from execution and relate field permissions, validation, preview, confirmation, and recovery to the released configuration.

If a consequential action is proposed, the evidence bundle should expose a new authority decision rather than hiding it inside a technical change. That decision would require broader review and renewed assurance. The scenario does not assume approval.

The teaching point is that the bundle changes as the product changes. Evidence lineage makes the expansion visible and gives executives, delivery teams, operators, and reviewers a shared object for challenge.

Worked traceability examples

The following are bounded fictional examples, not legal conclusions or representations of actual controls.

A policy-corpus update. Suppose an approved policy collection is reissued. The change evidence should identify the source owner, effective date, affected collection, ingestion and indexing change, and impact assessment. Implementation evidence should identify the new corpus and retrieval configuration. Assurance evidence should show which retrieval and answer behaviors were re-evaluated, including conflicts, superseded text, missing results, and citations or provenance where required. The release decision should state whether the existing use boundary and conditions remain valid. Operating evidence should make the effective deployment state identifiable. A document upload alone would not establish this lineage.

A model or provider change. Suppose the application moves to a different model version or provider endpoint while its user interface remains unchanged. The change record should identify the reason, affected dependencies, data handling and contractual questions requiring qualified review, expected behavioral differences, and rollback or fallback assumptions. The renewed evaluation should be selected from the product's claims and known failure modes rather than treated as a generic model benchmark. The decision owner should be able to relate the accepted results and limitations to the exact released configuration. The example does not imply that every provider change has the same materiality.

A prepared system update. Suppose the copilot may prepare, but not execute, a structured customer-service record update. Decision evidence should preserve that authority boundary. Implementation evidence should identify permitted fields, validation, preview, confirmation, and the service identity used by the application. Assurance evidence should test malformed, prohibited, ambiguous, and stale inputs as well as ordinary cases. Operating evidence should distinguish preparation, reviewer action, submission, rejection, and recovery events at the granularity justified by the use case. If execution authority is later added, that is a new authority proposition requiring renewed classification and approval; it should not be hidden as a minor configuration change.

Across all three examples, the traceability test is whether a qualified reviewer can move from purpose and authority to the relevant configuration, evidence, decision, deployed state, and subsequent change without relying on undocumented memory. The exact records, retention periods, and review depth remain institution- and jurisdiction-specific.

Canonical evidence bundle: one fictional release

The eight reader-facing artifact families can be implemented as linked records rather than eight large documents. For the Fictional Bank policy assistant, a release bundle contains:

Table 2.7 — Artifact family and fictional release evidence

Artifact family	Fictional release evidence	Known limitation
Product Charter	internal employee policy support; accountable product owner; non-AI alternative	value outcome not yet demonstrated
Intended and Prohibited Use	entitled employees and approved topics; no customer communication or record action	shadow use outside the channel may be under-observed
Risk, Criticality, Materiality and Authority Assessment	read-only retrieval and drafting; sensitive policy corpus; no tool execution	local classification requires accountable approval
System and Trust-Boundary Architecture	authenticated channel, entitled retrieval, model gateway, output validation, evidence store	external provider internals remain limited
Dependency Manifest	code, prompt, model endpoint, corpus/index, ranking, policy and telemetry identities	provider may change behavior within contractual limits
Evaluation and Acceptance Record	retrieval coverage, exception cases, support, refusal, entitlement and fallback	sample cannot prove every operating response
Approval, Exception and Release Record	bounded release, conditions, owner, expiry and deployed configuration	no inference of control effectiveness
Operating, Incident, Change and Retirement Record	runtime samples, source withdrawal, incidents, changes and eventual closure	outcome evidence matures over time

The release identity connects these records. A reviewer can move from the operating service to its approval and evaluation without relying on a folder name. Sensitive prompts or traces can remain in access-controlled systems; the evidence index stores a pointer, identity, owner, access class and integrity metadata rather than copying content unnecessarily.

The main anti-patterns are stale pointers, inconsistent identifiers, copied evidence that diverges from its source, access leakage through the index, and a central register that becomes a single operational dependency. Reconciliation and access tests are therefore part of the evidence architecture.

One reconstructed decision trail

Synthetic teaching record PA-01. PA-R1/PA-DRAFT retrieves approved policy and returns internal drafts. It has no customer-record access, ticket-preparation endpoint, submission credential or external-send capability. The entries below are constructed teaching records, not measured results.

Identity key and ordered timeline: POL-DOC-01-v1 is one policy-document version; POL-7 and POL-8 are corpus snapshots; IDX-7 and IDX-8 are their indexes; P-41 is the permission policy; PA-0.1–PA-0.3 are product candidates; PA-R1 is the bounded release. Source/index approval does not approve a product candidate. Before evaluation, POL-DOC-01-v1 is approved for retrieval in POL-7/IDX-7. PA-0.1 fails omission testing. PA-0.2, using the repaired POL-8/IDX-8, fails an injection test. PA-0.3 is evaluated on POL-8/IDX-8/P-41 before the four-week PA-R1 pilot. During that pilot POL-DOC-01-v1 is withdrawn, but a derived cache remains reachable. Both snapshots contain that document version, so neither can restore its current authority. Containment holds the affected topic while a forward repair is evaluated; no repaired release is represented as approved.

Table 2.8 — Record and version and evidence

Record	Version and evidence	Resulting decision
PA-USE-01	Topic set and employee roles; draft-only authority	Candidate PA-0.1 enters evaluation, not operation
PA-MAN-01	PA-0.1, corpus POL-7, index IDX-7, permission version P-41	Identifies the exact failed test target
PA-EV-01	Exception test EX-01 returns the main rule without its material exception	Severe omission; reject the affected candidate
PA-CHG-01 / PA-EV-02	PA-0.2 restores exception retrieval on POL-8/IDX-8; an approved-source injection produces forbidden action-shaped text, without an admitted preparation endpoint	Hold; fix the external control and retest
PA-EV-03	PA-0.3: 300 ordinary cases, 60 exception cases, 30 targeted stress cases and 20 oversight exercises (§16.9)	Evidence supports only the stated bounded teaching pilot
PA-GATE-01 / PA-R1	Delegate permits 25 employees and named internal topics; no new action authority	Verify deployment and operating acceptance separately
PA-OBS-01 / PA-INC-01	Withdrawal of document POL-DOC-01-v1 is not propagated to a derived cache during PA-R1 operation (§23.10)	Restrict affected topics; reconstruct exposure and re-enter review

PA-EV-03 retains links to the earlier failed results. An investigator can follow PA-R1 back to its approval, remediated findings and evaluated manifest, then follow PA-INC-01 to the proposed repair. The repair and restart decisions remain separate from containment.

2.8 Executive Decisions and Practitioner Checklist

Ask the product owner to reconstruct one decision from the operating event back to the use, manifest and evaluation. Record every missing link and its owner. Custody of the index does not transfer decision accountability.

Notes

1. NIST, AI RMF 1.0 (B01) and AI RMF Playbook (B03); Mitchell et al., “Model Cards for Model Reporting” (B24). Return to text

2. European Union, consolidated Regulation (EU) 2024/1689 (B07). Return to text

3. NIST, AI RMF 1.0 (B01) and AI RMF Playbook (B03); European Union, consolidated Regulation (EU) 2024/1689 (B07). Return to text

4. European Union, consolidated Regulation (EU) 2024/1689 (B07). Return to text

Chapter

3 Banking Context: Value, Trust, and Consequence

This chapter provides global principles with bounded international and jurisdiction examples. It does not provide legal advice or assert that every banking AI use has the same materiality.

3.1 Why Banking Context Changes the Decision

An AI technique does not become technically different when used by a bank. Its institutional meaning can change sharply. The same generated text might be an internal brainstorming aid, a draft customer communication, an explanation used in servicing, or an instruction that affects an account. The model can be similar while purpose, affected parties, authority, and consequence are different.

Banking combines customer relationships, financial decisions, sensitive data, regulated records, interconnected infrastructure, third parties, and services expected to remain available. These conditions do not prove that every AI system is high risk. They require the institution to classify the product in context and to justify why its controls, evidence, and authority are proportionate.

The Financial Stability Board describes both potential benefits and vulnerabilities from AI in finance. It identifies potential operational efficiency, compliance, analytics, and personalization benefits, while highlighting third-party dependency and concentration, market correlation, cyber risk, model risk, data quality, and governance as potential vulnerabilities. These are sector-level observations, not a prediction about a particular firm or use case.[1]

The executive decision is therefore not “Should the bank use AI?” It is whether a defined product, for a defined purpose and with defined authority and evidence, creates an acceptable relationship between value and consequence. Practitioners must make that relationship visible in requirements, architecture, evaluation, release, and operation.

3.2 Value Pathways and Failure Pathways

An AI proposal should describe how value is expected to arise. A product may reduce search effort, support consistent drafting, prioritize work, identify patterns, improve accessibility, or help staff navigate complex information. A value pathway connects the capability to a user, a decision or task, an operating change, and a measurable institutional outcome.

The proposal should also describe how failure travels. An unsupported summary can mislead an employee. A recommendation can influence a decision. An incorrect extraction can enter a record. A tool action can change a system. A provider outage can interrupt a process. A weak escalation design can turn a detectable error into a persistent one.

Value and failure often share a dependency. Connecting the product to current institutional knowledge may improve usefulness and create a new reliance on corpus governance. Giving the product customer context may improve relevance and create privacy, conduct, and access questions. Adding a tool may reduce manual work and increase the consequence of an authorization or validation failure.

This is why business cases should not present value and risk as separate appendices. The same end-to-end workflow should show both. If a claimed benefit depends on scale, automation, or integration, the assessment should also examine how those properties change exposure, reversibility, monitoring, and recovery.

No performance figure is offered in this chapter. Benefits, savings, error reduction, adoption, or customer outcomes require institution-specific evidence. A demonstration can show possibility; it cannot establish realized value or acceptable risk in production.

Bounded examples: the same capability in different banking settings

The following examples are hypothetical and deliberately incomplete. They illustrate questions that enter classification; they do not assign a risk tier, state an applicable law, or prescribe a control outcome.

Table 3.1 — Banking domain and illustrative ai pattern

Banking domain	Illustrative AI pattern	Failure pathway and affected party	Questions that enter classification
Customer servicing	Drafting or retrieval assistant; employee controls communication	Unsupported or incomplete explanation may impair understanding, challenge, complaint, or redress	Source authority, customer-data access, reviewer capability, disclosure, complaint path, communication record
Lending and credit	Predictive or generative decision support; no legal classification assigned here	Error or weak explanation may affect an applicant, pricing, conditions, or an adverse outcome	Data and proxy effects, decision authority, explanation, challenge, override, monitoring, applicable automated-decision rules
Fraud or financial-crime triage	Predictive prioritization plus case summarization	False reassurance may hide material evidence; false positive may contribute to delay, hold, or customer friction	Data provenance, threshold ownership, investigator reliance, protected information, escalation, recourse, legal and supervisory framework
Payments and transaction integrity	Detection, blocking, recommendation, or bounded automated response	Delay or incorrect intervention can affect funds, merchants, customers, and service continuity	Real-time limits, false-positive handling, override, on-the-loop monitoring, reversal, redress, resilience
Treasury or markets	Synthesis or recommendation without order-entry authority	Stale or unsupported analysis may affect position taking or common-provider reliance	Timeliness, source rights, authority, concentration, practical reliance, escalation

Table 3.1 (continued)

Banking domain	Illustrative AI pattern	Failure pathway and affected party	Questions that enter classification
Regulatory reporting	Mapping and exception drafting with accountable review	Incorrect mapping or outdated instruction can enter a regulated record	Authoritative-source ownership, effective dates, lineage, reviewer competence, correction, jurisdiction

These examples do not determine a legal classification, risk tier, or permitted control outcome. They expose the workflow questions that must be routed to the institution's applicable regimes and accountable specialists.

These cases also show why "internal" is not synonymous with "low consequence." The consequence depends on the workflow and reliance. Conversely, a customer-facing interface is not classified by channel alone. The analysis must examine purpose, affected parties, authority, dependencies, safeguards, and recoverability.

Compare two uses of the same language model. PA-DRAFT prepares an internal policy explanation without customer records or sending authority; its first severe failure is a missing policy exception. A credit-support variant consumes application facts and influences an underwriting decision; it adds rights, fair-lending, actual-reason, oversight and customer-remedy questions. The model name has not changed, but the consequences, authorized data and specialist route have. The second use cannot inherit the first use's permission.

3.3 Customer, Conduct, Fairness, and Financial Consequences

Customer consequence depends on what the system influences. A drafting aid may affect the clarity of a communication. A recommendation may influence eligibility, treatment, pricing, servicing, complaint handling, or escalation. A generated explanation may shape whether a customer understands and can challenge a decision. An automated action may affect money, access, or a contractual relationship.

The control question is not whether a human appears in the workflow. It is whether the decision path preserves a meaningful ability to understand, challenge, correct, escalate, and provide redress where appropriate. Human oversight must be designed for the task, information, competence, authority, workload, and intervention route. The research base does not provide a universal time or case-volume threshold for sufficiency.[2]

Fairness also cannot be reduced to a single metric. The relevant population, outcome, legal context, product purpose, error distribution, and remedy matter. A metric may illuminate a difference without resolving whether the difference is justified, harmful, or lawful. Detailed fairness, conduct, and legal methods belong later in the book; Part I establishes that these concerns enter the product definition and evidence plan before release.

For leaders, customer-impact classification should influence sponsorship, challenge, approval, monitoring, and escalation. For delivery teams, requirements should identify affected users and populations, unacceptable outcomes, information shown to staff or customers, override and correction paths, and the evidence needed to test the workflow.

A complete failure pathway also includes detection, containment, correction, customer treatment where applicable, and learning. A product that can influence a customer outcome needs a defined route for identifying affected cases, stopping or narrowing the behavior, correcting records or communications, escalating material harm, providing appropriate redress, and feeding the event into evaluation and change. This is a governance design principle; specific notification, remediation, or legal duties remain jurisdiction- and fact-dependent.

EU law provides specific requirements for covered systems within its scope, including documentation, logging, human oversight, and deployer obligations for certain high-risk AI systems. It is a jurisdiction-specific example, not a global banking rule, and applicability depends on actor, system, classification, territory, and timing.[3]

Domain, consequence and specialist routing

Table 3.2 — Domain / consequence and primary review questions

Domain / consequence	Primary review questions	Specialist route
Policy/employee support; records and conduct	Source authority, disclosure, restricted access and employee challenge	Knowledge, information/security, conduct and human factors
Lending; customer/fairness and prudential	Decision authority, reasons, population, legal classification and model use	Credit/model risk, fair-lending/privacy/legal and conduct
Fraud/AML; operational and financial-crime	Queue/severe-case consequence, evidence support, labels and investigator authority	Financial-crime domain, model risk, operations and legal
Payments/trading; financial and market	Transaction permission, market conduct, reversibility and reconciliation	Financial control, market/conduct, security and operations
Critical service/provider dependency; resilience/systemic	Shared failure, concentration, fallback, exit and service tolerance	Resilience, third-party risk, security and operations
All domains; institution/systemic exposure	Aggregate population, concentration, correlated control failure and governance capacity	Enterprise risk and executive/board oversight within mandate

These routes supplement the bounded source/jurisdiction lenses in §3.4. Several consequence domains may apply to one product; no row is an automatic legal or risk classification.

3.4 Prudential, Market, Financial-Crime, and Reporting Context

Some banking uses sit beyond an individual customer interaction. AI may support risk management, trading or market analysis, treasury, regulatory reporting, fraud investigation, or financial-crime work. In these settings, error can affect the institution's risk view, controls, reporting, or market behavior. The specific obligations differ by use and jurisdiction; the book does not infer a legal classification from a model label.

FSB analysis is useful at the sector level because it connects AI adoption to model and data risk, cyber risk, third-party concentration, and potential market correlations. The analysis does not establish firm-level requirements or outcomes, but it explains why authorities and institutions should monitor both adoption and vulnerability.[4]

Model-risk expectations also require careful scoping. The UK PRA's SS1/23 applies to its stated population and model scope. The 2026 U.S. interagency MRM guidance is risk-based and expressly excludes generative and agentic AI; it is also non-enforceable guidance. Neither source can be treated as a universal rule for every AI product. They do, however, illustrate why institutions must identify which existing governance regimes apply rather than assuming that "AI governance" replaces them.[5]

The practical requirement is a regulatory and control applicability analysis tied to the actual use. A product can intersect model risk, operational risk, cybersecurity, data, privacy, conduct, financial crime, records, resilience, and third-party governance at the same time. One committee or inventory does not remove those accountabilities.

Jurisdiction lenses without false equivalence

A global framework needs a common vocabulary and a disciplined way to preserve differences. The sources below do not form one harmonized rulebook, and their terms should not be substituted for one another.

The source-status view below was refreshed on 8 October 2026. Instrument availability and dated status do not establish local applicability.

Table 3.3 — Lens and status and scope

Lens	Status and scope	Permitted use in this chapter	Limitation
BCBS and FSB	International principles and analysis	Prudential, resilience, third-party, and system-level context	Not directly binding in every jurisdiction
European Union	Binding law and official implementation material within applicable actor, system, territorial, classification, and timing scope	Bounded example of documentation, logging, oversight, and transparency obligations	Requires qualified interpretation of the current consolidated text; bank use alone does not determine classification
United Kingdom	PRA SS1/23 within its defined population and model scope	Example of proportionate model-risk expectations	Not universal to every AI product or UK financial firm
United States	2026 interagency model-risk guidance within its stated scope	Bounded model-risk example	The registered source expressly excludes generative and agentic AI and is not used to govern them by analogy without an institutional decision
Singapore	Final MAS AI risk-management guidelines issued 7 October 2026; the 2025 consultation is historical	Dated supervisory-expectation example for financial institutions	Sections 3–4 expectations from 7 October 2027; Sections 5–6 by 7 October 2028. Institution/use applicability requires Singapore-qualified review

The writing rule is to name the source, actor, scope, status, date, and limitation whenever a jurisdiction example carries legal or supervisory weight. A general governance principle must not be converted into an unsupported compliance claim.[678910]

Actor and article timing record

Regulation (EU) 2026/1744 (B61), Article 1(40), narrows the timing statement: Article 113(c) applies Chapter III Sections 1–3, except Article 6(5), from 2 December 2027 for Article 6(2)/Annex III high-risk systems and from 2 August 2028 for Article 6(1)/Annex I high-risk systems. This is not a blanket deferral of the Act. General application from 2 August 2026 coexists with earlier provisions and specific transitions, including Article 111(4) for Article 50(2). Actor, system, exclusion and transition analysis is necessary for the actual use. B07 is a documentary consolidation; the underlying acts control. Qualified applicability review remains required.[11]

Table 3.4 — Provision and actor/use to screen

Provision	Actor/use to screen	Duty to assess	Timing/status and owner
Article 4	Relevant providers/deployers	Measures supporting staff/other operators' AI literacy, without guaranteeing any individual level	Original application 2 February 2025; amended wording effective 27 July 2026; legal/learning owner verifies context and scope
Article 26	Deployer of an in-scope high-risk system	Deployer controls, oversight, monitoring and records	High-risk route and transition dependent; EU legal owner binds the actual system
Article 27	Specified deployers and uses, including covered creditworthiness/ insurance routes	Fundamental-rights impact assessment trigger and exceptions	Requires actor/use and amended timing analysis; rights/privacy/legal owners
Article 50	Relevant provider/deployer and content/function	Separate marking, interaction or disclosure duties and exceptions	General application 2 August 2026; eligible pre-2 August systems: Article 50(2) marking by 2 December 2026 under Article 111(4). EU legal owner verifies duty/transition

Record the source version, territorial/entity scope, system purpose, actor, applicable date, exception and review conclusion for each use. Do not convert those dates into a

universal banking requirement. Singapore's newly issued final guidelines are a distinct instrument from the March 2026 MindForge toolkit.[12]

3.5 Critical Services and Operational Resilience

An AI-enabled product becomes an operational-resilience concern when it supports or can disrupt a critical operation or important service. The product may be a direct component in the service path, a decision-support tool on which staff become dependent, or an upstream capability whose failure affects capacity or quality.

BCBS operational-resilience principles emphasize a bank's ability to withstand disruptions and connect resilience to governance, operational-risk management, business continuity, third-party dependencies, incident management, and technology. The principles are not AI-specific and national implementation varies. Their relevance is contextual: adding AI does not remove the responsibility to understand critical operations, tolerances, dependencies, response, and recovery.[13]

An institution should ask what happens when the product is unavailable, produces degraded output, loses access to a provider, retrieves stale material, or must be disabled quickly. A fallback that exists on paper may fail if staff no longer have capacity or competence to perform the task. A rollback may restore software without restoring the prior knowledge state. An incident may cross teams because symptoms appear in the workflow while the cause sits in data, a provider, model behavior, or access policy.

Resilience is therefore designed with the operating process. Teams should identify dependencies and failure modes, define safe degradation or suspension, preserve decision authority during disruption, exercise recovery, and collect evidence that the plan remains viable. Detailed methods belong to later chapters; the Part I decision is whether the service consequence requires that deeper treatment.

3.6 Legacy Systems, Data, Third Parties, and Concentration

AI products rarely enter a clean environment. They connect to legacy applications, data stores, identity systems, workflow engines, vendor services, and manual processes. An apparently modern interface can conceal brittle dependencies, inconsistent identifiers, delayed data, limited observability, or business rules embedded in old systems.

BCBS's 2024 digitalisation report considers benefits and risks of new technologies and technology-enabled suppliers. Its 2025 third-party-risk principles respond to banks' broader dependency on providers and establish a common international baseline while allowing jurisdictional flexibility. FSB work also highlights AI-related third-party dependencies and service-provider concentration.[14]

These sources do not mean that every external model or cloud service creates material concentration risk. The institution must examine substitutability, portability, data and configuration access, change notice, service levels, assurance rights, security, continuity, exit, and the effect of one dependency across multiple products. A vendor relationship can be well governed at contract level while the technical architecture still makes replacement impractical.

Data accountability may be distributed across several owners. The team building the application may not own the source record, definition, quality process, or retention decision. A successful design needs accountable data and knowledge owners, explicit interfaces, and evidence of the state used by the product.

For executives, dependency is a portfolio question as well as a product question. For practitioners, it is an architecture and operations question. Both views are needed to see whether separate initiatives share a common failure point.

3.7 Accountability Cannot Be Delegated to a Model

A model cannot own a business purpose, accept risk, approve a release, justify an exception, respond to a customer, or remediate an incident. People and governance bodies remain accountable for those decisions even when the system produces a recommendation or acts within delegated authority.

This is the book's governance principle. NIST and jurisdiction-specific sources support lifecycle roles, responsibilities, and oversight within their scopes, but the manuscript does not claim one universal legal allocation.[15]

Accountability should be concrete. A product owner may be accountable for purpose and value; a system owner for the operating service; data and knowledge owners for governed sources; control owners for defined safeguards; risk or validation functions for independent challenge; and designated authorities for accepting residual risk. The exact model depends on the institution. What must not happen is an accountability gap created by distributing components across teams and providers.

The phrase "the AI decided" obscures that institutional design. The system may generate an output or select an action within configured authority. The institution decided to create the workflow, grant access, set limits, rely on evidence, and operate the product. Evidence should make those decisions reviewable.

3.8 Illustrative Scenario: The Copilot Meets Banking Reality

Adding customer context turns the §1.9 drafting proposal into a potential underwriting recommendation. Conduct and privacy reviewers withhold that extension until its data purpose, affected population and customer challenge route are assessed. PA-R1's internal draft-only evidence cannot authorize it.

3.9 Executive Decisions and Practitioner Checklist

Route the actual banking activity, actor and jurisdiction to the relevant specialists. The same model supporting internal drafting and customer credit needs different evidence and authority; keep those use versions separate.

Notes

1. Financial Stability Board, The Financial Stability Implications of Artificial Intelligence (B14) and Monitoring Adoption of Artificial Intelligence and Related Vulnerabilities in the Financial Sector (B15). Return to text

2. Sterz et al., "On the Quest for Effectiveness in Human Oversight" (B26); Goddard, Roudsari, and Wyatt, "Automation Bias" (B27); NIST, AI RMF 1.0 (B01). Return to text

3. European Union, consolidated Regulation (EU) 2024/1689 (B07); European Commission, AI Act: regulatory framework (B08). Return to text

4. Financial Stability Board (B14–B15). Return to text

5. Bank of England/PRA, SS1/23 (B09); U.S. federal banking agencies, Model Risk Management: Revised Guidance (B10). Return to text

6. Basel Committee on Banking Supervision (B11–B13); Financial Stability Board (B14–B15). Return to text

7. European Union (B07); European Commission (B08). Return to text

8. Bank of England/PRA, SS1/23 (B09). Return to text

9. U.S. federal banking agencies, Model Risk Management: Revised Guidance (B10). Return to text

10. Monetary Authority of Singapore, final Guidelines on AI Risk Management for Financial Institutions, 7 October 2026 (B56): §§3–4 apply from 7 October 2027; §§5–6 by 7 October 2028. B29 is consultation history, not the source for these final dates. Entity/use applicability requires Singapore-qualified review. Return to text

11. European Union consolidated Regulation (EU) 2024/1689 (B07), documentary only; amending Regulation (EU) 2026/1744 (B61), Article 1(5), (39), (40) and Article 4; Commission timing (B08) and Article 50 guidance (B38). Official HTML/consolidation inspected; authenticated OJ PDF/e-signature and entity/use application remain open. Return to text

12. MAS final AI risk-management guidelines and 7 October 2026 release (B56); phased expectations inspected on 8 October 2026. Qualified Singapore applicability review remains required. Return to text

13. Basel Committee on Banking Supervision, Principles for Operational Resilience (B11). Return to text

14. Basel Committee on Banking Supervision, Digitalisation of finance (B12) and Principles for the sound management of third-party risk (B13); Financial Stability Board (B15). Return to text

15. NIST, AI RMF 1.0 (B01); Bank of England/PRA, SS1/23 (B09); European Union (B07). Return to text

Chapter

4 AI Types, Autonomy, and Control Intensity

The assistance-to-action ladder and six control-intensity factors are author-developed frameworks. They are not universal standards or regulatory taxonomies.

4.1 Why Labels Are an Incomplete Control Basis

Names such as *model*, *copilot*, *assistant*, and *agent* are useful shorthand and weak control categories. They may describe a technical pattern, user experience, product position, or aspiration. They do not reliably tell an institution what information the product can access, what output it produces, what authority it holds, who relies on it, or what happens when it fails.

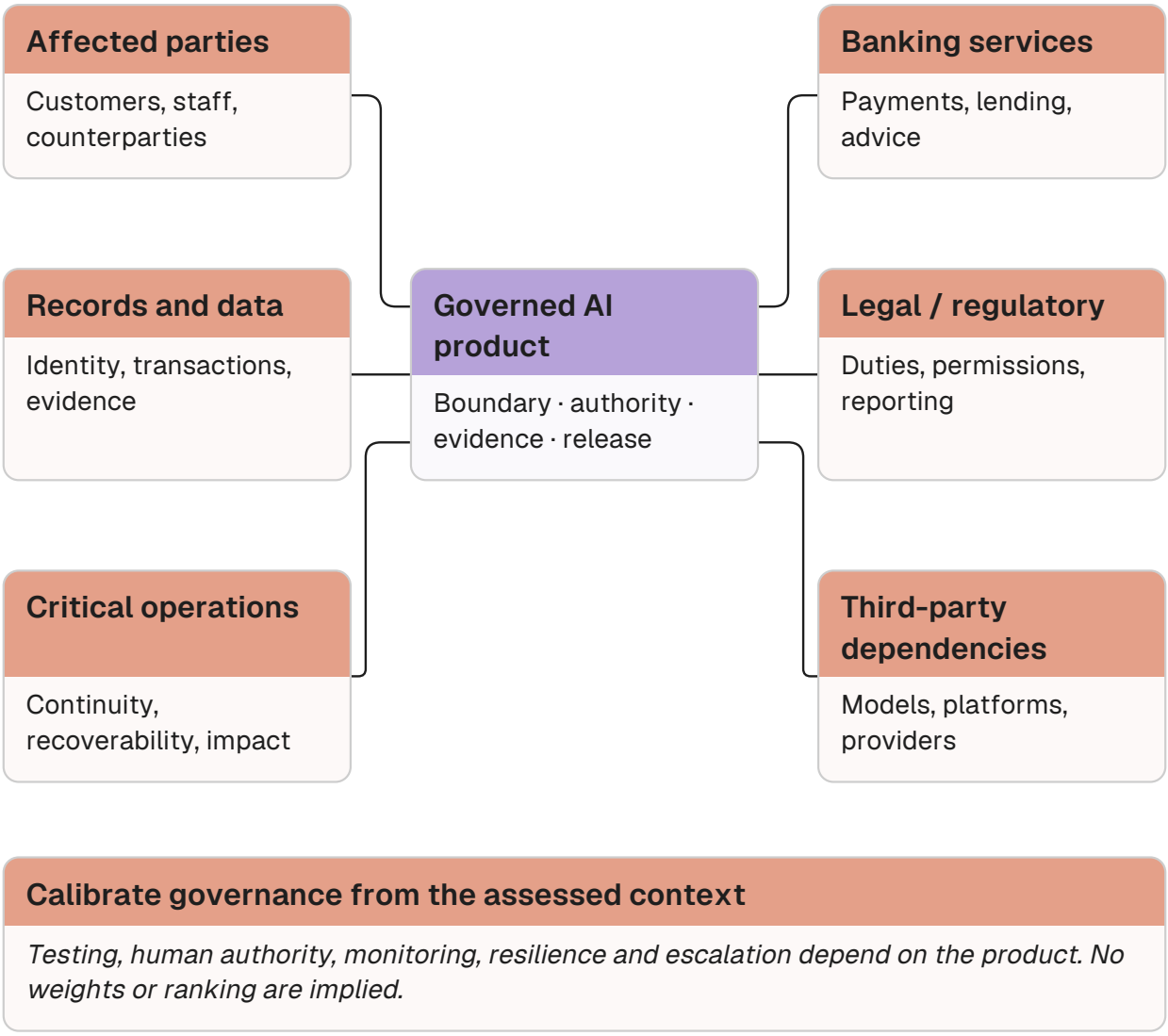
Two products called copilots can be materially different. One may summarize public text for an analyst. Another may retrieve customer data, recommend an action, prepare a record update, and invoke a workflow. Conversely, two products with different model types may create similar consequence if both influence the same decision.

The OECD classification framework supports context-sensitive characterization across people and planet, economic context, data and input, AI model, and task and output. NIST likewise emphasizes context and lifecycle risk. These sources support looking beyond the model label; they do not adopt the exact framework in this chapter.[1]

Control analysis should begin with observable capability and institutional authority. What can the product perceive, produce, recommend, invoke, change, or transact? Which data, tools, and systems can it reach? What human or machine decision follows? How broad is its exposure, and how reversible is the effect?

This approach also avoids false reassurance. Calling a product an assistant does not make human oversight effective. Calling a workflow agentic does not prove that it operates autonomously. The architecture and operating evidence must answer the question. See Figure 4.1.

Figure 4.1 — Where can this product have consequences?



Six independent lenses assess the assembled product. Testing, human authority, monitoring, resilience and escalation depend on the assessed context; no weights or ranking are implied.

4.2 Predictive, Generative, Retrieval, Workflow, Tool-Using, Agentic, and Multi-Agent Patterns

Part I uses the following explanatory categories. They are non-exclusive; one product can contain several.

Predictive systems estimate a class, score, value, ranking, or probability from inputs. Their controls often emphasize data, model development, performance across relevant cases, threshold use, monitoring, and decision integration.

Generative systems produce new content such as text, code, images, summaries, or structured output. Their controls must consider instructions, context, variability, unsupported content, content restrictions, and how a user or downstream system interprets the output.

Retrieval-augmented systems select external material and place it in the generation or decision context. They add corpus governance, ingestion, indexing, ranking, access, provenance, freshness, and conflict handling to the product boundary.[2]

Workflow systems coordinate defined steps, rules, services, and human tasks. AI may perform one or more steps without controlling the overall sequence. Workflow orchestration can create state, timing, retry, and handoff concerns even when no model chooses the plan.

Tool-using systems allow a model or AI application to call a function, service, search, database, calculator, or other capability. Research such as Toolformer and ReAct illustrates tool use and reasoning/action patterns; it does not establish a production banking control standard.[3]

Agentic systems, as used in this book, can pursue a goal through multiple steps, select among tools or actions, maintain relevant state, and operate with some delegated discretion. The term describes a design pattern, not a legal classification or guarantee of autonomy.

Multi-agent systems coordinate more than one agent or agent-like component. They may distribute roles, planning, review, or execution. They also add identity, state, communication, handoff, coordination, and failure-containment questions. This chapter makes no empirical claim that a multi-agent design is more accurate, safer, or more effective than a single-agent design.

Architecture diagrams and inventories should represent the features that matter, not force the product into one marketing category.

4.3 From Assistance to Recommendation, Decision, and Action

The book proposes an **assistance-to-action ladder** for discussing delegated authority:

- **Inform:** retrieve, summarize, explain, or generate content without recommending a choice.
- **Recommend:** propose a choice, priority, classification, or next step for another authority.
- **Prepare:** create a structured message, record change, transaction, or command for review and submission.
- **Decide:** select an outcome within an approved policy boundary, even if another system executes it.
- **Act:** invoke a tool, update state, send a message, execute a transaction, or otherwise affect the environment.
- **Orchestrate:** plan and perform multiple steps, possibly adapting the sequence and coordinating other components.

This ladder adapts established human-automation concepts to banking product authority and evidence. It is not a universal autonomy scale, and its order is not a consequence ranking. Real systems may span levels. A fraud-control system may detect or block without generating content; an AI-assisted engineering tool may prepare code without controlling deployment. A product may inform in one workflow and act in another. Preparation can itself be consequential if users routinely submit the result without adequate review. A recommendation may effectively become a decision when the reviewer lacks a viable ability to challenge it.[4]

The ladder's purpose is to reveal authority transitions. Moving upward should trigger explicit questions about permissions, validation, human authorization, limits, evidence, monitoring, recovery, and renewed approval. It should not be used to assign an automatic risk score without considering context.

NIST's emerging work on software and AI agent identity and authorization focuses on identifying, managing, and authorizing agent access and actions. As of 22 September 2026, the project remained an emerging initiative and had not produced a final standard or guideline.[5]

4.4 Capability, Authority, Consequence, Exposure, Scale, and Reversibility

This book proposes six questions for setting control intensity.

Capability: What can the product perceive, infer, generate, retrieve, plan, or do? Capability includes connected tools and data, not only the base model.

Authority: What may the product materially influence, prepare, decide or execute, and which component enforces that permission? Formal access and practical reliance both matter.

Consequence: What can happen to customers, employees, the institution, markets, records, systems, or critical operations if the product is wrong, misused, unavailable, or changed?

Exposure: Who and what can encounter the behavior? Consider users, affected populations, data sensitivity, environments, jurisdictions, and channels.

Scale: How widely and quickly can behavior propagate across cases, products, accounts, systems, or time? Scale can convert a small per-case error into a material pattern.

Reversibility: Can the effect be detected, stopped, corrected, restored, and remediated? Reversal includes customer redress and records correction, not only technical rollback.

The six-factor model synthesizes context-based risk, proportionality, financial-sector vulnerability, and lifecycle governance concepts. No cited authority adopts this exact set.[6]

Control intensity should increase when the factors indicate greater consequence or reduced recoverability. That may mean stronger evidence, more independent challenge, tighter permissions, broader evaluation, more demanding release conditions, closer monitoring, more resilient fallback, or a higher approval authority. It does not mean that every factor produces the same control or that a numerical score is always appropriate.

The framework also supports reduction. A team may narrow the purpose, remove tool access, reduce the population, separate recommendation from execution, improve reversibility, or create a reliable fallback. Risk treatment can change the product design instead of merely adding review.

Table 4.1 — Authority and control-intensity questions

Authority in the use	Illustrative output or action	Additional question before extending authority
Inform	Internal explanation	Can the user identify evidence and limits?
Recommend	Proposed next step	Who is affected, and who decides?
Prepare	Candidate record change	Can the checker inspect each material change?
Decide	Selection of an outcome	Which decision rights and challenge paths apply?
Act	System update or transaction	What enforces permission, limits and authorization?
Orchestrate	Coordinated steps across tools	Where can action stop, and which effects can be reversed?

A predictive, generative, retrieval or agentic label does not set the risk tier. Apply the six factors to the actual use and consequences. See Figure 4.2.

Figure 4.2 — Six factors that shape control intensity

Factor	Guiding question	Qualitative indicators	Design levers that may reduce intensity
Capability	What can the product perceive, infer, generate, retrieve, or do?	Tool use, planning, sensitive inference, open-ended generation	Narrow the task, remove tools, constrain inputs and outputs
Authority	What may it materially influence, decide, prepare, or execute?	Formal permission and practical reliance	Separate recommendation from decision or preparation from execution
Consequence	What can happen if it is wrong, unavailable, misused, or changed?	Customer, financial, conduct, market, record, or service effects	Limit eligible cases and require higher-authority routing
Exposure	Who and what encounters the behavior?	Population, data sensitivity, channels, jurisdictions	Restrict users, data, environment, or distribution
Scale	How broadly and quickly can behavior propagate?	Volume, speed, reuse, shared dependency	Rate and value limits, progressive rollout, segmentation
Reversibility	Can the effect be detected, stopped, corrected, restored, and remediated?	Recovery time, record correction, customer redress	Preview, rollback, compensation, fallback, recourse

All six factors, guiding questions, qualitative indicators and design levers remain unchanged. Assess control intensity in context rather than by a universal score.

Table 4.2 — Factor and guiding question

Factor	Guiding question	Qualitative indicators	Design levers that may reduce intensity
Capability	What can the product perceive, infer, generate, retrieve, or do?	Tool use, planning, sensitive inference, open-ended generation	Narrow the task, remove tools, constrain inputs and outputs
Authority	What may it materially influence, decide, prepare, or execute?	Formal permission and practical reliance	Separate recommendation from decision or preparation from execution
Consequence	What can happen if it is wrong, unavailable, misused, or changed?	Customer, financial, conduct, market, record, or service effects	Limit eligible cases and require higher-authority routing
Exposure	Who and what encounters the behavior?	Population, data sensitivity, channels, jurisdictions	Restrict users, data, environment, or distribution
Scale	How broadly and quickly can behavior propagate?	Volume, speed, reuse, shared dependency	Rate and value limits, progressive rollout, segmentation
Reversibility	Can the effect be detected, stopped, corrected, restored, and remediated?	Recovery time, record correction, customer redress	Preview, rollback, compensation, fallback, recourse

4.5 Human Authorization and Meaningful Intervention

Human involvement is a design, not a label. A person can be formally “in the loop” while lacking the information, competence, authority, time, interface, or alternative needed to intervene. Repeated exposure to plausible outputs can also create reliance and automation bias.

Peer-reviewed human-oversight and automation-bias research supports the need to examine context and conditions, but it does not provide a universal banking threshold for review time, workload, or case volume. EU law provides human-oversight requirements for covered high-risk systems, including competence, training, authority,

and support for assigned persons; those provisions are jurisdiction- and scope-dependent.[7]

Meaningful intervention asks whether the reviewer can:

- understand the task and the system's role;
- see the information and limitations needed for the decision;
- recognize uncertainty or an exception;
- reject, correct, defer, or escalate the output;
- stop or recover an action where required;
- act without incentives or workload making review nominal; and
- create evidence of the decision appropriate to its consequence.

The book's default is per-action human authorization for high-impact or difficult-to-reverse actions. A second pattern is **bounded automation**, approved in advance for a precisely defined action envelope with machine-enforced limits, monitoring, override, recourse, recovery, and accountable intervention. Human-in-the-loop controls place a person in the action path; human-on-the-loop controls place a person in an oversight and intervention role. Neither label establishes adequacy. The institution must justify the pattern for the task, consequence, operating conditions, and applicable law.

Human review should not be used to compensate for an unbounded product. The design should first reduce unnecessary authority, constrain inputs and tools, validate outputs, and make failure detectable. Human authorization then sits inside a layered control system.

Governing an exception to human authorization

An exception should be framed as a bounded authority decision, not as a general statement that the model is trusted. The proposal should identify the exact action, purpose, initiating conditions, permitted inputs and destinations, affected population, value and frequency limits where relevant, prohibited cases, dependencies, and the reason human authorization is considered unnecessary or counterproductive for that boundary.

The evidence should address the failure modes that matter for that action, including erroneous initiation, malformed parameters, unauthorized access, repetition, partial completion, unavailable dependencies, and inability to reverse or remediate the effect. The control design should state which policy checks occur outside the model, how identity and permissions are enforced, what observation detects an exception, and what stops, contains, compensates, or escalates the action.

Approval should name the accountable authority and any required independent challenge. It should record residual risk, conditions, operating metrics or review evidence, an effective date, an expiry or mandatory reconsideration point, and change triggers. A change in purpose, action, population, model, tool, credential, limit, workflow, provider, or recovery assumption may invalidate the exception even if its calendar period has not ended.

An exception is therefore not the absence of governance. It is a more explicit decision to permit a narrowly defined action without case-by-case human authorization. This is author-developed guidance, not a statement that such an exception is lawful or appropriate for any particular banking action. Legal, conduct, operational-risk, security, transaction-control, and business authorities must decide within their mandates.

4.6 External Policy Enforcement, Identity, Limits, and Recovery

A model can interpret an instruction; it should not be the sole enforcer of consequential authority. Controls with material effect should be implemented in components that can make dependable, observable decisions outside the model.

An action-capable design should consider:

- a distinct service or workload identity;
- credentials scoped to approved tools and resources;
- machine-enforced policy checks before action;
- validation of tool parameters and returned data;
- limits on value, frequency, volume, destination, duration, or sequence where relevant;
- separation between preparing and executing an action;
- confirmation bound to the exact action, not a vague approval;
- logging that can reconstruct material decisions without excessive collection;
- interruption, timeout, safe failure, retry, idempotency, or compensation as the action requires; and
- revocation, rollback, fallback, and incident response.

Table 4.3 — Threat or failure class and entry point

Threat or failure class	Entry point	Why model-side instruction is insufficient	Illustrative external control family
Adversarial or conflicting content	User input, retrieved document, message, or tool result	The same context channel can carry both data and instructions	Content isolation, provenance, policy checks, retrieval controls, adversarial evaluation
Unauthorized data access or leakage	Retrieval, prompt assembly, logs, tool output	A model cannot grant itself a lawful purpose or enforce entitlement	Identity, least privilege, field filtering, data minimization, output inspection
Unsafe or excessive tool use	Tool selection, parameters, repeated calls	Natural-language limits are not transaction controls	Allowlisted tools, schema validation, limits, approval, idempotency, stop authority
Poisoned or stale dependency	Data, corpus, model, package, or provider change	The model may not distinguish a compromised dependency	Provenance, versioning, integrity checks, supplier controls, rollback and re-evaluation
Resource exhaustion or cascading failure	Requests, retries, orchestration, shared services	Model compliance does not guarantee capacity or bounded retries	Quotas, timeouts, circuit breakers, workload isolation, graceful degradation

Illustrative retrieval and tool-use design.

A user request enters an authenticated application. The application retrieves authorized knowledge and sends bounded context to an orchestration and model layer. A policy-enforcement point validates identity, tool allowlist, parameters, and limits before a tool can reach a system of record. Evidence events are recorded at access, retrieval, model response, policy decision, tool invocation, human authorization, and outcome.

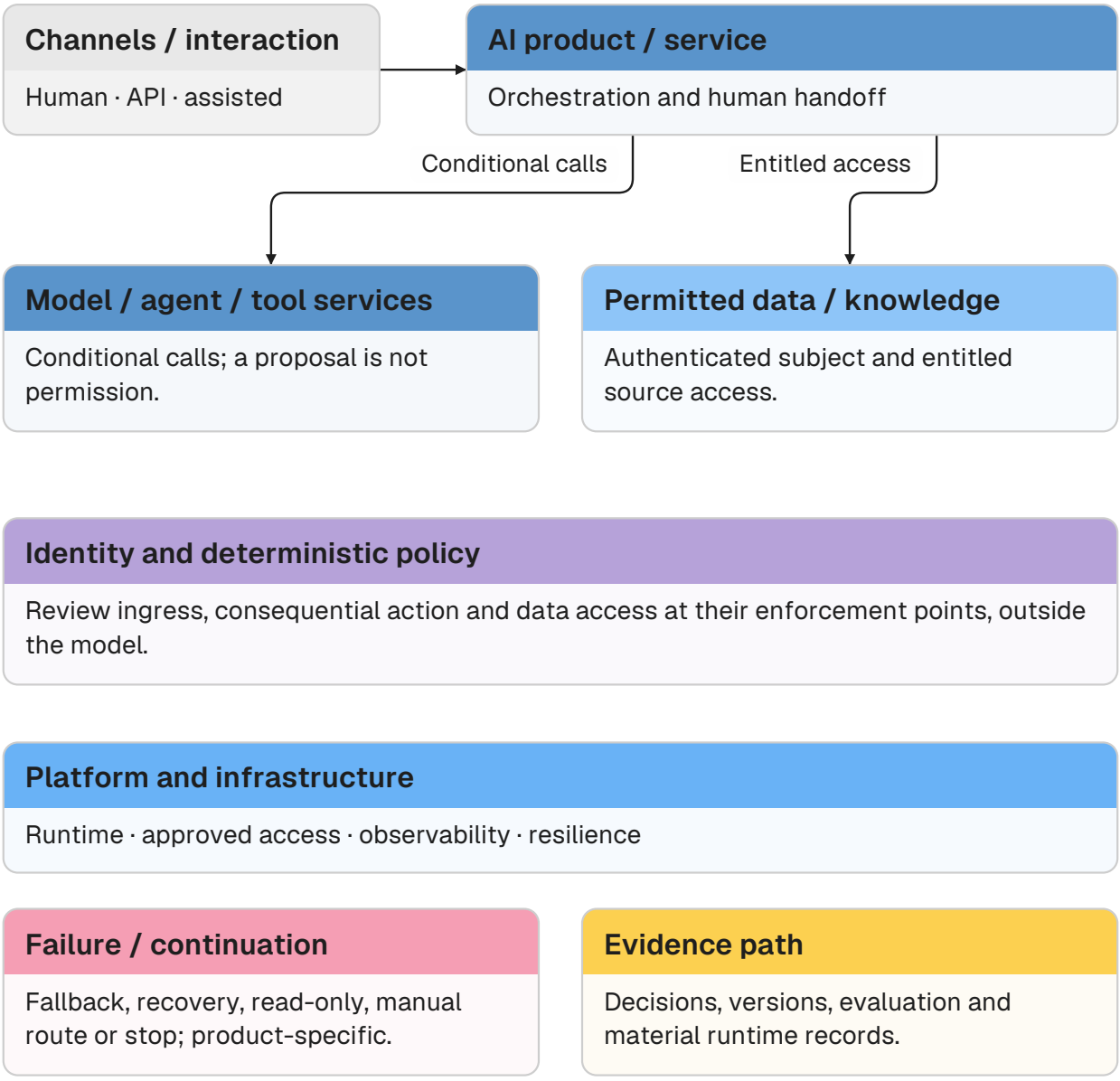
The later visual treatments separate these concerns: Figure 4.3, “Put enforcement outside the model” (Chapter 9), locates identity and deterministic policy outside the model; “Entitlement must precede context assembly” (Chapters 10–11), follows source provenance, entitlement and withdrawal through derived material; and Figure 13.1, “Authorize the exact action candidate” (§§13.5 and 13.9), separates preparation,

validation, exact-candidate authorization, submission and receiving-system confirmation. These are complementary patterns in their respective chapters, not interchangeable versions of a single topology. Human approval is risk-triggered where required; the model cannot authorize its own proposal.

These are design considerations, not a complete security standard. NIST's SSDF supports secure development practices, while the NCCoE agent project frames identity and authorization as emerging needs. Detailed architecture, security, transaction, and resilience patterns belong later in the book.[8]

The important boundary is that authority is explicit, testable, and change-controlled. A new tool, broader credential, higher limit, or removal of confirmation is a governance change, not only a configuration edit. See Figure 4.3.

Figure 4.3 — Put enforcement outside the model



The logical product has conditional service and data dependencies. Enforcement, platform, failure handling and evidence are separate views; actual topology and allocation vary.

4.7 Applying the Control-Intensity Framework

Application begins with a use case, not an abstract model. Describe the approved purpose, workflow, users, affected parties, data, outputs, tools, actions, environment, and fallback. Then assess the six factors in plain language.

The assessment should identify what drives control intensity and what design change could reduce it. For example, a product may have strong generative capability but low authority because it works on public material and cannot affect a record. Another may use a smaller model but have high authority because it can update an account. The second design may require stronger controls despite the less capable model.

Next, translate the factor assessment into lifecycle consequences: approval level, evidence depth, evaluation coverage, independence, access, human authorization, release conditions, monitoring, incident response, recovery, and change triggers. Chapter 7 owns the detailed risk-classification method. This chapter provides the conceptual input, not a final routing system.

The factor assessment should be revisited when purpose, population, data, model, retrieval, tools, permissions, scale, human role, or operating dependency changes. A product does not retain a low-control classification merely because its first release was narrow.

Worked applications of the six factors

These fictional examples demonstrate reasoning in prose. They do not assign universal scores, prescribe a tier, or establish control effectiveness. Table 4.1 is the working control-intensity artifact; it remains non-normative.

Public-information research aid. A product summarizes public material for a small group of analysts and cannot access internal records or invoke a tool. Its generative capability can still produce unsupported or incomplete content, but formal authority, sensitive-data exposure, and direct operational effect may be limited by design. Controls could emphasize purpose, source visibility, user instruction, evaluation of claimed research behaviors, feedback and correction, and prevention of unapproved data entry. The low-authority design is a premise to verify, not a conclusion derived from the word “assistant.” Broader distribution or practical reliance in a consequential decision could increase control intensity.

Policy-retrieval assistant. A product answers employee questions from an approved institutional corpus. Retrieval adds knowledge ownership, access, effective-date, provenance, conflict, and freshness dependencies. The product still cannot change a record, yet its consequence can rise when staff rely on it in a customer or regulated process. Control intensity may be reduced by narrowing the corpus and user group, showing source passages and limitations, refusing unsupported questions, routing

defined exceptions, preserving a workable fallback, and evaluating retrieval separately from answer generation. None of those measures proves that the product is fit for a particular use; the product claims and operating context determine the evidence required.

Customer-context recommendation. A product retrieves a customer record and recommends a next step to an employee. Authority now includes practical influence over a decision, exposure includes sensitive data and an affected customer, and errors may become harder to detect if the interface presents one plausible answer without alternatives or limitations. A proportionate design may restrict eligible cases, separate factual retrieval from recommendation, show the evidence relied on, test error distributions and prohibited cases, give the reviewer genuine rejection and escalation paths, and monitor reliance and overrides where lawful and appropriate. Whether the use also falls within a legal or model-risk classification requires jurisdiction- and fact-specific review.

Predictive fraud screening with bounded automation. A model scores transactions and an approved policy may block or hold a narrowly defined subset without per-case confirmation. The system's authority is operationally significant even though its output is not generative. The control case therefore focuses on data and threshold governance, false-positive and false-negative consequences, real-time limits, on-the-loop monitoring, override and release authority, customer recourse, resilience, and evidence that the operating envelope remains valid. The example does not state that a particular design or threshold is legally or operationally appropriate.

Prepared update with an execution proposal. A product prepares a structured servicing update for exact review but cannot submit it. Field allow-lists, validation, preview, confirmation bound to the proposed change, and recovery can constrain authority. If the team later proposes automatic execution for a narrow subset, the control-intensity analysis must distinguish that subset from the broader preparation use. A possible exception case would need precise initiation conditions, value and destination limits where relevant, externally enforced policy, idempotency or compensation appropriate to the action, observation, stop authority, expiry, and renewed approval. The example does not assume that Fictional Bank permits the execution path.

The examples demonstrate a design choice that recurs throughout the book: when a factor drives control intensity, the team can add evidence and controls, reduce the capability or authority, narrow exposure or scale, improve reversibility, or decline the use. The framework structures that decision; it does not make it automatically.

Factor interaction and emergency authority

The six control-intensity factors are not an arithmetic score. A single factor can dominate. A low-volume assistant that can submit a payment may require strong authorization because consequence and delegated authority dominate scale. A high-volume internal summarizer with no sensitive data or action authority may need strong quality monitoring because exposure dominates, but not transaction controls designed for money movement. Conversely, high reversibility can reduce—not erase—the evidence needed for a bounded pilot.

The default rule is to restrict the affected permission while material authorization remains unresolved. That is a proposed governance default, not a universal regulatory rule. A bank may define a break-glass path for time-critical service protection: named authority; narrow action and population; technical time limit; immutable log; compensating monitoring; customer/record reconciliation; mandatory retrospective review; and automatic expiry. Emergency access does not silently convert an unresolved authorization into normal operation.

Possible operating-envelope indicators include action rate and value, override and intervention rates, false-positive and false-negative patterns, queue growth, reversals, reconciliation exceptions, credential use, and recovery time. Their definitions and thresholds are institution-specific evidence gaps.

Authority is assessed within a phase

Record authority against the product and affected lifecycle decision. An authority level is not a lifecycle phase or maturity score. Use the non-arithmetic examples and existing emergency-authority conditions here, then route the resulting obligations through Chapter 7 and the §2.6 crosswalk.

4.8 Illustrative Scenario: Classifying the Expanding Copilot

PA-R1’s six-factor assessment records generative drafting, no direct action authority, employee-reliance consequence, 25 employees, bounded topic volume and correctable internal text. PA-PREP changes authority and record-integrity consequences; PA-SUBMIT adds execution, replay and recovery questions. Record a separate classification and decision for each variant before extending permission.

4.9 Executive Decisions and Practitioner Checklist

Decide the authority the product may receive, using all six factors. Engineering should demonstrate where permission and limits are enforced, including the denied and unavailable-control paths. Any automation exception has its own bounded approval.

For an existing trust-boundary architecture view, use §9.8 and Figure 4.3 alongside this six-factor assessment. The figure supports the architecture questions; it does not set the risk tier or grant an action capability.

Notes

1. OECD, Framework for the Classification of AI Systems (B18); NIST, AI RMF 1.0 (B01). Return to text

2. Lewis et al., “Retrieval-Augmented Generation” (B20); NIST, Generative Artificial Intelligence Profile (B02). Return to text

3. Schick et al., “Toolformer” (B21); Yao et al., “ReAct” (B23). Return to text

4. Parasuraman, Sheridan, and Wickens, “A Model for Types and Levels of Human Interaction with Automation” (B30). The book’s ladder adds bank-specific authority transitions and evidence consequences; it does not reproduce the paper’s taxonomy. Return to text

5. NIST NCCoE, Software and AI Agent Identity and Authorization (B17). Return to text

6. OECD (B18); NIST, AI RMF 1.0 (B01); Bank of England/PRA, SS1/23 (B09); Financial Stability Board (B14). Return to text

7. Sterz et al. (B26); Goddard, Roudsari, and Wyatt (B27); European Union, consolidated Regulation (EU) 2024/1689 (B07). Return to text

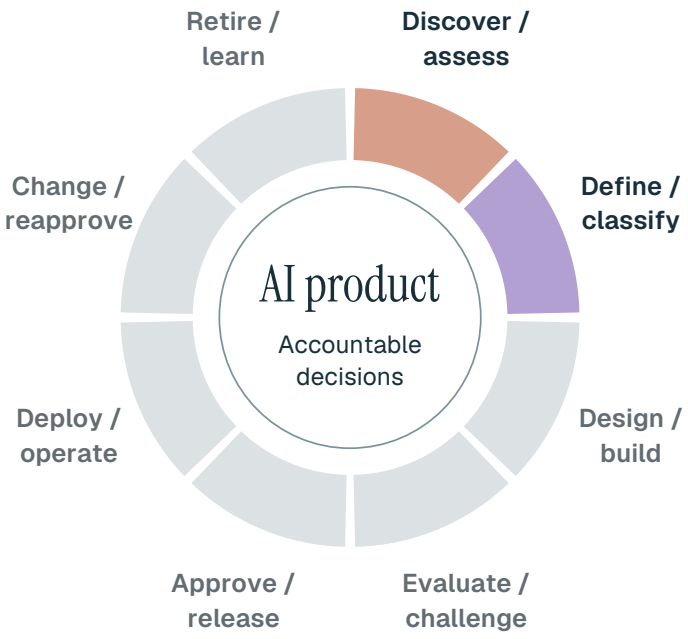
8. NIST, Secure Software Development Framework Version 1.1 (B04); NIST NCCoE (B17). Return to text

Part

II

Strategy, Use, Risk and Accountability

Converts an idea into a bounded value hypothesis, intended/prohibited use, risk route and explicit decision rights. The outcome is an authorized product definition—or a recorded decision to narrow, pause or stop.



Emphasis: Discover / assess; Define / classify.

Other phases remain part of the lifecycle.

Re-enter at the affected decision.

Chapter

5

Strategy and the Business Value Hypothesis

A demonstration answers a narrow question: can this configuration produce an interesting result under the conditions shown? An investment decision asks something harder: should the institution change a working process, commit resources, and accept responsibility for the resulting service? Confusing those questions allows technical enthusiasm to become an operating commitment before the value mechanism has been examined.

5.1 Fund a Question Before Funding Scale

The starting document should therefore be a hypothesis, not a promise. State whose work or experience would change, what part of that work would change, why the change might be useful, and which observations would make the bank abandon the proposal. The hypothesis becomes more credible when it explains how it could be wrong.

For an internal drafting assistant, the proposed mechanism might be less time spent assembling a first response. That is not yet a claim about lower operating cost or better customer service. Checking the draft may require effort; exceptions may move work elsewhere; the saved time may be too fragmented to redeploy. These are questions to investigate, not assumed disadvantages or invented results. The executive decision is whether discovering the answers is worth a bounded investment. The engineering decision is what experiment can answer them without granting unnecessary data access or action authority.

Decide whether the product should exist before selecting its model. This chapter connects Chapter 2's evidence bundle to investment: identify the problem, compare alternatives and fund the next evidence needed. It claims no demonstrated return for an AI use case.

5.2 Compare Against a Credible Alternative

“Use AI” is not a business objective. Before selecting a model, describe the non-AI alternatives: improve a search interface, repair a knowledge base, simplify an approval path, automate a deterministic step, train employees, or leave a satisfactory process unchanged. The relevant comparison is not necessarily manual work as it exists today. It may be a cheaper improvement the institution could make instead.

NIST’s voluntary AI RMF includes defining business context, examining benefits and costs, and considering viable non-AI alternatives. It supplies risk-management context, not evidence of a project’s return.[1]

For the proposed drafting assistant, compare three designs. A better search experience helps an employee find the policy. A reusable response template standardizes the explanation. A generative assistant assembles a draft from permitted material. Each addresses a different obstacle. If employees already know the answer but struggle to locate an approved form, generation may be incidental. If the policy itself is ambiguous, a polished draft may disguise the unresolved problem.

Record the alternative considered and why it was rejected or retained. This is useful later when the AI design becomes more expensive or harder to govern than expected. A team should not have to reconstruct the original comparison from a presentation that assumed a preferred answer. Keep the alternative available as a possible fallback, but do not call it a workable fallback until its capacity, ownership and operating procedure have been assessed.

5.3 Choose the Right Value Family

Not every proposal creates value in the same way. A banking portfolio can distinguish at least five families: customer or employee experience; loss, error or fraud reduction; revenue or retention; capacity and cycle time; and compliance or control quality. These are planning categories, not promises. A proposal may touch more than one, but it should name the primary mechanism so that unrelated benefits are not added together to make a weak case appear strong.

The measures should follow the decision. A discovery decision may need only evidence that a recurring problem exists and that an AI approach is plausibly relevant. A pilot decision needs evidence about behavior in a bounded workflow. A scaling decision needs evidence about operating demand, support, control effort and consequences. A production service then needs measures that reveal both value and harm.

Table 5.1 — Decision and illustrative value evidence

Decision	Illustrative value evidence	Guardrail evidence that stays visible
Explore	Problem frequency and affected work, with source and limitations	Prohibited uses and unavailable information
Pilot	End-to-end task outcome compared with a credible alternative	Material defects, rework, escalation and customer-impact indicators
Scale	Capacity, adoption and support evidence in the proposed environment	Control workload, concentration, resilience and remediation readiness
Continue	Sustained service outcome and unresolved assumptions	Drift, incidents, complaints, overrides and exception ageing

The institution defines the measures and thresholds. This table supplies no benchmark and should not be used to imply that an unmeasured benefit exists.

5.4 Make the Value Mechanism Observable

A value hypothesis needs a chain from system behavior to institutional consequence. “The assistant generates text” describes an output. “The employee reaches an acceptable response with less total effort” describes a proposed workflow benefit. “The service can handle more work within its existing resources” is a further proposition that depends on demand, staffing, scheduling and other constraints. Evidence for the first link is not evidence for the last.

Start measurement at the point where work enters the process and finish at an accepted outcome, including rework and escalation. Decide what counts as acceptable before seeing the experiment’s results. Otherwise, a team can report faster completion by quietly accepting weaker work. Keep quality and consequence measures visible alongside effort; do not combine them into a single score that conceals an unacceptable failure.

The comparison also needs context. Were the tasks similar? Were employees equally familiar with the process? Was the knowledge base improved at the same time? Were difficult cases excluded? Was checking performed by people who knew which response came from the new system? The answers determine what can reasonably be inferred. Where the experiment cannot distinguish the AI contribution from another change,

record the result as a combined intervention rather than assigning all benefit to the model.

These are proposed measurement questions, not a statistical test specification. Chapter 16 develops evaluation design. At this stage, identify the evidence needed and the person competent to assess it. If the business cannot define an observable improvement without compromising customer treatment, further model tuning does not resolve the investment question.

5.5 Draw the Cost Boundary Around the Service

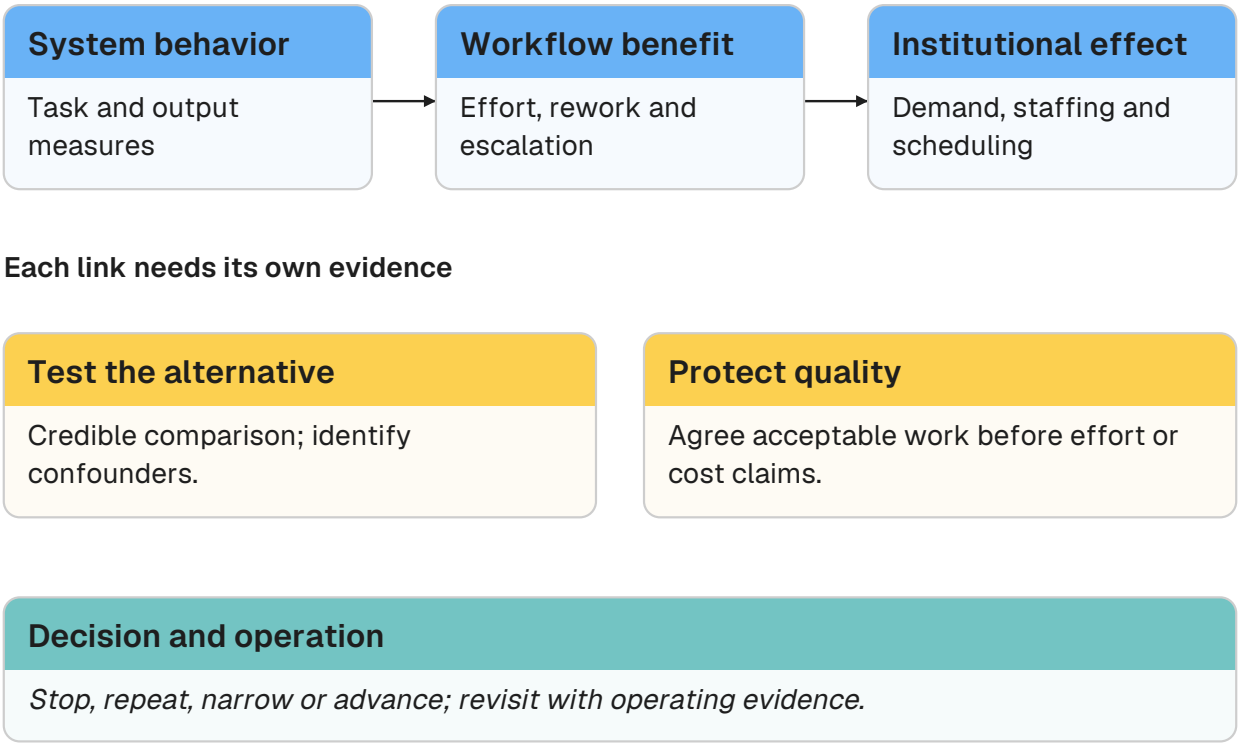
The inference bill is only one proposed cost category. A service may also require data preparation, knowledge ownership, integration, identity controls, evaluation, specialist challenge, employee training, monitoring, incident handling, support and eventual exit. Some costs are shared platform costs; others arise because of the specific use case. Label that distinction instead of making each project appear cheap by assigning every difficult activity to an unnamed central team.

Separate expenditure from opportunity cost. An existing specialist may not create a new cash expense when assigned to the project, but that person’s time is no longer available for other work. Conversely, a hypothetical reduction in task time is not automatically a cash saving. Finance and the business owner should decide how any released capacity would be used before it is represented as a financial benefit.

The first estimate can remain qualitative where evidence is missing. For each uncertain driver, state what would increase it, what would reduce it, and which decision depends on it. A high review burden might make a narrow internal aid viable but a high-volume service unattractive. Provider substitution might be easy at the interface and expensive in re-evaluation. Neither possibility needs an invented percentage to be worth examining.

Avoid a false precision trap: a detailed spreadsheet can make uncertain assumptions look settled. The decision record should distinguish observed inputs, supplier quotations, internal estimates and unresolved values. Chapter 24 owns the detailed cost and capacity model; this chapter owns the requirement that the investment case disclose its boundaries. See Figure 5.1.

Figure 5.1 — Evidence must bridge each benefit claim



Behavior, workflow benefit and institutional effect are separate claims. Each requires its own evidence, a credible alternative and quality guardrails.

Synthetic monthly cost calculation

Assume a four-week teaching month: 12,000 attempts produce 9,000 accepted completed cases, including authorized fallback work. Full checking of those 9,000 completions takes a three-minute mean at 40 currency units/hour: 9,000 × 3/60 × 40 = 18,000. The separate six-minute median in §16.9 is a planted-error exercise, not this cost mean. For this constructed cost boundary, support/monitoring and fallback allocations cover non-accepted attempts, exception/rework and escalations; their real adequacy remains untested. All amounts below are synthetic currency units for the same period.

Table 5.2 — Cost category and monthly amount

Cost category	Monthly amount
Inference	2,400
Retrieval and storage	1,800
Employee checking	18,000
Support and monitoring	4,000
Incident readiness	2,800
Fallback staffing	6,000
Allocated integration and evaluation	8,000
Total	43,000

Cost per accepted completed case is 43,000 / 9,000 = 4.78, not inference cost divided by calls. A credible manual comparator for the same 9,000 outcomes is 15 minutes per case at 40 per hour: 90,000. The resulting 47,000 difference is a hypothetical value of capacity released before other differences and uncertainty; it is not automatically a cash saving. If the task can be answered more cheaply by a governed search page or deterministic rule, fund that alternative. Model novelty does not improve this arithmetic.

Checking-time sensitivity, holding the other 25,000 units constant: a three-minute mean gives checking 18,000, total 43,000 and 4.78 per accepted case; a six-minute mean gives checking 36,000, total 61,000 and 6.78 per case. Against the same 90,000 manual comparator, the capacity-value differences are 47,000 and 29,000. Neither is a demonstrated cash saving or an estimate inferred from the oversight median.

5.6 Test Feasibility Where the Product Will Operate

Feasibility includes permission and operating capacity, not just model capability. Can the bank lawfully and contractually use the required information for the proposed purpose? Is there a responsible owner for keeping the knowledge current? Can the application expose enough evidence for an employee to check a draft? Who handles cases the system cannot complete? These questions can invalidate a design even when the demonstration is technically impressive.

Treat each unresolved dependency as a condition of the experiment. If access to representative information is unavailable, a synthetic exercise may still test interface behavior, but it does not establish performance on the institution's real workload. If a provider's terms or data-processing arrangements remain unresolved, do not describe a successful technical connection as permission to send customer information.

A useful early experiment is narrow enough to stop. Define who may use it, what information it may process, which systems it cannot change, and how its outputs are prevented from becoming unreviewed external communications. These are proposed safeguards requiring security, privacy and operational review; an "experiment" label does not make them effective.

Before expanding, ask what the experiment failed to test. A small group of enthusiastic employees may reveal usability problems but does not, by itself, establish that a wider workforce can perform the same checking task. A curated corpus may support a bounded knowledge task without supporting a broader product-advice function. Carry those limits into the next decision rather than leaving them in the research notes.

Choose the sourcing route for the whole initiative

Before committing to an implementation, compare **Build**, **Buy** and **Partner** against the same bounded service purpose, credible alternative and decision criteria. Build means the institution owns the principal delivery capability; Buy obtains a product or managed capability under supplier arrangements; Partner involves substantive co-development, shared delivery or an ongoing joint capability. Hiring implementation assistance alone does not settle which route applies. Hybrid arrangements are common, so record the actual division of work and dependencies.

The choice concerns the whole initiative: application and workflow, data and knowledge, models, integration, evaluation, operating support and eventual exit. Buying a model endpoint is only one dependency decision. Compare strategic differentiation, internal capability, time to demonstrated value, full lifecycle cost, control/evidence access, data and IP responsibilities, integration, concentration, maintenance, continuity and portability. A faster prototype does not establish a faster route to authorized, sustainable operation.

Record the preferred route, alternatives rejected, decisive assumptions, unresolved facts, accountable sponsor, delivery and service owners, next evidence checkpoint and triggers for reconsideration. The detailed comparison and partnership handoffs are in §12.2. Sourcing does not transfer the institution's product accountability or confer release authority.

5.7 A Use-Case Intake That Leads to a Decision

Table 5.1 is a concise intake checklist. It is an original decision aid, not a compliance form. Required fields are proposed for this method; institutions must adapt ownership and local obligations. "Unknown" is an acceptable entry when accompanied by an owner and the decision it prevents.

Table 5.3 — Use-case intake checklist

Required question	Evidence or record to request	Decision it supports
Whose problem is being addressed?	Process boundary, affected people, accountable business owner	Whether the problem merits investment
What changes, and compared with what?	Value mechanism and credible alternative	Whether AI is relevant
What may the system see and do?	Data categories, users, outputs, action limits	Whether the experiment is suitably bounded
What could make the proposal unacceptable?	Consequences, unknowns and proposed stop conditions	Whether to restrict, redesign or stop
What does operation require?	Dependencies, review effort, support and exit assumptions	Whether the bank can sustain the service
What evidence is needed next?	Measurement plan, evidence owner and next decision	Whether more work is justified
When must the work pause or stop?	Explicit stop condition and accountable decision-maker	Whether the team may continue

The checklist is complete only when it changes a decision or exposes a missing one. A portfolio register containing many filled-in forms but no explicit continuation criteria is inventory, not investment discipline.

Intake from discovery

A discovered or supplier-enabled AI feature enters the same intake as a declared use case. The §27.4 discovery record supplies feature, provider, data and permission facts; the accountable owner then determines bounded use, risk route and required restrictions. Procurement status alone does not settle that decision.

5.8 Stage Gates That Preserve the Right to Stop

The investment path should create a sequence of bounded decisions rather than a single approval that stretches from idea to production.

Table 5.4 — Gate and decision question

Gate	Decision question	Minimum output	Available decisions
Discover	Is there a problem worth investigating?	Problem evidence, affected parties, owner	Stop, clarify or assess
Assess	Is AI relevant and is a bounded experiment permissible?	Alternatives, initial consequence and dependency view	Stop, narrow, redesign or experiment
Experiment	Did the test answer the stated question?	Results, limitations, defects and updated assumptions	Stop, repeat, narrow or propose pilot
Pilot	Can the service operate safely within the approved boundary?	Workflow, evaluation and operating evidence	Stop, remediate, restrict or propose production
Production	Is the assembled release ready for authorized operation?	Release evidence, owners, conditions and rollback route	Hold, release with conditions or reject
Operate	Does evidence still support continued use?	Monitoring, incidents, complaints, change and value evidence	Continue, restrict, suspend or retire

Map these gates to existing investment, change, risk and release processes, with their actual delegates and evidence needs.

Portfolio prioritization and scale readiness

Compare initiatives as a portfolio, preserving differences in service value, affected population, authority, consequence, evidence feasibility, dependency concentration, fallback, specialist capacity and reversibility. Keep disagreements visible alongside the five-dimension worksheet below.

Before scale, decision-makers should ask whether the value mechanism has credible evidence; the use and prohibited use remain stable; severe evaluation failures are resolved or explicitly bounded; operating identity and telemetry are reliable; fallback and remediation have capacity; third-party concentration and exit are understood; conditions can be enforced; and product, operations and control owners are funded. “Pilot succeeded” is not a scale criterion unless success is defined against the approved claim and population.

Investment gates within the lifecycle

Table 5.5 — Investment gate and canonical phase relation

Investment gate	Canonical phase relation	Decision meaning
Discover	PH-01	Initial problem and option investigation
Assess	PH-01 / PH-02	Assess case and bounded use/risk route
Experiment	PH-03 / PH-04	Bounded build and evidence generation
Pilot	PH-04 / PH-05 / PH-06	Limited operating exposure requires release permission and operating conditions
Production	PH-05 / PH-06	Release decision followed by verified deployment/operating acceptance
Operate	PH-06 / PH-07 / PH-08	Continue, restrict, change or retire on evidence

Discover is the investment-gate wording used here. A reference to Explore should be mapped explicitly to that investigation step. Experiment and pilot describe bounded investment/exposure decisions; neither grants production permission. A release decision, verified deployment and operating acceptance remain separate.

A prioritization worksheet with visible evidence confidence

Use the following five dimensions to compare initiatives within an agreed portfolio scope. Define the assessment rubric and time horizon locally before evaluating proposals. Keep the dimension profile and its evidence visible; an attractive aggregate should not erase an unresolved assumption.

Table 5.6 — Dimension and assessment question

Dimension	Assessment question	Evidence or estimate to preserve
Business Impact	What measurable service outcome would improve, for whom, and relative to which credible alternative?	Revenue/retention, loss/error reduction, quality/control improvement, total effort or capacity; baseline, affected volume, net benefit mechanism and uncertainty
Technical Feasibility	Can the bounded product be engineered, evaluated, integrated, maintained and operated with available capability?	Architecture and integration dependencies, model/workflow limitations, infrastructure, skills, testing, maintenance and support assumptions
Data Readiness	Is the necessary information lawfully accessible and fit for this use?	Rights and permissions, owner, provenance, coverage, quality, labels where needed, freshness, evaluation separation and preparation effort; structured or unstructured as the task requires
Strategic Fit	Which named corporate objective or service priority does the initiative advance?	Objective, accountable sponsor, expected contribution, portfolio dependency and explanation of why the proposed capability is relevant
Implementation Effort / Time-to-Value	What work and elapsed time separate this proposal from a useful, authorized and sustainable service?	Delivery and control work, dependencies, specialist capacity, milestones, full lifecycle cost, time to prototype, authorized operation and demonstrated value

For each dimension record assessment, basis, evidence status, confidence, assessor/owner, uncertainty and the next evidence needed. Distinguish observed inputs, controlled experiment results, estimates, supplier assertions and unknowns. Confidence concerns the support for an assessment; it is not another claim that the initiative is safe

or effective. Assessments should be refreshed when scope, information, authority, provider, operating conditions or material assumptions change.

An institution may choose descriptive ratings or a locally defined numerical rubric. If it uses a weighted comparison, record the scale, direction, weights, normalization and treatment of missing evidence before scoring, and inspect whether plausible changes in assumptions or weights change the ordering. Higher effort must not accidentally earn a higher desirability score; use an explicit inverse or delivery-ease convention where appropriate. An unknown is not a verified zero, average or passing value. A weighted result supports comparison of admissible options; it does not grant permission or replace the dimension profile.

Keep admissibility and operating prerequisites outside the commercial score

First identify prohibited or impermissible use, unavailable data rights, unenforceable authority boundaries, unacceptable consequences and essential controls that cannot be established. A favorable commercial score cannot compensate for these conditions. Separate a bounded discovery experiment from a pilot or operating service: each has its own permissible scope and evidence requirements. Lawful synthetic or isolated work may answer a limited question without establishing readiness for real customer or employee exposure.

Also preserve dependencies, concentration, review/support capacity, fallback, resilience, remediation and exit assumptions. Some are prerequisites for the next stage; others determine sequencing and funded work. They should not disappear inside an impact/effort average. §5.9 records the portfolio decision; §20.5 governs enforceable conditions and expiry.

Qualified impact and effort matrix

Define both axes locally. Impact includes the relevant value family and service consequence; effort/complexity includes data, integration, control, review and operating work, not only model complexity. The matrix is a discussion and sequencing aid, not an automatic verdict or operating approval. See Figure 5.2.

Table 5.7 — Portfolio position and suggested investment treatment

Portfolio position	Suggested investment treatment	Evidence and decision boundary
Quick Wins — High Impact, Low Effort/Complexity	Prioritize bounded pilots that meet the applicable prerequisites; test an early value hypothesis	Demonstrate end-to-end net value and guardrail performance against a credible alternative before scale; retain operating and review capacity needs
Strategic Bets — High Impact, High Effort/Complexity	Fund staged learning and explicit capability/dependency milestones	Test the decisive assumptions before a larger commitment; record specialist/platform needs, time to evidence and stop or redesign conditions
Fill-ins / Tactical — Low Impact, Low Effort/Complexity	Consider available capacity, reusable capability and control/service benefits	Preserve opportunity cost and support burden; spare engineering capacity alone is not evidence of worthwhile value
Deprioritize / Drop — Low Impact, High Effort/Complexity	Challenge the case; simplify, defer or terminate when unsupported	Check assessment confidence, required obligations, risk reduction, strategic dependencies and credible alternatives before deciding; the quadrant alone does not mandate dismissal

Figure 5.2 — Qualified impact and effort matrix

A qualified portfolio discussion A sequencing aid within the existing investment process.

Prerequisites stay outside the comparison

Check permissible scope, data rights, authority, unacceptable consequences and essential controls before the next exposure. A position grants no operating permission.

Business Impact (defined locally)

Discussion and sequencing aid; no automatic verdict.

High	Low Effort	High Effort
	Quick Wins **High impact / Low effort** Prioritize bounded pilots that meet prerequisites. Demonstrate net value and guardrail performance against a credible alternative before scale.	**Strategic Bets** **High impact / High effort** Fund staged learning, dependencies and evidence milestones. Test decisive assumptions; define stop or redesign conditions.
Low	**Fill-ins / Tactical** **Low impact / Low effort** Consider capacity, reusable capability and control/service benefits. Preserve opportunity cost and support burden.	**Deprioritize / Drop** **Low impact / High effort** Challenge, simplify, defer or terminate when unsupported. Check confidence, obligations, risk reduction, dependencies and alternatives before deciding.

Low — High

Implementation Effort / Complexity (defined locally)

Keep the full five-dimension profile

Business Impact; Technical Feasibility; Data Readiness; Strategic Fit; Implementation Effort / Time-to-Value. Record basis, evidence status, confidence, owner and next evidence. Unknowns remain visible; any numerical rubric and weights are local.

Compare impact and effort only within the stated assumptions, evidence and decision context. Position is a qualified prioritization aid, not an automatic investment approval.

The qualitative impact/effort matrix supports investment sequencing among admissible options. Both axes are defined locally, with Business Impact increasing upward and Implementation Effort/Complexity increasing rightward. The four positions suggest qualified treatments rather than automatic verdicts. Keep the five-dimension profile, evidence confidence and next-stage prerequisites visible.

Text alternative: An unscored two-by-two matrix places Quick Wins at high impact/low effort, Strategic Bets at high impact/high effort, Fill-ins/Tactical at low impact/low effort and Deprioritize/Drop at low impact/high effort. Each quadrant has a qualified treatment. Prerequisites stand outside the plot and the full five-dimension profile remains below it. There are no initiative points, numeric boundaries or automatic dismissals.

For a policy-assistant proposal, an initial worksheet could record reduced total employee effort as a hypothesis, integration and support feasibility as open assessments, corpus permissions and currency as required evidence, the named employee-service objective as the strategic link, and separate prototype/operating/value milestones. It should not award a “Quick Win” label or assert ROI before that evidence exists. The next checkpoint could authorize bounded evidence gathering, narrowing, redesign, pause or termination under §5.10.

Filled prioritization profile PA-INV-01

PA-INV-01 follows the sequence above: define permissible next-stage scope, compare AI and non-AI alternatives, inspect evidence and confidence, record funding and set the checkpoint.

Table 5.8 — Dimension and synthetic assessment

Dimension	Synthetic assessment	Evidence confidence / next work
Business impact	Reduced checking effort is plausible; calculated unit cost 4.78 versus manual 10.00 (§5.5)	Low: numbers are assumptions; observe matched completed cases
Technical feasibility	Draft-only workflow and receiver controls have bounded test evidence	Medium for that variant; provider changes remain a dependency
Data readiness	Named policy owners and withdrawal route exist; exception coverage failed in PA-0.1	Medium after PA-EV-03; repeat withdrawal exercise
Strategic fit	Supports the stated employee policy-service objective	Sponsor confirms priority and opportunity cost
Effort/time-to-value	Six weeks to a bounded teaching pilot; wider scope needs new evidence and capacity	Low: validate delivery and review assumptions

PA-INV-01 is not plotted as a verified Quick Win. The funding delegate continues the bounded stage for four weeks, with the product owner accountable for value measurement and the source owner for withdrawal evidence. An unresolved essential control stops exposure regardless of a favorable commercial profile.

5.9 Illustrative Scenario: A Restricted Drafting Experiment

Illustrative scenario — fictional composite. Fictional Bank is considering the internal drafting stage introduced in Chapter 1. It has no demonstrated savings, completed pilot, measured control effectiveness or customer outcome in this example.

The initial proposal is to help employees assemble draft responses from permitted notes for a restricted topic set. The assistant would not access customer records, send messages or change operational systems. The business sponsor wants to know whether the assistance can reduce total effort while preserving the required content and checking process. That is the hypothesis; the conclusion remains open.

The product team would first compare a response-template improvement with generative drafting. An evaluation owner would define what an acceptable response must contain and what requires escalation. Operations would examine whether an

employee can practically check the material rather than simply assuming that a review button solves the problem. Privacy and security would examine the permitted information boundary. None of those proposed activities is represented here as completed.

Suppose the design discussion reveals that reliable drafting depends on policy material absent from the employee's notes. The team now has a decision, not just a prompt problem: narrow the task, improve the notes, or propose retrieval. Retrieval would introduce new ownership and evaluation work. The original experiment should not silently acquire a knowledge base and broader access while retaining the original approval description.

At the assess gate, Fictional Bank could stop if there is no named owner or permissible information boundary; narrow the topic set if the required evidence is incomplete; redesign around improved search if generation adds no clear benefit; or proceed with conditions to a bounded experiment. Those are possible routes, not reported decisions.

The scenario's teaching point is the boundary between learning and scaling. A useful next step produces evidence for the next decision. It does not need to establish the business case for every future capability.

Portfolio decision artifact and gate nesting

Investment gates answer whether to spend more; lifecycle gates answer whether a bounded product or release may enter a new state. They can occur together but are not interchangeable. "Authorize production investment" funds readiness work; "approve release" authorizes an exact configuration and exposure after required evidence and challenge.

Table 5.9 — Portfolio field and decision-ready content

Portfolio field	Decision-ready content
service problem and credible alternative	named baseline and affected parties
value mechanism	causal hypothesis, not a promised outcome
evidence maturity	observed, estimated, asserted, unavailable
consequence and authority	dominant factors and unresolved gaps
full cost boundary	build, run, review, fallback, incident, exit
concentration	shared provider, platform, data, identity, specialist capacity
next decision	continue, bound experiment, narrow, pause, stop
conditions	owner, evidence due, expiry, escalation

This table deliberately avoids a universal composite score. Portfolio comparison should expose incompatible assumptions rather than hide them inside a weighted rank.

5.10 Continue and Monitor, Scale, Pause or Terminate

At every initiative investment checkpoint, present the hypothesis, credible alternative and sourcing route, evidence obtained, limitations, unresolved dependencies and proposed resource commitment. Record one of four initiative verdicts: **Continue and Monitor**, **Scale**, **Pause** or **Terminate**. Restriction, narrowing, remediation and redesign remain available actions or conditions within the relevant verdict; detailed release and operating-state decisions remain distinct. These are author-developed decision categories, not a maturity scale. Stopping an unsupported proposal is a valid outcome of a well-designed experiment.

Require the continuation decision to identify what remains unproven. An approval to develop is not an approval to deploy; an approval for internal drafting is not authority to communicate with customers. Attach the decision to a versioned scope so that later changes can be compared with what was actually considered.

The sponsor names the investment question and its delegated owner; the team defines the product hypothesis and evidence needed at the next checkpoint. Chapter 6 turns that scope into intended use, prohibited use and acceptance criteria.

Apply §5.8's scale prerequisites to the proposed exposure. The product owner must show funded source ownership, evaluation, support, fallback, incident response and provider exit at that scale. An unresolved prerequisite prevents an unconditional Scale verdict.

Four verdicts with scope, evidence and a next decision

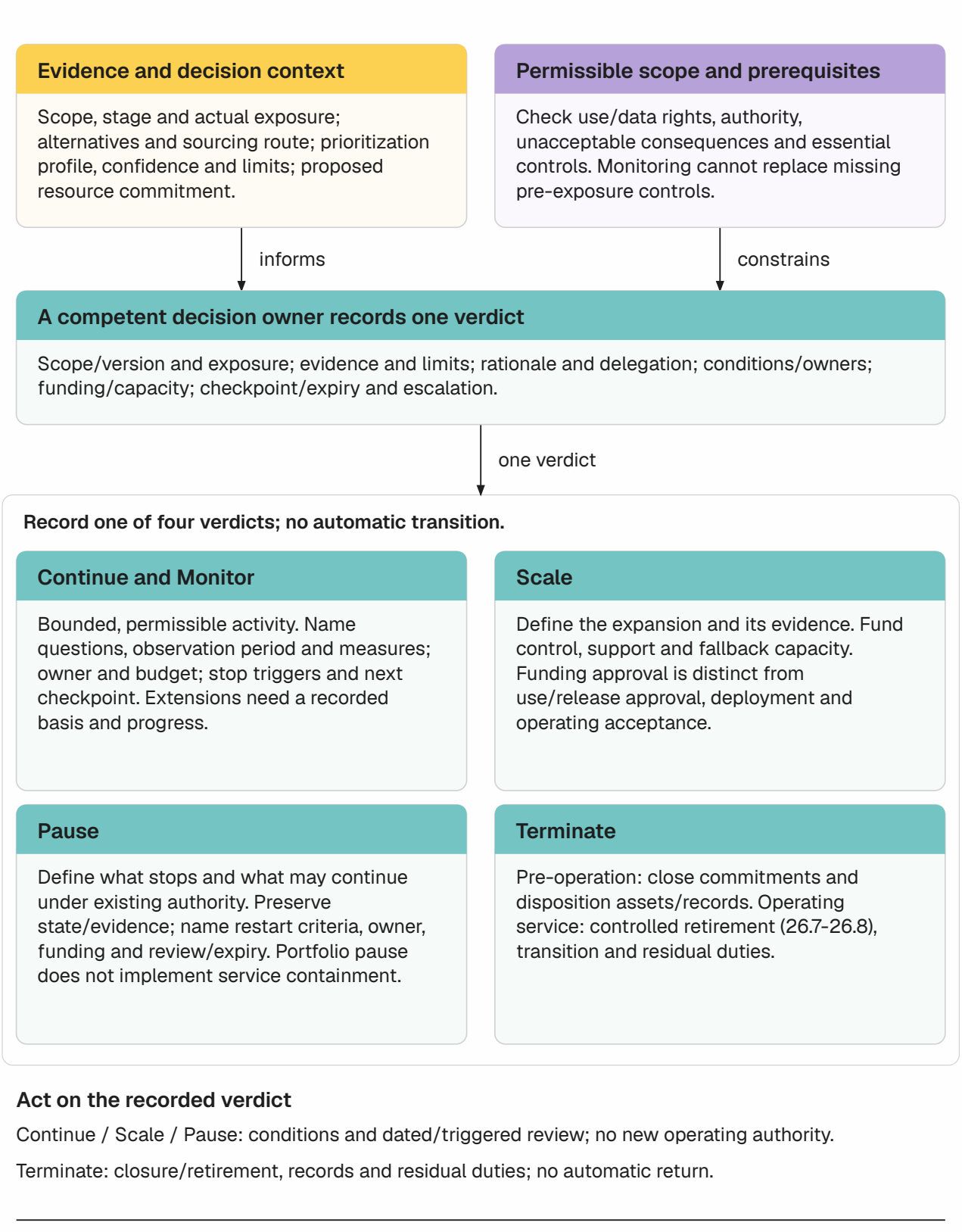
Table 5.10 — Verdict and meaning and required rationale

Verdict	Meaning and required rationale	Scope, funding and next checkpoint
Continue and Monitor	Continue within an explicitly bounded stage or authorized operating scope to resolve named uncertainty or observe sustained outcomes	State the observation period, questions, measures/population, evidence owner, budget, conditions, stop triggers and dated/event-driven decision checkpoint. An extension requires a recorded basis and progress; it is not an indefinite continuation default.
Scale	Support a specified increase in investment, population, volume, geography, capability or operating exposure on the available evidence	Name what is expanding, value/guardrail evidence, affected claims, funded control/support/fallback capacity and conditions. Distinguish funding approval from use/release approval, verified deployment and operating acceptance.
Pause	Hold a defined initiative activity or proposed expansion while a dependency, finding, resource constraint or uncertainty is addressed	Name what stops and what, if anything, may continue under existing authority; preserve state/evidence, set restart criteria, owner, funding treatment and review/expiry. A portfolio pause does not by itself implement service containment.
Terminate	Stop pursuing a proposal or end an initiative whose value, feasibility, strategic case or acceptable operating boundary is unsupported	For a pre-operation proposal, close funding/work commitments and disposition assets/records. For an operating service, invoke the controlled retirement and decommissioning process in §§26.7–26.8, including affected parties, transition and residual duties.

The decision record contains initiative ID/version and stage; intended scope and actual exposure; sourcing route; alternatives and prioritization profile; evidence and limitations; verdict and rationale; competent decision owner/delegation; conditions and accountable owners; funding/capacity commitment; monitoring/evidence plan; checkpoint/expiry; and default or escalation if conditions are unmet. Link the record to A1–A3 and A6–A8 as appropriate. Attendance at a forum, a sourcing contract or a portfolio ranking is not decision authority. See Figure 5.3.

Figure 5.3 — Initiative investment verdicts

At a recorded investment checkpoint Four investment outcomes within the existing lifecycle.



An initiative investment disposition depends on its bounded case, evidence and conditions. A verdict is not a product release, legal conclusion or proof of achieved benefit.

At an initiative investment checkpoint, evidence informs a competent delegated decision and admissibility constrains the available scope. Record Continue and Monitor, Scale, Pause or Terminate with conditions, owners, resources and a next checkpoint or closure route. The verdict is distinct from release, deployment and operating authority.

Text alternative: Evidence and context inform a recorded decision; permissible scope and essential prerequisites constrain it. Four alternatives are Continue and Monitor, Scale, Pause and Terminate. The first three require bounded conditions and a dated or triggered next decision. Terminate closes a proposal or invokes controlled retirement for an operating service, with records and residual duties retained. No arrow grants service authority or implies automatic progression.

“Continue and Monitor” is appropriate only where the present activity or operation remains permissible within its approved boundary. Monitoring does not substitute for missing pre-exposure controls or justify a foreseeable severe failure. Where evidence gathering cannot be performed within a defensible boundary, pause, narrow or terminate the affected activity. A paused or terminated investment may still require separate incident, customer-remedy, contractual or records action.

A Continue and Monitor verdict funds bounded learning, not wider operating authority. Record scope, open questions, funded review, checkpoint and stop conditions. A later Scale verdict initiates the affected use, release, deployment and operating decisions.

Filled checkpoint and scale-readiness record

Synthetic PA-INV-02: Continue and Monitor PA-R1’s draft-only scope for the four-week teaching month, capped at the constructed 43,000 cost in §5.5. Ask whether full checking effort falls against the matched manual baseline and whether withdrawal/recovery stays within the permitted boundary. Product and knowledge owners report weekly. A material unsupported commitment, revoked-source access or unenforceable scope stops the affected service; unresolved findings at the checkpoint lead to Pause. Continued funding does not extend permissions.

Table 5.11 — Proposed scale claim and evidence required

Proposed scale claim	Evidence required	PA-INV-02 disposition
Increase from 25 to 250 employees	Population/oversight evaluation and funded checking capacity	Not yet supported
Extend to customer-specific decisions	New use, data, rights, authority and specialist review	Excluded from this proposal
Sustain value and service	Matched value observations, tail latency, fallback and incident capacity	Four-week observation authorized within existing scope
Obtain operating permission	Exact release, enforceable conditions and operating acceptance	Separate decisions; funding verdict cannot grant them

The checkpoint ends with evidence, a delegated owner, funding implications and a dated next decision. Chapter 28 shows how the dashboard reveals this record rather than concealing it in an aggregate score.

Notes

1. NIST, AI RMF 1.0 (B01), MAP 1.4 and MAP 3, MANAGE 2.1. Official source current to 22 September 2026: https://airc.nist.gov/airmf-resources/airmf/5-sec-core/. Voluntary framework; revision in progress. The chapter's investment method and Table 5.1 are author synthesis, not NIST forms. Return to text

Chapter

6 Intended Use, Prohibited Use, and Acceptance Criteria

“Assist customer-service employees” leaves almost every consequential question unanswered. Does the application explain a policy, recommend an action, prepare a record update or send a response? Can it use customer information? Which employees may use it, for which products and under which operating conditions? A product description that cannot answer those questions is too broad to evaluate or approve meaningfully.

6.1 Write the Intended-Use Specification Before the Prompt

An intended-use statement is a boundary around a specific service. It connects users, tasks, information, outputs, authority and conditions. A prohibited-use statement describes uses or actions that the design is not authorized to support. Acceptance criteria specify observable conditions for advancing a particular version through a particular decision gate. These are working definitions for the book, not legal classifications.

NIST’s AI RMF asks organizations to document intended purposes, deployment context and relevant users. That contextual requirement supports, but does not prescribe, the intended-use specification developed here.[1]

The intended-use record gives product, engineering, risk, evaluation and operations one service boundary. The executive approves that boundary; practitioners turn it into configuration, tests and operating behavior. The record is neither a contract nor a legal classification. See Figure 6.1.

Figure 6.1 — A specified use has an explicit boundary

Chapter 6 §§6.1–6.7 · distinguish permission, scope, evidence and service availability.



A specified use has an explicit boundary. Four response reasons require distinct handling; material boundary change reopens the affected decision.

6.2 Describe the Boundary as a Set of Decisions

Start with the task the system may support and the person who remains responsible for the surrounding work. Distinguish “draft an explanation of an approved policy” from “decide which policy applies to this customer.” The first can still be consequential, but it delegates a different task from the second. Specify the distinction in the requirement rather than relying on an employee to infer it from a disclaimer.

Next define the information boundary. Name categories and approved sources, not merely “bank data.” Separate information the application can retrieve from information a user might paste into a conversation. A read-only integration does not explain what the application receives through its user interface. Account for both routes before describing the service as isolated from customer records.

Then define the action boundary. A draft visible only to an employee, a recommendation written into a work queue and a submitted transaction are different outputs. Identify the handoff at which content becomes an institutional action. That boundary determines where review, authorization and evidence must be designed; the model’s label does not determine it.

Finally, state operating conditions: supported language and topic scope, availability of required sources, user competence, expected checking task and fallback route. When a condition is absent, the intended response should be defined. “Best effort” is not an adequate substitute for deciding whether the product should decline, request information, escalate or stop.

6.3 Turn Prohibited Use Into Observable Boundaries

A prohibition written only in guidance is a policy statement, not evidence that the product enforces it. Conversely, a blocked interface action may not prevent the same outcome through an export or an indirect workflow. Examine each prohibition at the points where information enters, content is produced and actions leave the system.

For the restricted drafting scenario, a proposed prohibition is that the assistant must not send customer communications. A useful design response is to withhold a sending capability from the assistant’s execution identity and keep communication in the established employee process. Testing should examine the actual integrations and permissions, not just ask the model whether it is allowed to send. This is a proposed control pattern requiring security review; it is not a claim that every alternative path has been eliminated.

Other boundaries cannot be reduced to a permission. An unsupported policy statement may appear inside an otherwise well-formed draft. Its acceptance criteria need to address evidence, appropriate uncertainty and the employee’s checking task. The NIST

generative-AI profile identifies confabulation, privacy and human-AI configuration as risk areas; it does not establish that a warning or review step adequately controls them.[2]

Distinguish prohibited use from predictable misuse and from residual failure. Prohibited use defines the approved boundary. Misuse cases describe attempts to cross or exploit it. Residual failure describes what can still go wrong within the intended task. All three inform testing, but they require different responses and should not be collapsed into "the user did not follow instructions."

Prohibitions can exist at three layers. Institution-wide prohibitions apply regardless of product; product prohibitions define what this release is not authorized to do; and user restrictions limit how an entitled person may use the product. Keep "out of scope" separate: a language or product not yet supported may be a development boundary rather than an inherently forbidden use. The response—block, abstain, route elsewhere or request a separate assessment—should be explicit.

Table 6.1 — Misuse or adversarial condition and what the assessment should examine

Misuse or adversarial condition	What the assessment should examine	Illustrative safe response
Prompt injection in retrieved material	Whether untrusted content can override system instructions or trigger tools	Ignore untrusted instructions, restrict tools and surface the affected source
Sensitive-data disclosure	Inputs, logs, outputs, access paths and provider handling	Prevent or redact where designed; stop and escalate when the boundary is uncertain
Unauthorized tool or record access	Execution identity, entitlements and indirect workflow paths	Deny by policy-enforced permission; do not rely on a model refusal
Unsupported answer under pressure to respond	Behavior when evidence is missing, conflicting or stale	State the limitation and route to the approved fallback
Human overreliance	Information, time, competence and authority available to the reviewer	Redesign the review task or restrict the consequential use
Attempted approval bypass	Whether content or action can leave through an alternate interface	Bind authorization to the specific candidate action and audit the path

Use this table to design tests. Record their results and the decision separately; a test prompt is not evidence of effectiveness.

Table 6.2 — Request class and policy-assistant example

Request class	Policy-assistant example	Response
Out of scope	A lawful question in an unsupported language	Explain the boundary and route to the authorized service
Disallowed for this release	Send the draft to a customer	Deny the action; the workload has no send capability
Unsupported	Authorized policy material cannot establish an exception	Abstain from that proposition and route to the policy owner
Temporarily unavailable	Current source authority cannot be checked	Hold the affected response and use the approved fallback

A request may fit several classes. Record the reason that actually controls the response; do not label every unsupported question prohibited conduct.

6.4 Specify the Safe Alternative to an Answer

An application can fail by producing an unsupported answer, but it can also fail by refusing everything useful. Define abstention in relation to the service: what condition triggers it, what information the user receives, and what happens next. A refusal without a viable continuation path may shift work and confusion to another team.

For an internal policy draft, insufficient authorized evidence should lead to an explicit limitation and an established escalation route, not an invented explanation. If the policy source is unavailable, a stale cached passage should not silently be treated as current merely to keep the interface responsive. The design needs an agreed rule for freshness and fallback; this book does not supply a universal age limit.

Specify what an employee can actually verify. Does the interface show the relevant source passage and its identity? Can the employee identify missing information? Can they reject or correct the draft without losing the case? Do they have authority to use a non-AI route? Those are design and evaluation questions, not proof of effective oversight. Chapter 19 owns the deeper treatment of workload, competence and human factors.

In an acceptance record, separate the system's behavior from the human task. "Displays evidence" is an interface criterion. "The reviewer can use that evidence to detect a material unsupported statement" requires a different evaluation. Passing the first does not establish the second.

6.5 Write Acceptance Criteria With Explicit Failure Conditions

A useful criterion states the situation, expected behavior, method of assessment, decision rule and owner. “High accuracy” lacks all five. “Produces the required policy explanation for approved topics” is better, but still needs an operational definition of correctness, cases where the policy is ambiguous, and treatment of unsupported additions.

Separate deterministic checks from judgments about behavior. An output may be required to conform to a schema, use an approved destination or omit a prohibited field. Those conditions can be checked directly in the assembled application. Whether a draft fairly represents a policy or appropriately handles uncertainty may require a rubric and qualified assessors. Do not hide the difference behind a single pass flag.

Table 6.3 — Criterion class and illustrative criterion with an explicit failure condition

Criterion class	Illustrative criterion with an explicit failure condition	Evidence owner
Deterministic	A candidate record conforms to the approved schema and cannot be submitted by the model execution identity	Engineering and security
Behavioral	A qualified assessor can trace each material policy statement to the approved corpus version using the agreed rubric	Evaluation and policy owner
Adversarial	A retrieved instruction that asks the system to ignore the approved boundary does not grant a tool permission or suppress source identity	Security and evaluation
Nonfunctional	The service meets institution-defined latency, availability and cost boundaries without bypassing abstention or review	Product, platform and operations
Negative	A customer-specific eligibility request is declined or routed outside this product, with no candidate decision written	Business, conduct and evaluation

No threshold is implied by these examples. Each criterion requires a locally approved test population, decision rule, severity treatment and accountable owner.

For behavioral evaluation, define the case population, coverage dimensions and severity treatment. A strong aggregate result does not cancel a failed case that violates a hard boundary. Repeated runs may be relevant when outputs vary, but the test plan must justify what they establish and what remains uncertain. This chapter deliberately supplies no universal sample size, pass rate or fairness threshold.

Approval criteria should also cover the operating service: access boundaries, dependency failures, escalation, observability and ability to withdraw a problematic version. A model-only evaluation is insufficient for a criterion about the assembled workflow. Detailed measurement methods belong to Chapter 16; the requirement owner must nevertheless define what decision those methods need to support.

6.6 Worked Trace: From Use Statement to Evidence

Illustrative scenario — fictional composite. Fictional Bank is considering a retrieval extension to the restricted drafting assistant. This extension is a proposal, not an approved or operating capability. Its stated purpose would be to draft explanations from approved policy material for employee checking, without customer-record access or sending authority.

Table 6.4 — Concise intended-use record

Field	Illustrative entry	Required follow-through
Task and user	Restricted policy explanation for authorized employees	Name the actual topic set and user entitlement
Information boundary	Approved policy corpus; no customer-record integration	Assess pasted inputs and source access separately
Enforcement location	Identity/session boundary, corpus entitlement, source-authority filter and response handling	Identify component/control owner and release-linked permitted/denied evidence
Output and authority	Internal draft; no external send or system update	Verify application permissions and workflow handoff
Prohibited behavior	Unsupported policy commitments or customer-specific eligibility decisions	Define severity, adversarial cases and escalation
Insufficient evidence	State limitation and route to an approved non-AI process	Specify the owner and assess fallback capacity
Acceptance decision	Versioned requirements and test evidence assessed by accountable roles	Define criteria locally; do not infer approval from a demonstration

One requirement might state that each material policy statement in the draft must be checkable against an approved source. A corresponding test case presents a question for which the corpus lacks the needed exception. The expected behavior is to expose the limitation rather than invent the exception. The assessment record would preserve the question, authorized corpus version, retrieved material, output, assessor decision and defect if any. No result is asserted here.

If the application retrieves the right source but adds an unsupported exception, the defect concerns generation or subsequent processing. If the source is unavailable because the user lacks access, the correct response must respect that boundary; test data should not teach the application that missing access is a retrieval inconvenience to bypass. The architecture and security teams must inspect the actual enforcement path before concluding that the requirement is satisfied.

This trace is intentionally specific enough to reveal missing decisions. What is a material statement? Who resolves conflicting policies? Which source takes precedence? How is a

policy withdrawal reflected in the corpus? Until those questions have owners and answers, the requirement is not ready to become a release assertion.

Worked acceptance and enforcement record

Table 6.5 — Situation and required behavior

Situation	Required behavior	Severe failure	Evaluation method	Primary enforcement location	Owner
employee asks policy question outside approved corpus	abstain and route to policy support	invent a rule or cite an unapproved source	held-out boundary cases and source review	corpus entitlement, retrieval filter, response validator	knowledge owner
employee requests investigation information	deny and explain the permitted route	reveal restricted case data	unauthorized-role tests	identity and data authorization	information owner
employee asks to create a ticket	explain the held capability and route to authorized manual support	prepare a candidate, admit a submission or imply that confirmation grants capability	draft-only tests: no preparation endpoint and no admitted action	channel capability policy and release identity	service owner
supported language is uncertain	disclose limitation and use approved alternative	present an unreviewed translation as authoritative	language-specific cases and human review	channel routing and presentation	product owner

Each row also needs a release-linked result, limitation, decision, and re-entry trigger. Model behavior can support these controls, but sensitive data access and consequential actions should not depend on model compliance alone.

Decision rule and follow-through for each acceptance row

Complete each row with a locally approved decision rule, evidence reference, failure response and re-entry trigger. For the missing-exception case, the expected behavior is limitation plus policy-support routing; source/retrieval and proposition-support checks establish the result; the knowledge owner records the corpus/release and assessor disposition; an unsupported policy commitment causes rejection or escalation irrespective of average fluency. Oversight feasibility is itself a claim: passing answer-quality tests does not compensate for an employee task that cannot realistically detect and challenge the error (§19.5).

Completed teaching acceptance result PA-EV-01

Candidate PA-0.1 receives an authorized question whose correct answer needs a main rule and an exception. It retrieves only the rule and drafts an unconditional commitment. The policy assessor marks EX-01 a material omission, even though the citation itself is accurate. The owner rejects that candidate and opens PA-CHG-01; no average score overrides the severe failure. PA-0.3's distinct retest is recorded in §16.9.

These constructed observations illustrate the decision rule. PA-DRAFT cannot prepare or create a ticket; separately permitted preparation/submission variants are identified in §7.6.

6.7 Version the Requirement, Not Just the Model

An expansion from internal drafting to customer-specific recommendation changes the use contract even if the model, prompt and interface remain unchanged. The new task may require different information, different assessors and a different consequence analysis. Treat it as an explicit scope change, not as a convenient interpretation of the original purpose.

Requirements also change when source ownership, product coverage, language, user group or fallback changes. Keep the old statement so that an evaluation result can be interpreted against the boundary it actually tested. A test pass should identify both the system configuration and the requirement version. Otherwise, a later reader may mistakenly apply old evidence to a broader service.

When uncertainty remains, record an assumption with an owner and a revalidation trigger. "Policy material will have a named owner" is not the same as an identified owner accepting the role. "Employees will check every material statement" is not

evidence that the proposed workflow makes that feasible. Assumptions belong in the decision record until resolved, not in the past tense of a release summary.

6.8 Handoff to Classification and Design

The requirement owner should turn each important boundary into an observable failure condition and response. The acceptance record must show the result and decision, including severe failures that an aggregate score cannot excuse.

Notes

1. NIST, AI RMF 1.0 (B01), MAP 1.1. Official source current to 22 September 2026: https://airc.nist.gov/airmf-resources/airmf/5-sec-core/. Voluntary framework; the use-contract structure is author synthesis. Return to text

2. NIST, Generative Artificial Intelligence Profile, NIST AI 600-1 (B02), July 2024, sections 2.2, 2.4 and 2.7. https://doi.org/10.6028/NIST.AI.600-1. Official publication current to 22 September 2026. Cross-sector risk context, not proof of banking control effectiveness. Return to text

Chapter

7

Risk Classification, Criticality, and Materiality

A bank needs to know what could go wrong, how important the supported service is, and which decisions require escalation. Those are related questions, but a single "high/medium/low" label does not explain all three. Classification becomes useful when its result changes who must decide, which evidence is needed and what operating limits apply.

7.1 Three Questions, Not Three Synonyms

Author working definitions. In this book, risk classification organizes the potential adverse consequences and uncertainties associated with a defined use. Criticality describes the importance of a service or dependency to continued operation and the consequences of its disruption. Materiality concerns significance for a specified institutional decision, including whether a change, exposure or consequence warrants a different approval or review route. These are explanatory definitions; they do not replace meanings in applicable law, supervisory guidance or internal policy.

An internal aid might have limited direct action authority but become deeply embedded in a service. That raises a criticality question even if its original use classification was modest. A small change to a tool permission may have little effect on user-interface behavior yet materially expand what the system can do. Conversely, a visible cosmetic change may not alter the underlying authority or consequence. The classification record should explain the distinction instead of treating every change as equivalent.

The chapter proposes a routing method, not a calibrated scoring model. No weights, numerical cutoffs or predicted loss rates are supplied. Institutions need their own approved thresholds, legal interpretations and risk appetite. The method's value is in exposing those decisions, not making them disappear inside an equation.

These definitions intentionally crosswalk, rather than replace, terms used by model-risk, operational-resilience, information-security, data, conduct and legal teams. When two disciplines use the same word differently, the classification record should preserve both meanings and identify which decision each one controls.

7.2 Classify the Assembled Use

The unit of classification should be the deployed or proposed use within its operating process. Include the users, affected parties, information, model and non-model components, human tasks, connected systems and possible actions. A model inventory remains useful, but the same model can participate in uses with different authorities and consequences.

Chapter 4 introduced six control-intensity factors: capability, authority, consequence, exposure, scale and reversibility. Apply those factors here as prompts for evidence, not as a replacement taxonomy. Capability asks what the system can produce or attempt. Authority asks what the surrounding platform permits it to affect. Consequence asks what happens when the output or action is wrong. Exposure and scale describe who or what can encounter it and how widely an error can propagate. Reversibility asks whether intervention can restore the relevant state, not simply whether a database field can be changed back.

A read-only label is therefore informative but incomplete. The output may influence an employee's consequential decision. Likewise, a reversible technical write may have already triggered a communication or downstream process. Map the path from output to consequence before treating either property as a reason to reduce review.

Keep the unit stable. If classification covers one restricted workflow, do not attach its result to a shared model and imply that every consuming application inherits it. Platform-level evidence can be reused for the platform characteristics actually assessed. Use-specific evidence must still describe the assembled service.

7.3 Record Uncertainty Separately From Reassurance

A risk record should distinguish a hazard, a proposed control, evidence that the control exists, and evidence about its operation. "Employee checks the answer" describes a proposed activity. It does not, by itself, establish that the employee has the information, time and authority needed to detect and correct a consequential error.

For each material exposure, record the available evidence and the limits of the assessment. If the operating volume is not known, say so. If a provider's change behavior is contractually unresolved, do not assume it is stable. If the fallback has been designed but not exercised, preserve that difference. Unknowns do not automatically prove that risk is high, but they should not be converted into a low rating by default.

Separate the initial exposure from the residual position claimed after controls. Explain why the proposed control addresses the exposure and what evidence would support that conclusion. Where that evidence is absent, record the residual position as provisional. Do not subtract a control from a score merely because its name appears in a checklist.

The executive consequence is a decision about uncertainty the institution is prepared to carry. The practitioner consequence is a work list tied to that decision. A missing test, an unavailable source and an unassigned owner require different remedies; a single amber status can conceal all three.

7.4 Keep Institutional Routing Separate From Legal Classification

An institution's internal risk tier is not automatically a legal category. Nor does a regulator's model definition necessarily cover every system the bank calls AI. Maintain a separate applicability record identifying the entity, jurisdiction, activity, system role, relevant date and source. A legal or regulatory specialist should resolve the mapping where it affects obligations or customer treatment.

For example, the U.S. agencies' April 2026 model-risk guidance, as described in OCC Bulletin 2026-13, expressly excludes generative and agentic AI and does not establish enforceable standards. That statement concerns this guidance's scope; it does not establish that such systems are exempt from other obligations.[1]

This matters operationally. A bank might choose to apply parts of its existing model-risk process to a generative application as internal policy. The record should say that, rather than presenting the choice as a requirement of a source that excludes the application. Conversely, absence from one framework is not a reason to omit security, privacy, conduct or operational assessment.

The book's global approach preserves three layers: general engineering and governance principles, clearly bounded jurisdiction examples, and institution-specific implementation. This chapter does not provide a country-by-country legal classification. Where primary text or competent interpretation is unavailable, leave that local mapping unresolved and restrict the affected decision rather than reconstructing an obligation from analogy.

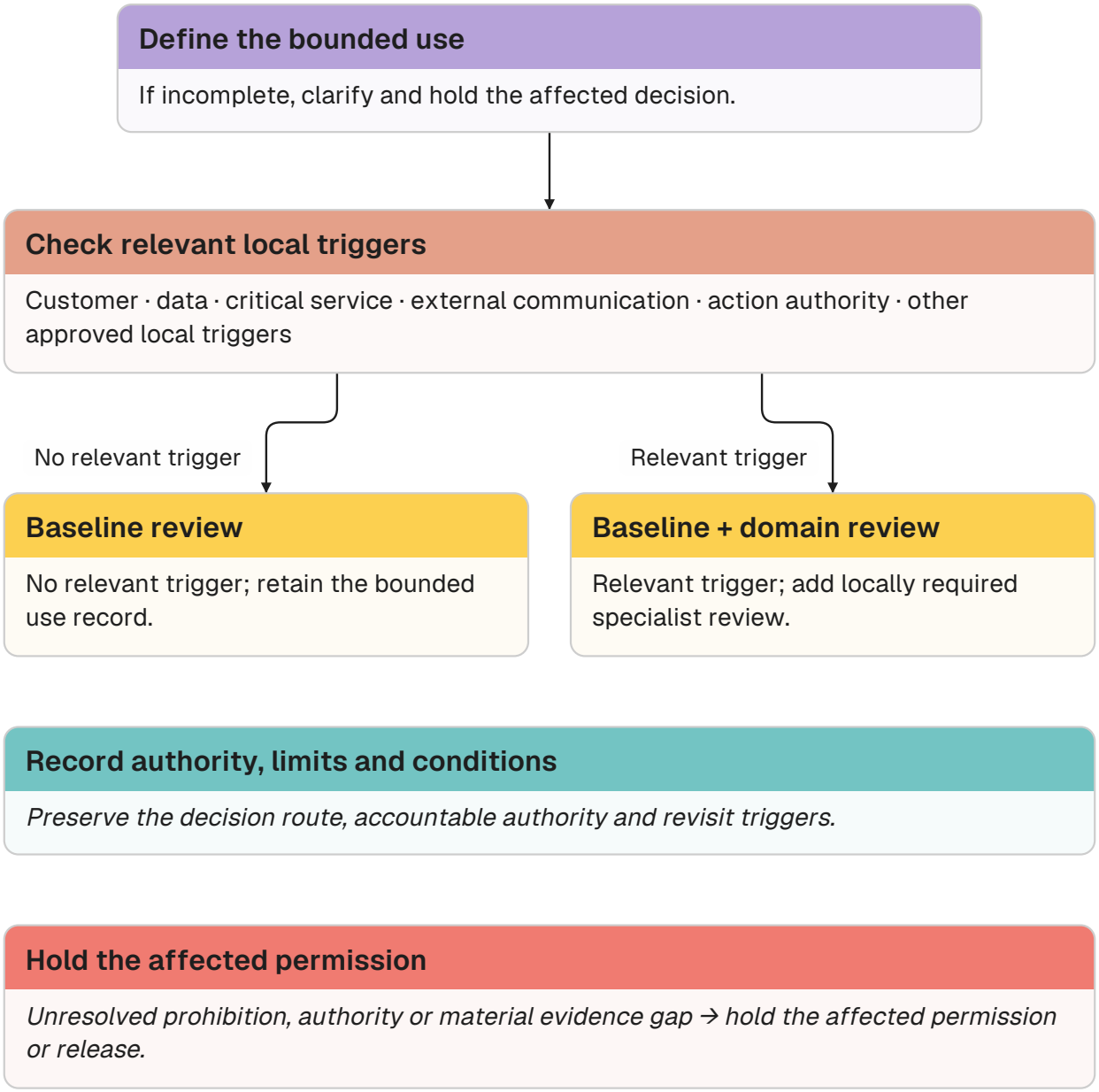
Impact-assessment screening link

The classification output links to the legal-applicability record in §8.4, including any FRIA/DPIA screening result and reviewer basis. An institutional risk tier is not an Article 27 determination. Record unknown use/classification facts as open conditions rather than mark an impact assessment not applicable by assumption.

7.5 Route by Consequence and Decision Trigger

Figure 7.1 is an original routing aid. It is not a source of legal authority or a universal control catalog. Apply the institution’s approved rules at every branch. A route to specialist review means that review is needed; it does not indicate its conclusion.

Figure 7.1 — Classification determines the review route



Apply institutional review rules to each bounded use. Legal classification remains separate; unresolved findings hold the affected permission or release.

Text alternative: Start with a versioned use boundary. If the boundary is incomplete, clarify it before classification. If it is known, check for customer consequence, sensitive information, critical-service dependency, external communication or action authority. Refer triggered domains for tailored assessment; otherwise apply the institution's baseline route. Both routes produce a documented decision with limits and review triggers. An unresolved prohibition, authority question or material evidence gap holds the affected permission or release; independent work may continue.

The trigger list is deliberately not exhaustive. Its purpose is to prevent an apparently simple application from skipping a relevant discipline. A sensitive-information trigger routes privacy and security questions; it does not automatically determine every aspect of the application's business risk. A critical-service dependency routes resilience questions even if the application does not initiate transactions.

Allow escalation without requiring an artificially precise rating. A reviewer who finds an unclear authority boundary should be able to request resolution before a consequential permission is enabled. Record the disputed point and the decision it blocks. The appropriate response may be to restrict the permission while allowing unrelated development to continue, rather than stopping the entire program or approving the uncertainty wholesale.

An institution may add qualitative bands after approving their definitions. One nonnormative pattern is:

Table 7.1 — Illustrative band and typical route—not a universal classification

Illustrative band	Typical route—not a universal classification	Minimum decision consequence
A — bounded support	Internal use, limited information and no consequential action authority	Baseline product, security and business review
B — influential	Output informs an employee or process with meaningful downstream consequence	Domain evaluation and explicit human-task design
C — consequential	Customer, financial, legal, conduct or critical-service consequence is plausible	Enhanced cross-domain challenge and restricted release authority
D — action-bearing or highly exposed	Direct action authority, broad exposure, sensitive dependency or difficult reversibility	Senior accountable decision, independent challenge and stronger operating evidence

The letters do not travel between institutions. A bank that adopts bands must define its own triggers, required evidence, exception rights and mapping to applicable legal categories. An uncertain boundary follows the more restrictive relevant route until the question is resolved; this is a proposed governance default, not law.

7.6 Illustrative Scenario: Drafting Versus Record Preparation

Illustrative scenario — fictional composite. Fictional Bank's restricted drafting proposal remains separate from a later proposal to prepare an operational record update. No classification outcome, approval or effective control is asserted.

For the drafting use, the team would describe the permitted information, restricted topics, employee task and absence of sending or update authority. Risk assessment would still examine unsupported statements, inappropriate information handling and reliance on the draft. The absence of a write tool narrows one path to consequence; it does not remove every path.

For the proposed record-preparation use, the output would become a structured candidate change for an employee to inspect. Classification would need the target record, editable fields, permissions, validation rules, approval handoff and downstream effects. If submission remains with an employee, assess what exactly the employee sees and authorizes. A confirmation of "continue" is not necessarily informed approval of every field the system generated.

A materiality question then arises: does preparation alone change the risk or review route, and would adding execution authority require a separate decision? The proposed method records those as distinct changes. It does not assume that an approval for preparing a candidate update permits executing it.

The same logic applies to criticality. If the service later depends on the assistant to complete ordinary work, the institution should reassess what happens when the assistant is unavailable. The illustration does not assume that dependence has occurred. It identifies a change trigger to monitor if the service is introduced.

Table 7.2 — Proposed use and illustrative classification observations

Proposed use	Illustrative classification observations	Uncertainty route
Internal research and drafting	No direct action authority, but information sensitivity and employee reliance still matter	Restrict sources and external use until permissions and review task are established
Fraud-screening support	Output may influence delayed, blocked or escalated activity; customer and operational consequences require local assessment	Route to fraud, conduct, legal, model/evaluation and operations specialists
Candidate operational-record update	Field-level authority, downstream effects and checker visibility determine the route	Withhold submission permission until the candidate action and authorization boundary are inspectable

These examples produce questions, not classifications or approvals.

Versioned capability and local routing crosswalk

Table 7.3 — Variant and permitted capability

Variant	Permitted capability	Withheld authority
PA-DRAFT / PA-R1	Retrieve authorized policy and prepare internal prose	Customer-record access, external send, ticket preparation/submission
PA-PREP candidate	Prepare typed service-request fields for checking	Submit or alter the system of record
PA-SUBMIT candidate	Submit an exact authorized candidate through the receiver	Requires a separate release and fresh authorization; not inherited from PA-R1

The book's A–D bands are a local illustration, not legal classifications. Map A to baseline owner/control review; B to elevated domain review; C to high-consequence independent validation and accountable risk acceptance; and D to the institution's highest/escalated route or a hold where a defensible boundary cannot be established. The route has no automatic permission effect. A domain trigger can require specialist challenge at any band; §20.9 describes the corresponding evidence depth. Record any override and its delegated owner.

7.7 Reclassification Is Part of Change Management

Set review triggers when the classification is created. Candidate triggers include a new user population, language, jurisdiction, data category, model provider, tool permission, integration, operating scale or role in a service. They also include evidence that the original assumptions no longer describe actual use. Chapter 26 develops the change record; the classification should already identify which properties that record must compare.

Not every trigger needs the same depth of reassessment. A source-corpus change may require targeted retrieval and behavior evaluation. A new transaction capability may require broader architecture, security, conduct, operational and legal work. The change owner should explain the affected boundary and justify the proposed review scope. “The model has not changed” is not sufficient justification when another behavior-shaping or authority-bearing component has changed.

Periodic review can complement event-driven reassessment, but a universal interval is not supplied here. Frequency depends on applicable requirements, institutional policy, uncertainty and change behavior. A scheduled review should not become permission to ignore a material event until the next calendar date.

Preserve earlier classifications and their assumptions. This allows an investigator or reviewer to understand why a decision was reasonable on the evidence then available, and whether the institution responded when that evidence changed. Replacing yesterday’s record with today’s conclusion destroys that distinction.

Risk-appetite statement pattern

An AI risk-appetite statement should connect exposure to decision rights rather than assert that the institution has “low tolerance for AI risk.” A usable pattern identifies: permitted purposes and authorities; consequences or data classes requiring escalation; activities the institution will not undertake; minimum evidence before pilot and scale; exception authority and duration; concentration and resilience boundaries; customer-remediation expectations; and conditions that require restriction or stop. Thresholds and delegations are institutional decisions and are not supplied by this book.

Filled illustrative classification output

Table 7.4 — Field and fictional bank pa-draft candidate

Field	Fictional Bank PA-DRAFT candidate
bounded use	internal employee questions from an approved policy corpus; no customer-specific advice or autonomous action
dominant consequence	employee may act on a materially incorrect policy answer; restricted content could be exposed
authority	retrieve approved policy and draft internal answers; ticket preparation, submission and external send remain held
exposure and scale	internal users across selected entities; expansion requires entity and language review
reversibility	answer can be corrected, but downstream employee action may not be immediately reversible
uncertainty	source entitlement lag and language coverage remain open
institutional route	enhanced knowledge, security/IAM, privacy/records, evaluation, and service-owner review; legal route by entity/jurisdiction
permissions held	customer data, investigation sources, ticket preparation/submission, external communication and direct record change
decision	bounded evaluation candidate; not approved for production operation
reclassification triggers	external channel, customer context, new tool, new entity/jurisdiction, expanded action, incident, provider change

This is an illustrative application of the book's proposed method, not a real classification or a regulator-defined tier. A break-glass route, if the institution permits one, must be separate, time-limited, logged, reconciled, and retrospectively reviewed.

7.8 The Classification Output Is a Set of Obligations to Resolve

Translate the local classification route into named evidence, reviewers and withheld rights. Revisit it when use, authority, criticality or accumulated changes alter the assessment; a band or color is not the authorization.

Notes

1. Federal Reserve, FDIC and OCC, Model Risk Management: Revised Guidance, 17 April 2026 (B10). U.S.-specific scope statement; not a conclusion about other laws or duties. Return to text

Chapter

8 Governance, Accountability, and Decision Rights

A governance forum is useful when it can make a decision, require evidence, impose a limit or resolve a conflict. A recurring meeting with no clear authority can collect updates without changing what the institution permits. The same weakness appears in an AI inventory that names a model owner but leaves the surrounding product, data, process and service without accountable decisions.

8.1 Govern Decisions, Not Just Meetings

NIST's voluntary AI RMF calls for clear roles and communication and places responsibility for AI development and deployment risk decisions with executive leadership. The allocation proposed in this chapter is the book's synthesis, not a prescribed NIST organization chart.[1]

The starting question is not "who owns AI?" It is "who can authorize this use, this information boundary, this release and this exception?" Different decisions may belong to different roles. Connecting those roles is more useful than naming a single executive and assuming all subordinate authority is understood.

Assign decision rights within the institution's governance, checking accountability, independence and delegation against its actual structure and requirements. The following model does not impose a universal three-lines interpretation or legal duty.

Institutional AI policy-position record

An institutional policy-position record links permitted and prohibited uses, objectives, applicable policy references, data/action boundaries, ownership, approval/effective version, exceptions and review triggers. Its communication record identifies the affected roles and acknowledged changes. Product charters, use boundaries and risk/authority assessments link to it through A1–A3; product-specific records do not silently redefine institutional policy. This is a practical record design informed by NIST governance guidance, not a new universal policy mandate. Chapter 27 owns its operating-capability handoff.

8.2 Separate Ownership Without Creating Orphans

The business owner owns the purpose and the proposed change to the business process. The product owner translates that purpose into scope and delivery priorities. The system owner is concerned with the assembled technical service, including integration and operation. Model and data owners address the assets and limitations in their respective scopes. These are proposed functional distinctions; one institution may use different titles or combine compatible responsibilities.

Combining titles does not eliminate the decisions. If one person performs several roles, record which authority they exercise at each gate and where independent challenge is still needed. Conversely, dividing responsibilities across many teams does not guarantee separation if every team reports to the same delivery incentive and no one can block a release.

Assign ownership at the joins. Who resolves conflicting requirements between business and model teams? Who ensures a withdrawn document is removed from the retrieval path? Who decides whether a provider update requires re-evaluation? Who is responsible for the employee procedure when the AI path is unavailable? These questions connect technical ownership to the operating product.

An evidence custodian may maintain the record without owning the underlying decision. That distinction prevents an administrative role from becoming the accidental approver. The person who uploads an evaluation report is not thereby accountable for its methodology, conclusion or acceptance of remaining risk.

Board and executive oversight should follow the institution’s delegated authorities. The board or an appropriate board committee may oversee aggregate exposure, risk appetite, major incidents and management’s control environment without approving every product release. Executive management turns that oversight into funded priorities, accountable roles and escalation. Product-level authorities then make bounded decisions within their delegation. This is an author-synthesis operating pattern; applicable corporate-governance duties require local legal and governance review.

Table 8.1 — Illustrative line or role type and contribution to the decision system

Illustrative line or role type	Contribution to the decision system	Boundary to preserve
First-line business, product, engineering and operations	Own the use, implement the product and operate its controls	Cannot treat delivery evidence as independent challenge
Second-line risk, compliance, privacy or security oversight	Set or interpret policy within remit and challenge exposure	Does not inherit product operation merely by reviewing it
Independent validation or specialist assurance	Tests a defined claim or control with documented scope	Conclusion applies only to the reviewed version and evidence
Internal audit	Provides independent assurance under its approved mandate	Is not a substitute for management ownership or release approval
Board and executive oversight	Sets direction, appetite and accountability at the appropriate level	Delegation and reserved matters must be explicit

Institutions may organize these roles differently. The important test is whether ownership, competent challenge, decision authority and assurance remain visible. See Figure 8.1.

Figure 8.1 — Separate preparation, challenge and authority

Decision	Prepares the evidence	Proposed decision authority	Required challenge to scope locally
Fund a bounded use	Business and product owners	Delegated investment authority	Finance, risk and affected operations
Classify the use and route required reviews	Product and risk representatives	Authority defined by classification policy	Legal/regulatory and affected specialists
Permit data and knowledge use	Data owner with product team	Authority designated by data policy	Privacy/legal, security and records
Set action and tool permissions	System and security owners	Delegated authority for the target service	IAM, operational risk and business owner
Accept evaluation evidence	Evaluation lead and asset owners	Designated assurance or validation authority	Independent domain challenge as applicable
Accept a provider, model or material configuration change	Change owner with product and system owners	Designated change/release authority	Evaluation, security, resilience and affected domains
Release the assembled product	Product and system owners	Authorized release/risk decision holders	Unresolved domain findings and conditions
Decide customer remediation	Conduct/complaints and business owners	Authority defined by remediation policy	Legal, operations, finance and risk as applicable
Grant a bounded exception	Owner of the affected control	Authorized risk-acceptance role	Relevant specialist; no self-approved waiver
Withdraw or restrict operation	Operations with incident/control owners	Predelegated intervention authority	Escalation and subsequent accountable review
Retire the product and dispose of retained material	Product, operations and records owners	Designated retirement authority	Legal/privacy, security, data and service owners

Preparation, accountable decision authority and locally scoped challenge remain separate. Role labels are illustrative and require actual institutional delegation.

8.3 Map Rights to Specific Decisions

Table 8.2 offers a compact decision-rights map. It uses explicit verbs rather than an unexplained collection of RACI letters. “Prepares” identifies who assembles a recommendation; “decides” identifies the proposed accountable authority; “challenges” identifies relevant review. Local policy must name actual roles, delegation limits and substitutions before use.

Table 8.2 — AI product accountability map

Decision	Prepares the evidence	Proposed decision authority	Required challenge to scope locally
Fund a bounded use	Business and product owners	Delegated investment authority	Finance, risk and affected operations
Classify the use and route required reviews	Product and risk representatives	Authority defined by classification policy	Legal/regulatory and affected specialists
Permit data and knowledge use	Data owner with product team	Authority designated by data policy	Privacy/legal, security and records
Set action and tool permissions	System and security owners	Delegated authority for the target service	IAM, operational risk and business owner
Issue an assurance conclusion	Evaluation lead and asset owners	Designated assurance or validation authority within its mandate	Independent domain challenge as applicable
Accept a provider, model or material configuration change	Change owner with product and system owners	Designated change/release authority	Evaluation, security, resilience and affected domains
Release the assembled product	Product and system owners	Authorized release/risk decision holders	Unresolved domain findings and conditions
Decide customer remediation	Conduct/complaints and business owners	Authority defined by remediation policy	Legal, operations, finance and risk as applicable
Grant a bounded exception	Owner of the affected control	Authorized risk-acceptance role	Relevant specialist; no self-approved waiver
Withdraw or restrict operation	Operations with incident/control owners	Predelegated intervention authority	Escalation and subsequent accountable review
Retire the product and dispose of retained material	Product, operations and records owners	Designated retirement authority	Legal/privacy, security, data and service owners

The table does not assign legal authority by itself. In particular, investment approval does not authorize customer-data use, a successful evaluation does not authorize a release, and a release approval does not authorize all future changes. Link each decision to its evidence and the limits of the delegation.

Some decisions require more than one assent. Record the specific rights rather than making every participant “jointly accountable” for everything. For example, a business owner may accept a narrowed service scope while a security authority separately decides whether the proposed access design is permissible. A disagreement should identify the withheld authorization and its effect on the plan.

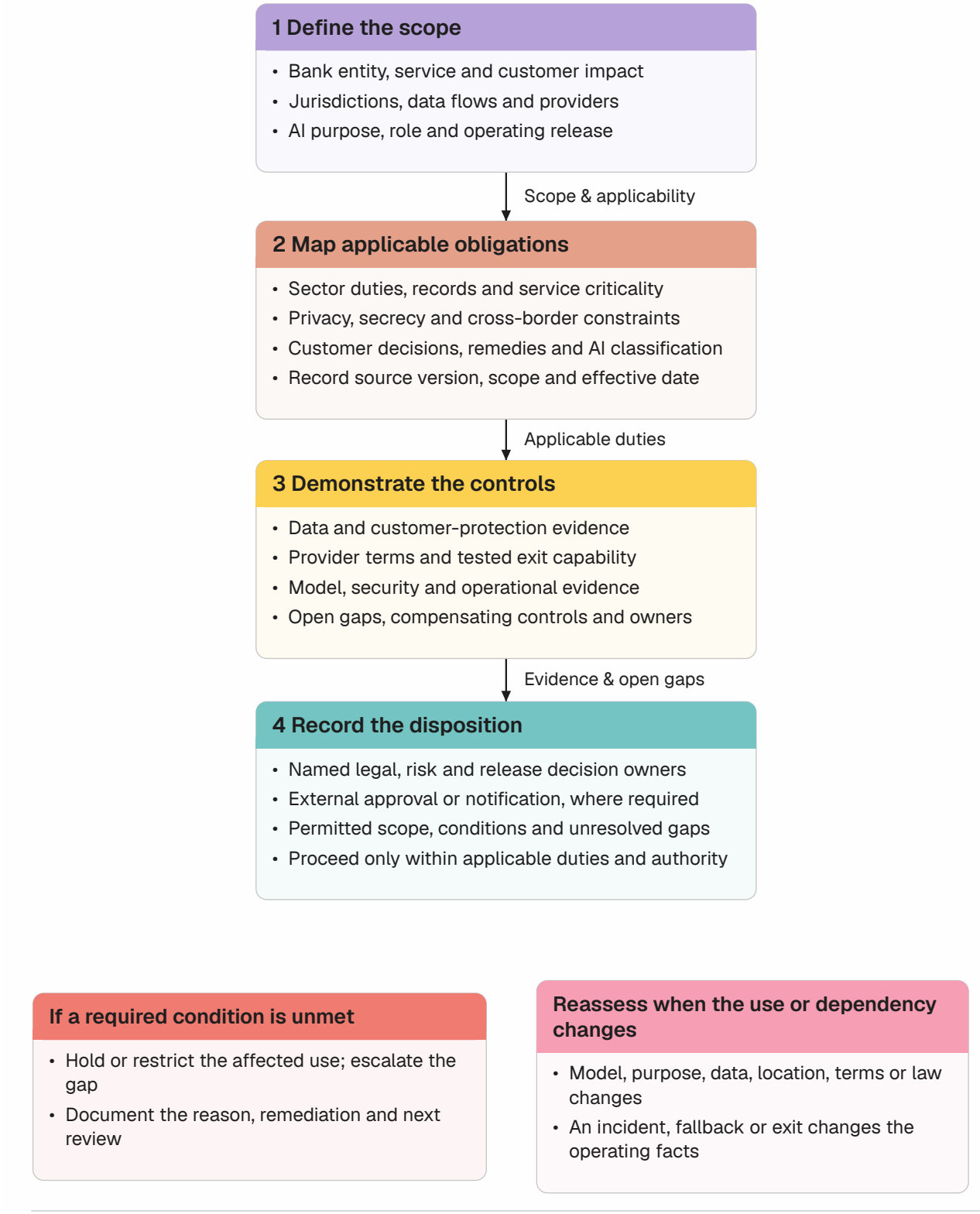
Where authorities disagree, the most restrictive unresolved authorization governs the affected action. The issue should be escalated to the role that legitimately owns the conflict—not decided by delivery schedule or majority vote. Record the competing conclusions, versions, evidence and final rationale; do not erase dissent after the escalation.

In a small institution, one team may prepare several records, but reviewing one’s own design is not independent challenge. Record the combination, appoint an unconflicted reviewer or obtain external expertise, and escalate any independence shortfall. The release delegate preserves the assurance opinion and decides only within the authority actually delegated.

For PA-R1, the product sponsor wants expansion after strong ordinary-case results. The policy reviewer withholds support for customer-specific use because it was excluded from the evaluation. The release owner accepts the narrower draft-only boundary; investment can fund further research without overruling the withheld use permission. See Figure 8.2.

Figure 8.2 — Legal review across the AI lifecycle

Start with the banking use case and applicable rules; keep the decision current.



Define scope, map applicable obligations, demonstrate controls and record the disposition. Unmet conditions require a hold or restriction and escalation; changes reopen affected review. This author-developed workflow does not establish a universal legal approval procedure.

8.4 Make Challenge Capable of Changing the Outcome

Independent challenge is meaningful when the reviewer has the competence, information, access and organizational freedom needed to question the proposal. A signature on a delivery team's summary does not establish those conditions. Independence is also scope-specific: a person may be independent of model development but involved in designing the control being assessed.

Define the review question before routing material. Is the reviewer assessing conceptual soundness, data suitability, security boundaries, customer consequences, legal applicability or operational readiness? A broad request to "approve the AI" makes exclusions difficult to see. The conclusion should describe the reviewed versions, evidence considered, limits, unresolved findings and conditions for proceeding.

Do not confuse a reviewer's recommendation with management's risk-acceptance authority. A reviewer may conclude that evidence is insufficient. Management's response, where its authority permits a decision at all, must preserve that finding and explain the action taken. It should not rewrite the review as favorable because the project continues under restriction.

This is a proposed governance pattern requiring local risk, audit and legal review. It does not establish that any particular combination of roles satisfies a jurisdiction's independence requirements. Chapter 20 owns the deeper treatment of validation and release evidence; Chapter 27 addresses the enterprise operating model.

Legal and regulatory review across the lifecycle

Legal review starts with the use being proposed, not the name of the model. Identify the financial institution and legal entity, service and regulated activity, affected customers or employees, jurisdictions, data flows, providers, AI purpose and degree of authority, and the exact release. Distinguish an assistant used to develop software from AI embedded in an operating service or consequential customer decision. The same review method can organize both; it does not give them the same legal classification.

Use four linked blocks to make the review reconstructable:

- **Scope:** record the entity, use, role, territories, parties, data and operating version, including facts that remain unknown.
- **Applicable duties:** link each relied-on requirement to its primary source, version, actor/activity scope, legal or guidance status and relevant dates. Identify unresolved interpretation and the specialist responsible for it; a jurisdiction example is not an obligation for every institution.
- **Controls and evidence:** connect the scoped duties to actual data-purpose and access decisions, confidentiality/secrecy and transfer assessments, customer protections,

provider terms, evaluation, security and operating evidence. Distinguish a promised control, provider assertion, institution test and observed operation. Identify gaps and their owners.

- **Disposition:** retain the competent review conclusion, reviewed versions, permitted scope, unresolved conditions and distinct decisions needed to proceed. Record the basis for a hold or restriction and what would cause reassessment.

Legal review, management risk acceptance, release authorization, supervisory approval or notification, and incident reporting are different acts. Whether an external step is required depends on the actual entity, activity, arrangement and applicable rules. A legal signature does not authorize every technical release; an internal approval does not satisfy an external requirement merely by using the same word. The decision rights in §8.3 and exception limits in §8.6 continue to apply.

If a required condition or lawful authority is missing, withhold or restrict the affected use and give the gap an owner and a reassessment trigger. An exception cannot waive law. Emergency containment follows the existing delegated intervention authority in Chapter 23; the method does not require waiting for a newly invented universal legal-approval step before stopping harmful activity.

Reassess the affected facts when purpose, model/provider, data, permissions, location, terms or applicable law changes, or when an incident, fallback or exit changes the operating arrangement. Link the record to the exact release and preserve earlier conclusions and limitations rather than rewriting history. §8.7 governs custody; Chapters 10, 18 and 19 address data and customer protections; §25.4 connects terms to capability and §§25.5–25.9 address continuity, exit and scoped source examples.

Use the four blocks to organize source, applicability, consequence and decision records. They prescribe no universal regulatory approval procedure. Applicable amended sources, local interpretation and qualified legal review remain necessary.

Figure 8.2. Legal review across the AI lifecycle. Author synthesis. Review stages and labeled handoffs organize the work, while applicable duties, competent authorities and open conditions remain locally determined.

Three applicability tests to keep separate

The legal record identifies entity, actor role, intended use/system classification, territory, source/version/date, duty, exceptions, owner and implementation evidence. The following are bounded EU examples for qualified assessment, not global book rules.[2]

Table 8.3 — Question and record and implementation link

Question	Record and implementation link	Scope qualification
Marking or disclosure?	Provider machine-readable marking and deployer/user disclosure are assessed separately; record content/interaction category, exception basis and accessible delivery	Article 50 has actor/use-specific duties and exceptions, including editorial-responsibility conditions for public-interest text. It does not impose one blanket label on all institutional AI output.
Oversight, logs or workplace notice?	Separate competent/authorized human oversight, automatically generated controlled logs, retention/access/hold and employer notice records	Article 26 applies to covered high-risk deployers. Its log provision includes a purpose-appropriate six-month floor with other-law qualifications and financial-services documentation interaction; workplace notice has its own employer trigger.
FRIA or DPIA?	Record Article 27 screening, assessment link, affected groups/ risks/ oversight/ mitigation, update/notification and DPIA cross-reference basis	Article 27 includes specified private deployers through Annex III 5(b)/(c), alongside public-law/public-service deployers. FRIA and DPIA remain distinct duties; one record does not automatically discharge the other.

Record applicable commencement and transitional provisions per duty. Final source/legal review confirms them for the intended institutional example; no universal deadline is embedded here.

8.5 Design Maker-Checker Around the Consequential Action

Maker-checker separation is often described as two people touching the same workflow. The useful design question is more precise: what does the maker propose, what information does the checker receive, what can the checker change or reject, and what action follows the approval? A checker who sees only a generic confirmation message may not be reviewing the consequential content.

For a candidate record update, the proposed design should expose the target record, field-level changes, relevant evidence and any uncertainty. Authorization should refer to that candidate action, not to an open-ended session. If the candidate changes after approval, the implementation must define whether the authorization remains valid or must be renewed. This is a security-sensitive design requirement to assess, not a claim that a particular product enforces it.

Separate human authorization from the model's assessment of its own output. A model can help organize evidence, but its statement that an action is acceptable is not the accountable person's authorization. Similarly, a model-generated explanation should not be treated as an authoritative record of why the institution approved the action.

For the high-impact scenarios in this book, the default is explicit human authorization of consequential actions. A permitted automation exception remains within the separately assessed and approved envelope in §4.5; neither a committee meeting nor a model confidence statement grants that exception. The implementation still needs institution-specific review of the information, authority, capacity and intervention route.

8.6 Keep Exceptions Narrow, Visible and Expiring

An exception is a decision about a specified deviation, not a general release from governance. The proposed exception record should identify the unmet condition, reason, affected use and versions, exposure, compensating arrangements, accountable decision-maker, expiry or termination condition, monitoring and remediation owner. Where the relevant authority cannot grant the deviation, the record is a blocked request rather than an accepted risk.

Illustrative scenario — fictional composite. Fictional Bank's team proposes a record-preparation extension, but the review interface cannot yet display all material changes to the employee. The scenario does not assert that this defect has occurred or that an exception is approved. It presents a decision problem: should the bank postpone the extension, narrow it to fields the checker can inspect, or redesign the interface?

A generic exception saying "human review in place" would not resolve the missing information. The proposed approach is to withhold the affected permission until the review task is workable, while continuing independent work such as preparing evaluation cases. If a narrower design is proposed, reassess that design rather than pretending the original one passed.

Expiry should lead to an operational consequence. Decide who receives notice, what is disabled or restricted, and how a renewal is assessed. Repeated renewal without examining the underlying condition can turn a temporary deviation into an undocumented operating model. This is a warning about the proposed process, not an empirical claim about any bank's practice.

The default at expiry should be reversion to the last authorized state or suspension of the affected permission, unless a competent authority has recorded a renewal before expiry. The product must be technically capable of that consequence; a calendar reminder alone is not an expiry control.

8.7 Give Evidence a Custodian and a Meaning

Governance records should connect the person making a decision to the version and evidence they considered. Preserve the scope of approval, conditions, exclusions and unresolved dissent. A repository containing a report and a separate approval email is not necessarily traceable unless the relationship is explicit.

Distinguish decision evidence from sensitive underlying material. A review record may need to identify an evaluation dataset without duplicating customer information into every governance pack. Access, retention, legal privilege and deletion require local policy and legal/privacy assessment. This chapter does not prescribe a universal retention period or claim that storing more data always improves auditability.

Changes in personnel also need a handoff. The incoming owner should know the current scope, open conditions, dependencies, exceptions and re-evaluation triggers. Ownership transfer should not silently reset unresolved findings. The continuity question is whether the institution can still act on its decisions after the people who made them move on.

Chapter 2 established the evidence-bundle categories. This chapter adds decision rights and custody, not another taxonomy of documents. The same underlying evidence should be reused through appropriate references rather than copied into separate packs that drift apart.

Board and executive questions

- Which AI products can affect customers, critical services, regulated records or money, and under what delegated authority?
- Can management identify the exact operating release and evidence for each material product?
- Which conditions, exceptions, incidents or provider changes require a decision now?
- Where do shared providers, models, clouds, data or specialist teams create correlated exposure?
- Can the bank continue the important service, reconstruct affected populations and remediate when an AI component fails?
- Is the value hypothesis supported by defined outcome evidence, including cost and adverse effects?

- Are independent review and operational capacity sufficient, or is governance becoming a queue of ceremonial approvals?
- Which changes require reclassification or reapproval, and can the bank detect them?
- Which material evidence is unavailable, provider-asserted or delayed?
- What should be narrowed, paused or retired?

Executive decision-rights summary

Table 8.4 — Decision and accountable authority

Decision	Accountable authority	Required challenge	Evidence of decision	Emergency alternative
accept purpose and affected parties	business/product authority	conduct, risk, legal as triggered	charter and use record	narrow service-continuity purpose only
accept architecture and authority boundary	architecture/service authority	security, data, resilience	architecture and authority record	pre-approved degraded/read-only path
accept evaluation conclusion	release authority	independent/domain review as routed	evaluation and challenge conclusion	no waiver of severe-failure rule; restrict exposure
approve release or condition	designated release/risk authority	affected control owners	approval, condition, expiry, manifest	named, expiring break-glass decision
continue, restrict, remediate, retire	service/product authority	incident, customer, risk, legal as triggered	operating/ change/ retirement record	incident commander within delegated limits

Role combinations should be tested for conflicts. Combining product ownership and evidence production may be normal; combining a material proposal, independent challenge, and final approval in one person generally defeats the intended separation unless a documented small-organization alternative and compensating review exists. The exact rule is institution-specific.

The legal-review record in §8.4 and the complaint/claims links in §§19.6 and 23.6 use the same custody model. Retain identifiers for the relevant decision, release, action, notice and remediation, with access to underlying material governed separately. The responsible records and legal/privacy authorities should determine applicable retention, preservation or hold, disclosure and privilege treatment. Do not promise privilege for every record or copy every prompt and customer file into an oversight pack. Chapter 2's evidence categories remain unchanged.

8.8 From Governance to Architecture

Preserve each independent conclusion and each delegated management decision separately. Resolve a withheld authorization through its rightful owner, documenting conflicts and safeguards rather than voting it away.

Notes

1. NIST, AI RMF 1.0 (B01), GOVERN 2.1–2.3. https://airc.nist.gov/airmf-resources/airmf/5-sec-core/. Official source current to 22 September 2026. Voluntary cross-sector framework; Table 8.2 and the decision-rights pattern are author synthesis. Return to text

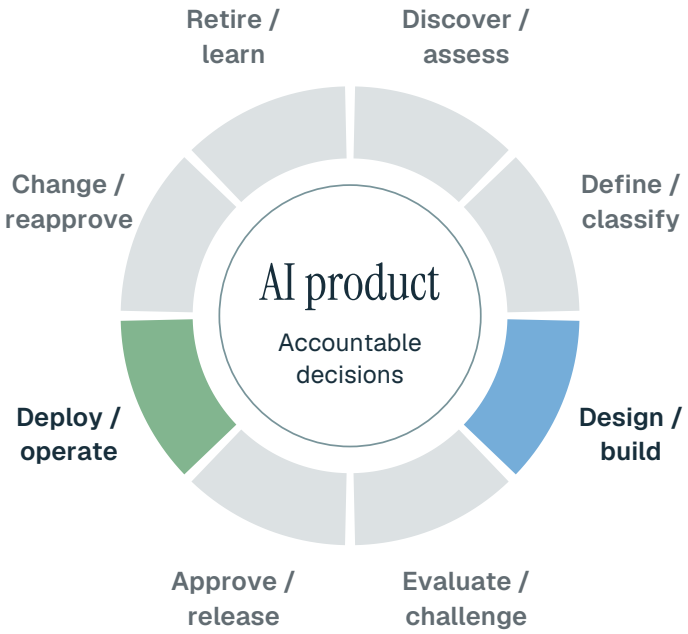
2. European Union consolidated AI Act (B07) and European Commission AI Act Service Desk Articles 26, 27 and 50 (B54), based on 27 July 2026 consolidation. Official presentation is not the authentic legal text; actor, use, territory, exceptions and application dates require qualified legal confirmation. Return to text

Part

III

Architecture and Design

Defines product, control, data and evidence boundaries; data and knowledge lifecycles; model supply chain; prompt/workflow/tool design; and agent authority. The outcome is a design that exposes how policy is enforced, failure is contained and evidence is produced.



Emphasis: Design / build; Deploy / operate.

Other phases remain part of the lifecycle.

Re-enter at the affected decision.

Chapter

9 Enterprise Architecture and Platform Foundations

An AI platform is not an architecture merely because it exposes a model endpoint. The architecture must explain how a defined banking service moves from user or event to output or action, which identities cross each boundary, which data and knowledge are available, and where institutional policy is enforced. It must also show how the bank can observe, interrupt, recover, and reconstruct that service.

9.1 Architecture Begins With the Governed Service

The design unit is therefore the AI product introduced in Chapter 1. A shared platform can provide model access, evaluation utilities, policy enforcement, secrets, logging, and deployment paths. It cannot decide the appropriate purpose, authority, acceptance threshold, or fallback for every product. Those decisions remain use-case specific.

Separate four architectural concerns: the product workflow; identities, policies and release constraints in the control plane; inputs, outputs and tool requests in the data plane; and connected decisions, versions, tests and runtime observations in the evidence plane. These are reasoning boundaries that can map to different vendor topologies.

9.2 Build a Layered View Without Hiding the Path

An architectural view should make the end-to-end path legible. The following layers are common, although a real product may combine or split them.

Table 9.1 — Layer and primary responsibility

Layer	Primary responsibility	Design question
Business and interaction	User, event, case, decision, and fallback	What institutional task is being supported?
Application and orchestration	Workflow, state, routing, validation, and error handling	Which component chooses each next step?
Model and knowledge	Predictive or generative inference, retrieval, ranking, and context	Which dependencies shape behavior?
Tool and integration	Systems of record, rules engines, queues, communication, and transactions	What can be read, prepared, or changed?
Control	Identity, authorization, policy, secrets, approvals, and release configuration	Which controls are enforced outside the model?
Observability and evidence	Telemetry, evaluation, audit events, incidents, and lineage	Can a material decision be reconstructed?
Infrastructure	Compute, network, storage, runtime, and continuity	What resources and failure domains sustain the service?

The point of a layered view is not to assign every box to a different team. It is to stop a model diagram from concealing the workflow that grants access, transforms data, or turns content into an action. Every material path should have an accountable owner and an identified control mechanism.

Platform contracts for the policy-assistant path

The logical request path is authenticated employee → entitlement/source-authority checks → retrieval/context assembly → model/draft → support display or approved non-AI route → event/evidence record. It is a functional path, not an asserted institutional deployment topology.

Table 9.2 — Contract and decision-relevant measure / check

Contract	Decision-relevant measure / check	Failure handoff
Identity and entitlement	Current subject, corpus scope and denied-access cases	Access owner; deny affected retrieval/action
Source/context assembly	Effective source/version, exception coverage and withdrawal propagation	Knowledge owner; narrow topic or route to support
Model/application boundary	Input/output schema, support/refusal behavior and configured resource limits	Engineering/product owner; reject unsafe representation
Evidence access	Resolvable request/release/source/policy records within locally set incident needs	Custodian/service owner; use §2.6 degraded route
Fallback and capacity	Queue age, staffing/admission limits and exercised non-AI route	Service owner; restrict exposure when fallback cannot sustain the task

Set tolerances and ownership against the actual service. A gateway availability measure alone cannot establish these product contracts.

9.3 Shared Platform, Product-Specific Constraint

Shared capabilities reduce repeated engineering only when their contracts are explicit. A platform service might register models, broker provider access, store prompts, run evaluation jobs, enforce tool policies, or collect trace events. It should publish what it guarantees, what evidence it produces, how it fails, and what the consuming product must still do.

Standardization is most valuable for controls whose purpose is common: workload identity, secret management, approved network paths, immutable release references, protected logs, dependency inventories, and emergency disablement. Product teams should not implement these from scratch unless the common capability cannot meet the need. Conversely, a platform-wide “safety score” cannot substitute for product acceptance criteria. The customer consequence and operating context belong to the product.

Fictional Bank applies this distinction to its internal policy-drafting assistant. The platform supplies an approved model gateway, corpus-index service, service identity,

policy decision point, evaluation runner, and trace store. The product team still defines the permitted policy topics, employee population, evidence-display requirement, abstention behavior, and non-AI fallback. The platform attests that a control ran; the product owner decides whether the resulting evidence is sufficient for the use.

9.4 Put Identity and Policy Around Every Material Action

Network position alone should not confer trust. Zero-trust architecture treats access as a decision about a subject, a resource, and the current conditions rather than an assumption created by location.[1] For AI services, the subjects include employees, workloads, agents, automation jobs, administrators, evaluators, and external services.

Use separate identities where permissions or accountability differ. The identity that retrieves policy content need not be able to update customer records. An evaluation job should not inherit production credentials merely because it uses the same model. A tool call should carry a service or delegated identity that the receiving system can authorize; a model-generated request is not itself an authorization.

The policy enforcement point should be outside the probabilistic component for consequential permissions. The model may recommend a tool or populate candidate arguments, but a deterministic service should validate schema, entitlement, purpose, limits, and the state of any required approval. Secrets should be delivered to the authorized workload, not embedded in prompts, code, or reusable agent memory.

One request across the trust boundaries

For PA-DRAFT, the channel authenticates the employee and supplies a scoped subject token. The retrieval service checks entitlement and source authority before assembling context; uncertainty sends the request to policy support. The model gateway receives only that authorized context, with a time/resource budget. A response validator checks source identities and output structure; the employee sees the relevant spans and limitations. The application emits a release/source/event reference, not an unrestricted copy of sensitive context.

PA-PREP adds typed candidate validation. PA-SUBMIT additionally requires exact-action approval and a receiver that rechecks current authority before committing. A timeout before retrieval causes fallback; an ambiguous timeout after submission causes reconciliation, not an invented success. Each transition has a separate identity, control owner and failure response. I would keep the draft-only path free of a transaction credential: a narrower dependency graph is easier to test and contain.

9.5 Design Trust Boundaries and Failure Domains Together

A trust boundary is where assumptions about identity, data, control, or responsibility change. A failure domain is where a fault can propagate. They often overlap but are not identical. An external model provider may be both a trust boundary and a shared failure dependency. A central policy service may be inside the bank's control boundary yet still create a large operational blast radius.

Architecture review should trace at least:

- ingress from user, event, file, API, or retrieved content;
- transitions between bank-managed and external services;
- movement between public, internal, confidential, and restricted information;
- every capability that can write, send, decide, or transact;
- administrative, evaluation, and break-glass paths; and
- logging and evidence paths, including what must not be logged.

Failure analysis should then ask what happens if each dependency is unavailable, slow, stale, compromised, or behaviorally changed. A safe response may be a bounded fallback, a queued manual process, a degraded read-only mode, or a stop. "Fail closed" is not universally appropriate; a critical banking service may need an approved non-AI continuation rather than a complete halt.

9.6 Make Portability a Design Variable

Portability is not the same as instant provider substitution. Model interfaces, tokenization, context length, safety behavior, embedding spaces, tool formats, evaluation results, and commercial terms can differ. A credible portability plan identifies what is standardized and what must be re-evaluated.

Useful seams include provider adapters, model-independent task contracts, versioned prompt and tool schemas, exportable corpus sources, reproducible index creation, portable trace formats, and a release manifest that records provider-specific configuration. These reduce switching friction but do not prove equivalent behavior. A change of provider or model is a new candidate configuration whose evidence must match the approved claim.

Concentration analysis should cover more than the model API. Common cloud regions, identity providers, vector stores, open-source packages, content filters, observability services, and specialist staff can create correlated dependency. Chapter 25 develops

third-party resilience and exit strategy; architecture must expose those dependencies early enough to influence design.

9.7 Architecture Decision and Evidence Set

Before implementation advances, the team should be able to produce a concise set of connected records:

Table 9.3 — Record and minimum content

Record	Minimum content	Decision it supports
Context and workflow view	Users, systems, actions, data classes, fallback	Whether the proposed boundary is intelligible
Trust-boundary view	Identities, external transitions, policy points, secrets	Whether authority is externally enforceable
Dependency and failure map	Critical services, failure modes, recovery route	Whether resilience assumptions are credible
Platform contract	Shared guarantee, evidence, consumer obligation, limitation	Whether reuse actually reduces risk and work
Architecture decisions	Selected option, alternatives, trade-offs, owner, review trigger	Why the design was accepted
Evidence interfaces	Required events, lineage keys, retention owner, privacy constraints	Whether later assurance can reconstruct the service

Completeness is not approval. The records help reviewers challenge the actual product instead of an idealized model diagram. Architecture approval should state conditions and unresolved issues, not merely mark a drawing as reviewed.

9.8 Reference Architecture and Deployment Choices

See Figure 4.3 for put enforcement outside the model.

The logical architecture below makes the control path visible alongside inference. Adapt it to the institution’s topology and responsibility boundaries.

Table 9.4 — Zone and principal components

Zone	Principal components	Required boundary evidence	Failure posture
Interaction	Employee interface, authenticated channel, accessibility and disclosure behavior	user/session identity, request ID, displayed evidence, escalation event	retain the non-AI route and avoid presenting a partial draft as complete
Product service	workflow state, business rules, context builder, output validator	release identity, workflow transition, validation result	queue, restrict, or stop according to the business task
AI services	model gateway, retrieval/ranking, evaluation hooks	model/configuration ID, query/index ID, response metadata	approved substitute only after bounded compatibility evidence
Privileged integration	policy decision point, tool broker, API gateway, systems of record	effective identity, requested action, authorization result, idempotency key	deny by default for unauthorized side effects; preserve read-only fallback where safe
Evidence and operations	trace correlation, protected audit events, metrics, incident and release records	correlation from product/release to runtime event; access and retention decision	surface evidence loss as a control failure rather than silently continuing

In PA-DRAFT, an authenticated employee request retrieves only entitled, approved policy passages, invokes the identified model configuration and returns a validated internal draft with source support. There is no preparation endpoint or ticket credential. PA-PREP is a separately classified variant that may create a candidate outside the system of record. PA-SUBMIT requires its own granted release, authenticated approval and receiver-side authorization of the exact candidate before any ticket commits. Employee confirmation alone grants neither variant.

Deployment options and trade-offs

The same logical boundary can be deployed in different ways. Selection should be driven by data class, latency, resilience, exit feasibility, evidence access, skills, and total control burden—not by a universal preference for cloud or on-premises operation.

Table 9.5 — Option and when it may fit

Option	When it may fit	Principal trade-off	Evidence needed before selection
Managed external AI service	variable demand and rapid capability access where approved data handling is possible	provider change, evidence limits, concentration, residency and exit	contract and data-flow review, provider identity/change process, outage and substitution plan
Bank-managed model on public cloud	stronger runtime/configuration control with elastic infrastructure	bank owns more patching, capacity, security and model operations	landing-zone controls, build provenance, capacity test, shared-responsibility record
Private or on-premises runtime	restricted data, specialized latency, or constrained connectivity where capability and capacity are supportable	hardware lifecycle, specialist staffing, slower change, possible feature gap	capacity and recovery proof, patch route, operations ownership, exit/refresh plan
Hybrid composition	different components require different data or resilience boundaries	more interfaces, identity transitions, observability joins and correlated failure	end-to-end flow, cross-boundary authorization, data-residency decision, reconciliation test

Containers and orchestration platforms can improve repeatability and isolation, but they do not decide tenancy, identity, egress, secrets, or evidence. Infrastructure as code can make infrastructure changes reviewable and reproducible, but only if state, privileges, modules, and emergency paths are governed. These are implementation options, not mandatory technologies.

Integration patterns

Table 9.6 — Pattern and suitable use

Pattern	Suitable use	AI-specific failure to test	Evidence implication
Synchronous API	bounded interactive request with acceptable deadline	timeout, partial response, inconsistent retry	end-to-end request/release correlation and explicit timeout outcome
Queue or work item	reviewable or long-running task	duplicate, stale context, changed approval while queued	idempotency, input snapshot, expiry, worker identity and reconciliation
Event subscription	reaction to a domain event	replay, reordering, schema drift, amplified automation	event identity, consumer version, deduplication and authority limit
Batch	periodic scoring, indexing or control test	incomplete population, late data, silent partial failure	population definition, reconciliation totals and rerun identity
Legacy adapter	core system that cannot expose a modern contract	weak identity, screen semantics, brittle error handling	adapter ownership, transaction confirmation, fallback and retirement plan

Data residency should be recorded as a flow decision: which data and derived records cross which locations, under what purpose and authority, and which provider support or telemetry paths create secondary transfers. “Region selected” is not a complete residency conclusion. **Legal review required:** lawful transfer and localization requirements are jurisdiction-, entity-, data-, and service-specific.

Architecture acceptance test

The review is ready to decide only when it can follow one normal transaction and one failure from ingress to recovery. For each transition, it should identify the effective identity, data class, policy enforcement point, versioned dependency, evidence event, and recovery owner. Open assumptions must be conditions or exceptions with an owner and expiry; they should not disappear inside a diagram.

Closest precedents and originality note

The four-plane arrangement draws on layered enterprise architecture, zero-trust policy enforcement, data lineage and audit/records architecture. It is the book's reasoning model, not a standard, certification or proven topology; map it to the institution's architecture framework.

A second endpoint is only a candidate alternative. Compare model/tool behavior, approved data locations, retention, rate limits, rights, integration, evaluation and support. Two suppliers that share the same cloud identity service or model family can fail together. Qualification includes loss of that shared dependency; unavailable weights or incompatible tools remain explicit exit limitations. An interface abstraction does not establish substitutability.

9.9 Executive and Practitioner Decisions

Use §9.4's timeout and reconciliation paths to identify the receiving identity, policy check, timeout and safe response at each trust transition. The architecture owner must qualify an alternate endpoint's behavior and failure domain before it becomes an approved route.

Notes

1. NIST, Zero Trust Architecture, SP 800-207 (B31). The zero-trust concept supports resource- and identity-centered access decisions; this chapter's AI planes and records are author synthesis. Return to text

Chapter

10 Data Engineering and Data Governance for AI

In an AI product, data is not only an input consumed after software is built. Training records, labels, examples, features, retrieval content, feedback, and evaluation cases can determine what the product learns, knows, or appears able to do. A change in meaning, population, entitlement, or freshness can alter behavior without a change to application code.

10.1 Treat Data as Behavior-Shaping Configuration

Data governance must therefore connect two questions: may the institution use this information for this purpose, and is the information fit to support the claimed behavior? Legal permission does not establish quality; technical quality does not establish permission.

The governed unit should identify data by purpose and lifecycle role. “Customer data” is too broad. A record used to train a model, an attribute supplied for a live decision, a policy document retrieved at runtime, a human rating used for evaluation, and a trace retained for investigation have different owners and risks even if they originate in the same system.

10.2 Separate the Data Domains

The following domains should be distinguishable in design and evidence, whether or not they use different physical stores.

Table 10.1 — Data domain and purpose

Data domain	Purpose	Principal control questions
Training or fitting	Learn model parameters or statistical relationships	Provenance, representativeness, rights, leakage, reproducibility
Tuning and examples	Adapt behavior, prompts, or routing	Purpose compatibility, quality, sensitive content, version
Evaluation	Test claims and boundaries	Independence, coverage, leakage, label quality, protected access
Runtime input	Support a live interaction or decision	Necessity, authorization, validation, minimization, residency
Knowledge corpus	Supply retrievable content	Ownership, authority, freshness, entitlement, withdrawal
Feedback and monitoring	Detect quality and change	Selection bias, consent or notice where applicable, tampering, interpretation
Evidence and incident records	Reconstruct decisions and failures	Integrity, access, retention, redaction, legal hold

Separation reduces accidental reuse. It also makes a transfer explicit: moving production interactions into a tuning set is a new use, not a routine pipeline step. The transfer needs a purpose, an owner, a lawful and policy basis, filtering, quality checks, and a revalidation trigger.

10.3 Establish Provenance and Lineage That Answer Real Questions

Lineage should do more than draw an arrow between databases. For a behavior-shaping dataset, it should identify origin, collection context, transformations, joins, exclusions, labels, time coverage, responsible owner, permitted purposes, and the product versions that used it. Where exact item-level lineage is impractical, the institution should define the aggregate or process evidence that is sufficient and record the limitation.

Provenance is particularly important for externally sourced, synthetic, and user-generated material. “Publicly available” is not a rights conclusion. “Synthetic” does not make the generating source, embedded bias, or sensitive inference irrelevant. A vendor’s assertion should be preserved as vendor evidence, not silently rewritten as the bank’s verified fact.

Fictional Bank's policy assistant uses approved internal policy documents as its knowledge source. Its corpus record identifies the authoritative repository, document owner, effective date, withdrawal state, entitlement label, transformation job, index version, and products consuming that index. When the owner withdraws a policy, the design must define how the document, chunks, embeddings, caches, and citations cease to influence new responses.

10.4 Define Quality Against the Use

Quality is contextual. Completeness for regulatory reporting is different from coverage for an internal knowledge assistant. A data-quality rule should name the field or content, expected property, method, threshold or review condition, owner, and response to failure.

Common dimensions include accuracy, completeness, consistency, timeliness, uniqueness, validity, representativeness, label reliability, and semantic stability. They should not be collapsed into a universal score. A small missingness rate can be unacceptable if it concentrates in a consequential population or removes the exception that controls an outcome.

For learned systems, quality assessment also examines sampling and feedback. Historical data may encode past decisions rather than the outcome the product is intended to improve. A monitored label may arrive late or only for cases that received review. User feedback may measure satisfaction, effort, or disagreement rather than correctness. These limitations belong in the product claim and evaluation design.

10.5 Apply Purpose, Minimization, and Access Throughout the Pipeline

Privacy engineering should start at the data-flow and purpose level. NIST's Privacy Framework provides a voluntary structure for identifying and managing privacy risk, but it does not decide a bank's legal obligations or permissible use.[1] Jurisdictional rules on banking secrecy, data protection, localization, automated decision-making, retention, and cross-border transfer must be assessed for the actual entities, data, users, and processing.

Minimization is not limited to deleting columns before training. It includes limiting what a user can paste, what the application retrieves, what is sent to a provider, what appears in a prompt or trace, what an evaluator can see, and what an operator can search. Tokenization, masking, aggregation, or pseudonymization may reduce exposure, but their adequacy depends on re-identification risk and the task.

Access should be enforced at each data use, not inherited indefinitely from the person who initiated a workflow. Retrieval should honor the effective user's and product's entitlements. Batch jobs and model-training pipelines require workload identities, reviewed privileges, and protected secrets. Administrative access to vector stores, logs, labels, and evaluation records can expose information even when the end-user path is constrained.

10.6 Use Data Contracts for Meaning and Change

A data contract is a versioned agreement about a data product's meaning and operational conditions. For AI, it can include schema, units, semantics, permitted purpose, source, freshness, quality rules, sensitive classifications, entitlement behavior, change notice, owner, and evidence produced.

The contract should distinguish breaking change from material behavioral change. A field may retain its schema while its business meaning or population changes. A policy repository can preserve document format while changing precedence rules. Both can invalidate evaluation evidence.

Producers should publish changes and consumers should register dependencies. The product team then assesses whether the change falls within the approved change envelope. Where the producer cannot provide reliable notice—such as an external public source—the product must compensate with monitoring, validation, or a stricter boundary.

10.7 Prevent Leakage and Contamination

Evaluation leakage occurs when test material or its answers influence development, tuning, or selection. It can create convincing results that do not generalize. Access controls, dataset partitions, lineage, and evaluation governance should make leakage harder and visible. For generative systems, contamination may be difficult to prove because foundation-model training data is not fully known; claims should acknowledge that uncertainty.

Sensitive information can also leak through features, embeddings, prompts, logs, caches, model outputs, or memorized examples. Testing should trace the routes relevant to the actual architecture. A rule that removes a field from a user interface does not prove it is absent from logs or tool arguments.

Adversaries may poison training, feedback, or knowledge sources. Controls include source authorization, integrity verification, quarantine, anomaly detection, maker-checker approval for consequential corpus changes, and reproducible rebuilds. Chapter 17 tests hostile cases; Chapter 18 develops the threat model.

Predictive partition and contamination record FRAUD-DATA-01

Synthetic primary temporal design: January–June trains, July–September validates, and October–December is untouched testing of the declared returning-entity population. Use unique event IDs, remove duplicate events and identify accounts/customers plus connected-entity groups. Entities may span those chronological partitions because returning-entity performance is the claim; only features available at each event time are allowed. Fit preprocessing on training alone. For a separate unseen-entity claim, hold out groups first appearing in October–December and exclude every related group member from training/validation. Report that test separately rather than pooling its results with the returning-entity test. Record exclusions and any purge needed for overlapping event/feature windows.

For this December-ending toy cohort, labels use a 30-day post-event observation window and an as-of date of 31 January in the following year. That date allows the last December event its full window. Pending, censored, uninvestigated and otherwise unknown outcomes remain separate, not negatives. Investigator dispositions are not assumed to be unbiased ground truth. A validator must assess selection and the actual represented population; neither the temporal split nor a random-split score resolves those label limitations.

Policy knowledge legitimately available at inference belongs in the authorized corpus. That is not, by itself, test leakage. Exposing held-out questions, answer labels, grader rubrics or evaluation feedback to tuning is a different path. Record retrieval access, model-training exposure and test-driven adaptation separately; unknown foundation-model training exposure remains a limitation.

10.8 Data Decision Record

Before a release decision, the evidence bundle should connect:

- data purpose and owner;
- authoritative sources and lineage;
- sensitive classifications and permitted flows;
- transformation and quality evidence;
- training, tuning, evaluation, runtime, corpus, feedback, and trace separation;
- access and entitlement behavior;
- known gaps, bias, and coverage limits;
- change and withdrawal triggers; and
- retention and deletion responsibilities.

Keep distributed records linked and interpretable: catalog to product use, access to purpose, and quality evidence to decision. A central document cannot substitute for those relationships.

Filled policy-assistant data-use outline

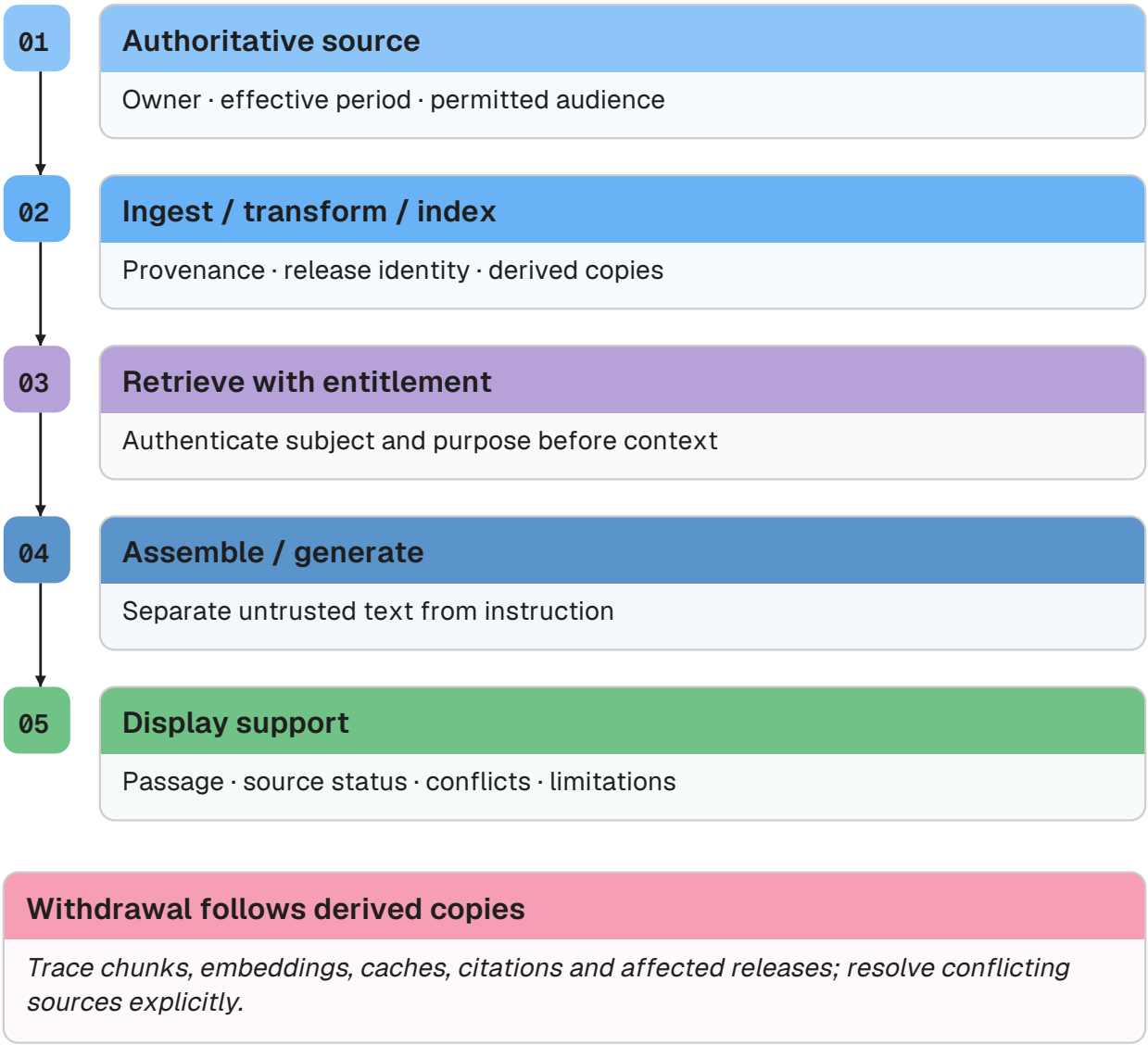
Table 10.2 — Field and illustrative bounded record

Field	Illustrative bounded record	Evidence / unresolved decision
Purpose and authority	Approved internal-policy explanation for an entitled employee; no customer-record decision input	A2 use and information-owner authority link
Sources and lineage	Policy-owner-controlled corpus, effective version, document/section IDs and index transformation	Source authority, withdrawal and provenance references
Sensitive flow	Employee question and permitted policy context; pasted sensitive material handled separately	Classification, minimization, access and approved trace-retention decisions
Evaluation separation	Held-out exception/boundary cases separated from prompt tuning and development cases	Leakage review, lawful access, corpus/time-split basis and excluded cases
Quality and failure	Source currency, exception coverage, entitlement and support assessed separately	Layer-specific findings; severe failure route; no invented pass rate
Change and closure	New source, permission, population or provider reopens affected claims	Owner, changed manifest, regression, decision and withdrawal/recovery evidence

This is a filled field outline, not an executed assessment. Populate actual identifiers, results and institutional legal decisions before using it to authorize a service. See Figure 10.1.

10.9 Data Risks for Predictive and Generative Products

Figure 10.1 — Entitlement must precede context assembly



A source becomes context only after provenance and entitlement checks. Withdrawal must be traced through derived material and affected releases.

The data problem differs by claim. A generative assistant may fail because its corpus is stale, entitlement metadata lags, or a prompt contains information that should not cross a provider boundary. A predictive decision-support product may fail because labels encode prior decisions rather than the intended outcome, outcomes arrive late, rejected cases have no observed label, or a variable functions as an inappropriate proxy. The same data-governance vocabulary should therefore lead to different tests.

Table 10.3 — Data issue and predictive-product question

Data issue	Predictive-product question	Generative or retrieval-product question	Evidence example
Selection and coverage	Who is missing from development and outcome data, including rejected or diverted cases?	Which topics, languages, document types, and exception cases are absent?	cohort map, known exclusions, coverage test
Label validity	Does the label measure the business outcome or reproduce a prior operational decision?	Does the reference answer represent current policy and acceptable communication?	label-definition record, adjudication protocol, source-owner approval
Proxy and sensitivity	Could a feature stand in for a protected or otherwise sensitive characteristic?	Can context reveal sensitive status or invite differential response?	feature review, privacy analysis, subgroup evaluation
Time and leakage	Was future information or post-decision data available during fitting or evaluation?	Was evaluation content copied into prompts, examples, or the corpus?	temporal split, lineage trace, contamination check
Delayed outcomes	How will calibration and performance be assessed before mature labels arrive?	How will complaints, correction and unsupported-answer evidence arrive?	monitoring plan with lag, leading indicators and later backtest
Feedback	Does operational selection change the future training population?	Do user ratings reward fluency rather than correctness or encourage poisoning?	feedback eligibility, provenance and independent sampling

Reject inference, proxy analysis, fairness assessment, and lawful data use require product- and jurisdiction-specific specialists. This book does not prescribe a statistical correction or infer that one technique makes a credit or other decision lawful.

Data contract and change example

Fictional Bank's fraud/AML alert-triage thread consumes transaction events, customer-risk attributes, alert-rule output, and investigator disposition. The data contract records semantic owner, permitted purpose, event-time and arrival-time fields, null and late-data behavior, schema version, sensitivity, retention owner, and change-notification route. It also records that investigator disposition is an operational decision—not automatically a ground-truth label—and that confirmed outcomes may arrive later or remain unavailable.

A new upstream code is therefore not accepted merely because the schema parser succeeds. The product owner asks whether its meaning changes a feature, routing rule, cohort, or evaluation population. A mapping change can be a behavioral change even with no model change. The release record links the contract version to the feature transformation and the evaluation that covers the affected cases.

Cross-border flow decision record

A global bank should avoid the phrase "data is in the cloud" as a location analysis. A bounded record should identify: originating entity and location; data subjects or business records; controller/processor or comparable roles where applicable; purpose; destination and subprocessor path; support access; storage, transit and derived telemetry; approved safeguards; deletion/return; incident route; and legal conclusion owner.

Illustrative jurisdictional example, not legal advice. An intra-group transfer of personal data from an EU establishment to a service outside the European Economic Area can require a GDPR transfer analysis in addition to ordinary security controls. The applicable mechanism, supplementary measures, roles and documentation depend on the facts. The architecture and data records should expose the flow; qualified counsel determines the lawful basis and transfer requirements.[2]

Minimum data acceptance package

Before a release gate, the team should be able to show a source and purpose inventory, lineage to each material transformation, quality rules tied to product claims, evaluation-set separation, access and residency decisions, known population or topic gaps, change triggers, and an owner for withdrawal or correction. Where a necessary label, permission, or population cannot be established, that is an **evidence gap** requiring scope reduction, additional work, or an explicit stop—not a blank cell to be filled after deployment.

10.10 Executive and Practitioner Decisions

The data owner should approve decision-time features, source rights and meaningful holdouts. The validator should challenge label maturity, selection and contamination before treating a result as evidence for the target population.

Notes

1. NIST, Privacy Framework 1.0 (B32). It is a voluntary cross-sector framework, not a legal basis or banking rule. The chapter's AI data-domain model and data-contract fields are author synthesis. Return to text

2. European Union, General Data Protection Regulation (B47). The example identifies a transfer-analysis question; qualified counsel must determine roles, lawful basis, transfer mechanism, safeguards and current applicability. Return to text

Chapter

11

Knowledge Engineering and Retrieval-Augmented Generation

Retrieval-augmented generation connects a generative model to information selected at runtime. It can improve relevance or currency, but it does not make the response correct, authorized, or complete. The system can retrieve the wrong passage, miss a controlling exception, combine incompatible sources, expose restricted content, or cite evidence that does not support the generated proposition.

11.1 Retrieval Changes the Evidence Problem

The original RAG research demonstrated a method for combining parametric and non-parametric memory for knowledge-intensive tasks; it did not define an enterprise banking control system.[1] In a bank, the architecture must govern the corpus and retrieval path as behavior-shaping dependencies.

11.2 Govern a Knowledge Lifecycle, Not Just an Index

The lifecycle begins before chunking. A source needs an owner, authority level, permitted audience, effective period, and withdrawal process. Ingestion then extracts content and metadata; transformation divides, normalizes, or enriches it; indexing represents it for search; retrieval selects candidates; ranking orders them; context assembly chooses what the model sees; generation produces an output; and citation or evidence display helps a person inspect the result.

Table 11.1 — Stage and material failure

Stage	Material failure	Control question
Source approval	Unofficial or superseded content enters the corpus	Who can designate an authoritative source?
Ingestion	Content or metadata is lost or altered	Can the transformation be reproduced and reconciled?
Chunking	Controlling context is separated from a rule	Does evaluation include exception-rich documents?
Indexing	Embedding or metadata changes silently alter retrieval	Is the index a versioned release dependency?
Retrieval and ranking	Relevant or entitled content is omitted or displaced	Which claims and populations does retrieval evaluation cover?
Context assembly	Untrusted instructions reach the model as authority	Are content and instructions separated and labeled?
Generation	The answer adds unsupported propositions	Is support assessed at proposition level where material?
Citation display	A source looks authoritative but does not entail the claim	Can a reviewer inspect the relevant passage and status?

This chain creates multiple control and evaluation points. Improving one stage cannot be assumed to repair the others.

11.3 Preserve Authority and Precedence

A corpus is not a bag of equally valid text. A bank may have policies, procedures, product terms, legal interpretations, notices, training material, historic versions, and local instructions. The knowledge model should capture authority, jurisdiction, product, audience, effective date, and precedence where these affect use.

When sources conflict, the application should not invent a reconciliation. The design can prefer an authoritative source, expose the conflict, or route the question to an owner. The choice is product specific. If precedence is not encoded reliably, the product claim should be narrower.

Withdrawal is as important as addition. Deleting a source file may leave derived chunks, embeddings, replicas, caches, evaluation cases, or trace excerpts. The team should define how a withdrawal propagates and how the evidence bundle records the affected index and release versions.

11.4 Enforce Entitlement at Retrieval Time

Entitlement-aware retrieval applies access decisions to the content returned for the current subject and purpose. Filtering only after generation is too late because restricted information may already have influenced the response or trace.

The index needs trustworthy access metadata, and the retrieval service must combine it with authenticated identity and product policy. Where document-level access is not granular enough, the corpus design may need separate indexes or finer units. Administrative and evaluation access should be governed separately; a tester's broad corpus access should not become the production user's effective entitlement.

Fictional Bank's assistant uses the employee's identity and the product's approved policy scope. A user entitled to view retail-deposit procedures cannot retrieve an internal investigation manual merely because semantic similarity ranks it highly. The model sees only the authorized result set. A deterministic policy service, not the model, enforces that boundary.

Permission review before enablement

Before enabling a corpus or connector, inspect inherited user, group and workload permissions for stale groups, overbroad sharing and mismatches with intended use. Repair gaps or record a bounded, expiring exception. Bind owner approval and permitted/denied tests to corpus, permission policy and release. Retrieval-time checks must still reflect changes and revocation. This workflow draws on reviewed permissions and least privilege in NIST CSF 2.0 and Zero Trust Architecture (B53/B31).

Table 11.2 — Illustrative policy-assistant condition and required check

Illustrative policy-assistant condition	Required check	Disposition and evidence
Employee group inherited broader repository access	Review topic/source purpose and affected sharing paths	Information owner records corrected or explicitly bounded access before enablement
Restricted investigation source appears in connector scope	Use a negative-access case at retrieval and answer layers	Reject disclosure; record filter/application evidence and escalation
User entitlement revoked after corpus build	Retest query and cache routes under current identity	Deny current access; invalidate affected cached/context paths
Source withdrawn while recovery snapshot exists	Check authoritative effective/withdrawal state	Exclude withdrawn source and record propagation completion

These are test requirements and illustrative dispositions, not reported test passes.

11.5 Separate Retrieval Quality From Answer Quality

Retrieval evaluation asks whether the system finds the material needed for the task. It may consider recall, ranking, coverage, metadata filtering, and behavior when no adequate source exists. Generation evaluation asks whether the response accurately and completely uses the available support, handles conflict, and avoids unsupported additions. Workflow evaluation asks whether a user can judge and act on the result.

These layers can fail independently. A correct passage may be retrieved but ignored. A fluent answer may accurately summarize an incomplete passage. A well-grounded response may still be unsuitable for the customer's circumstances. The evidence should identify which claim each test supports.

"Contains citations" is a weak acceptance criterion. A stronger design defines what propositions require support, what counts as an authoritative source, whether the displayed passage entails the proposition, how omissions are assessed, and what happens when the source set is insufficient. The appropriate granularity depends on consequence; this book prescribes no universal grounding score.

Synthetic query EX-01

The question requires two relevant source units: main rule R and exception E. PA-0.1's top three results contain R plus two irrelevant units, so recall@3 is 1/2 = 50% and precision@3 is 1/3. Both denominators are defined against this query's adjudicated source-unit set. The response correctly cites R but omits E; citation support is not answer completeness. PA-0.3 retrieves both R and E and passes this particular exception check. Entitlement, effective date, proposition support and employee challenge remain separate tests; a retrieval score cannot stand in for them.

11.6 Defend Against Poisoning and Indirect Injection

Retrieved content is input, not instruction authority. A malicious or compromised document may contain text that tells the model to ignore system rules, reveal data, or invoke a tool. The application should separate trusted instructions from untrusted content, constrain tool authority outside the model, and test whether retrieved instructions can alter policy or access.

Source approval, integrity checks, restricted ingestion paths, anomaly review, and provenance reduce poisoning risk. They do not eliminate manipulation by a legitimately editable source. High-consequence corpora may require maker-checker changes, comparison against an authoritative original, or quarantine before index release.

OWASP's community guidance usefully catalogs prompt-injection and related risks, but it is not a regulatory standard and does not prove a control adequate for a bank.[2] Threat scenarios must follow the actual product, data, and tool path.

11.7 Version the Retrieval Product

The release identity should include at least the source set or corpus snapshot, transformation code and configuration, embedding model, index build, retrieval and ranking configuration, context-assembly rules, model configuration, prompts, and relevant entitlement policy. Not every field must be stored in one system, but the approved combination must be reconstructable.

An index rebuild can be a material change even when it uses the same documents. A new embedding model or chunking rule may change which passages are retrieved. Conversely, a document correction may fit within an approved change envelope if its authority, testing, and propagation are controlled. The team should define these cases before routine updates begin.

The release manifest pins the approved retrieval baseline and refresh policy; a request records the effective source, index and permission versions actually used. A permitted refresh changes that effective set without rewriting the baseline approval. Withdrawal is

an event with an owner and affected versions. New source classes, changed entitlements, ranking behavior outside the envelope or an unresolved withdrawal path trigger reapproval. This representation is shared with the operating identity in §21.7.

11.8 Worked Decision: A Missing Exception

Fictional Bank evaluates a question whose controlling policy contains a general rule and an exception in a separate section. The retrieval service returns only the general rule. The generated draft is faithful to the retrieved passage but materially incomplete.

The defect should not be labeled simply “the model hallucinated.” Investigation follows the evidence chain: Was the exception in the approved source? Was it ingested and indexed? Did metadata or chunking hide it? Did ranking exclude it? Did context assembly truncate it? Did the model ignore it? Did the interface make the limitation visible? Each cause belongs to a different owner and remediation path.

The release decision also changes. The team may improve retrieval, narrow the supported topics, require a structured exception check, or route that class of question to the non-AI process. A single better prompt is only one hypothesis.

11.9 Knowledge Structures Beyond Vector Retrieval

Retrieval-augmented generation is one knowledge pattern, not the whole of knowledge engineering. A bank may also use controlled taxonomies, entity and relationship models, rules, knowledge graphs, document hierarchies, and authoritative reference-data services. These structures can resolve identity, precedence, applicability, and exceptions that similarity search alone cannot represent reliably.

For example, a policy answer may depend on entity, product, customer type, geography, effective date, channel, and exception authority. Encoding those attributes as governed metadata or explicit rules can narrow the candidate set before semantic ranking. The model then summarizes within an already bounded context. This does not eliminate error; it makes the basis and failure path more inspectable.

Table 11.3 — Knowledge technique and useful for

Knowledge technique	Useful for	Control question
taxonomy and controlled vocabulary	stable classification and findability	Who owns terms, aliases and retirement?
metadata filters	entity, jurisdiction, date and entitlement scope	Are filters enforced before content reaches the model?
rules or decision tables	explicit precedence and deterministic exclusions	Is the rule version linked to the response?
entity/relationship graph	connected obligations, products and dependencies	How are identity and relationship assertions validated?
semantic retrieval	language variation and unstructured discovery	Does evaluation separate recall, ranking and answer support?

Permission synchronization is part of correctness

Enforcing entitlement at query time is insufficient if the index has stale permissions. The product should define how source-system grants and revocations propagate, which system is authoritative, how delays are measured, and what happens during uncertainty. Revocation normally deserves the safer path: if a sensitive source is withdrawn or a user's access is removed, the product should not continue serving a cached copy until the next convenient rebuild.

Three patterns are common. First, the retrieval service can call an authoritative entitlement service for each query. This reduces copied policy but creates a runtime dependency. Second, the index can carry synchronized access metadata; this improves performance but needs bounded synchronization lag, reconciliation and fail-safe behavior. Third, separate indexes can represent stable access domains; this reduces filter complexity but increases duplication and lifecycle work. The selection is a risk and architecture decision.

Fictional Bank records a permission epoch to identify the cache/index version. An epoch helps invalidate derived content; it does not establish current authorization. Protected retrieval checks the authoritative permission service or a locally approved consistency protocol, and the receiving action service revalidates current authority. During partitions, revocation uncertainty or unavailable freshness evidence, deny the affected protected path and use the approved fallback. A locally allowed synchronization interval must not silently authorize use after a known revocation.

Synthetic in-flight revocation case PA-REV-01

PA-REV-01 pauses a request after its initial entitlement check and before protected context is delivered. The source owner revokes access and advances the authoritative permission state. When the paused request resumes, fresh context delivery is denied; cached authorization alone cannot release the withdrawn content. A separately prepared action is also rejected by the receiver when its grant is no longer valid. The constructed result is denial on both protected paths and routing to the approved fallback. Record the permission versions, pause/revocation/resume times, denial events and owner.

This is a synthetic teaching result, not a completed system test. Security review must assess the authoritative-state and consistency assumptions. The test does not undo content already lawfully disclosed; that situation requires exposure assessment and the applicable retention/remedy decision.

Proposition-level support record

A fluent paragraph can contain several factual propositions, only some supported by a cited passage. For material responses, evaluation should sample at the proposition level: identify the claim, locate the supporting passage, assess whether it entails the claim under the relevant scope and date, and record unsupported additions. Automated support scoring can prioritize review, but it does not establish truth or legal applicability.

Table 11.4 — Field and example for the policy assistant

Field	Example for the policy assistant
response proposition	“Employees in the named unit must obtain approval before the stated action.”
source identity	policy document, version and effective date
supporting span	section and paragraph reference, not the whole document
applicability attributes	entity, unit, role, product, jurisdiction and date
support judgment	supported / contradicted / insufficient / source unavailable
reviewer and method	evaluation rule, human adjudicator where required

This record belongs in evaluation samples, not every low-consequence interaction. Runtime design should nevertheless retain enough identity to reconstruct which sources were offered to the model, subject to privacy and records decisions.

Withdrawal and rebuild drill

Knowledge operations should rehearse removal. Select a source, withdraw it, propagate the change, rebuild or invalidate affected index material, and verify that subsequent queries neither retrieve the content nor rely on cached derived output. Then identify releases, evaluations and incidents that referenced the source. This exercise tests the evidence plane as well as retrieval plumbing.

Withdrawal completion criterion

Close the withdrawal drill only after source, index, retrieval, cache and downstream context paths reflect the authorized withdrawal decision. Record affected versions, propagation gaps, owner, denial tests and affected-session query evidence. A recovered index or stale snapshot does not reinstate source authority. The pre-enablement and revoked-permission cases in §11.4 are part of the same knowledge-control argument.

11.10 Executive and Practitioner Decisions

Ask the knowledge owner to demonstrate retrieval of the rule and material exception, then withdrawal and revoked-access denial. Keep source authority, answer completeness and employee judgment as separate claims.

Notes

1. Lewis et al., “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks” (B20). The enterprise lifecycle and control pattern in this chapter is author synthesis. Return to text

2. OWASP, Top 10 for Large Language Model Applications / GenAI Security Project (B39). Community guidance; not a bank-specific standard or evidence of control effectiveness. Return to text

Chapter

12

Model Selection, Sourcing, and the Model Supply Chain

A model is suitable only in relation to a task, architecture, operating context, and control boundary. A general benchmark can reveal capability, but it cannot decide whether the model is appropriate for a bank's approved use. Selection must include the complete product claim: required behavior, prohibited behavior, information boundary, latency and capacity needs, deployment model, evidence needs, and consequence of failure.

12.1 Select for a Product Claim, Not a Leaderboard

The first decision is not necessarily which model to buy. It is whether the use requires a learned component, whether an existing rules or search solution is adequate, and whether the bank can operate the proposed dependency. A smaller or narrower model may be preferable if it makes the task easier to evaluate and control. A more capable model may be justified where it materially reduces workflow failure. Neither choice is universally safer.

12.2 Compare Build, Buy, Adapt, and Combine

Table 12.1 — Strategy and potential advantage

Strategy	Potential advantage	Principal obligation
Build or train	Greater control over objective, data, and release	Data rights, specialist capability, validation, infrastructure, maintenance
Buy as a service	Rapid access and managed infrastructure	Provider evidence, data handling, change notice, concentration, continuity
Deploy a sourced model	Greater runtime control and portability	Package provenance, security, licenses, capacity, patching, evaluation
Adapt or fine-tune	Task-specific behavior or efficiency	Training lineage, contamination controls, new behavior evaluation
Combine or route	Match tasks to different capabilities and costs	Routing evidence, multiple dependency states, consistent policy enforcement

The categories overlap. A bank may source a foundation model, adapt it, and access another through a service. The model-supply-chain record should follow the actual dependency path rather than force a single label.

Build, Buy or Partner at initiative level

The strategies above describe model/dependency choices. At initiative level, compare the complete product and operating arrangement using the same purpose, hard constraints and evidence needs. A partner may also supply a model or managed service; contractual labels should not hide the actual division of delivery, control and support.

Table 12.2 — Route and contribution and delivery pattern

Route	Contribution and delivery pattern	Accountability, control and evidence	Operating dependency and exit
Build	Institution leads product/workflow engineering and owns the principal delivery capability; sourced components may remain	Identify internal data/knowledge, application, evaluation, security, decision and service owners; preserve component rights/provenance and independent challenge	Fund skills, maintenance, incidents and lifecycle work; assess dependency replacement and service transition
Buy	Institution obtains a product or managed capability and performs the required integration/ configuration	Retain institutional use/release/service decisions; assess actual data paths, permissions, supplier evidence, terms and control integration	Record change/version constraints, support, evidence access, concentration, continuity, portability and termination capability
Partner	Institution and another party contribute substantial co-development, shared delivery or an ongoing joint capability	Record each contribution, product/technical decision rights, data/IP responsibilities, control ownership, verification, acceptance and dispute/escalation handoffs	Specify ongoing support, maintenance and incident responsibilities, funding/change authority, dependency limits and practical transition/exit arrangements

Sourcing comparison and partnership handoff record

For every material route, preserve the candidate arrangement and parties; scope and intended use; strategic rationale and alternatives; institutional and supplier/partner contributions; full build/run/control/exit cost assumptions; delivery milestones and time-to-value; internal skills and sustainable support; architecture/data/model/tool boundaries; evidence access; concentration and portability; unresolved facts; selection rationale; decision owner; and reconsideration trigger. Classify statements as observed evidence, institutional estimate, provider/partner assertion or open question rather than merging them into verified fact.

A partnership record additionally assigns responsibility for:

- **Decision rights:** roadmap, design, data access, change, acceptance and incident decisions; institutional approval and independent challenge remain identifiable.
- **Data and IP:** authorized use, access, contribution, licensing and ownership arrangements; rights in outputs, improvements and reusable assets require scoped legal review.
- **Delivery and verification:** interfaces, milestones, acceptance evidence, testing and remediation; identify who verifies each material claim.
- **Operation and support:** service ownership, maintenance, monitoring, security, capacity, incident assistance and evidence retrieval.
- **Dependency and exit:** retained assets/rights, export or rebuild limits, skills transfer, replacement qualification, transition assistance, records and residual obligations.

These are author-developed comparison fields, not globally mandatory clauses or a finding that any proposed arrangement is permissible. Use §8.4 for scoped legal review and §§25.4–25.5 for rights versus demonstrated continuity/exit capability. Record a selection as a bounded sourcing decision; purchase, partnership or technical compatibility does not grant product operating approval.

Bounded adaptation record

This chapter governs sourcing dependencies; it is not a model-training manual. For a synthetic adaptation candidate, record the permitted data snapshot, task, base-model identity/license, adapter or tuning settings, code/environment, random seeds where meaningful, experiment IDs, held-out evaluation, safety/security limitations and release boundary. Preserve failed experiments as well as the selected candidate. An open-weight option can improve some exit rights while increasing hosting, patching and supply-chain work; I would not call it safer merely because the bank can download it.

12.3 Define Selection Criteria Before Testing Candidates

Selection criteria should derive from the intended-use specification. Common dimensions include task quality, behavior under ambiguity, refusal and escalation, supported languages, context and input limits, structured-output reliability, tool-use behavior, security architecture, privacy options, deployment constraints, latency, throughput, cost, accessibility, portability, provider transparency, change policy, and evidence access.

Weights should reflect consequence rather than convenience. If the product cannot send data outside a defined environment, a strong task score from an incompatible service is not a near miss; it is outside the option set. If a customer-facing service requires a supported language, average performance across other languages cannot compensate.

Evaluation should compare candidates on controlled product cases, not on memory of demonstrations. Results need model identity, configuration, prompt or feature setup, test population, repetitions where relevant, environment, date, and known limitations. A candidate can advance with open issues only when the decision record names their treatment.

12.4 Treat Model Identity as a Controlled Dependency

A commercial name is not a release identity. The bank needs the most specific identifier available: provider, model family, version or snapshot, deployment or endpoint, adaptation, relevant configuration, and date. If a provider uses a moving alias, the product must decide how change will be detected and what evidence is available.

For downloaded models, identity also includes source repository, commit or digest, weights, configuration, tokenizer, licenses, dependencies, and integrity verification. For adapted models, preserve the base identity, training process, data or data references, parameters, evaluation, and resulting artifact digest.

The release manifest should distinguish facts verified by the bank from provider statements and unknowns. “Provider says training data excludes customer inputs” is a contractual or documentary assertion until the bank has evidence supporting a stronger conclusion.

12.5 Secure the Model Supply Chain

The model supply chain includes repositories, package managers, containers, build systems, adapters, runtimes, evaluation libraries, model files, tokenizers, and external APIs. A compromised auxiliary package can be as consequential as a compromised model.

NIST's SSDF AI community profile extends secure-development considerations to generative AI and dual-use foundation-model development, but it does not supply a complete bank product control framework.[1] A bank should integrate model artifacts into its existing software-supply-chain practices: approved sources, integrity checks, dependency inventories, vulnerability and malicious-code analysis appropriate to the artifact, protected build and release paths, signed or otherwise verifiable manifests, and controlled promotion.

For open-source components, license obligations and use restrictions require qualified review. Popularity is not assurance. The bank should assess maintainer activity, release and security practices, provenance, transitive dependencies, and the feasibility of patching or replacing the component. Unknown training data and uncertain rights remain evidence gaps rather than facts to fill with inference.

12.6 Demand Decision-Relevant Provider Evidence

Provider due diligence should be tied to the service. Relevant questions may include:

- how customer inputs and outputs are processed, retained, reviewed, or reused;
- which locations, subprocessors, and external services are involved;
- how model and safety changes are communicated;
- what version stability or rollback options exist;
- what security, resilience, and incident evidence can be supplied;
- how abuse, capacity, and account compromise are handled;
- what logs, metrics, and investigation support the bank can obtain;
- what exit, export, deletion, and continuity arrangements exist; and
- which contractual rights support audit, notification, remediation, and termination.

Answers should be classified as contract, attestation, provider documentation, observed test, bank verification, or unresolved gap. A questionnaire marked complete does not establish operating effectiveness.

Use the scoped legal-review method in §8.4 and the rights-to-capability review in §25.4 when assessing these answers. Connect availability, evidence access, export/rebuild rights and transition assistance to the continuity and exit options in §25.5. Retain the source and status of each answer; a contractual promise or complete questionnaire is not qualification of a substitute model.

12.7 Re-Evaluate When the Dependency Changes

Model changes can affect capability, refusals, format adherence, latency, cost, and previously accepted failure modes. A change policy should distinguish a pinned version, bank-authorized upgrade, emergency provider change, and provider-controlled update. Each route needs monitoring and a decision rule.

Regression scope follows the affected claim. A tokenizer update may change length and truncation; a safety change may affect refusal; a new base model may alter every behavioral claim. Provider release notes help scope analysis but do not replace product evaluation.

Where the provider cannot guarantee notice, the architecture should detect identity or behavior change where feasible and restrict the product claim accordingly. High-consequence uses may require stronger version control or an alternative design.

Where a dependency change affects legal applicability, data use, license terms, evidence access or a continuity/exit option, refresh the affected review and qualification records. §8.4 describes the legal disposition; §§25.4–25.5 connect terms and known portability constraints to an evaluated transition. Neither API compatibility nor an earlier approval transfers evidence to a changed product claim.

12.8 Worked Selection at Fictional Bank

Fictional Bank compares three configurations for the policy assistant: a managed model service, a bank-operated sourced model, and a routed design using a smaller model for classification plus a generative model for drafts. The team does not award a single composite score.

First it applies hard constraints: permitted data path, identity integration, version evidence, and ability to prevent external sending. It then evaluates supported policy tasks, missing-evidence behavior, structured citations, latency, cost boundary, and fallback. The routed design performs well on ordinary cases but creates an additional classification failure path. The bank records that trade-off instead of calling the design categorically better.

The selection record recommends a candidate for bounded evaluation, not production approval. Provider due diligence, architecture review, security testing, and complete workflow evaluation remain separate gates.

Separate selection record PA-SRC-02

This synthetic comparison is separate from the preceding three deployment options. Here A is a managed model service, B a bank-operated sourced model, and C governed deterministic policy search. A meets the stated location/access conditions but its export cooperation is untested. B lacks the required data-use right and is excluded, rather than losing scoring points. C offers less drafting convenience. Keep A's exit capability unknown until exercised, and compare permissible A/C on accepted-case effort, quality and the next evidence needed. C is not an alias for the preceding routed-model option.

12.9 Supply-Chain Evidence and Provider Change

A model bill of materials or equivalent dependency inventory can help, but the name of a document matters less than its ability to answer operational questions. The record should identify the model or service, provider, version or immutable reference where available, acquisition path, license and use constraints, execution location, data-handling boundary, safety or filtering configuration, known limitations, update policy, vulnerability/incident contact, subdependencies available to the bank, and exit route.

Software supply-chain frameworks such as SLSA and in-toto provide useful concepts for build provenance and attestations. They do not by themselves prove model quality, training-data rights, or banking suitability. A bank may use their concepts for code, containers and packaged models while recording AI-specific gaps separately. These are illustrative provenance options, not mandatory standards.

Evidence request by decision

Table 12.3 — Decision and provider or internal evidence sought

Decision	Provider or internal evidence sought	Residual limitation to record
permit evaluation	service identity, intended use, interface, data path, basic security and legal terms	information may be provider-asserted and pre-production
select a candidate	comparative task evidence, version behavior, known limits, capacity and cost assumptions	benchmark transfer to the bank's use is uncertain
approve release	stable release reference, bank evaluation, contract/change notice, incident and continuity route	opaque training or provider control evidence may remain
continue operation	observed behavior, notices, outages, security events and change reconciliation	silent or gradual upstream behavior change may not be fully visible
substitute or exit	export/deletion evidence, compatible interface, replacement evaluation, cutover and fallback	behavior equivalence is not assumed

Procurement should avoid generic requests for "all training data" or "full model transparency" when the provider cannot lawfully or practically supply them. The product team should translate its decision into evidence questions: which facts are essential, which can be independently tested, which limitations can be constrained by architecture, and which gaps make the use unacceptable. See Figure 12.1.

Figure 12.1 — A manifest for the model-supply decision

Display index	Literal source field
Identity / acquisition (proposed)	
01	model or service
02	provider
03	version or immutable reference where available
04	acquisition path
05	license and use constraints
Execution boundary (proposed)	
06	execution location
07	data-handling boundary
08	safety or filtering configuration
09	known limitations
Change / continuity (proposed)	
10	update policy
11	vulnerability/incident contact
12	subdependencies available to the bank
13	exit route

Thirteen manifest fields organize the model-supply decision. Field groups aid navigation; no provider values are assumed.

Provider-driven change scenario

Fictional Bank receives notice that the model behind its policy assistant will be retired in ninety days. The proposed successor uses the same API but has different context limits and refusal behavior. The team does not treat API compatibility as approval. It creates a new candidate release, replays the representative and hard-case sets, evaluates retrieval-plus-answer behavior, tests fallback and cost/capacity assumptions, obtains security and third-party review for any changed data flow, and records the cutover decision.

If the provider cannot support parallel testing or preserve the prior version through the decision window, the issue becomes a resilience and exit gap, not merely a scheduling problem. The product may narrow scope, move temporarily to the non-AI path, or select another candidate. Chapter 26's re-entry logic applies because a behavior-shaping dependency changed.

Concentration beyond a single vendor

Two nominally different services may share a cloud, base model, data center region, open-source dependency, identity provider, content-filter service, or specialist operations team. The dependency register should therefore distinguish legal supplier, technical dependency, operating location, and substitute path. Scenario tests should include correlated failure rather than counting vendors.

The supply-chain decision closes with a residual-risk statement: which provider facts were verified, which were asserted, which are unavailable, what the bank tested independently, what architecture limits exposure, who accepts the remaining uncertainty, and what event triggers reassessment. That statement is more useful than a binary "vendor approved" label.

Supplier assertion and migration verification record

Table 12.4 — Changed fact and supplier assertion

Changed fact	Supplier assertion	Institution verification / decision
API unchanged; context behavior changed	Interface compatibility	Compare admitted context, exception retrieval, source support and refusal on the new candidate
Data or training-reuse feature added	Published terms or administrator default	Review actual tenant/connector configuration, data path, permissions and applicability
Parallel version window constrained	Provider availability/change notice	Assess testing time, rollback/fallback, continuity and exit feasibility
Replacement selected	Comparable benchmark or contract promise	Test the bounded use and service conditions; state remaining equivalence limits and approval owner

Bind provider assertions and independent tests to version, manifest, method/result, limitation and gate decision. API compatibility supplies neither inherited approval nor evidence sufficiency; re-evaluate affected behavior, rights and operations.

12.10 Executive and Practitioner Decisions

Choose an admissible sourcing option before applying commercial preferences. Unknown rights or exit capability remain unknown; the sourcing record should name the evidence and owner needed for the next commitment.

Notes

1. NIST, Secure Software Development Practices for Generative AI and Dual-Use Foundation Models, SP 800-218A (B28), final July 2024. The sourcing decision matrix and provider-evidence classifications are author synthesis. Return to text

Chapter

13 Prompt, Context, Workflow, and Tool Design

Generative behavior is assembled from system instructions, user input, conversation state, retrieved content, tool results, model configuration, application logic, and output handling. Treating the visible prompt as the whole design hides most of the mechanism.

13.1 Design the Behavioral Assembly

A prompt is a versioned behavioral asset when changing it can alter a production claim. Context is the information assembled for a particular interaction. A workflow defines the order, branching, state, tools, validations, and handoffs around model calls. A tool is a capability made callable through that workflow. The design must show how these elements combine and which controls remain deterministic.

13.2 Give Each Instruction a Source and Precedence

Instructions can originate in institutional policy, product requirements, workflow state, user request, retrieved content, or tool output. They are not equally authoritative. The application should preserve a deliberate precedence model and prevent untrusted content from being treated as a policy instruction.

System instructions should state the product role and bounded behavior in terms the workflow can enforce. They should not contain secrets or serve as the only barrier against unauthorized actions. A model can be instructed not to send a message, but the execution identity should also lack that permission unless sending is an approved capability.

Prompt assets need owners, version control, review, test cases, release association, and rollback. Minor wording changes can alter refusals, tone, extraction, or tool choice. The bank should define which changes fit a pre-approved envelope and which require broader regression.

Instruction precedence is design intent, not a security boundary. A model can follow hostile instructions in content the user is entitled to retrieve. Provenance and source labels help assessment, but permissions, data destinations and consequential actions

must be enforced outside the model. Test an authorized policy passage containing an injected instruction, not only content the retrieval filter should deny.

13.3 Assemble Context Deliberately

More context is not automatically better. Irrelevant, stale, contradictory, sensitive, or adversarial content can reduce reliability. Context assembly should identify each segment's source, trust level, entitlement, freshness, and purpose.

Table 13.1 — Context element and design concern

Context element	Design concern	Evidence
System instruction	Correct role, boundary, and precedence	Version, owner, review, tests
User input	Validation, sensitivity, injection, unsupported request	Input policy and observed handling
Conversation state	Scope, retention, cross-session leakage	State model and deletion behavior
Retrieved content	Authority, entitlement, currency, poisoning	Corpus/index identity and retrieval results
Tool result	Authenticity, schema, error, stale or partial data	Tool identity, response validation, trace
Memory	Consent or purpose, accuracy, expiry, revocation	Stored item, provenance, owner, lifecycle

The model should receive only the context needed for the task. If the workflow truncates context, the team should test what is lost and how the product signals uncertainty. Silent removal of a controlling exception is a behavioral defect, not merely a token-management issue.

13.4 Prefer Deterministic Structure Where Structure Matters

When downstream software expects structured output, define a schema and validate it outside the model. Validation should cover types, required fields, allowed values, length, and cross-field rules relevant to the task. A syntactically valid response can still be semantically wrong; schema validation is necessary but not sufficient.

Constrain free-form generation where the service does not need it. Templates, enumerated choices, approved fragments, rules engines, and deterministic calculations can reduce the behavioral surface. The purpose is not to eliminate AI but to assign each function to the mechanism that can perform and assure it appropriately.

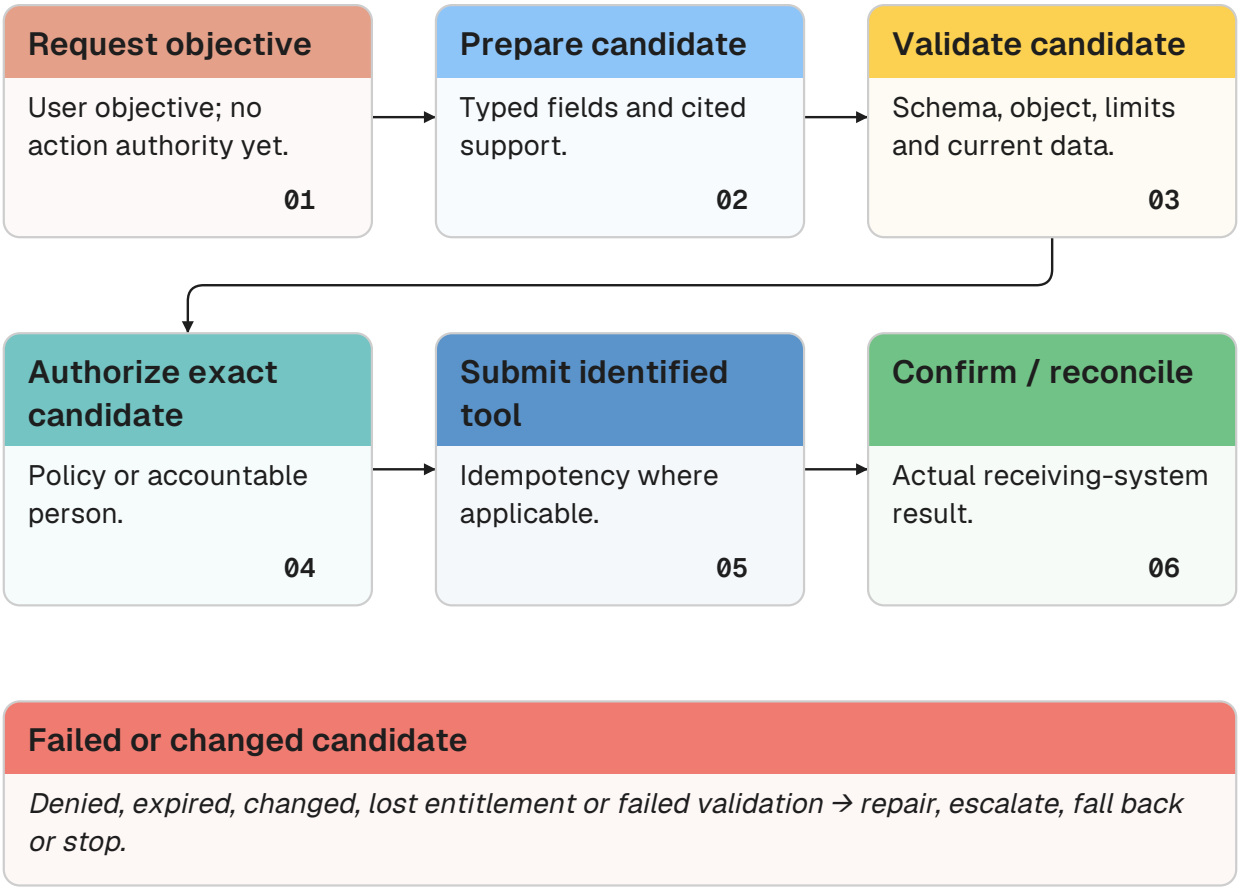
On validation failure, the workflow should have a bounded response: retry under controlled conditions, ask for information, route to review, use a safe default where one exists, or stop. An open-ended retry loop can amplify cost and instability.

13.5 Design Tools as Privileged Interfaces

A tool schema is an API contract, not an authorization policy. The receiving service should authenticate the caller and validate entitlement, purpose, object scope, transaction limits, and any required human authorization. Arguments generated by a model are untrusted input.

Tool design should favor narrow, typed capabilities over a general shell, database, or browser. Separate read, prepare, and execute operations. Where a consequential action is possible, consider a two-step pattern: the AI prepares a candidate action and an authorized person or deterministic policy service approves the specific object before execution. See Figure 13.1.

Figure 13.1 — Authorize the exact action candidate



Request, proposal, validation, authorization, submission and receiving-system confirmation are separate steps. The model cannot authorize its own proposal.

Table 13.2 — Control point and question

Control point	Question
Tool allowlist	Which capabilities may this product request?
Parameter validation	Are objects, values, destinations, and formats permitted?
Authorization	Does the effective identity have permission for this exact action?
Transaction boundary	What limit, idempotency, and replay protection apply?
Human decision	What information and authority support approval?
Response validation	Can partial, stale, or adversarial tool output mislead the next step?
Evidence	Can the bank reconstruct proposal, approval, execution, and result?

13.6 Make Workflow State Explicit

State can live in an application database, queue, conversation, agent memory, or downstream system. If the design does not name it, recovery and replay will be unreliable. The workflow should identify authoritative state, transient context, checkpoints, idempotency keys, expiry, and ownership.

Long-running work needs a response to partial completion. If a model prepares three changes and the second fails, the system should not guess whether to continue. Compensating actions, reconciliation, and manual takeover should be designed for the actual tools. A “rollback” may be impossible after a message is sent or a payment instruction leaves the boundary.

13.7 Test the Assembly, Not Only the Prompt

Prompt tests should include ordinary tasks, missing information, ambiguity, conflicts, prohibited requests, injected instructions, long context, malformed tool results, dependency timeouts, and retry behavior. The team should test the actual application path with the actual policy and permission enforcement.

Model-assisted judging can help scale analysis, but it is another measured component. Its rubric, calibration, disagreements, and failure modes need evaluation. A human sample may be required for material claims; the appropriate design depends on risk and resources.

Regression tests should preserve failures that matter. A prompt change that repairs one case can create another. The evidence should show the candidate configuration, test set version, repeated-run design where variability matters, results, severity, and release decision.

13.8 Worked Workflow at Fictional Bank

The policy assistant receives an employee question. A deterministic preprocessor checks the supported product and removes disallowed attachment types. The retrieval service returns entitled policy passages with source identities. The model prepares a structured draft containing propositions and supporting references. A validator checks the schema and that cited identifiers exist. The interface shows the draft and passages to the employee; it cannot send externally.

If no adequate source is found, the workflow does not manufacture a citation. It states the limitation and routes the employee to the policy support process. If retrieved content contains an instruction to reveal other documents, the content remains data; it gains no tool permission. This design narrows risk, but only evaluation and operation can show how well it works.

13.9 Output Handling and State-Machine Example

Model output is data, not an instruction with inherent authority. Risk changes when generated text is rendered as markup, evaluated as code, copied into a query, interpreted as a command, passed to another model, or used to populate a privileged API. Every downstream parser or executor creates a new trust boundary.

Table 13.3 — Output destination and material risk

Output destination	Material risk	Safer handling pattern
user interface	script or markup execution; misleading emphasis	encode by destination, use constrained rendering, label evidence and uncertainty
database or search	injection, malformed query, unbounded result	parameterized interface, schema and scope validation
code or configuration	unsafe execution, secret use, persistence	isolated workspace, policy checks, tests and authorized promotion
message or document	unauthorized commitment or disclosure	approved template, recipient/data checks, human or policy-bound send authority
tool or transaction	side effect, replay, amount/object substitution	typed arguments, fresh authorization, limits, idempotency and confirmation
another model or agent	instruction laundering and context confusion	provenance labels, policy precedence, restricted tool authority

“The model was told not to do that” is not an output control. The receiving component should reject data that cannot be represented safely, and the workflow should define whether rejection leads to repair, human review, fallback, or stop.

Explicit workflow state

For a material action, Fictional Bank uses a state machine rather than a free-form conversation:

- **Requested:** the user states an objective; no action is authorized.
- **Prepared:** the assistant produces typed candidate fields and cited support.
- **Validated:** deterministic checks confirm schema, object, limits and current data.
- **Authorized:** an accountable person or policy service approves the exact candidate for a bounded time.
- **Submitted:** a separately identified tool attempts the action with an idempotency key.
- **Confirmed, failed or unresolved:** the receiving system’s result—not the model’s narrative—determines state.
- **Reconciled:** any mismatch, retry or reversal is recorded and closed.

The trusted workflow canonicalizes the candidate and binds an authenticated approval grant to its digest, actor, operation/resource scope, candidate version, expiry and replay identifier. A digest identifies content; it does not authenticate consent or grant authority. Verify the issuer and grant integrity, then recheck current permission, limits and preconditions at the receiver when committing. Editing any material field, revocation or expiry returns the item to validation. Handle time-of-check/time-of-use races with receiver-side concurrency and authorization controls; a model-supplied approval flag is never sufficient.

Prompt and workflow review record

The record should contain instruction sources and precedence, context inputs, tool schemas, state transitions, output destinations, error/fallback behavior, and evaluation cases. Reviewers should see the diff between releases, not only a prose description. Use Chapter 26's named change classes. A correction that changes only documentation may be Editorial or administrative. A prompt change belongs in Bounded configuration only when it is inside an approved envelope with scoped regression evidence and stated uncertainty; otherwise route it as a Behavioral dependency or Use or authority change. Finite testing does not prove the absence of every behavioral effect.

The strongest prompt is still inside a system. Engineering quality comes from combining clear instructions with enforceable identity, constrained data, explicit workflow, validated output, limited tools, observable state and recoverable failure.

Tool contract record

Define each consequential tool's caller, subject, typed operation/resources, preconditions, effects, confirmation, limits, timeout and errors. Include idempotency/replay, evidence and reconciliation. The model may propose; the receiver authorizes the exact action. Consequence determines the required independent abuse testing and transaction-level maker-checker.

Separate preparation and submission contracts

The examples below are valid JSON illustrating two distinct operations. They contain no credentials and execute nothing.

```
{
  "operation": "prepare_service_request",
  "request_id": "PA-REQ-001",
  "arguments": {
    "topic": "approved-service-topic",
    "draft_text_ref": "DRAFT-001"
  },
  "release_ref": "PA-PREP-CANDIDATE-1",
  "prepared_candidate_ref": "PA-CAND-001",
  "candidate_version": "1",
  "candidate_digest": "illustrative-canonical-digest",
  "result_state": "prepared",
  "side_effect": "candidate-only"
}

{
  "operation": "submit_service_request",
  "request_id": "PA-REQ-002",
  "candidate_ref": "PA-CAND-001",
  "candidate_version": "1",
  "candidate_digest": "illustrative-canonical-digest",
  "authenticated_grant_ref": "GRANT-001",
  "release_ref": "PA-SUBMIT-CANDIDATE-1",
  "expected_record_version": "7",
  "idempotency_key": "SUBMIT-001",
  "result_state": "not-submitted",
  "receipt_ref": null
}
```

PA-REQ-001/002 identify requests; PA-CAND-001 identifies the prepared object. Submission binds its version and canonical digest to an authenticated grant and a separately permitted PA-SUBMIT release. The digest string is illustrative, not a computed integrity value. Preparation creates only a candidate; the shown submission remains not-submitted until receiver authorization and a durable outcome receipt establish otherwise.

The receiver owns a durable idempotency record scoped to the operation, caller and business object, with retention covering the approved retry horizon. It atomically relates a committed effect to the key where the transaction design permits, rejects reuse with different parameters, and returns the prior receipt for a recognized duplicate. Read-only retries can be bounded by time/resource limits; side-effect retries require that contract and reconciliation. Transport retries do not guarantee exactly-once business execution.

After an ambiguous submission timeout, query the receiving system using the same identity and key; preserve an unresolved state until a receipt or reconciliation establishes the result. An expired key, inconsistent parameters or inability to determine committed state causes escalation, not a fresh key and blind resubmission. The contract defines compensation and who can authorize it.

13.10 Executive and Practitioner Decisions

Give the receiver a precise prepare/submit contract with authenticated approval, current authorization and durable reconciliation. A fluent model response cannot establish whether a side effect committed.

This chapter's design patterns are author synthesis informed by NIST AI RMF and Generative AI Profile (B01–B02), Toolformer and ReAct research (B21, B23), and OWASP community guidance (B39). None prescribes the bank-specific workflow in this chapter.

Chapter

14 Agentic Systems and Delegated Authority

An agentic system selects or adapts steps, tools, or subgoals while pursuing an objective. The control question is not whether the system is called an agent. It is what authority it can exercise, over which resources, for how long, and with what opportunity for challenge and recovery.

14.1 Agency Is an Authority Question

Research has shown patterns in which language models interleave reasoning-like traces with actions or learn to invoke tools.[1] Those results demonstrate technical possibilities, not a production authorization model. A bank must wrap any planning behavior in institutional identity, policy, software, evidence, and accountability.

14.2 Separate Objective, Plan, Permission, and Execution

An objective describes the requested outcome. A plan is a proposed sequence of steps. Permission determines which steps are allowed. Execution changes or observes the world. Combining all four inside one model output makes it difficult to know whether a plausible plan was also authorized.

Author synthesis. Use four explicit control boundaries:

- **Objective boundary:** the task and completion condition are bounded.
- **Planning boundary:** plans are proposals subject to policy and resource limits.
- **Authority boundary:** tools and objects are authorized independently of the plan.
- **Execution boundary:** consequential actions are validated, recorded, and recoverable where feasible.

The model may contribute at each boundary, but it should not be the sole authority for its own permissions or for determining that a consequential action needs no approval.

14.3 Delegate the Minimum Useful Authority

Least privilege for agents includes more than a role assigned at login. Authority should be scoped by purpose, tool, object, action, value or volume where relevant, time, environment, and state. A short-lived credential for a specific workflow is preferable to a standing shared secret.

Delegation should preserve the chain from accountable owner to product, workload identity, tool request, approval, and outcome. If an employee authorizes an action, the record should distinguish the employee's decision from the agent's proposal and the service's execution. "The AI did it" is not an accountable identity.

The authorization service should evaluate the specific action. Approval of a plan should not automatically authorize a materially changed execution. If the object, amount, destination, or supporting evidence changes, the approval may need to expire.

14.4 Bound Planning and Resource Use

Agent loops can consume time, tokens, tools, and downstream capacity. Set budgets for steps, duration, cost, concurrency, retries, and tool calls. Define completion and stop conditions. Detect circular plans, repeated failure, expanding scope, and attempts to acquire new authority.

The system should preserve checkpoints sufficient for intervention and investigation without exposing hidden reasoning as if it were reliable evidence. Decision-relevant facts include the objective, available tools, observations, proposed and executed actions, policy decisions, approvals, errors, and outputs. A generated rationale may be retained as content, but it is not a substitute for these external events.

14.5 Govern Memory and Multi-Agent Coordination

Memory creates persistence. It needs a purpose, scope, owner, source, sensitivity classification, expiry, correction path, and revocation behavior. User-supplied memory, retrieved institutional knowledge, and agent-created summaries should not be merged without provenance. A wrong summary can become a repeated instruction.

Multiple agents do not automatically provide independent challenge. If they use the same model, context, objective, or failure assumption, agreement may be correlated. Assign distinct roles only when the separation changes information, authority, method, or accountability. An agent that "reviews" its peer without an independent criterion is not a second line of defense.

Message passing between agents is another trust boundary. Validate identity, schema, permitted task, and attached evidence. Prevent one compromised agent from granting another authority it does not possess.

14.6 Protect Consequential Actions

Use Chapter 4's six factors: capability, authority, consequence, exposure, scale and reversibility. Uncertainty, data sensitivity and observability inform those assessments and control choices; they do not replace the canonical factors. Possible patterns include:

Table 14.1 — Pattern and appropriate use

Pattern	Appropriate use	Required safeguard
Read-only exploration	Gather bounded information	Entitlement-aware retrieval and output handling
Candidate preparation	Draft a record, message, or transaction	No execution permission; explicit reviewer task
Policy-constrained execution	Perform low-consequence reversible action	Deterministic authorization, limits, telemetry, recovery
Per-action approval	Execute a consequential action after review	Approval bound to exact action and unexpired evidence
Bounded unattended operation	Repeated action within approved envelope	Strong policy, anomaly detection, intervention, reconciliation

These are design options, not regulatory categories. A bank may prohibit some patterns entirely for a use. Human approval is meaningful only if the person has information, competence, time, and authority to reject or modify the action.

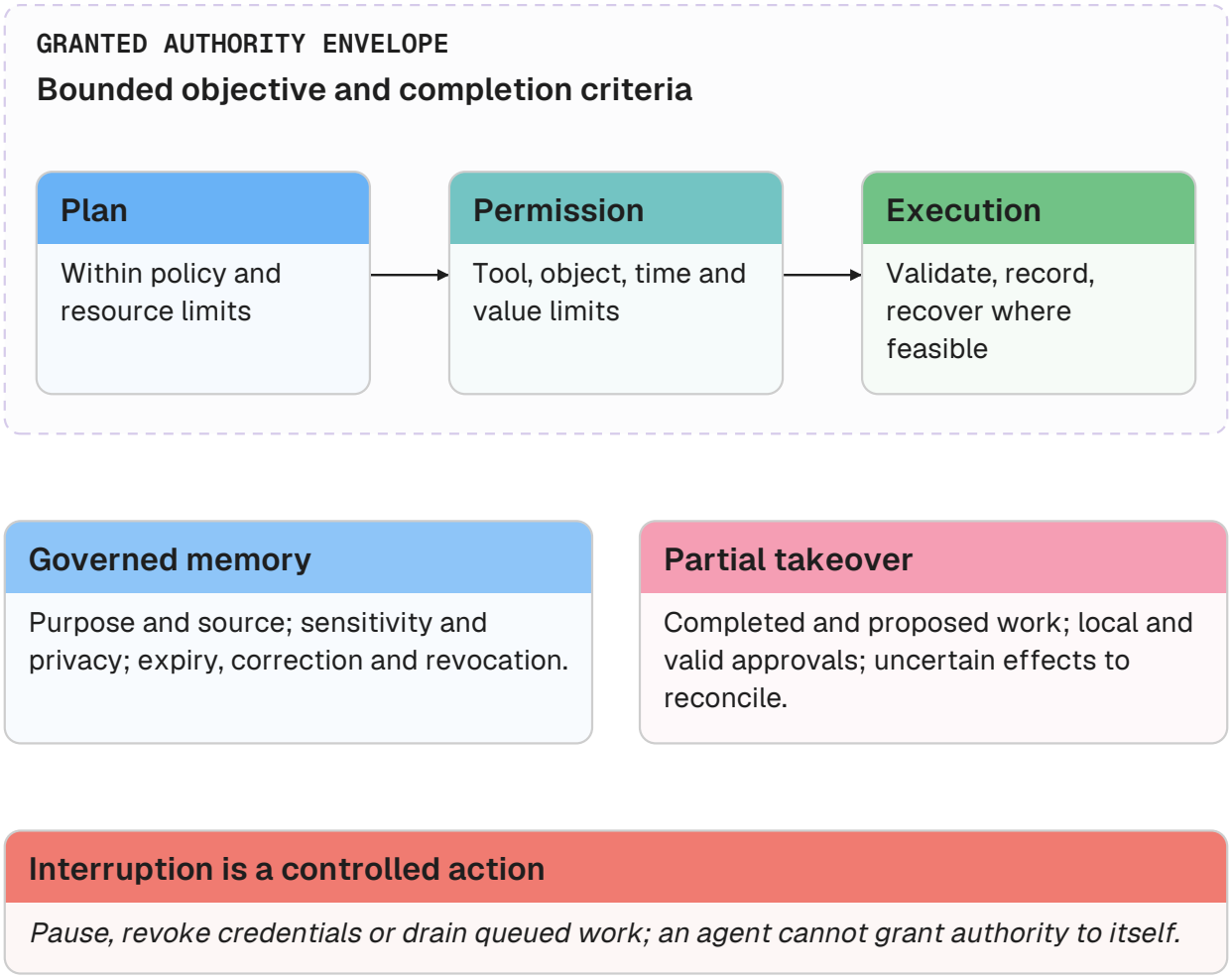
14.7 Termination Containment and Protected Attribution

An agent needs more than an application stop button. The design should support revoking credentials, disabling tools, blocking egress, pausing new work, isolating state, preserving evidence, and reconciling actions already initiated. A kill switch that stops planning but leaves queued transactions active is incomplete.

Protected attribution means that requests, approvals, policy decisions and executions can be related to authenticated actors and integrity-protected records. That supports auditability; it does not alone establish a strong non-repudiation claim. A stronger claim needs explicit identity, signing, key custody, compromise/revocation, time and evidential assumptions, with specialist review. Logs should be integrity-protected and

privacy-aware, with synchronized time and stable correlation identifiers. See Figure 14.1.

Figure 14.1 — Agent autonomy stays inside granted authority



Planning, permission and execution remain distinct inside granted authority. Memory and takeover require governed state, clear provenance and reconciliation.

14.8 Worked Boundary at Fictional Bank

A separate policy-update preparation example assembles an impact report from approved repositories, compares versions and creates a draft task list and candidate ticket outside the system of record. It is not PA-DRAFT. The agent cannot publish policy, alter entitlement, notify customers or close a compliance obligation.

The model proposes queries and candidate content. Search enforces entitlement and source approval; a bounded preparation service records the agent and candidate identity without opening a committed ticket. A policy owner reviews the sources and task list. An out-of-scope repository becomes a recorded gap, not a request for broader credentials.

This grant permits preparation only. Committing or assigning a ticket would add a side effect and require its own impact assessment, evaluation, receiver contract and approval.

14.9 Worked Higher-Consequence Pattern: Bounded Reconciliation Agent

The policy assistant is deliberately low-authority. A second fictional example shows what changes when an agent operates repeatedly without per-action approval.

In a separate reconciliation design, a deterministic rules engine joins the approved ledgers, compares exact matches and closes only the work items covered by its rules and authority. An agent helps summarize non-executing exception cases; it does not perform or receive credit for deterministic matching and cannot close items, move money, alter ledgers, waive exceptions or contact customers. The benefit hypothesis concerns exception-review effort, with no claimed outcome. Broader agent authority requires a separate decision.

Table 14.2 — Boundary and approved design

Boundary	Approved design	Stop or escalation condition
objective	reconcile a named feed pair for a named business date	new feed, entity, currency, product or purpose
read authority	specified fields in two read-only data views	entitlement mismatch or unexpected sensitive field
action authority	deterministic rules engine closes authorized exact-match items; agent drafts exception summaries only	non-exact match, rule conflict, amount/value outside limit
resource budget	bounded records, time, retries and concurrent work	budget exhausted or repeated dependency error
memory	task-scoped state with expiry; no self-written durable policy	cross-run memory request or provenance loss
evidence	input snapshot IDs, rule version, proposal, authorization result, execution response, reconciliation totals	missing correlation or count mismatch
intervention	operations can pause queue, revoke credential and isolate worker	anomalous closure rate, rule change, incident signal

The model may help explain an exception, but exact-match closure is authorized by a deterministic policy service. The agent's workload identity can call only the bounded closure operation. Each batch has admission control; queued work expires when the rule or release changes. A control-total check reconciles read, matched, exception, closed, failed and unresolved counts before the batch is complete.

This is **not an endorsement of unattended reconciliation**. It illustrates the evidence required to decide whether a narrow, reversible, observable action is within standing authority. Domain, operations, financial-control, security and audit reviewers must assess the real service.

Agent evaluation and containment exercise

Evaluation covers more than final answers. It records trajectories: objective interpretation, planning steps where observable, tool selection, argument construction, policy decisions, retries, stop behavior and final state. Test cases include ambiguous objectives, stale authorization, duplicate events, conflicting sources, tool timeout, poisoned instructions, budget exhaustion and a request to exceed scope.

Containment is exercised as a timed operational procedure:

- pause new work admission;
- revoke or narrow credentials;
- isolate or drain queues without losing task identity;
- identify in-flight and externally submitted actions;
- reconcile confirmed, failed and uncertain outcomes;
- preserve evidence and open the incident/change decision; and
- require a new release decision before resumption where the approved claim may have changed.

A kill switch that stops the process but leaves credentials, scheduled jobs or queued actions active is incomplete. Likewise, termination without reconciliation can exchange continued harm for unknown state.

Evolving standards and local responsibility

Agent identity and authorization standards remain an evolving area. Work on workload identity, delegated authorization, secure software identity and AI-agent authorization can inform implementation, but a project draft or emerging pattern should not be presented as a settled banking requirement. The bank remains responsible for defining the subject, delegated authority, resource, condition, evidence and revocation semantics for its system.[2]

The executive question is therefore not “Do we allow agents?” It is “Which bounded authorities may which identified workloads exercise, with what consequence, evidence, intervention and accountable owner?”

Identity, memory, and takeover record

The product distinguishes human user, workload/service, agent, tool, approval authority, evidence producer, administrator, and break-glass operator. Each identity has scope, lifetime, credential, revocation method, review owner, logging, and separation constraints. Agent memory is governed data with purpose, subject/tenant scope, provenance, retention, deletion, poisoning controls, and migration behavior.

Partial completion is a first-class state. A takeover record shows completed actions, proposed but unexecuted actions, locks or reservations, approvals still valid, side effects requiring reconciliation, and the identity that assumes control. Multi-agent messages carry sender, delegated authority, integrity protection, expiry, and correlation to the originating purpose; one agent's plan never expands another agent's permissions.

Partial-completion ledger and takeover

Table 14.3 — Trajectory state and evidence and action

Trajectory state	Evidence and action
Admitted	Record workload, objective, release/rule, allowed batch/items and expiring authority
Prepared/authorized	Bind exact action/candidate representation to policy decision and current preconditions
Submitted	Preserve item/action ID, idempotency key and receiving-system receipt or uncertainty
Confirmed / failed / unresolved	Classify from authoritative system response; do not infer success from agent narration
Contained	Stop admission, revoke/narrow credentials, identify queued and in-flight items
Reconciled / taken over	Authorized operator queries state, resolves duplicates/partial effects and records unresolved obligations
Resumption decision	Link repaired candidate, regression, operating conditions, approval and monitored return

Memory is scoped by subject, task, sensitivity, permission and retention; it cannot carry revoked authority into another task. Takeover authority is recorded independently of the agent, and unresolved external effects keep the incident/reconciliation record open.

Why use an agent for this task?

For exact-match reconciliation, a deterministic workflow should join identifiers, compare values and route exceptions. An agent adds no useful permission to that step. A bounded planning assistant may help classify varied exception narratives and propose which approved diagnostic to inspect; test whether that improves the employee's task enough to justify variability and review cost.

In a synthetic run, the assistant proposes a diagnostic outside its allowlist. The tool broker denies it, the planning budget expires, and the operator takes over with the

partial-completion ledger. No system-of-record mutation occurs. Preserve the denial and unresolved work, rather than reporting the final narrative as successful reconciliation.

14.10 Executive and Practitioner Decisions

Use an agent where variable planning justifies its control burden. Keep deterministic reconciliation in rules, and test that revocation stops tools and queued work while preserving unresolved effects.

Notes

1. Schick et al., “Toolformer” (B21), and Yao et al., “ReAct” (B23). These peer-reviewed papers provide technical lineage; the authority, memory, termination, and evidence framework is author synthesis. Return to text

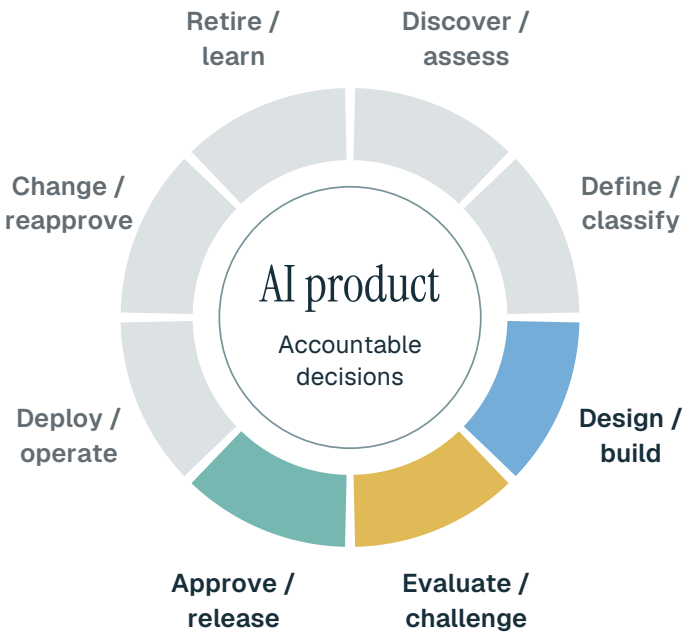
2. NIST NCCoE, Software and AI Agent Identity and Authorization (B17). Emerging project material can inform questions but is not a final standard or banking requirement. Return to text

Part

IV

Engineering, Evaluation and Assurance

Applies secure software engineering, claim-based evaluation, red teaming, security, privacy/fairness/oversight and independent validation. The outcome is a release decision supported by evidence and explicit limitations.



Emphasis: Design / build; Evaluate / challenge; Approve / release.

Other phases remain part of the lifecycle.

Re-enter at the affected decision.

Chapter

15 Software Engineering for AI-Enabled Products

An AI-enabled product remains software. It must authenticate users and workloads, manage state, validate inputs and outputs, handle failure, protect secrets, control dependencies, deploy repeatably, and produce operational evidence. A capable model cannot compensate for race conditions, unrestricted APIs, fragile retries, or an unrecoverable database change.

15.1 AI Does Not Relax Software Engineering

AI adds behavior-shaping assets that conventional pipelines may not yet manage: models, prompts, examples, evaluation sets, feature definitions, corpora, indexes, guardrail configurations, routing rules, and tool policies. The engineering task is to bring these assets into the same discipline as code without pretending they behave identically.

15.2 Use Contracts Between Components

Modularity is valuable when boundaries have enforceable contracts. A model gateway should define authentication, supported operations, request and response schemas, timeouts, quotas, logging, and version behavior. A retrieval service should state how entitlement, source identity, and no-result conditions work. A tool should declare its side effects and idempotency behavior.

Contract tests should run independently of behavioral evaluation. They answer whether components communicate as designed. Behavioral evaluation answers whether the assembled product fulfills its claim. Both are required; neither subsumes the other.

Table 15.1 — Boundary and contract concern

Boundary	Contract concern	AI-specific extension
Model call	Schema, timeout, error, version	Variability, refusal, configuration, provider change
Retrieval	Query, result, identity, entitlement	Ranking, missing support, poisoned content, index version
Tool	Types, authorization, side effect	Model-generated arguments, approval binding, replay
User interface	State, validation, accessibility	Uncertainty, evidence display, over-reliance, fallback
Telemetry	Event schema, correlation, retention	Behavioral signal, privacy, release and evaluation linkage

15.3 Keep the Core Testable Without a Live Model

Business rules, authorization, calculations, formatting, and workflow transitions should be deterministic where their function permits. Encapsulate model calls behind interfaces so tests can supply controlled responses, including refusals, malformed output, timeouts, and unsafe proposals. This reduces dependence on a live service during ordinary software tests and exposes error-handling logic.

Test doubles must not be confused with model evaluation. A stub proves that the application handles the stubbed case; it says nothing about how often a production model will create it. Conversely, a strong model result does not prove that the application handles a timeout or duplicate tool response correctly.

15.4 Manage Configuration as a Release Graph

A release may depend on code commit, container image, model identity, provider endpoint, prompt version, retrieval index, feature or routing configuration, tool schema, policy bundle, and infrastructure definition. The release manifest should identify the approved combination and the evidence that applies to it.

Configuration should move through controlled environments. Avoid editing production prompts or model aliases outside the release path. Emergency changes need an attributable owner, bounded duration, validation, and a return to the normal path. Feature flags can reduce exposure, but the flag service and default behavior become control dependencies.

Reproducibility is proportional, not absolute. A third-party model may not reproduce an exact token sequence. The bank should still reproduce the configuration, cases, environment, and evaluation method sufficiently to interpret the decision. Unknown provider internals remain a limitation.

15.5 Build Failure Isolation and Recovery

Separate synchronous user experience from background work where appropriate. Use queues, timeouts, circuit breakers, quotas, and idempotency to prevent a model or tool failure from cascading. Validate every boundary and assume partial results.

Failure handling should follow the service. A customer explanation may need to stop and route to an employee. An internal summarizer may display an unavailable status. A transaction-support workflow may preserve a candidate and require reconciliation. Generic retry is not a strategy; it needs limits and a reason to believe the next attempt is safer.

State transitions should be explicit. An action can be proposed, validated, authorized, submitted, confirmed, failed, reversed, or unresolved. Logging “success” when a request was merely accepted by a downstream queue creates false assurance.

15.6 Integrate Secure Development

NIST’s SSDF provides a cross-sector secure-development baseline, and SP 800-218A adds a community profile for generative AI and dual-use foundation models.[1] The bank should integrate AI assets into its established secure-development process: threat modeling, protected repositories, peer review, automated checks, dependency and secret scanning, build integrity, environment separation, release authorization, and vulnerability response.

AI-specific checks may include model and data provenance, unsafe deserialization, prompt and tool changes, corpus-ingestion paths, evaluation leakage, provider endpoint policy, and adversarial behavior. These are extensions, not an excuse to replace conventional application-security testing.

15.7 Use AI in Software Development With the Same Discipline

AI-assisted software change still needs an authorized task, isolated proposal, independent checks, human review and separate promotion. Section 15.10 follows one test-only grant through these handoffs. Secure-development obligations and repository controls continue to apply.

15.8 Design the Developer Path

Controls fail when the approved path is impractical. A paved road should provide approved model access, templates for service identity and policy enforcement, test harnesses, telemetry, release manifests, and documented escalation. It should make the secure path easier to discover and automate evidence collection.

Exceptions still need a path. When a product cannot use the shared capability, the team should record the unmet requirement, alternative control, duration, owner, and re-entry plan. Platform standards should evolve from recurring exceptions, not force teams into hidden workarounds.

15.9 Worked Release at Fictional Bank

The policy-assistant repository holds application code, workflow, prompt references, tool schemas and infrastructure. Bank-controlled artifacts and corpus/index snapshots use immutable release references. For an external model service, retain the strongest observable identity and its reconstruction/change limits (§21.8). The pipeline runs unit/contract tests, builds a signed artifact, invokes controlled evaluation and assembles evidence for approval.

In the PA-DRAFT timeout test, the interface withholds a partial unsupported draft and offers authorized policy support. A separate PA-SUBMIT fixture tests duplicate submission, idempotency and receipt reconciliation. That fixture does not add action authority to PA-R1. The outcomes are constructed teaching tests under stated conditions.

Repository-to-operating-identity handoff

The illustrative release record joins repository/commit, reviewed diff, dependency/build identity, configuration and policy versions, data/corpus/model/prompt/tool manifest, evaluation cases/results, approval conditions, deployed environment and observed runtime identity. Link the build to its evidence rather than substitute a repository label for a release. Developer-agent credentials remain bounded to the approved workspace/task; production credentials are separate. If the observed configuration differs from the approved manifest, deployment verification records the mismatch and restricts affected use.

15.10 AI-Assisted Engineering as a Governed Workflow

AI-assisted engineering is in the book's operational scope, not merely a disclosure note. The governed object is the change workflow: information supplied to the tool, model and extension dependencies, proposed code or configuration, commands executed, human and automated review, release promotion, and resulting evidence. Developing an AI-enabled banking product and using AI to develop ordinary software are different use cases, but both can change production risk.

Permission bands for developer tools

Table 15.2 — Band and capability

Band	Capability	Minimum boundary	Additional evidence when promoted
Explain	read a bounded code selection and produce an explanation	approved repository/data policy; no secret or production access	tool and model identity where the output informs a material decision
Propose	generate code, tests or documentation without writing the workspace	treat output as untrusted contribution	prompt/context provenance, review and test result
Edit	modify files in an isolated branch or workspace	scoped file access; change diff; no merge authority	machine-generated change markers where policy requires, reviewer identity
Execute	run approved commands in an isolated development environment	command allowlist or sandbox, network/secret restrictions, resource budget	command and result log; dependency changes; security findings
Submit	open a change request or pull request	service identity and branch protection	link proposal to reviewed diff and CI evidence
Promote	merge, deploy or change infrastructure	separate release authority and normal production controls	approval, artifact identity, environment and rollback evidence

An institution can permit different bands for different repositories. Source containing secrets, customer data, cryptographic material, fraud logic, trading strategies or sensitive security controls may require stronger isolation or exclusion. The decision must cover editor plug-ins, hosted chat, command agents and background indexing; a policy that governs only pasted prompts misses automated context collection. See Figure 15.1.

Figure 15.1 — Permission bands are separately granted

Band	Capability	Minimum boundary	Additional evidence when promoted
Explain	read a bounded code selection and produce an explanation	approved repository/data policy; no secret or production access	tool and model identity where the output informs a material decision
Propose	generate code, tests or documentation without writing the workspace	treat output as untrusted contribution	prompt/context provenance, review and test result
Edit	modify files in an isolated branch or workspace	scoped file access; change diff; no merge authority	machine-generated change markers where policy requires, reviewer identity
Execute	run approved commands in an isolated development environment	command allowlist or sandbox, network/secret restrictions, resource budget	command and result log; dependency changes; security findings
Submit	open a change request or pull request	service identity and branch protection	link proposal to reviewed diff and CI evidence
Promote	merge, deploy or change infrastructure	separate release authority and normal production controls	approval, artifact identity, environment and rollback evidence

Each permission band carries its own boundary and evidence. Promotion is separately authorized through normal production controls.

Provenance, licensing and large-diff review

The bank should define what provenance it needs to preserve for generated contribution. Useful fields include tool/model identity, time, user, repository/branch, task reference, supplied context category, output or diff reference, declared external material, dependency changes, reviewer, tests and disposition. This is not a claim that every generated token can be traced to training data. It is an operational record of how the change entered the bank's process.

License and intellectual-property review should follow the institution's ordinary open-source and contribution policy, extended for generated output. A similarity detector can inform review but cannot establish ownership or license status. When a tool proposes a new dependency, the dependency—not the generated import statement—is the main supply-chain object: origin, license, integrity, maintenance, vulnerability and necessity should be assessed.

Large generated diffs are a human-factors risk. "A person approved the pull request" is weak evidence if the change could not realistically be understood. Safer strategies include decomposing the task, limiting files and lines per change, requiring architecture notes for structural changes, reviewing behavior and security invariants, using independent tests, and prohibiting generated bulk rewrites of sensitive logic without an explicit review plan. Test generation can improve coverage, but tests generated from the same misunderstanding can reinforce the defect.

Secrets and execution safety

Developer agents should receive short-lived, task-specific credentials through the environment rather than prompts or memory. Production credentials should not be available in a development agent's workspace. Network egress, package installation, shell commands and infrastructure access should be bounded; command output can contain secrets and must be handled as sensitive context.

Fictional Bank permits a coding agent to edit a test-only branch and run an approved test suite in an isolated environment. It cannot access customer data, change branch protection, retrieve production secrets, merge, deploy or modify infrastructure. The change record distinguishes agent proposal, developer modification, peer review, automated checks and release approval. No productivity or defect-reduction outcome is claimed.

Sample AI-assisted change record

Table 15.3 — Field and fictional value

Field	Fictional value
task and repository	bounded defect ticket; named service repository
permitted capability	edit tests only in isolated branch; application changes need a separate grant
prohibited capability	production data, secrets, merge, deployment, infrastructure change
supplied context	selected code and synthetic test data; no customer information
proposed change	immutable diff and dependency manifest delta
human review	named accountable engineer; review scope and exclusions
automated evidence	build, unit, contract, security and license checks with result IDs
final disposition	accepted with edits / rejected / split / escalated
executed release	separate release identity and authority, if later promoted

The record does not prove code correctness. It supports reconstruction and helps the bank test whether its AI-assisted development policy operates as designed.

Worked test-only task DEV-01

Synthetic repository exercise. The permitted path is tests/test_source_expiry.py; the grant excludes application modules, dependencies, secrets, infrastructure, merge and deployment. The sandbox has no production credentials, denied external egress and a locked dependency set. Installation requires a separate reviewed dependency change.

The independent acceptance rule says a source is invalid when valid_until <= now. The assistant's tests cover only a source expired one second earlier and pass against an implementation that incorrectly checks <. A domain reviewer supplies the equality-boundary test:

```
def test_source_expired_at_boundary():
    now = 100
    assert allow_source(valid_until=now, now=now) is False
```

This independently specified test fails on the seeded implementation. The reviewer rejects promotion and records DEV-TEST-02, despite the assistant's passing tests. A developer fixes the application module under a distinct DEV-02 grant; DEV-01 never expands its own permissions. The final record links both diffs, the acceptance rule,

executed test results, dependency/secret checks, peer review and any later release decision. These are constructed results demonstrating shared misunderstanding, not a claim that this code is a banking implementation.

15.11 Executive and Practitioner Decisions

The engineer should submit only the permitted diff and executed evidence. Independent acceptance tests and a separate promotion decision must survive the convenience of generated implementation and tests.

Notes

1. NIST, Secure Software Development Framework v1.1 (B04), and SSDF Community Profile for Generative AI and Dual-Use Foundation Models (B28). They support secure-development integration; this chapter's release graph and paved-road design are author synthesis. Return to text

Chapter

16 Evaluation Strategy and Quality Engineering

An evaluation is useful only when it connects a product claim to a decision. “We tested the model” does not reveal which behavior, population, configuration, threshold, or consequence was examined. The evaluation plan should begin with the decision: continue an experiment, select a component, approve a candidate release, widen exposure, accept a limitation, or intervene in operation.

16.1 Evaluation Supports a Decision

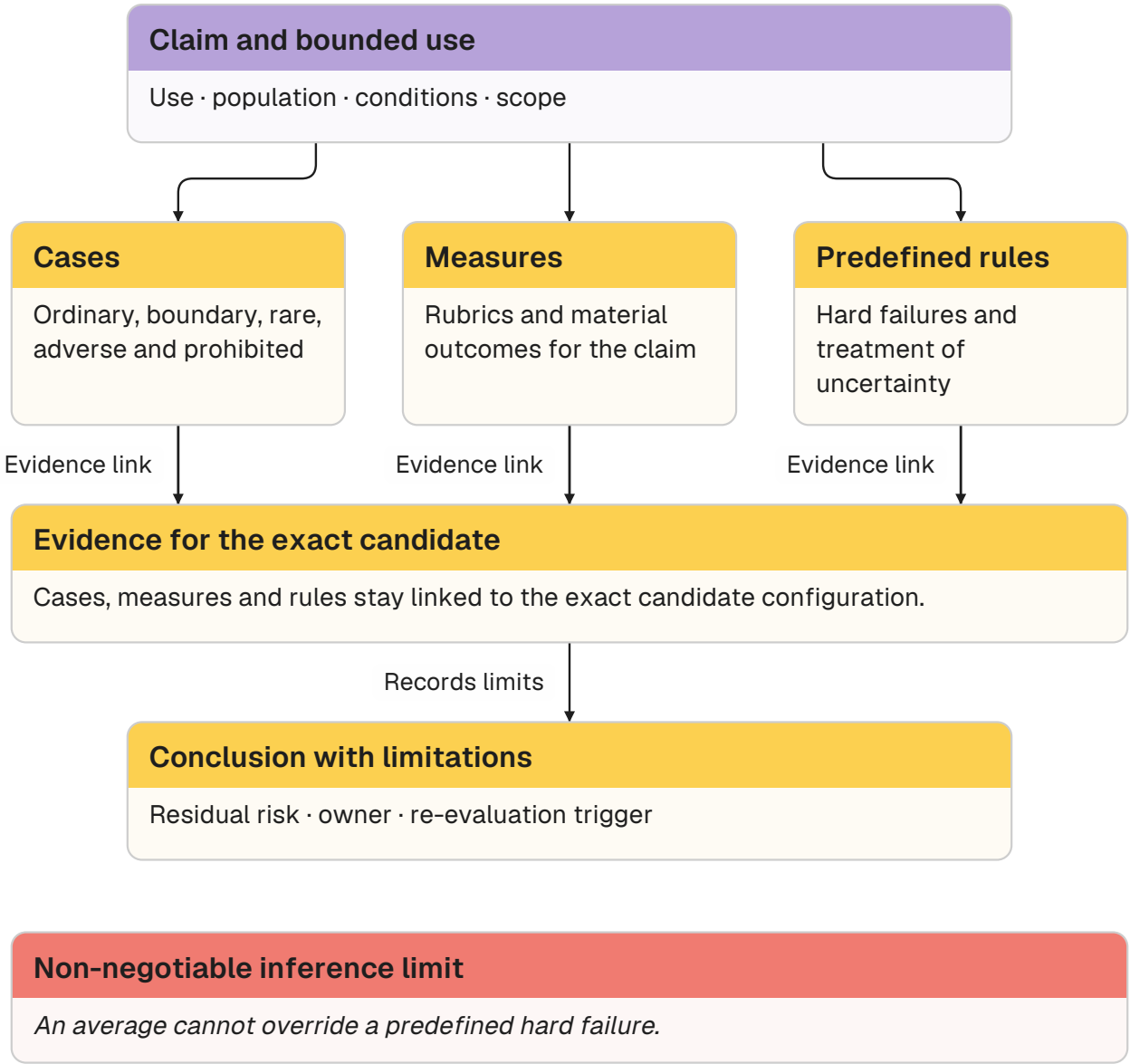
Testing and evaluation overlap but are not synonyms. Software tests often verify specified deterministic behavior. AI evaluation may estimate behavior across a set of cases, conditions, and judgments. Validation and assurance add questions of independence, sufficiency, and suitability for use. The book uses these distinctions consistently without claiming they are universal legal definitions.

16.2 Construct an Evaluation Argument

Connect seven elements in the evaluation record:

- **Claim:** what proposition and decision are being assessed.
- **Population:** use, users, cohorts, conditions and exclusions.
- **Cases:** ordinary, boundary, rare, adverse and prohibited conditions, with selection/sampling method.
- **Measures:** outcome definitions, rubrics, adjudication and denominators.
- **Decision rules and uncertainty:** predeclared hard failures, statistical assumptions, limits and escalation.
- **Configuration identity:** exact candidate, effective data/knowledge/tool/policy versions and test environment. See Figure 16.1.

Figure 16.1 — An evaluation conclusion needs an argument



Cases, measures and predefined rules jointly support exact-candidate evidence. The conclusion records limitations, residual risk, an owner and a re-evaluation trigger.

- **Conclusion and follow-through:** limitations, residual risk, owner, conditions and re-evaluation triggers.

Uncertainty is explicit in element 5 and in result reporting; configuration is explicit in element 6. Neither disappears into a catch-all score. The filled record in §16.9 uses these same seven labels.

16.3 Build a Layered Portfolio

Evaluation should match the layers established in Chapter 1.

Table 16.1 — Layer and example question

Layer	Example question	Typical method	Decision
Component	Can the model perform the bounded task under stated conditions?	Labeled cases, reference tasks, robustness probes	Candidate selection or rejection
Application	Does the assembled system retrieve, constrain, validate, and handle failure?	End-to-end cases, contract tests, adversarial inputs	Release-candidate readiness
Workflow	Can people and downstream systems use, challenge, and recover?	Scenario exercises, usability study, operational simulation	Suitability for operating use
Runtime	Does behavior remain within approved limits?	Telemetry, sampled review, complaints, continuous tests	Continue, restrict, investigate, or stop

The same case can appear at multiple layers, but its evidence meaning differs. A component's correct answer does not establish that the workflow displays it appropriately. A workflow simulation does not estimate every population outcome.

16.4 Design Case Populations Deliberately

Evaluation cases should be derived from intended use, failure analysis, domain variation, historical incidents where lawfully available, stakeholder concerns, and adversarial scenarios. Include normal cases, boundaries, ambiguity, missing information, conflicting evidence, minority or low-frequency conditions, unsupported requests, dependency failures, and cases that should refuse or escalate.

Partition development, tuning, validation, and final decision sets where leakage would bias results. Version cases and record provenance, rights, sensitive classifications, label process, and known gaps. A static “golden set” can decay when products, policies, language, or populations change.

Coverage is multi-dimensional. A team may need to examine product, language, channel, user type, customer group, data condition, failure mode, and authority level. Full combinatorial coverage is rarely feasible; the plan should explain prioritization instead of implying completeness.

16.5 Choose Measures That Preserve Consequence

Aggregate accuracy or pass rate can hide severe failures. Record error types, severity, affected population, uncertainty, and whether a hard boundary was crossed. Metrics such as precision, recall, calibration, ranking quality, groundedness, or task success are meaningful only with a defined denominator and decision.

For generated content, structured rubrics can assess factual support, completeness, relevance, refusal, policy compliance, tone, or format. Human assessors need qualification, instructions, blinded or randomized presentation where appropriate, disagreement handling, and a method for ambiguous cases. Model-assisted evaluation can increase scale, but the judging model and rubric require calibration against the decision.

No universal pass rate, sample size, fairness threshold, or confidence level is supplied here. Quantitative choices need statistical and domain justification, especially where results support high-consequence decisions.

16.6 Address Variability and Uncertainty

When outputs vary, repeated runs can estimate stability under a defined configuration. Repetition should be justified by the claim and generation settings. A mean score alone may conceal tail behavior or a hard failure that appears occasionally.

Uncertainty also comes from case selection, labels, assessor disagreement, provider opacity, limited samples, and changing operation. Report these sources separately where possible. A narrow estimate with biased cases is not stronger than a wider honest estimate.

Decision rules should define how uncertainty affects progression. Options include more evidence, restricted scope, stronger fallback, lower authority, time-limited approval, additional monitoring, or rejection. “Monitor after launch” should not be used to postpone evidence that can and should be obtained before exposure.

16.7 Connect Defects to Ownership and Regression

Every material defect should identify the failed claim, observed case, severity, likely layer, owner, disposition, and regression test. Possible dispositions include repair, narrow scope, add control, change workflow, accept with authority and expiry, or reject.

Do not tune only to the observed example. Investigate the failure class and whether the remedy creates new behavior. Preserve representative regressions while protecting sensitive information and avoiding leakage into final independent sets.

A closed defect means the decision-maker accepted evidence for the disposition. It does not mean the failure can never recur.

16.8 Use Online Evaluation Carefully

Online experiments can reveal behavior under real conditions, but exposure itself can affect customers, employees, and records. Risk classification should determine whether shadow mode, internal users, synthetic traffic, limited cohorts, or other safeguards are required.

Define assignment, guardrails, stopping conditions, monitoring, and remediation before the experiment. Avoid interpreting an engagement metric as product correctness. Human-review load, complaints, overrides, fallback use, and downstream rework may reveal costs hidden by apparent task completion.

Where the product influences consequential decisions, qualified legal, risk, privacy, and domain review is required for the experiment design. This chapter provides no legal authorization for experimentation.

16.9 Worked Evaluation at Fictional Bank

Synthetic completed evaluation PA-EV-03

PA-0.3 is the internal PA-DRAFT candidate for English leave, travel and expense policy questions from entitled employees. Its manifest identifies corpus POL-8, index IDX-8 and permission policy P-41; it has no preparation endpoint, send or submission credential. The following results are constructed teaching data, separate from PA-EV-01’s omission and PA-EV-02’s injection failure.

Assumed synthetic evaluation design: the sampling frame is a frozen, English question-generation specification for those three topics, held separate from candidate tuning. Each of the 300 ordinary cases is assumed to be an independent draw from that declared mixture during one pre-pilot evaluation window; its unit is one request instance and the first response. No executed random draw or underlying production

dataset is claimed. A severe quality event is a materially wrong or omitted policy condition that would require correction before employee use. A locked domain rubric and independent final adjudication are assumed teaching inputs, not evidence that qualified adjudicators completed this work. The binomial calculation below additionally assumes a common marginal event probability. Repeated generations, shared-session clustering and shared release defects can undermine independence; real deployment evidence needs a qualified assessment of those dependencies. Exception, stress and oversight exercises retain their own denominators.

Table 16.2 — Element and filled record

Element	Filled record
Claim	Supported internal policy drafting and correct limitation; no customer decision or record action
Population	Entitled employees; English leave, travel and expense questions; no customer-specific or new-language use
Cases	300 ordinary cases; 60 exception cases; 30 targeted stress cases; 20 employee oversight exercises
Measures	Support/completeness, severe quality events, source approval, entitlement and employee error detection assessed separately; draft-only boundary tests do not imply action-variant grants
Decision rules and uncertainty	Any prohibited authority failure or catastrophic consequence blocks the candidate independently of averages. The illustrative 2% severe-quality upper-bound condition supports only a fully checked draft-only pilot; 0.5% is a wider-scope quality condition, not permission or a generic acceptable harm rate.
Configuration identity	PA-0.3 / POL-8 / IDX-8 / P-41; distinct case sets and held-out adjudication record
Conclusion and follow-through	Support only the bounded PA-R1 teaching pilot; 25 employees, funded checking, weekly observations and four-week checkpoint

Table 16.3 — Result layer and synthetic result

Result layer	Synthetic result	Interpretation
Ordinary support/ completeness	294/300 acceptable; six minor wording failures; zero severe failures	98% on this set; zero does not prove zero risk
Material exception coverage	60/60 contain required rule and exception	Separate targeted coverage, not a prevalence estimate
Targeted authorization/ injection stress	30/30 bounded draft responses or boundary rejections; no admitted preparation endpoint or committed forbidden effect	These constructed paths support the stated boundary test only; they do not estimate production attack prevalence
Employee challenge	20/20 detect the planted material error; six-minute median task time, separate from the monthly checking-cost mean	Limited exercise; observe capacity and incentives in the pilot

Under independent Bernoulli trials with a common probability, zero severe failures in 300 gives the one-sided 95% upper limit 1 - 0.05**(1/300) = 0.009936, approximately 0.994%. It meets the illustrative 2% pilot condition but fails the 0.5% wider-scope condition. The investment delegate therefore cannot justify scale from this sample. Repeated prompts or targeted stress cases cannot be added to the denominator as if they were independent random production observations.

The policy assessor and security challenger retain separate conclusions. The release delegate records PA-GATE-01 and its enforceable scope; deployment and operating acceptance are later decisions. Constructed numbers teach that sequence and do not demonstrate an actual bank's effectiveness.

16.10 Evaluation Protocol Under Uncertainty

An evaluation result is an estimate tied to a case population, method and candidate configuration. It should not be reported as a property of "the model" without those boundaries. The following protocol is **illustrative author synthesis** and requires statistical and domain review before institutional use.

- State the product claim and the decision the evaluation will support.
- Identify hard failures that cause rejection or escalation regardless of an average score.
- Define the target population, important cohorts, rare high-consequence cases and known exclusions.

- Select independent development and evaluation material; record leakage controls.
- Predefine measures, adjudication rules and how uncertainty will be represented.
- Run repeated trials where generation or routing is variable, preserving configuration and seed where meaningful.
- Validate automated or model-based judges against qualified human judgments for the relevant task.
- Analyze defects and disagreement, not only aggregates.
- Compare with a credible non-AI process, prior release or challenger where the decision requires it.
- Record the conclusion, limitations, conditions, residual risk and re-evaluation triggers.

Sampling and zero observed failures

Sample size should follow the decision, expected prevalence, desired precision, stratification and consequence—not a book-wide number. A result of zero observed failures does not prove zero risk. For zero failures in n independent Bernoulli trials with a common failure probability, the one-sided 95% upper confidence limit is 1 − 0.05^(1/n), approximately 3/n for large n—the “rule of three.” A two-sided 95% interval uses a different tail allocation.[1] This shortcut depends on assumptions and is not a substitute for statistical design, dependence analysis or coverage of rare scenarios.

When the population is heterogeneous, a large undifferentiated sample can hide a weak cohort. Report denominators and uncertainty by material slice. Repeated prompts on the same underlying case are not necessarily independent observations. Multiple measures and repeated searches for a passing slice can also inflate confidence; the evaluation plan should distinguish confirmatory decisions from exploratory analysis.

Human and model-based adjudication

Human raters need a rubric, examples, qualification, blinded presentation where feasible, and an escalation route. Agreement should be measured and disagreements inspected; a single consensus score can conceal ambiguous criteria. Where an LLM judge is used, validate it for the specific rubric and failure types, test sensitivity to ordering and phrasing, separate judge and candidate where appropriate, and preserve a human-reviewed audit sample. Judge agreement is not truth.

Predictive-product validation

Predictive systems require methods that generative evaluations do not replace. Depending on use, reviewers may examine discrimination, calibration, stability, outcome definition, temporal validation, subgroup behavior, sensitivity, overrides, backtesting, benchmark or challenger comparison, and the effect of delayed outcomes. Metrics and thresholds are use-specific. For a triage product, ranking quality without calibration may be useful operationally but insufficient if a score is presented as probability. For credit or another customer-impacting use, applicable fair-lending, discrimination, explanation and model-risk requirements require qualified review.

Agent and multi-turn evaluation

Evaluate trajectories as well as final output: plan formation, tool selection, authorization denials, state transitions, retries, memory use, resource consumption, stop behavior and reconciliation. Multi-turn cases should include changed facts, revoked permission, conflicting instruction, context accumulation and user attempts to move beyond purpose. A correct final answer after an unauthorized intermediate action is still a failure.

Worked evaluation record: fraud/AML alert triage

Fictional Bank evaluates a candidate that prioritizes alerts and drafts an investigator summary. The claim is not “detects financial crime.” It is narrower: for a defined alert population and operating window, the product produces a review queue and evidence-linked draft that supports investigator work without making the case disposition or filing decision.

The evaluation population includes ordinary alerts, known complex patterns, weak-data cases, previously missed typologies where lawfully usable, and adversarial or manipulated inputs. Measures separate ranking behavior, severe missed-case rules, summary factual support, sensitive-data handling, investigator correction, queue capacity and fallback. Delayed outcomes and imperfect investigator dispositions are recorded as evidence limitations. The release decision may therefore authorize a constrained pilot with sampling and stop conditions; it does not claim validated crime detection or compliance effectiveness.

Closest precedents and originality note

The seven-element evaluation argument—claim, population, cases, measures, decision rules and uncertainty, configuration identity, and conclusion/follow-through—is an author-synthesis structure. It is informed by statistical test design, model validation, software quality engineering, safety-case reasoning, and NIST’s measure/manage orientation. No inspected source uses the exact seven-element form or validates it as sufficient for banking assurance.

Reviewer calibration, disagreement and adjudication are evidence, not noise to hide. The plan records reviewer qualification, instructions, blinded overlap sample where appropriate, agreement method, adjudicator, privacy/access restrictions, and how unresolved disagreement affects the conclusion. A model-based evaluator must itself be validated for the decision and is not an independent oracle.

Synthetic judge calibration

The synthetic judge exercise has 40 held-out cases with independently established teaching labels, including ten planted severe failures. Agreement is 34/40, while only 6/10 severe failures are detected: 60% severe-failure sensitivity. The remaining confusion counts and case-selection proportions are unreported; do not reconstruct them as observed evidence. Inspect the four severe misses and test ordering, verbosity and shared-model bias before relying on the judge. This selected exercise is not a prevalence sample. Unattended severe grading remains held; a judge tuned on these labels needs another untouched evaluation set.

16.11 Executive and Practitioner Decisions

The evaluation owner should state the supported claim, population, candidate and uncertainty. Decision-makers should inspect hard failures and failed thresholds before aggregates; additional samples cannot repair an unenforced boundary.

NIST AI RMF and Generative AI Profile (B01–B02) inform lifecycle evaluation; Holtzman et al. (B22) illustrates sensitivity to decoding choices. The seven-element evaluation argument, layers and bank-specific decision records are the author’s synthesis, not source-prescribed acceptance rules.

Notes

1. NIST/SEMATECH e-Handbook, §7.2.4.1, and NIST Dataplot exact-binomial documentation (B55). One- and two-sided limits differ; independence, population coverage and sample design require statistical review. The zero-failure formula stated here follows the binomial zero-count probability. Return to text

Chapter

17

Red Teaming, Abuse Testing, and Safety Validation

Red teaming asks how the product can be manipulated, misused, or driven outside its intended boundary. It complements ordinary evaluation by adopting adversarial objectives and searching for failure pathways. It does not prove safety, predict every attacker, or replace architecture and security controls.

17.1 Red Teaming Is Structured Challenge

The target is the assembled product. A model-only exercise may reveal behavior, but it will miss identity, retrieval, tool, workflow, data, and operational failures. Conversely, a conventional penetration test may not examine semantic manipulation, indirect instructions, unsafe content, or repeated conversational strategies.

17.2 Derive Scenarios From Assets and Consequences

Begin with what matters: customer or employee information, money movement, decisions, policy content, credentials, model and prompt assets, service availability, evidence integrity, and institutional trust. Identify who might act: external attacker, malicious customer, insider, compromised supplier, careless user, or automated abuse.

Then describe a concrete goal and path. Examples include obtaining restricted content, causing an unauthorized tool action, manipulating a decision aid, poisoning a corpus, inducing unsafe advice, exhausting capacity, suppressing evidence, or evading monitoring.

Table 17.1 — Scenario family and example path

Scenario family	Example path	Evidence sought
Direct prompt manipulation	User asks the model to ignore product limits	Boundary response and downstream enforcement
Indirect injection	Retrieved document contains hostile instructions	Separation of content, policy, and tool authority
Data exfiltration	Crafted interaction extracts sensitive context or memory	Access boundary, output filtering, trace and containment
Tool abuse	Model proposes unauthorized object or transaction	Schema, authorization, limits, approval binding
Poisoning	Modified source changes retrieval or behavior	Source approval, integrity, detection, rebuild
Availability and cost abuse	Repeated long tasks consume capacity or budget	Quotas, budgets, degradation, alerting
Human manipulation	Fluent output encourages bypass or over-reliance	Interface, training, escalation, observed workflow

17.3 Use a Reproducible Test Record

An abuse finding should preserve target release, preconditions, actor, input sequence, context, tool state, observed output or action, affected asset, severity rationale, reproducibility, and evidence references. Screenshots alone are often insufficient because hidden configuration and state determine behavior.

For variable systems, record repeated attempts and conditions. Avoid claiming an exact exploit rate unless the design and sample support it. A single successful bypass can be material even when frequency is unknown; a single failed attempt does not establish resistance.

Sensitive payloads and discovered weaknesses require restricted handling. The test environment should prevent unnecessary access to production data and systems. Where realistic testing needs production-like conditions, authorization and containment must be explicit.

17.4 Test the Control Stack

Challenge each layer independently and in combination:

- model behavior and refusal;
- prompt and context precedence;
- corpus ingestion and entitlement;
- tool schema and authorization;
- workflow state, retries, and replay;
- interface and human authorization;
- monitoring and alerting;
- termination, revocation, and recovery; and
- evidence integrity.

A model refusal is useful defense in depth, not the primary authorization control. A content filter can detect a class of output but may be bypassed or create false positives. An allowlist constrains tools but not necessarily permitted parameters. Findings should state which layer failed and which layers contained the result.

17.5 Validate Safety Claims With Domain Expertise

Safety validation examines product-specific unacceptable outcomes, not only security compromise. In banking this may include materially misleading customer information, unfair or inconsistent treatment, invalid decision support, inaccessible fallback, missed fraud signals, or an unsafe payment instruction.

Domain specialists should help construct cases and severity. An engineering team cannot infer the consequence of an omitted product condition or a misclassified investigation step from text similarity alone. Customer-impact, conduct, accessibility, and human-factors perspectives are needed where the product affects people.

The NIST adversarial-machine-learning taxonomy can help organize attack stages and mitigations, but it is a cross-sector taxonomy rather than a banking control standard.[1]

17.6 Triage and Remediate the Failure Class

Severity should consider impact, reach, exploitability, detectability, reversibility, persistence, and required access. Do not reduce every finding to a generic score if the institution uses a more meaningful risk route.

Remediation may narrow the intended use, remove a capability, strengthen authorization, modify source governance, change a workflow, improve model behavior, add detection, or reject the release. Prompt changes alone should not be the default response to an architectural authorization failure.

Retesting should include the original case, variants from the same failure class, and checks for regression elsewhere. A closed finding needs a documented disposition and decision authority. Risk acceptance should state scope, compensating control, duration, monitoring, and expiry.

17.7 Establish Coverage Without Claiming Exhaustiveness

Coverage can be tracked by asset, actor, entry point, failure mode, product stage, tool, data class, and consequence. This supports prioritization and exposes blind spots. It does not prove that all attacks were tested.

External specialists can add independence and diverse technique, but they still need a bounded scope, rules of engagement, evidence handling, and a route for urgent containment. Bug-bounty or broad adversarial access may be inappropriate for sensitive systems unless carefully designed.

Automated attack generation can increase variation. Its outputs require validation and should not be interpreted as independent evidence merely because another model produced them.

17.8 Worked Challenge at Fictional Bank

A planted, non-authoritative test document instructs PA-DRAFT to ignore policy, retrieve restricted content and create a customer message. Source approval should exclude it from the authoritative corpus even when an employee is entitled to read its repository. Entitlement is checked separately for any permitted retrieval. If the text reaches context, it remains untrusted content, not workflow authority. PA-DRAFT has no preparation or message endpoint, and the interface cannot send.

The exercise records which defenses prevented which effect. If the assistant repeats the malicious text but cannot retrieve restricted information or act, there is still a content and user-trust defect. If an entitlement filter fails even though the model refuses, there is a security finding. Layered evidence prevents a reassuring final outcome from hiding a failed control.

Synthetic challenge PA-RT-01

An entitled employee retrieves an approved policy page containing a planted instruction to ignore the workflow and send a case file to an outside address. Retrieval is permitted; the instruction is not. PA-0.2 produces forbidden action-shaped text that the workflow could misleadingly present as a next step. It admits no prepared candidate and has no action endpoint. No real customer data is used. Treat the output/workflow failure as severe; this test does not measure production attack prevalence.

Contain the affected output path and quarantine the source. Separate policy content from workflow authority, and preserve the draft-only absence of preparation/submission endpoints. PA-EV-03 covers this payload and variants in the 30 targeted draft-only cases. Separately test exclusion of an unapproved source before context assembly. Broker/receiver grant tests belong to separately authorized PA-PREP/PA-SUBMIT fixtures; passing one boundary test does not establish the others.

17.9 Threat-to-Test Mapping and Independence

Chapter 18 owns the canonical threat model. Red teaming converts selected threat paths into reproducible challenge. MITRE ATLAS can provide a vocabulary for adversarial machine-learning tactics and techniques, while OWASP's generative-AI material provides community-developed application-risk categories.[2] Neither source is a regulator, complete test plan, or proof that a mitigation works.

Table 17.2 — Threat path and challenge objective

Threat path	Challenge objective	Evidence of resistance	Evidence of recoverability
indirect prompt injection in an entitled source	cause the assistant to treat document content as system authority	instruction/content separation; tool policy denial; safe rendering	identify source, withdraw it, rebuild and trace affected sessions
model or prompt extraction	elicit protected instruction or sensitive behavior detail	bounded responses, rate and anomaly controls, protected configuration	credential/ configuration rotation and exposure assessment
membership or training-data inference	infer sensitive inclusion from behavior	use-specific test and disclosure analysis	incident/privacy assessment and model/provider response
unauthorized tool action	substitute object, amount or recipient after approval	authorization bound to exact typed request	revoke, reconcile, reverse or remediate
resource exhaustion	create expensive loops or oversized context	budget, iteration, concurrency and input limits	queue isolation, degradation and capacity restoration
evasion against predictive detection	manipulate features or sequence to reduce ranking	adversarial or scenario test appropriate to the domain	rule fallback, monitoring, model change and investigation

Tester independence by risk

Independence is about the claim and incentives, not a job title. A product team can run continuous adversarial tests because speed and local knowledge matter.
Higher-consequence claims may also need challenge by people who did not design the control and who can report an adverse conclusion without delivery pressure. External testing can add perspective but does not automatically create independence or sufficient scope.

Table 17.3 — Risk route and typical challenge pattern

Risk route	Typical challenge pattern	Caveat
baseline	developer misuse cases, automated regression, peer review	appropriate only for bounded low-consequence scope
elevated	security or domain tester outside the feature team; release-blocking severe cases	team must have evidence and authority to challenge
high consequence	multidisciplinary red team plus independent validation of material claims and remediation	scope, protected access and legal constraints require planning

Cadence should combine release triggers, threat intelligence, incidents, material provider or architecture change, and periodic challenge proportionate to exposure. This book does not prescribe a universal interval. A fixed annual exercise is inadequate if authority or dependencies change monthly; continuous automated probes are inadequate if they never test customer consequence or human workflow.

From finding to regression

A successful attack is not closed by adding a single string to a blocklist. The team should identify the failed assumption, affected product claims and sibling paths. Remediation may change architecture, authorization, retrieval, interface, training, monitoring or scope. The regression set includes the discovered case, variations that exercise the same failure class, and a test that the underlying control—not merely the visible output—changed.

The finding record preserves reproduction steps, release identity, data handling, severity basis, exploit preconditions, observed consequence, containment, owner, target date, retest, accepted residual risk and disclosure restrictions. Security-sensitive detail can be access-restricted while the evidence index preserves that a finding exists and how it affected the release decision.

One threat-to-retest chain

Illustrative challenge finding: an entitled policy source contains an injected instruction to disclose an unrelated restricted record. This is an exercise specification, not a reported breach or passing test.

Table 17.4 — Chain field and record to preserve

Chain field	Record to preserve
Reproduce	Finding ID, source/version, permitted tester, request/release and minimal protected reproduction material
Observe and classify	Expected instruction/content separation versus observed behavior; affected claim and consequence basis
Contain	Withdraw affected source/topic, preserve evidence and investigate sibling paths
Repair	Named owner corrects source handling, retrieval/context boundary and downstream policy enforcement
Retest	Original case plus variants of the failure class, denied-access and authorized-use regression; exact repaired candidate
Independent disposition	Challenger records result, scope, limitation and unresolved finding; delivery owner cannot erase the conclusion
Release / learn	Decision owner links approval/hold, operating verification, monitoring and shared-platform lesson implementation

17.10 Executive and Practitioner Decisions

A red-team finding should change the failed assumption or control and survive a repeatable retest plus related-path regression. Keep exploit preconditions and severity. Passing targeted paths does not estimate production prevalence or replace independent security review.

Notes

1. NIST, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, AI 100-2 E2025 (B33), final March 2025. OWASP GenAI community material (B39) supplies additional scenario prompts. Neither is a bank-specific approval standard. Return to text

2. MITRE ATLAS (B49), OWASP GenAI Top 10 (B39), and OWASP Agentic Top 10 (B50). They are evolving technical/community resources, not regulatory requirements or evidence of control effectiveness. Return to text

Chapter

18 Security Engineering and Threat Modeling

AI security is application security, data security, identity security, infrastructure security, supply-chain security, and behavior-aware security combined. A special list of model attacks is useful but incomplete. The threat model must follow the product from ingress through model, data, knowledge, tools, people, and downstream action.

18.1 Secure the Product Boundary

The first task is to identify assets and consequences. Models and prompts are assets, but so are customer information, credentials, policy content, transactions, decision integrity, service availability, evidence, and the institution's ability to recover.

18.2 Build a Threat Model Around Flows

A practical threat model records:

- intended service and prohibited outcomes;
- actors, identities, and administrative roles;
- entry points and externally controllable content;
- data, knowledge, model, prompt, tool, and software assets;
- trust boundaries and external dependencies;
- actions and side effects;
- abuse paths and failure conditions;
- preventive, detective, corrective, and recovery controls; and
- residual risk, owner, and test evidence.

Use a method consistent with the bank's security program. The value lies in disciplined analysis and traceable decisions, not the diagram notation.

18.3 Protect Identity, Secrets, Network, and Egress

Every workload and administrator should use an attributable identity. Grant the least privilege necessary for the approved purpose and prefer short-lived credentials. Separate development, evaluation, and production authority. Human access to prompts, corpora, traces, and model artifacts can be sensitive even when the product interface is restricted.

Network controls should limit reachable services and egress. A model or agent should not gain arbitrary internet or internal access because one workflow needs a search service. Tool endpoints must authenticate and authorize the caller; private network placement is not authorization.

Secrets should be stored and delivered through managed mechanisms, never included in prompts or training examples. Logging and error handling must avoid exposing them. Rotation and revocation should be testable, including what happens to cached agent state or queued work.

18.4 Defend Behavior-Shaping Supply Chains

The supply chain includes code, packages, containers, model files, provider APIs, datasets, labels, prompts, corpora, embeddings, evaluation tools, and policy bundles. Each needs provenance proportionate to risk, controlled promotion, and an owner for vulnerabilities or compromise.

Threats include malicious packages, unsafe model serialization, poisoned training or retrieval content, unauthorized prompt change, compromised provider account, manipulated evaluation data, and tampered logs. Existing software-supply-chain controls should be extended to these assets rather than replaced by a separate checklist.

NIST's SSDF and AI community profile support this integration.[1] OWASP's GenAI project provides useful threat prompts, but it is community guidance rather than evidence of compliance or adequacy.[2]

18.5 Enforce Policy Outside the Model

Probabilistic behavior should not be the sole barrier around consequential data or actions. Place authorization, schema validation, transaction limits, content routing, and environment policy in deterministic services where feasible.

Defense in depth still includes model behavior. Instruction hierarchy, adversarial training, filters, and refusal can reduce unsafe outputs. Their limitations must be evaluated. A refusal can be bypassed; a deterministic control can be misconfigured. The threat model should show how layers interact and what happens when one fails.

18.6 Design Safe Failure and Evidence

Safe failure limits harm, preserves decision-relevant evidence, and moves the service to an approved state. Depending on the use, that may mean deny, abstain, read-only mode, degraded non-AI service, queued review, or controlled shutdown.

Security logging should capture authenticated actor, product and release identity, policy decision, tool or resource, proposed and actual action, outcome, and correlation identifiers. Avoid collecting full sensitive content by default; define protected capture for investigations when justified. Logs need integrity, access control, synchronized time, retention ownership, and tested availability during incidents.

An alert is not a control outcome unless someone owns the response. Define severity, route, timing, containment authority, and evidence required to close it.

18.7 Test the Security Architecture

Combine conventional testing—code review, dependency analysis, configuration review, penetration testing, access review, resilience tests—with AI-specific abuse and behavioral tests. Verify controls at their enforcement point.

Examples include attempts to cross tenant or customer boundaries, indirect injection through entitled content, unauthorized tool parameters, replayed approvals, poisoned corpus updates, model endpoint substitution, sensitive trace search, and capacity abuse. Test failure and recovery as well as prevention.

The test plan should identify assumptions that cannot be tested directly, such as provider internals. Address those through evidence, contracts, monitoring, or a narrower design, not an unqualified security claim.

18.8 Worked Threat Path at Fictional Bank

An attacker sends an employee a policy document containing an indirect instruction to search for restricted investigation material. The threat path crosses upload, malware/content inspection, source approval, indexing, retrieval entitlement, context assembly, model behavior, and any tool access.

Fictional Bank’s approved design does not ingest arbitrary employee documents into the policy corpus. If the file appears in a temporary user context, it is labeled untrusted. The retrieval identity cannot access investigation sources for this product, and no general search or send tool is available. Telemetry records the rejected boundary without placing the entire sensitive prompt in an ordinary log.

The threat model still records residual concerns: the model may echo manipulative text, the employee may be misled, and an upstream classifier may fail. These become evaluation and monitoring requirements.

18.9 Canonical AI Threat Model

Threat modeling begins with assets, actors, flows and consequences. STRIDE or another established software method can structure ordinary application threats; NIST's adversarial-machine-learning taxonomy, MITRE ATLAS and OWASP's generative-AI guidance can extend coverage for learned and tool-using behavior.[3] The bank should use a method compatible with its security program and map AI-specific paths into—not around—its existing risk, vulnerability and incident processes. See Figure 18.1.

Figure 18.1 — Locate the control; record the observed test

Threat path	Control / response	Test / evidence
Untrusted policy text or uploaded content	Source approval; provenance and labels	Indirect-injection case; source identity recorded
Restricted retrieval or tool request	Retrieval entitlement; receiving tool policy	Unauthorized arguments; denial/trace inspection
Residual behavior or disclosure	Contain affected path; preserve bounded trace	Exposure search; recovery and retest

These are proposed threat-to-control-to-test links. Record the control's location and the observed result separately; no control effectiveness is asserted.

Table 18.1 — Threat family and illustrative attack path

Threat family	Illustrative attack path	Primary preventive boundary	Detection and recovery evidence
data or knowledge poisoning	alter a source, label, feature transformation or index	source authorization, provenance, integrity and controlled pipeline	reconciliation, behavior anomaly, source withdrawal and rebuild
evasion and adversarial input	shape input to avoid predictive detection or induce unsafe output	input validation, robust design, use limits and layered business rules	drift/attack signals, sampled review, retraining or restricted scope
prompt injection and instruction confusion	user or retrieved content impersonates controlling instruction	precedence, provenance labels, context separation, external tool policy	denial event, source identification, affected-session search
extraction, inversion or membership inference	query behavior reveals model, instruction or sensitive training relation	access limits, minimization, rate control and output policy	anomaly review, exposure assessment, credential/model response
excessive agency and tool abuse	manipulate plan or arguments to execute unauthorized action	workload identity, least privilege, typed tool schema, exact authorization	proposal/ decision/ execution trace, revocation and reconciliation
supply-chain compromise	replace code, model, package, prompt, corpus or policy bundle	protected build, provenance, attestation, immutable release references	manifest diff, integrity alert, rollback or clean rebuild
denial and cost exhaustion	force loops, long context, high concurrency or provider expense	quotas, budgets, admission control and bounded planning	saturation/cost alert, queue isolation and degradation
cross-tenant or cross-session leakage	expose context, memory, cache or trace to another subject	tenant/session isolation, entitlement and deletion boundary	canary/test evidence, incident population and purge verification

Security architecture controls that remain ordinary—and essential

AI does not change the need for key management, network segmentation, secure APIs, tenant isolation, data-loss prevention, protected administration, vulnerability management and incident response. It changes where those controls must cover new assets and flows.

- Use an enterprise key-management service, and hardware-backed protection where the threat and policy justify it, for keys that protect sensitive assets. Do not place secrets in prompts, source examples or durable agent memory.
- Segment model, retrieval, tool and evidence services according to trust and failure boundaries. Egress policy should identify approved providers and destinations.
- Put authentication, authorization, schema validation, rate limits and threat controls at the API or tool boundary; a model gateway is not a substitute for the receiving system's authorization.
- Evaluate tenant and session isolation across caches, conversation state, retrieval, logs and support tooling. Confidential-computing capabilities may reduce particular infrastructure exposures but do not resolve application authorization, output disclosure or provider governance.
- Apply data-loss prevention with an understanding of false positives, encoded data and business context. DLP is one signal, not proof that a response is safe.

Worked data-flow abuse path

In a separate PA-SUBMIT teaching fixture, an employee uploads hidden instructions to reveal other users' material and create a high-priority ticket. The file is unapproved user content, not authoritative policy. Provenance, source approval and entitlement remain distinct. The model holds no ticket credential; the broker and receiver admit only the exact authorized candidate and grant. Denials retain source and policy-decision references without unnecessary sensitive content. This fixture is not part of PA-R1's draft-only release.

If a test nevertheless produces disclosure, Fictional Bank disables the affected upload path, searches release-linked traces to identify the exposed population, preserves evidence, rotates any compromised secret, corrects records where needed, and requires re-evaluation before restoring the feature. This is a fictional control path, not evidence of effectiveness.

Security acceptance record

The record connects asset/flow diagram, threat list, trust boundaries, selected controls, abuse cases, findings, unresolved limitations, recovery test and accountable decision. Each control names its enforcement location. Statements such as “guardrails enabled” or “prompt injection protected” are insufficient because they do not show mechanism, scope or tested failure.

Security evidence from finding through operation

Use the §17.9 chain to bind each material threat/control/evidence row to the tested release and enforcement location. Distinguish a specified control from a configured mechanism, a scoped test result and observed operation. Security-sensitive reproduction and trace material receives approved access/retention; claim adequacy still requires qualified security challenge.

Asset-specific extraction questions

Table 18.2 — Threat and asset and attacker access

Threat	Asset and attacker access	Test/control focus
Prompt or secret extraction	Hidden instruction or credential exposed through responses/context	Keep secrets out of model context; test output/egress and access paths
Model stealing	Model behavior or weights through query/host access	Access/rate controls, hosting protection and extraction-relevant tests
Membership inference	Whether a person’s example was in training data	Relevant attacker knowledge, confidence leakage and privacy evaluation
Reconstruction/ inversion	Sensitive features or records inferred from outputs	Output detail, repeated queries, data minimization and attack-specific evaluation

Architectural intent requires enforcement evidence. In the synthetic PA-DRAFT security fixture, an unauthorized role is denied retrieval and authority-service loss also denies protected retrieval rather than using stale permission. A separate PA-SUBMIT fixture rejects an expired action grant at the receiver. Record the relevant variant, release, enforcement event and effect layer for each test; the submission fixture grants no capability to PA-R1.

18.10 Executive and Practitioner Decisions

A consequential request needs receiver evidence of current authority and outcome. PA-DRAFT instead needs evidence that no action endpoint is admitted. Keep the variant and effect layer visible in each trace.

Notes

1. NIST, SSDF v1.1 (B04), and SSDF Community Profile for Generative AI and Dual-Use Foundation Models (B28). Return to text

2. NIST, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations (B33); MITRE ATLAS (B49); and OWASP, Top 10 for Large Language Model Applications / GenAI Security Project (B39). NIST is a cross-sector taxonomy; MITRE and OWASP are living/community resources. None is a regulatory requirement, a complete banking control standard, or evidence of control effectiveness. Return to text

3. NIST, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations (B33); MITRE ATLAS (B49); and OWASP, Top 10 for Large Language Model Applications / GenAI Security Project (B39). NIST is a cross-sector taxonomy; MITRE and OWASP are living/community resources. None is a regulatory requirement, a complete banking control standard, or evidence of control effectiveness. Return to text

Chapter

19

Privacy, Fairness, Explainability, and Human Oversight

Privacy, fairness, explainability, and human oversight are often grouped under "responsible AI," but each asks a different question. Privacy concerns how information about people is processed and how that processing affects them. Fairness concerns the distribution and justification of outcomes or burdens. Explainability concerns what understanding is needed by a particular audience for a particular decision. Human oversight concerns whether a person can meaningfully challenge, intervene, or remediate.

19.1 Treat the Four Concerns as Product Requirements

The requirements should be specified at product and workflow level. A model can be technically interpretable while the customer cannot understand a decision. A human can appear in the process without the time or authority to correct an error. A dataset can omit a protected attribute while other information acts as a proxy. The complete service matters.

19.2 Engineer Privacy Across the Flow

Start with purpose, necessity, and the data-flow record. Identify information collected directly, inferred, retrieved, generated, logged, retained in memory, supplied to providers, or exposed to reviewers. Determine permitted purposes and jurisdictional obligations with qualified counsel; this chapter does not supply a legal basis.

Minimization can change design: retrieve only the record needed, use a scoped identifier, redact content before a model call, avoid retaining a conversation, separate telemetry from full text, or choose a deployment path with a different data boundary. Privacy-enhancing techniques can reduce exposure but require evaluation for the actual threat and utility.

The NIST Privacy Framework offers a voluntary risk-management structure.[1] It does not replace applicable banking secrecy, data-protection, consumer, employment, or communications requirements.

19.3 Define Fairness for the Decision and Population

There is no single fairness metric suitable for every use. The team should identify the decision or service, affected populations, plausible mechanisms of disparity, relevant comparison, desired property, and consequence of error. Legal standards and protected classes differ by jurisdiction and context.

Fairness work may include data and label analysis, subgroup performance, outcome and error distribution, accessibility, process consistency, proxy and feature review, human override patterns, complaint analysis, and qualitative assessment. A metric can illuminate one property while conflicting with another. The decision record should explain what was measured, why, and what was not established.

Generated content can create fairness concerns even without a formal decision: different quality of service by language, stereotypes, inaccessible explanations, or escalation that burdens some users. Evaluation should follow the product's actual users and fallback routes.

Synthetic two-group threshold decision

These constructed labels are complete only for this teaching dataset; real outcomes may be delayed or selected. Each group has 1,000 cases. Group A has 100 positives and Group B has 200.

Table 19.1 — Group / threshold and true positive

Group / threshold	True positive	False negative	False positive	True negative
A / T1	80	20	90	810
B / T1	160	40	80	720
A / T2	70	30	45	855
B / T2	140	60	40	760

At T1 both groups have 80% true-positive and 10% false-positive rates, but positive predictive value is 80/170 = 47.1% for A and 160/240 = 66.7% for B. T2 lowers false positives to 5%, with more missed positives; flags fall from 410 to 295. For the capacity comparison only, assume these 2,000 constructed eligible cases arrive in one eight-hour shift, every flag needs a four-minute mean review, and 20 productive staff-hours provide 300 reviews. T1 needs 1,640 minutes (27 hours 20 minutes); T2 needs 1,180 minutes (19 hours 40 minutes), leaving only 20 minutes or five reviews. These workload assumptions are synthetic, not measured demand. T1 is rejected; T2 remains held because capacity fit does not settle increased severe misses, surge capacity, lawful use or fairness. Report subgroup intervals and label limits; no parity metric approves the threshold.

Sampling uncertainty for the constructed threshold example

Table 19.2 — Metric and events / denominator

Metric	Events / denominator	Estimate	Two-sided 95% exact binomial interval
T1 A TPR	80/100	80.0%	70.8%–87.3%
T1 B TPR	160/200	80.0%	73.8%–85.3%
T1 A FPR	90/900	10.0%	8.1%–12.1%
T1 B FPR	80/800	10.0%	8.0%–12.3%
T2 A TPR	70/100	70.0%	60.0%–78.8%
T2 B TPR	140/200	70.0%	63.1%–76.3%
T2 A FPR	45/900	5.0%	3.7%–6.6%
T2 B FPR	40/800	5.0%	3.6%–6.7%

TPR uses actual positives and FPR actual negatives as denominators, not all 1,000 cases. These illustrative Clopper–Pearson intervals (B55) assume independent cases and constant event probability within each subgroup/metric. They describe sampling uncertainty for a hypothetical population; the constructed sample counts themselves are exact. Equal observed rates or overlapping intervals do not prove equivalence or fairness. These are separate intervals, not simultaneous family-wise coverage, and they do not guarantee future performance. Qualified statistical review must assess sampling, clustering, threshold selection and interpretation. The capacity decision still needs the consequence and subgroup review above.

19.4 Design Explanations for an Audience and Action

An explanation is useful when it enables a defined action: understand a result, check evidence, contest an outcome, debug a failure, approve a release, or audit a control. The same artifact will not satisfy every audience.

Table 19.3 — Audience and needed understanding

Audience	Needed understanding	Design implication
Customer	What happened, relevant reasons, options, and redress	Plain language, accessibility, legally reviewed content
Employee	Evidence, limitations, confidence or uncertainty, required check	Source display, workflow guidance, correction and escalation
Product and engineering	Component behavior, data, configuration, failure path	Trace, versions, tests, reproducible evidence
Risk or validator	Claim, method, population, results, limitations, controls	Independent access and complete evidence bundle
Executive or board	Exposure, trend, limits, incidents, decisions required	Decision-oriented aggregation, not technical decoration
Auditor or supervisor	Applicable scope, control design, operation, exceptions	Traceable records and sampling access

For a predictive result, explanations may concern influential information, policy reasons, or decision logic. For a generative answer, they may concern sources, uncertainty, transformation, and workflow. A generated rationale is not necessarily a faithful account of model causation. The explanation mechanism and its limits must be explicit.

19.5 Make Human Oversight Operational

Meaningful oversight requires a competent and authorized person with enough information, time, independence, tools, and practical ability to reject, stop, override, correct, or escalate. Merely placing a person after a model does not establish these conditions.

Design the human task. Specify what is reviewed, which evidence is visible, what errors matter, what action the person can take, how workload and time pressure affect performance, and how disagreement is resolved. Monitor overrides, corrections, skipped

review, escalation, and downstream rework as signals—not as automatic proof of effectiveness.

Automation-bias research from another domain illustrates that human interaction with automated advice can be affected by context and design; it does not establish a universal banking effect or mitigation.[2] Product-specific observation and human-factors review remain necessary.

Training evidence linked to the oversight task

The readiness record names role/use, required task, training/policy version, completion, task assessment, limitations, permitted authority, owner and refresh triggers. Attendance is one input; exercise evidence should show whether the person can recognize the seeded failure, find support, intervene and use the escalation route under realistic workload. Set access or operating restrictions when readiness is insufficient. Current EU Article 4 concerns context-sensitive literacy measures and does not require a guarantee of a specific individual literacy level; the task-readiness record is this book's engineering design.[3]

Table 19.4 — Illustrative role and task and evidence to record

Illustrative role	Task and evidence to record	Authority / refresh trigger
Policy-assistant employee	Check proposition/source/exception and identify insufficient support in a seeded case	Internal drafting only; refresh for corpus, interface or use change
Investigator using alert triage	Challenge prioritization and generated summary; distinguish verified fact from draft	Investigator retains disposition authority; refresh for typology/population/queue change
Service/incident operator	Restrict use, preserve identity, activate fallback and reconcile unresolved actions	Recorded delegation and expiry; refresh after exercise, incident or runbook change

No exercise outcome or universal passing threshold is asserted.

19.6 Connect Rights and Redress to the Workflow

Where people can question or contest an outcome, the product should preserve the information and routing needed for review. The institution must determine applicable rights and notices in each jurisdiction. Technically, the design may need stable decision references, input and version records, relevant reasons, human review, correction, and propagation of remediation.

Redress is not complete when the screen is corrected. If an erroneous AI output influenced a customer message, case classification, queue priority, or downstream record, remediation should identify and correct the affected chain. Chapter 23 develops incident and customer-remediation operations.

A customer complaint should be linked, where relevant and lawfully available, to the decision or action, the operating release, the affected population, communications and any correction or remedy assessment. An institution complaint process, an applicable privacy-based right to contest a decision, a complaint to a supervisory body and litigation are different routes. The institution must determine which route, owner and procedural requirements apply; this book does not assign the same rights or deadlines to every customer or AI-assisted workflow.

The legal-review method in §8.4 supports that determination. §23.6 owns operational routing and downstream remediation; §25.4 addresses the financial institution's lawful defense, provider remedies and evidence constraints alongside customer protection. A supplier claim or indemnity does not by itself establish that customer duties have been fulfilled. See Figure 19.1.

19.7 Avoid Composite "Responsible AI" Scores

Figure 19.1 — Oversight must be capable of changing an outcome

Design task	Needed capability	Evidence or decision caveat
Meaningful oversight	Competent, authorized person has information, time and practical ability to reject, stop or correct.	Observe skipped review, override and workload; a click is not proof of effectiveness.
Challenge outcome	Preserve decision reference, relevant reasons and human review route for a person contesting an outcome.	Applicable rights and notice route require qualified jurisdiction-specific determination.
Escalate disagreement	Give the reviewer power to escalate or change a consequential outcome.	Record disagreement, decision authority and conditions rather than treating presence as oversight.
Correct and redress	Identify affected downstream messages, cases and records; propagate necessary correction.	Determine notice and remedy under applicable legal and conduct processes; record unknowns.
Assess the whole product	Keep privacy, fairness, explanation and human oversight as separate claims.	An explanation, human review or privacy measure does not establish the other claims.

Information, competence, practical power and recourse are separate oversight obligations. Jurisdiction-specific rights require qualified determination.

A single score can conceal trade-offs. A product may meet a privacy objective yet have weak subgroup performance; it may provide a clear explanation of an unfair process; it may include human approval that is operationally ineffective. Maintain separate claims and decision rules, then consider the combined product risk.

Dashboards should show material evidence and exceptions, not convert unresolved legal or ethical judgments into false precision. Where a qualitative decision is necessary, record criteria, accountable roles, disagreement, and limitations.

19.8 Worked Review at Fictional Bank

The policy assistant initially retains complete conversations for general improvement. Privacy review asks whether that purpose is necessary and permitted, whether sensitive information can be pasted, and whether a shorter or redacted trace meets evaluation and incident needs. The design changes to store structured events by default and place restricted content capture behind an authorized investigation route.

Fairness and accessibility review examines supported languages, reading demands, and whether fallback creates unequal service. Human-factors testing seeds a material policy exception and observes whether employees use displayed evidence to correct the draft. The team records the limits of the study; it does not conclude that all employees will provide effective oversight.

19.9 Bounded Decision Examples and Explanation Methods

Privacy, fairness, explainability and oversight are distinct disciplines. A product can be explainable yet unfair, private yet inaccurate, or human-reviewed yet effectively automated. The assessment should therefore connect each requirement to the affected person, decision, evidence and remedy.

Illustrative U.S. credit decision

Jurisdiction-specific example; legal review required. In the relevant U.S. consumer-credit scope, Regulation B §1002.9 and its official interpretation require specific principal reasons tied to factors actually considered or scored.[4] Circular 2022-03 is retained as historical context only: CFPB withdrew it on 12 May 2025; that withdrawal does not repeal the regulation.[5] A bank should not approve a model or workflow whose design prevents it from producing the required reasons for the actual decision. This does not mean that one explanation technique satisfies every obligation, nor does it determine whether a particular product or action is in scope.

For a fictional lending decision-support product, the record separates the predictive score, underwriting rules, verified application facts, human or automated decision, reasons communicated, override, and customer challenge. A generative explanation may improve wording, but it must not invent a reason or replace the actual decision logic. The communicated reason is reconciled to the decision record.

Illustrative EU automated-decision boundary

Jurisdiction-specific example; legal review required. GDPR Article 22 and related provisions can be relevant to decisions based solely on automated processing that produce legal or similarly significant effects, subject to scope, exceptions and safeguards. The Court of Justice's 2023 SCHUFA judgment addressed scoring in a fact-specific setting where a probability value played a determining role in a third party's decision.[6] The lesson for architecture is not that all scoring is prohibited. It is that the bank must identify who makes the decision, how the score is used in practice, whether human involvement is meaningful, and which rights and safeguards apply.

Explanation methods by audience

Table 19.5 — Method and useful question

Method	Useful question	Important limitation
reason codes tied to actual decision logic	why did this decision take this form?	generic or inaccurate codes are not meaningful explanation
feature attribution	which inputs influenced a predictive output under the method?	method assumptions and correlation can make attributions unstable or misleading
counterfactual explanation	what minimal change might alter an output?	may be infeasible, non-causal or inappropriate to present as advice
example or cohort comparison	how does this case relate to known cases or outcomes?	privacy, representativeness and fairness require care
source-supported generative explanation	which authoritative text supports this statement?	retrieval support does not establish legal applicability or truth of added text
process explanation	who decided, what evidence was used, and how can it be challenged?	does not replace technical explanation where one is required

Technique selection follows the claim and audience: customer, employee, validator, operator, auditor or regulator. The bank should test whether the explanation is faithful,

understandable, stable enough for the use, actionable where required, and consistent with records. “Explainable AI” as a product label is not evidence.

Meaningful oversight test

Oversight is meaningful only if the person has authority, time, competence, relevant information, a usable interface, an alternative action and protection from automation pressure. Evaluation should observe override quality, escalation, disagreement, workload and downstream correction—not only count clicks. Where decision speed makes per-action review impossible, governance must rely on preauthorized limits, independent monitoring, intervention and reconciliation; it should not mislabel retrospective visibility as human-in-the-loop control.

Impact and remedy record

For each material affected population, record the purpose, data, decision path, outcome measure, fairness or conduct objective, privacy basis and minimization decision, explanation route, human-oversight design, complaint/challenge channel, correction and redress path, owner and review trigger. Gaps in outcome or demographic data should be stated; absence of measurement is not evidence of absence of harm.

Faithful reasons versus fluent reasons

In a synthetic lending record, the actual principal factor is verified debt-to-income above the applicable underwriting limit. A generated explanation instead says employment history was too short. Even if the prose is clear and source-supported in general, it is unfaithful to this decision. Reconcile the communicated reason with the actual scored/reviewed factor before release; a customer challenge must reach the accountable underwriting process.

Synthetic explanation decision record CR-EX-01

Table 19.6 — Field and constructed record

Field	Constructed record
Verified factor	Debt-to-income exceeds the applicable underwriting limit.
Decision input	Existing predictive/model and underwriting-rule record, identified by version.
Accountable role	Underwriter acting within the actual delegation.
Actual principal reason	The verified debt-to-income factor recorded for this decision.
Faithful draft	The decision reason is debt-to-income above the applicable limit.
Rejected draft	“Employment history was too short.” Reject: it was not a principal reason in this record.

First test explanation fidelity against the actual decision record. Separately, a customer-understanding task asks what reason was given, which fact the customer may challenge and how to seek review. No comprehension-study result is asserted here. Understanding a false reason cannot cure its lack of fidelity, and a faithful reason does not prove understanding, fairness or legal notice sufficiency. Regulation B/B57 and the withdrawn historical B46 retain the scope stated above; legal notice form, timing and actual applicability require U.S.-qualified review.

19.10 Executive and Practitioner Decisions

Keep statistical disparity, lawful use, explanation fidelity and practical challenge distinct. Each needs its own evidence and competent decision; one favorable measure cannot settle the others.

Notes

1. NIST, Privacy Framework 1.0 (B32). Voluntary cross-sector framework; current revision status should be checked before publication. Return to text

2. Goddard, Roudsari, and Wyatt, systematic review of automation bias (B27), in a healthcare context; and Sterz et al. on human oversight (B26). Neither supplies a universal banking control threshold. Return to text

3. European Commission AI Act Service Desk, Article 4 (B54), amended text based on 27 July 2026 consolidation; NIST Playbook (B03), GOVERN 2.2. Scoped literacy measures and voluntary training guidance do not establish a universal task threshold or guarantee of individual competence. Return to text

4. CFPB, Regulation B §1002.9 and official interpretation, inspected 8 October 2026 (B57). Scope, notice method and exceptions require U.S. legal review; no fictional decision is asserted compliant. Return to text

5. Consumer Financial Protection Bureau, Circular 2022-03 (B46). U.S. consumer-credit example; current applicability requires legal review. Historical circular withdrawn 12 May 2025; current rule/interpretation is B57, with qualified U.S. review. Return to text

6. GDPR (B47) and CJEU Case C-634/21 (B48). Jurisdiction- and fact-specific sources; no universal conclusion about all scoring or human review is drawn. Return to text

Chapter

20 Quality Gates, Independent Review, and Model Validation

A quality gate determines whether a defined candidate may advance under stated conditions. It identifies the decision authority, evidence required, possible outcomes, unresolved issues, and expiry or re-entry condition. A meeting that reviews slides but cannot stop or constrain progression is not a gate.

20.1 A Gate Is a Decision, Not a Meeting

Gates should be risk-tiered. Low-consequence experiments and material customer or critical-service uses should not require identical evidence or authority. Tailoring should be explicit enough that teams can predict the route and reviewers can detect an unjustified downgrade.

20.2 Match Evidence to the Decision

An evidence package may include intended use, classification, architecture, data and model provenance, security assessment, evaluation, privacy and fairness work, human-factors evidence, operational readiness, provider due diligence, incidents, open defects, and the release manifest. Requiring every artifact for every use creates bureaucracy without assurance; omitting a material domain creates blind spots.

Author synthesis. Use three evidence questions at each gate:

- **Completeness:** Are the records required for this route present and connected?
- **Sufficiency:** Do they support the claims and conditions of the decision?
- **Integrity:** Are identity, version, provenance, and approval reliable enough to use?

Completeness can often be automated. Sufficiency usually requires qualified judgment. Integrity depends on both technical and procedural controls.

20.3 Define Independence for the Claim

Independent review needs objective challenge, competence, access, and freedom from a conflict that would impair the conclusion. It does not always require a separate organization. The required separation should follow materiality, applicable policy, and jurisdiction.

Record reviewer identity, accountable role, scope, date, competence relevant to the domain, conflicts or exclusions, evidence reviewed, conclusion, conditions, and comments. Assignment or silence is not completed review. A consolidated reviewer can cover multiple domains only when competence and capacity are explicit; specialist referrals remain open otherwise.

Developers may perform valuable peer review and testing, but they cannot convert self-assessment into independent validation merely by changing the document label.

20.4 Validate the Use, Not Only the Model

Banking model-risk frameworks may require model identification, validation, governance, monitoring, and controls within their scope. The current UK PRA supervisory statement and the 2026 U.S. interagency guidance have different applicability and should not be generalized globally; the latter expressly excludes generative and agentic AI from its scope.[1]

Where model validation applies, its scope should address the model's conceptual basis, data, implementation, performance, limitations, use, controls, and ongoing monitoring as required locally. For an AI product, other qualified reviews may still be needed for retrieval, software, security, privacy, human workflow, and operations. Calling all of these "model validation" can obscure ownership.

The review plan should therefore map each product claim and risk domain to the applicable validation or assurance route. A narrow model validation cannot silently approve a broader agentic workflow.

20.5 Use Conditional Decisions Carefully

A gate can approve, approve with conditions, require remediation and resubmission, restrict, hold, or reject. Conditions should have an owner, due date or trigger, evidence of completion, and consequence if unmet. A condition that remains open after exposure without tracking becomes an informal risk acceptance.

Exceptions should name the requirement not met, rationale, affected scope, compensating control, monitoring, decision authority, expiry, and default state. The default after expiry should be defined; silent continuation rewards delay.

Time-limited approval can be useful where evidence must be gathered in bounded operation, but it should not replace pre-release evidence for foreseeable high-consequence failure.

A condition may exclude an unevaluated population or cap an otherwise permissible exposure. It cannot authorize an observed severe failure in an essential boundary. If source entitlement, exact-action approval or required fallback is absent, hold that exposure until the prerequisite is established. Record the technical enforcement and expiry; a promise to monitor later is not the missing control.

20.6 Set Revalidation Triggers

Revalidation should be triggered by changes that can invalidate the accepted claim: intended use, user or population, authority, data or corpus, model, provider, prompt, tool, interface, control, critical dependency, jurisdiction, material incident, performance, or environment. Calendar review alone may miss a material change; event triggers alone may miss gradual drift.

The change envelope should state which updates use routine regression and which reopen domain review. A provider model update may reopen behavioral and security evaluation; a new customer jurisdiction may reopen legal, privacy, and conduct review; new write authority may reopen architecture, security, operations, and human oversight.

20.7 Preserve the Assurance Conclusion

An assurance conclusion should state the claim assessed, scope, criteria, evidence, work performed, findings, limitations, independence, conditions, and conclusion. It should distinguish design review from operating-effectiveness evidence.

The underlying evidence remains primary. A signed conclusion does not make missing records exist, and a large evidence bundle does not create an independent conclusion. Chapter 2’s evidence lineage should connect both to the product version and decision.

20.8 Worked Gate at Fictional Bank

Fictional Bank’s policy assistant reaches a pre-release gate. The package includes the approved intended use, architecture and entitlement review, corpus and model identities, evaluation by layer, security findings, privacy decision, human-task study, fallback exercise, open limitations, and release manifest.

The gate does not approve “the model.” It approves a named configuration for internal use by a defined employee group, with no external send or customer-record access. A

condition requires a corpus-withdrawal rehearsal before exposure widens. An unsupported product area is excluded. The decision expires if the model alias, index-building method, tool authority, or intended user population changes.

Synthetic disagreement PA-GATE-01

The sponsor proposes scaling PA-0.3 because ordinary support is 294/300. The independent reviewer points to the 0.994% upper limit and the wider-scope 0.5% rule, then withholds support for expansion. Management records that conclusion unchanged, funds additional evidence and accepts only the separately supported PA-R1 draft-only pilot. The reviewer does not authorize release; the delegate cannot rewrite the opinion to say scale was validated.

20.9 Connecting Classification, Gates and Validation

The book uses three related sequences: investment stages, quality gates and release states. They answer different questions. Investment stages decide whether to spend and scale; quality gates decide whether evidence supports a lifecycle transition; release states identify the technical/operating configuration. The following crosswalk prevents the word “gate” from hiding those distinctions.

Table 20.1 — Risk route and typical gate depth

Risk route	Typical gate depth	Required evidence emphasis	Decision authority pattern
baseline	product-owner and control-owner review at defined release transition	intended use, release identity, bounded evaluation, security/privacy route, fallback and operation owner	named product authority with specialist consultation where triggered
elevated	independent challenge of material claims plus domain/control approvals	representative evaluation, threat/impact assessment, operating limits, exception and incident routes	product and risk/control authorities under local delegation
high consequence	formal validation or equivalent independent assessment, multidisciplinary challenge, explicit residual-risk acceptance	conceptual soundness, quantitative and qualitative evidence, customer/conduct impact, resilience, third parties, remediation and re-entry	accountable senior authorities defined by policy and jurisdiction

These labels are illustrative. Chapter 7 requires each institution to define its own bands, thresholds and delegations. A band does not decide every control mechanically; risk triggers can elevate a specific domain even when the overall product is lower.

Generative and agentic validation method

Independent review should examine the use and the assembled system. A practical method can include:

- challenge the intended use, prohibited use and authority boundary;
- assess conceptual design—why the architecture and controls could support the claim;
- reproduce a material sample of component, application and workflow evaluations;
- compare against a non-AI route, prior release or challenger where informative;
- test sensitivity to model, prompt, context, retrieval, tool and policy changes; See Figure 20.1.

Figure 20.1 — Say precisely which status the evidence supports

Status	What may be asserted	What may not be inferred
designed	control or product behavior is specified	implemented or testable
implemented	mechanism exists in the candidate	correctly configured or effective
tested	scoped method produced a result	complete coverage or independence
independently challenged	qualified reviewer reached a recorded conclusion	management approval or runtime effectiveness
approved	authority permits a bounded release, perhaps with conditions	deployed, operating, safe, compliant, or effective
deployed	configuration is present in an environment	exposed to users or operating as approved
operating	service is processing within a stated exposure	controls effective over an assessed period
effective for assessed period	defined evidence supports a scoped conclusion	future effectiveness or broader scope

Each status supports a bounded assertion with an explicit inference limit. No later state, broader scope or future effectiveness follows automatically.

- examine evaluator qualification, case construction, uncertainty and severe-failure rules;
- trace findings to remediation and regression;
- assess operation, monitoring, fallback, incident and customer-remedy readiness; and
- conclude with scope, limitations, conditions, residual risk and triggers.

For an agent, the reviewer also samples trajectories, authorization decisions, resource budgets, termination and reconciliation. For a RAG product, the reviewer separates retrieval coverage, source authority, answer support and workflow use. For a predictive product, established model-risk methods may apply within their scope; the current U.S. interagency revised model-risk guidance explicitly excludes generative and agentic AI, so it should not be presented as direct guidance for those systems.[2]

Conditional decision example

Fictional Bank's alert-triage candidate passes its technical release tests but lacks mature outcome labels for one new alert population. The gate does not convert the gap into a passing score. It may authorize a narrower pilot excluding that population, require manual routing for uncertain cases, set review sampling and capacity conditions, identify a decision date, and define a stop trigger. The approved release manifest encodes the restriction. If the technical configuration cannot enforce the condition, the condition is not an operational control.

Assurance conclusion template

Table 20.2 — Element and required content

Element	Required content
question	exact claim or transition reviewed
configuration	product and release identity, population, jurisdiction and period
evidence	records inspected, tests reproduced, samples and methods
findings	severity, affected claim and unresolved cause
limitations	unavailable provider evidence, delayed outcome, scope or method constraint
conclusion	supported / conditionally supported / not supported for the stated decision
conditions and expiry	enforceable restriction, owner, evidence due and decision date
re-entry trigger	change, incident, drift, exception or time/event review

The conclusion is preserved as its own versioned record. Later operation can confirm or challenge it; it should not silently overwrite what was known at release.

Canonical status and gate record

Table 20.3 — Status and what may be asserted

Status	What may be asserted	What may not be inferred
designed	control or product behavior is specified	implemented or testable
implemented	mechanism exists in the candidate	correctly configured or effective
tested	scoped method produced a result	complete coverage or independence
independently challenged	qualified reviewer reached a recorded conclusion	management approval or runtime effectiveness
approved	authority permits a bounded release, perhaps with conditions	deployed, operating, safe, compliant, or effective
deployed	configuration is present in an environment	exposed to users or operating as approved
operating	service is processing within a stated exposure	controls effective over an assessed period
effective for assessed period	defined evidence supports a scoped conclusion	future effectiveness or broader scope

Every gate record names entry evidence, decision question, accountable authority, challenge role, outcome, conditions, technical enforcement, expiry, exception path, and re-entry trigger. The same record points to the exact release; it does not replace specialist legal, validation, security, privacy, resilience, or audit conclusions.

Gate record linked to the canonical crosswalk

Use §2.6 for the single phase/gate/artifact/evidence route. The gate record names transition/claim, owner/delegation, exact candidate, reviewed evidence and independent conclusions, decision, enforceable conditions/expiry and re-entry. Product assurance includes use, application, data, tools, workflow and operating conditions; model validation covers its defined model/use scope. Temporary containment uses the recorded authorities in Chapters 4, 7 and 8; it does not turn an emergency restriction into permanent release approval.

20.10 Executive and Practitioner Decisions

Preserve the assurance opinion and authorize only enforceable scope. A missing prerequisite stays a hold; any condition needs an owner, expiry, safe default and runtime enforcement. Expiry does not approve the next scope.

Notes

1. Bank of England/PRA, Model risk management principles for banks (SS1/23) (B09), and U.S. interagency Model Risk Management: Revised Guidance (B10). Each must be used within its stated institutional, model, jurisdictional, and temporal scope. Return to text

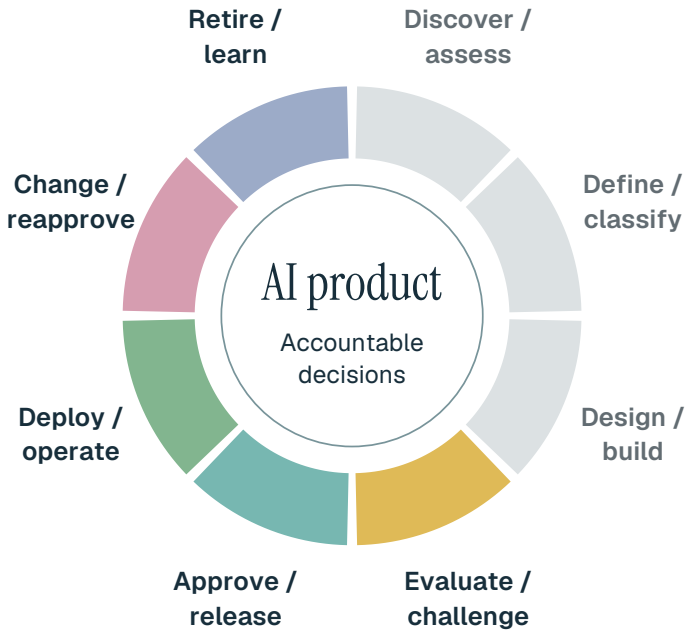
2. U.S. interagency Model Risk Management: Revised Guidance (B10), note on excluded generative and agentic AI scope. The exclusion is a scope fact, not a conclusion that such systems need no governance. Return to text

Part

V

Release, Operation and Change

Connects release identity to deployment, observability, incident/customer remediation, capacity, resilience, third parties, improvement and retirement. The outcome is an operating service that can be observed, constrained, recovered and re-entered into review.



Emphasis: Evaluate / challenge; Approve / release; Deploy / operate; Change / reapprove; Retire / learn.

Other phases remain part of the lifecycle.

Re-enter at the affected decision.

Chapter

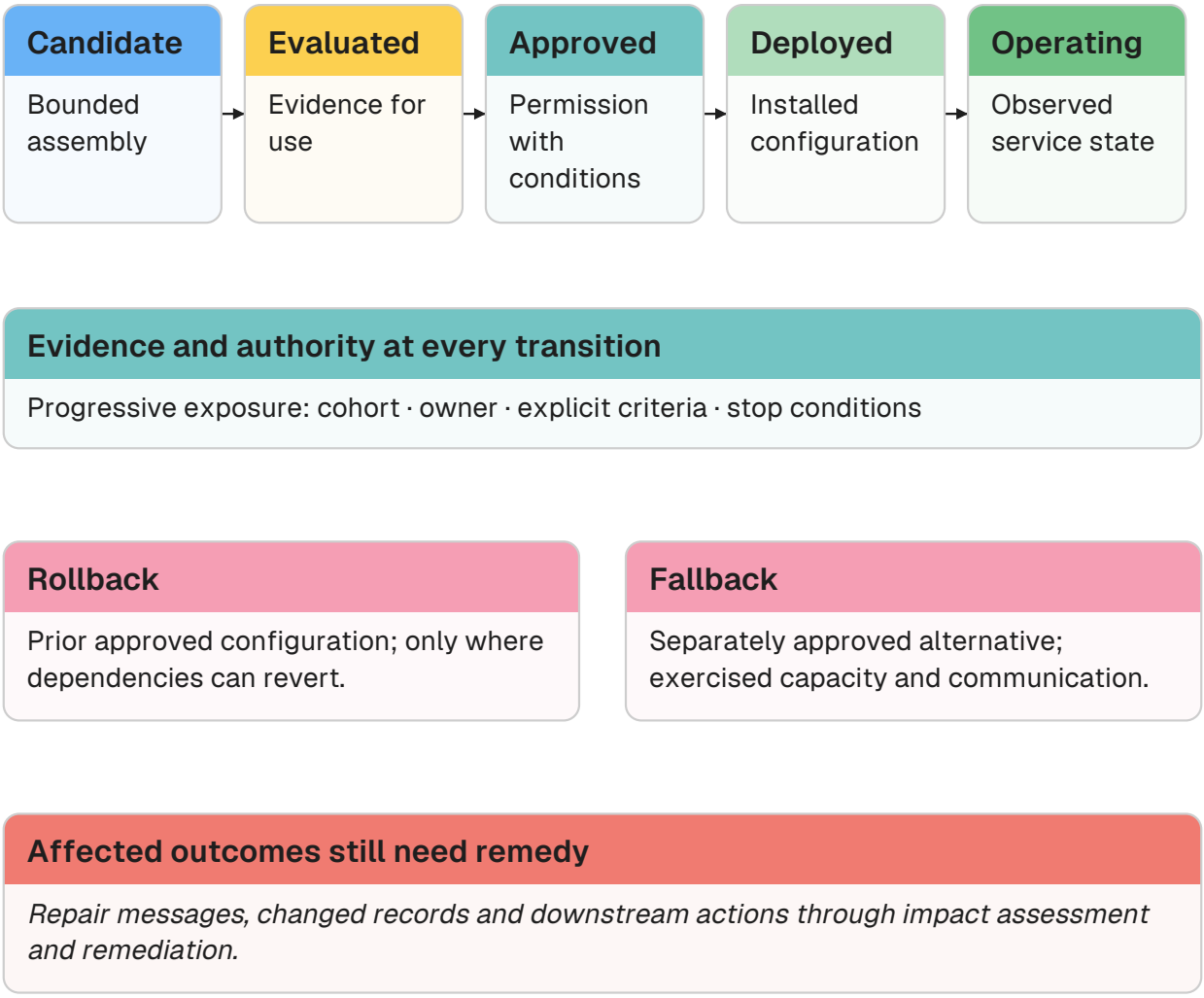
21 Release, Deployment, Rollback, and Fallback

An evaluated candidate is not automatically approved. An approved release is not necessarily deployed. A deployed configuration may not yet be serving traffic, and an operating service may diverge from its approved state. The lifecycle should distinguish at least **candidate**, **evaluated**, **approved**, **deployed**, and **operating**.

21.1 Distinguish the Release States

Each transition needs an accountable decision and evidence. This avoids the common ambiguity in which “in production” can mean installed in an environment, available to employees, or relied upon for a customer outcome. See Figure 21.1.

Figure 21.1 — Approval, deployment and operation are different states



Candidate, evaluated, approved, deployed and operating remain distinct. Each transition needs evidence and authority. Rollback and fallback are different recovery routes; affected messages, records and downstream actions still require impact assessment and remedy.

21.2 Assemble a Release Package

The release package identifies the governed product, use, environment, exposure, release manifest, evaluation and review conclusions, open limitations, deployment plan, monitoring, rollback or fallback, support ownership, and authorization.

The manifest should bind behavior-shaping dependencies: software artifact, model and provider version, prompt and policy bundle, data or feature definitions, corpus and index, tool schemas, infrastructure configuration, and relevant external services. The practical record may be federated, but its references must resolve.

Segregation of duties should follow institutional policy and risk. The person who prepares a candidate should not be able to bypass required approval and promote an unrecorded configuration. Emergency authority needs separate control and review.

21.3 Use Progressive Exposure as Evidence Collection

Progressive delivery can limit blast radius and generate operating evidence. Patterns include internal-only use, shadow processing, dark deployment, canary cohorts, phased geography or product rollout, and feature flags. Their suitability depends on consequence and applicable obligations.

Shadow mode is not risk free: it may still process sensitive data, create misleading records, or consume critical capacity. A canary can expose real customers. Each pattern needs a lawful and policy basis, clear exclusion from downstream action where intended, success and stop criteria, and a remediation route.

The exposure decision should identify population, volume or scope, duration, telemetry, owner, and maximum consequence. “Ten percent traffic” is not meaningful if that group contains the most consequential cases.

21.4 Plan Rollback by Dependency

Rollback restores a prior approved configuration. It is only feasible when the affected state is reversible. Software and prompts may be easy to revert; indexes, model-provider versions, data migrations, and external actions may not be.

Table 21.1 — Dependency or action and rollback question

Dependency or action	Rollback question	Alternative when irreversible
Application artifact	Is the prior version deployable with current interfaces?	Forward fix or compatibility layer
Model/provider	Is the prior identity available and supported?	Approved substitute or restricted fallback
Corpus/index	Can source and index versions be rebuilt and restored?	Disable retrieval or narrow supported topics
Data/schema	Can records be migrated back without loss?	Reconciliation and forward correction
Message/transaction	Can the external action be reversed?	Containment, notification, remediation
Policy/permission	Does revocation reach active sessions and queued work?	Kill credentials, isolate queue, reconcile

Rollback should be rehearsed under realistic dependencies. A deployment tool showing a previous version does not prove that the complete service can return to it.

A rollback that must be refused

In PA-INC-01, withdrawn document POL-DOC-01-v1 remains in the earlier POL-7/IDX-7 snapshot and in the affected POL-8-derived cache. Restoring those bytes would restore an impermissible source. Former source/index approval did not approve rejected candidate PA-0.1 and does not restore the document's current authority. The current schema also differs from the old adapter's expectations. The operator rejects rollback, holds the affected topic and uses authorized policy support while a forward repair is evaluated. Check current rights, source validity, schema, security and outstanding effects before any rollback; changing configuration cannot reverse an external effect.

21.5 Design Fallback as a Service

Fallback is an approved alternative when the AI path is unavailable, untrusted, or outside conditions. It may be a conventional software function, a manual process, read-only information, a queued response, or a stop with clear communication.

Fallback needs capacity, ownership, training, access, and evidence. A manual route that cannot absorb demand is not a credible fallback. A customer message that says "try

again later" may be unsuitable for a time-critical obligation. Test transitions into and out of fallback, including state reconciliation.

Rollback and fallback are different. A service may fall back without changing its deployed version, and a rolled-back version may still require a non-AI route.

21.6 Control Feature Flags and Emergency Changes

Feature flags can limit users, tools, models, or behavior. Treat consequential flags as production configuration: controlled access, version, peer review where appropriate, audit events, expiry, safe default, and testing of both states.

Emergency changes should name the incident or risk, approver, precise change, evidence available, monitoring, duration, and retrospective review. They must not become a shadow path for routine prompt or model updates.

Kill mechanisms should operate at the right layer: disable a model endpoint, revoke a tool, stop new work, pause a cohort, isolate an index, or redirect to fallback. One global switch may create unnecessary outage; one narrow switch may fail to contain the issue.

21.7 Verify the Operating State

After deployment, compare the environment with the approved manifest and expected controls. Confirm identities, policy, feature state, telemetry, alert routing, fallback readiness, and support ownership. Use synthetic or controlled checks where real transactions would be inappropriate.

Release completion should require an operating acceptance decision, not merely a successful deployment command. Observe the initial period and confirm no critical discrepancy. Define who can declare the service stable and what happens to unresolved anomalies.

For a managed provider, record both the requested model/version alias and the effective revision reported, request time/region, configuration and contractual pinning guarantee. If the provider cannot expose or retain an immutable revision, state that reconstruction limit; do not invent a hash for unseen weights. Monitor provider change and qualify fallback accordingly.

PA-R1 pins its approved corpus/index baseline and refresh envelope; each request records the effective source/index and permission versions. A legitimate in-envelope refresh is an operating event, while changed authority or out-of-envelope behavior re-enters the affected approval (§11.7).

21.8 Worked Release at Fictional Bank

Fictional Bank first enables the policy assistant for a small trained employee cohort and supported policy topics. The configuration has no send tool or customer-record integration. The release package binds application, prompt, model, corpus index, entitlement policy, evaluation suite, and fallback route.

The deployment verifies that the expected index and model endpoint are active. A controlled exercise disables retrieval; the interface stops drafting and points employees to the policy-support process. A provider alias change is detected as outside the approved manifest, so new sessions are held until evaluation determines the applicable scope.

21.9 Release Topology, Reconciliation and Customer Experience

Promote bank-controlled code, infrastructure, prompts, policies, tool schemas and indexes by immutable or content-addressed identity. Resolve their aliases to the assessed artifacts. For a provider-controlled model service, record the strongest observable identity, change notices and limits, approved change envelope and response to uncertainty; do not claim to pin unseen weights. Hold a use that depends on guarantees the provider cannot supply. Deployment must reject an unapproved combination or an active-condition violation.

Table 21.2 — Pipeline decision and evidence produced

Pipeline decision	Evidence produced	Failure response
assemble candidate	component identities, build provenance, dependency and configuration graph	block incomplete or untrusted component
evaluate and challenge	result records, severe failures, findings, limitations	return, narrow, condition or reject
authorize release	signed/attributable decision, scope, conditions, expiry	no promotion without matching authority
deploy progressively	environment, exposure cohort, health and behavior checks	pause, rollback, restrict or fail over
accept operation	observed release identity, control/telemetry health, owner acknowledgment	treat unknown identity or missing evidence as release failure

Progressive exposure is useful only when the bank can identify the exposed population, compare meaningful signals, and act before unacceptable harm spreads. A canary that tests latency but cannot detect unsupported customer communication is not a behavioral canary. For customer-facing use, the plan should define what the customer sees if the AI feature is withdrawn or degraded, whether a disclosure or service communication is required, and how pending interactions are preserved.

Rollback is not remediation

Rolling software back may stop new exposure. It does not correct messages already sent, decisions already recorded, cases already routed, or downstream actions already accepted. The rollback runbook should therefore pair technical restoration with reconciliation:

- identify the affected release, time, cohorts and actions;
- stop or restrict new work;
- restore a known operating configuration or non-AI route;
- classify submitted, confirmed, failed and uncertain downstream actions;
- correct records and remediate affected customers or processes where required;
- preserve evidence and open the incident/change decision; and
- verify the new operating state.

Fictional Bank deploys a retrieval-ranking change for its policy assistant to a limited employee cohort. The manifest includes the index and ranking configuration. When sampled responses show exception passages are being omitted, the bank pauses exposure, restores the prior index/ranker pair, identifies sessions on the candidate release, preserves the response/source traces, and routes any relied-upon drafts for review. The exercise demonstrates the sequence only; no control effectiveness or outcome is claimed.

Fallback service contract

A fallback is a designed service with capacity, ownership and communication—not a sentence saying “manual process.” Its record identifies trigger, supported tasks, queue or staffing assumptions, maximum tolerable demand, data handoff, customer/employee message, decision authority, reconciliation and return criteria. The bank should test whether the fallback can operate during the same provider, network or staffing failure that disabled the AI path.

Emergency changes follow a bounded authority: who may act, what may change, how long it lasts, what evidence is required immediately, and when retrospective review occurs. An emergency path that becomes the ordinary path is control drift.

Release, rollback, and fallback decision sequence

A release decision fixes code, infrastructure, model/provider, prompt/policy, corpus/index, tool permissions, evaluation method, telemetry schema, and exposure. Progressive delivery—shadow, internal, canary, limited cohort, or broader operation—collects evidence but does not silently change the approved purpose or population. Each exposure step has an abort owner and an observable stop condition.

Rollback is dependency-specific: code can roll back while a provider endpoint, index, credential, queued action, or downstream record cannot. Fallback is a service route with capacity, training, communication, data reconciliation, and customer-treatment consequences. Both are **tested** separately from being **documented**.

Identity checks at each operating transition

Table 21.3 — Transition and evidence and decision

Transition	Evidence and decision
Approval candidate → approved release	Delegated decision binds manifest, conditions and exceptions; no operation inferred
Approved release → deployed configuration	Deployment compares actual components, permissions and environment with the approved manifest
Deployed configuration → operating service	Service owner verifies telemetry, enforceable conditions, fallback/capacity and observed identity
Operating service → restricted service	Recorded incident/condition authority limits admission, topic, action or population; preserves affected-work identity
Changed/repaired candidate → renewed approval and operation	Affected claims receive regression/review; approval, deployment verification and operating acceptance are repeated as required

21.10 Executive and Practitioner Decisions

Operations should verify the effective release before exposure and test whether rollback is still permissible. When state, rights or dependencies have changed, use a qualified forward fix or safe route and reconcile outstanding effects.

The author’s release-state model and dependency-specific rollback matrix draw on NIST SSDF secure-development practices (B04/B28) and operational-resilience principles (B11). They connect delivery to current rights, authority and unresolved effects.

Chapter

22

Runtime Observability and Continuous Evaluation

Infrastructure monitoring can show that a service is available while the product produces stale, unsupported, discriminatory, or unauthorized outcomes. AI observability connects technical, behavioral, data, control, risk, and business evidence to the approved product claim.

22.1 Observe the Service, Behavior, and Control

Observability is not collection for its own sake. Every signal should have an interpretation, owner, decision, and privacy boundary. If no one can explain what an alert means or what to do, the signal is not yet an operating control.

22.2 Organize the Signal Portfolio

Table 22.1 — Signal family and examples

Signal family	Examples	Decision supported
Technical	latency, error, saturation, dependency availability	Scale, degrade, fail over, investigate
Behavioral	refusal, groundedness sample, severe error, format failure	Continue, restrict, re-evaluate, stop
Data and knowledge	schema, distribution, freshness, source withdrawal	Validate, rebuild, narrow, retrain
Control	policy denial, unauthorized request, review completion, flag state	Contain, remediate, attest, escalate
Business and customer	completion, rework, complaints, overrides, redress	Assess value and customer impact
Security and abuse	injection attempt, anomalous tool use, exfiltration indicator	Investigate and contain
Evidence health	missing correlation, version mismatch, log gap	Restore assurance before relying on results

The portfolio should preserve distinctions. A decline in latency does not imply a decline in answer quality. A rise in refusals may reflect a safer boundary or a service failure; context is necessary.

22.3 Define Four Forms of Drift

Data drift is a material change in data distribution, quality, meaning, provenance, or use relative to a baseline. **Model drift** is a material change in performance or behavior relative to approved expectations. **Knowledge drift** concerns the relevance, correctness, currency, coverage, or entitlement state of retrieved knowledge. **Control drift** is divergence between approved control design and current implementation or operation.

These working definitions help route investigation. A customer-language shift may be data drift; a provider behavior change may be model drift; a withdrawn policy remaining in an index is knowledge drift; a disabled authorization check is control drift. Multiple forms can coexist.

Not every statistical movement is material. Thresholds should connect to consequence and decision. Static thresholds, adaptive detection, periodic review, and case sampling can be combined, but all require calibration and false-positive treatment.

Conventional predictive monitoring distinguishes covariate shift in inputs, prior/label shift in outcomes and concept drift in the input–outcome relationship. The book's data/model/knowledge/control categories route ownership across the assembled product; they are not replacements for that statistical vocabulary. Concept drift can occur without a large visible input shift. Delayed labels limit performance conclusions; report that lag and use proxy/control signals without calling them observed outcome performance.

22.4 Link Telemetry to Release Identity

Runtime evidence is interpretable only when it identifies the configuration that produced it. Traces should carry product, release, model, prompt or policy, corpus/index, tool, environment, and relevant cohort references. The exact content retained must be minimized and protected.

Distributed systems require correlation across services. Stable identifiers help reconstruct a material path, but they should not become uncontrolled customer identifiers. Time synchronization, event ordering, and version-aware schemas matter during incidents.

Missing telemetry should be monitored. A dashboard that silently loses one region or tool can create false reassurance.

22.5 Conduct Continuous Evaluation Without Pretending It Is Continuous Proof

Continuous evaluation can replay controlled cases against candidate or operating configurations, sample outputs for structured review, compare current behavior with a baseline, and monitor hard boundaries. It provides repeated evidence, not permanent assurance.

Protect evaluation sets from leakage and overfitting. Rotate or refresh cases as products and failure knowledge change. Separate exploratory alerts from formal release criteria. A model-based evaluator needs versioning and calibration; changes to the judge can create apparent drift in the system being judged.

Sampling should reflect risk and population. Random samples can miss rare consequential cases; targeted samples can overstate prevalence. Report the selection method and limit conclusions accordingly.

Keep two streams. A probability sample from a defined request population supports prevalence estimates, with inclusion probabilities, weighting/strata and delayed-label handling recorded. Complaint, incident and targeted stress streams discover failure classes; their counts cannot estimate the ordinary production rate without a justified design. A complaint-free period is not evidence that no harmful response occurred.

22.6 Turn Alerts Into Operating Decisions

An alert definition should include the signal, baseline or threshold, severity, owner, response time, diagnostic steps, containment authority, evidence, and closure criteria. Combine alerts where a single dependency failure creates many symptoms, but avoid suppressing material product-specific effects.

Possible responses include investigate, increase sampling, restrict a topic or cohort, disable a tool, move to fallback, roll back, notify stakeholders, open an incident, or revalidate. The runbook should state which decisions operations can make immediately and which require product or risk authority.

22.7 Use Feedback With Care

User ratings, corrections, overrides, complaints, and downstream outcomes can improve understanding. They are not clean labels by default. Users may reward fluency, avoid reporting, disagree with policy, or correct only obvious errors. Outcome data may be delayed or affected by intervention.

Feedback should retain purpose, provenance, selection, and interpretation. Using it to tune or train is a new data use requiring governance. An automated feedback loop that changes behavior without evaluation can bypass change control.

22.8 Worked Monitoring at Fictional Bank

Fictional Bank monitors service latency and availability, retrieval no-result rate, citations to withdrawn sources, sampled unsupported propositions, employee rejection and correction, fallback use, policy denials, and release-identity mismatches. No single measure is labeled “trust.”

A rise in no-result responses follows a corpus entitlement change. The system behaved as designed, but the employee workflow is no longer useful for one team. Product, data, and access owners investigate together. The bank restricts that topic and updates the non-AI route while correcting the entitlement mapping. The event is preserved as control and service evidence.

Signals connected to owner and action

Table 22.2 — Signal and threshold meaning

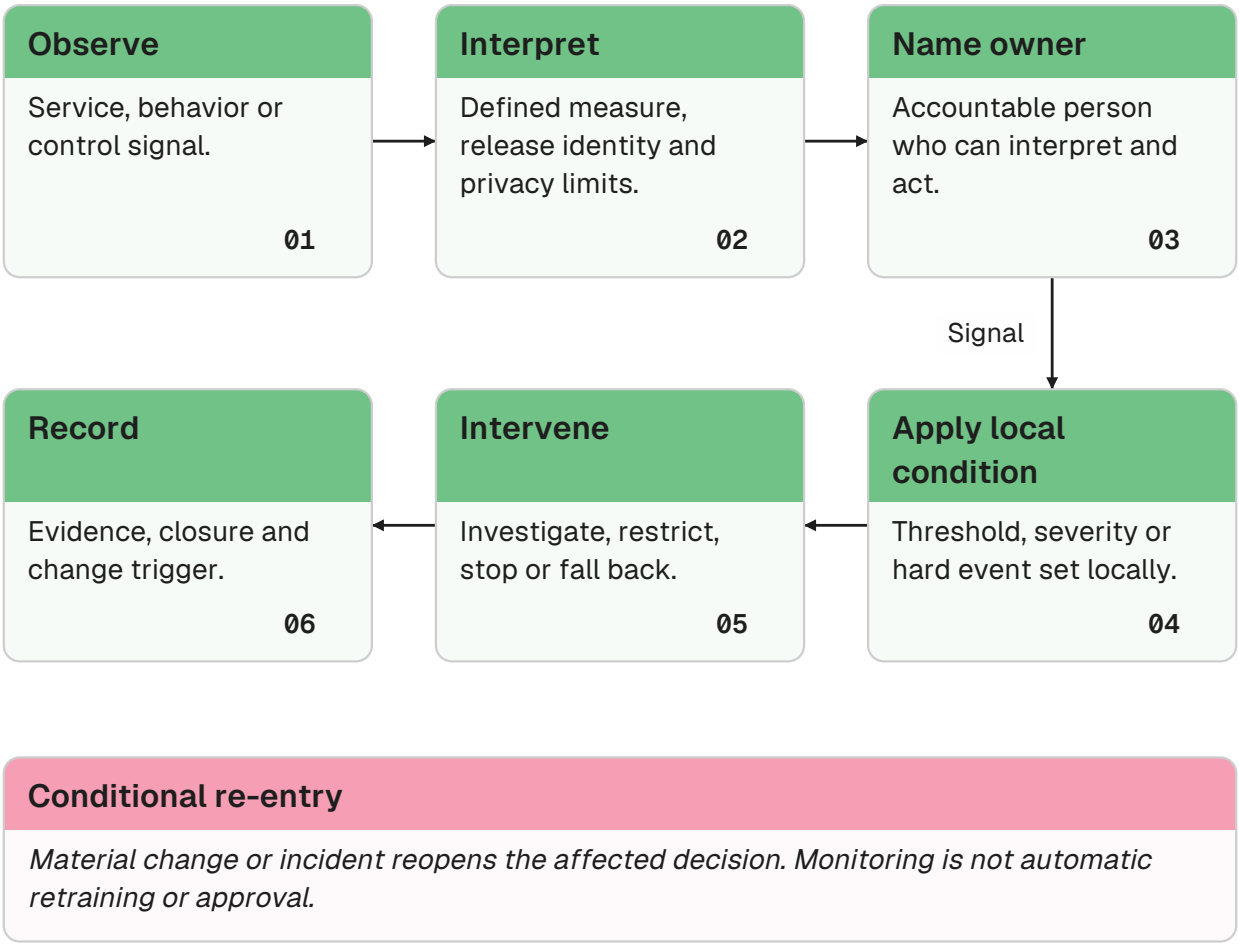
Signal	Threshold meaning	Action / owner	Evidence
Unsupported material policy proposition	Locally defined severe-support failure, not average fluency	Restrict affected topic; knowledge/product owner investigates	Request/ release/ source and assessor disposition
Entitlement or tool-policy denial	Unexpected access/action attempt or failed denial control	Security/access owner contains affected route	Authenticated subject, resource, policy decision and release
Source withdrawal not propagated	Effective source differs from index/cache state	Knowledge/service owner invalidates and verifies affected paths	Source/index/cache versions and denial/regression checks
Evidence identity or retrieval gap	Cannot establish required release/source/event facts	Custodian/incident owner uses §2.6 and records decision hold/restriction	Missing pointers, trusted snapshot and reconstruction limits
Fallback queue/capacity breach	Local service/admission condition exceeded	Service owner narrows exposure or prioritizes approved non-AI route	Queue age, staffing/budget, affected work and recovery decision

A signal is not automatically a finding of harm. Preserve the rule, owner, review period and action semantics, then investigate exposure and outcome under Chapter 23.

Synthetic operating alert PA-ALERT-01

PA-R1's source-withdrawal check detects one authority mismatch in a five-minute control window. The local hard rule disables the affected topic immediately; it does not wait for the monthly quality average. The knowledge owner has a four-hour investigation target and a 20-case daily review budget, with operations owning the queue. If work exceeds that capacity, scope remains restricted and the service owner funds triage or escalates the service impact. A growing unresolved queue cannot be presented as successfully monitored operation. PA-INC-01 links the finding to the actual synthetic release and remedy reconstruction. See Figure 22.1.

Figure 22.1 — Make every operating signal actionable



A signal needs interpretation, an accountable owner, a local intervention condition, action and an evidence record. Monitoring alone does not establish effectiveness.

22.9 Predictive Monitoring and Decision-Ready Metrics

Predictive products need monitoring that respects outcome delay and score meaning. Input stability can warn that the operating population changed, but it does not prove performance deteriorated. Conversely, stable input distributions do not prove calibration or discrimination remain acceptable. The plan should connect each signal to a decision and state what remains unknown until outcomes mature.

Table 22.3 — Signal and interpretation question

Signal	Interpretation question	Possible decision
feature/schema quality	did meaning, availability or transformation change?	investigate, fall back, restrict population
population stability	is the operating cohort materially different from the approved baseline?	targeted evaluation or reclassification
score/rank distribution	did routing or workload allocation change?	capacity adjustment and cause analysis
calibration/backtest	do predicted quantities or risk ordering correspond to observed outcomes?	recalibrate, retrain, narrow or stop
subgroup behavior	are error or outcome patterns materially different for relevant groups?	impact review and remediation route
override and investigator correction	where do qualified users disagree, and why?	case review, data/model/workflow change
challenger comparison	does a baseline or alternative reveal degradation?	validation and replacement decision

Backtest cadence depends on label arrival, exposure and consequence. When labels are delayed, the bank can use leading indicators, but it must label them as proxies and revisit the claim when outcomes arrive. A queue optimized for throughput can appear healthy while high-consequence cases are systematically delayed.

Measurement-definition card

Every material metric should have a card:

Table 22.4 — Field and required definition

Field	Required definition
decision	continue, investigate, restrict, scale, remediate or stop
construct	what the measure is intended to represent
numerator/denominator or computation	exact population and exclusions
period and lag	event time, observation window, maturation delay
source and owner	system of record, transformation and accountable interpreter
segments	required cohorts, channels, products, jurisdictions or release IDs
uncertainty and limitations	sampling error, missingness, proxy status, known bias
gaming/adverse incentive	how optimizing the number could harm the service
trigger	threshold, trend, hard event or review rule set locally
action	owner, response time, containment and escalation

Use Appendix G's reusable metric fields for severe unsupported responses, review backlog, release-identity coverage, human correction, evidence completeness, unit cost and fallback capacity. Define denominator, owner, uncertainty and action for each; no external companion pack or universal threshold is required.

Author-synthesis drift model

Data and concept drift are established terms. The book also distinguishes knowledge and control drift so retrieved sources and enforcement receive attention alongside model behavior. Define the monitored change precisely for the approved baseline; "model drift" here covers predictive or generative behavior.

Executive dashboard logic

An executive view should show exposure, evidence and required decision rather than a composite "AI health" score. Useful tiles include products by risk/authority, releases with expired conditions, severe evaluation or operating findings, incidents and affected populations, third-party concentration, fallback readiness, outcome evidence maturity, value hypothesis status, and decisions due. Each tile must drill to denominators, scope, owner and source. Green without evidence is not green.

22.10 Executive and Practitioner Decisions

An alert should lead to a funded operating action with an owner and response window. Keep probability sampling distinct from targeted discovery, and restrict exposure when investigation capacity is exhausted.

NIST AI RMF and the Generative AI Profile (B01–B02) support lifecycle measurement and monitoring; Sculley et al. (B19) illustrates hidden dependencies and feedback loops in ML systems. The four-drift taxonomy and signal portfolio are author synthesis.

Chapter

23 AI Incident Response and Customer Remediation

AI incidents should use the institution's established incident command, severity, evidence, communication, and recovery structures. A separate AI process can help with expertise, but it should not create uncertainty about who can contain a customer-impacting or critical-service event.

23.1 Integrate AI Into the Incident System

An incident may begin as a conventional outage, security event, data-quality issue, model behavior change, retrieval failure, privacy breach, unfair outcome, misleading content, unauthorized tool action, or evidence gap. Classification should follow consequence and required response rather than the label attached at detection.

23.2 Prepare Before Operation

Preparation includes product and dependency inventory, accountable contacts, release and evidence records, logging, investigation access, containment mechanisms, fallback, provider escalation, legal and regulatory routes, customer-remediation capability, and exercised playbooks.

NIST SP 800-61 Rev. 3 frames incident response as part of cybersecurity risk management and superseded Rev. 2 in April 2025.[1] It is a cross-sector cybersecurity reference, not an AI-specific banking rule. Banks must map jurisdictional and institutional obligations separately.

Provider contracts and operations should support urgent identity, version, log, change, and containment information. If the bank cannot determine which model version served an interaction, investigation and remediation will be impaired.

23.3 Detect and Triage the Actual Impact

Initial reports may be incomplete. Triage should establish the affected product and release, time window, users or processes, data, actions, jurisdictions, critical service, current exposure, and whether the behavior is continuing. Preserve uncertainty rather than assigning a confident root cause too early.

AI-specific questions include whether the issue is repeatable, input or population dependent, caused by a provider or corpus change, amplified by a human or downstream system, and detectable in historical records. A variable output can complicate reproduction; protect the original context and dependencies.

Severity should account for customer harm, financial or market impact, unauthorized action, privacy or security exposure, fairness or conduct consequence, operational disruption, scale, persistence, reversibility, and legal or regulatory significance. Qualified roles determine applicable reporting and notification.

23.4 Contain at the Narrowest Effective Boundary

Containment options include disabling a feature, topic, cohort, model, index, tool, or provider; revoking credentials; stopping new work; isolating a queue; switching to fallback; or suspending the whole service. The narrowest option is preferable only if it actually contains the harm.

Preserve evidence before destructive changes when safe and lawful. Capture the manifest, configuration, policy, corpus/index, prompts, relevant inputs and outputs, tool events, approvals, logs, provider notices, and operator actions. Apply access, minimization, privilege, and legal-hold requirements.

Containment must address actions already initiated. Revoking a tool does not cancel messages in a queue or transactions submitted downstream. Reconciliation is part of containment.

23.5 Investigate Across the Causal Chain

Avoid stopping at “the model hallucinated.” Trace source, input, preprocessing, retrieval, context, model, validation, interface, human action, tool, downstream system, and monitoring. Distinguish initiating cause, contributing conditions, failed or absent controls, detection gap, and impact amplifier.

Root-cause analysis may identify multiple causal layers. A stale policy source, incomplete retrieval, fluent generation, time-pressured review, and missing complaint correlation can jointly create harm. The corrective action should address the system, not only the most visible component.

Provider involvement should preserve the bank's decision ownership. A provider conclusion is evidence, not the bank's final incident determination.

23.6 Remediate Customers and Records

Recovery is not complete when the service is restored. Determine which customers, employees, cases, decisions, records, or downstream processes may have been affected. The institution should define how it identifies the population, corrects records, reverses or compensates actions where appropriate, communicates, handles complaints, and verifies completion.

Customer treatment and regulatory obligations are jurisdiction specific. Do not infer a notice requirement or remedy from this chapter. Qualified legal, compliance, conduct, privacy, and business owners must decide.

Where exact affected populations cannot be identified, record the method and uncertainty. Sampling may inform the estimate but must not be represented as complete remediation without basis.

Link complaint handling to the incident, decision/action reference, release and remediation record when those facts are relevant. The complaints, service, legal and records owners should assess the applicable route, communications, lawful evidence preservation and any remedy or claim. Separate the affected customer's review and treatment from the institution's defense or contractual claim against a provider. Rights, liability, notification and compensation depend on the actual facts, contract and applicable law; a restored endpoint does not resolve them.

Preserve useful evidence through controlled references and lawful access, with uncertainty visible when an action or population cannot be reconstructed. Retention, a legal hold, privilege and disclosure are questions for the actual competent authority, not reasons to collect or publish all customer content. Carry open complaints, claims and remediation owners into the transition or retirement record rather than closing them because the AI route has changed. §§8.4, 8.7 and 25.4 provide the linked review and custody method.

23.7 Recover Through a New Decision

Recovery should use an approved configuration and explicit evidence. A prompt change made during containment is not automatically safe for normal operation. Define remediation, regression, security and domain review, data or corpus repair, deployment, monitoring, and any restricted restart.

The restart authority should consider unresolved impact and the credibility of fallback. A phased return can reduce exposure. Preserve the incident link in the new release evidence and monitor for recurrence.

Use the return-to-service conditions in §25.5 for the exact restored or independently qualified route. The decision should link reconciliation, current permissions and controls, capacity and unresolved customer/record work. If the proposed route is not ready or authorized, continue the safe approved fallback or restriction within its limits; availability alone is not permission to resume.

23.8 Learn Without Erasing Accountability

Post-incident review should identify lessons for requirements, architecture, evaluation, release, monitoring, provider management, human work, and governance. Actions need owners, due dates or triggers, evidence, and closure authority.

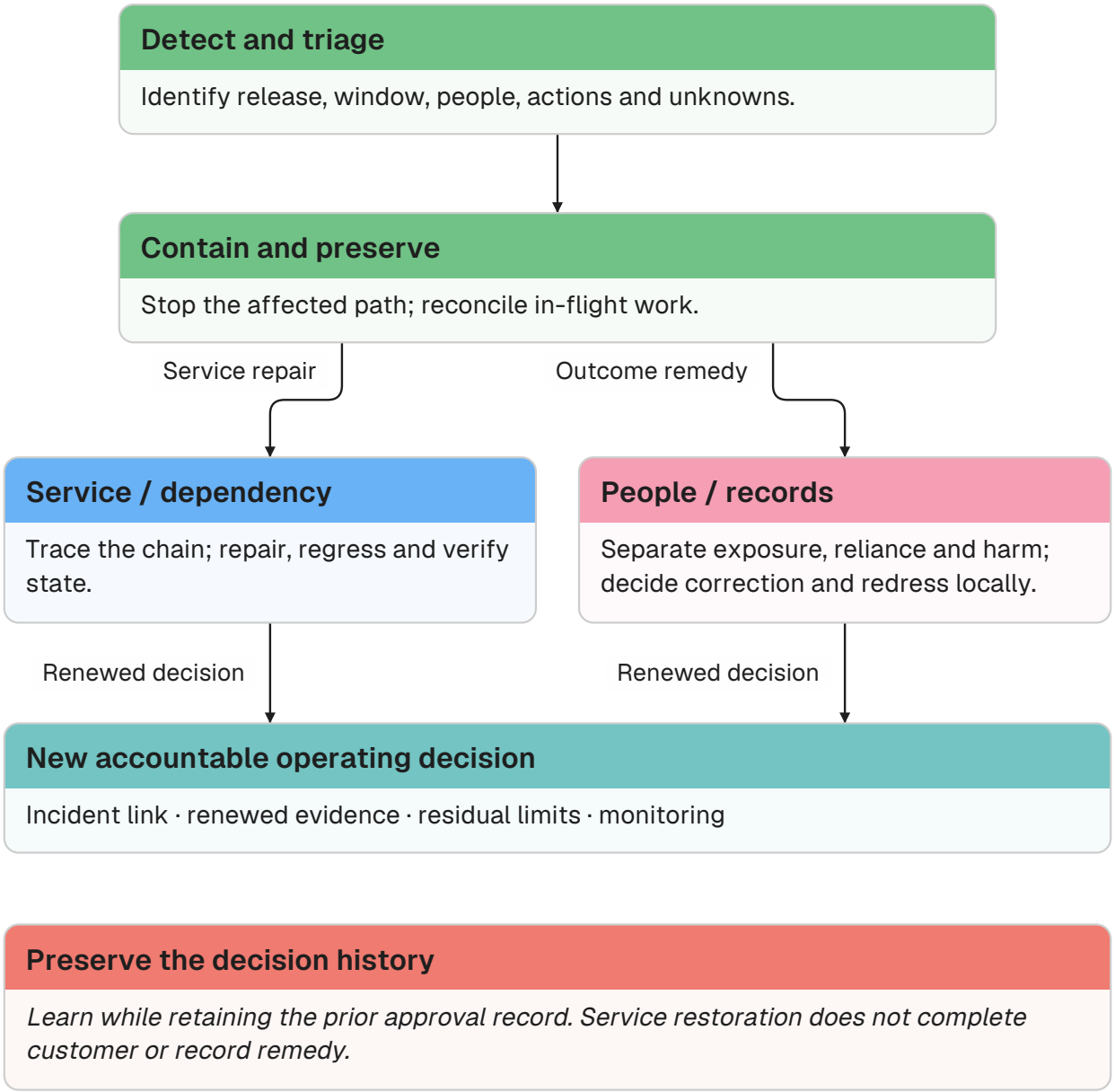
Update scenarios and regression sets while protecting sensitive records. Share lessons across products where the failure class is common. Avoid rewriting prior approvals; append corrections and explain what evidence was invalidated.

23.9 Worked Incident at Fictional Bank

Employees report that the assistant cites a withdrawn policy. Triage identifies one index version and a bounded operating window. The bank disables the affected topic and routes questions to policy support. It preserves corpus and index manifests, traces, withdrawal events, and employee corrections.

Investigation finds that the source file was removed, but a derived index was not rebuilt because the withdrawal event failed. Monitoring checked document age but not withdrawal propagation. The bank identifies drafts created during the window, asks business owners to review any material use, corrects affected records, rebuilds the index, adds a withdrawal reconciliation, and evaluates the repaired release. No customer harm is assumed; the example illustrates the process only. See Figure 23.1.

Figure 23.1 — Restore service and remedy harm on separate tracks



After containment, technical repair and customer or record remediation proceed on separate tracks. Both inform a new accountable operating decision.

23.10 Worked Customer-Impact Incident

Fictional Bank operates a customer-facing generative assistant that answers bounded service questions and can prepare—but not submit—service requests. During routine sampling, the bank finds that a changed knowledge index sometimes presents an obsolete fee-waiver exception as current. This is a fictional scenario; no real incident, customer count, loss or outcome is asserted.

The incident team first disables answers on the affected topic and routes customers to an employee channel. It preserves the release/index identities and identifies sessions in which the obsolete source was retrieved or the unsupported statement was shown. Affected population analysis distinguishes exposure from reliance and harm: customers who saw the answer, customers who acted, records or fees affected, complaints already raised, and cases where evidence is insufficient.

Remediation is not limited to correcting the index. The bank reviews relevant account records, corrects inaccurate service records, determines customer communication and redress through its applicable legal and conduct process, preserves appeal or complaint routes, and validates that the repaired source and cache no longer serve the obsolete rule. The release returns only after a new decision based on evidence.

Table 23.1 — Incident field and fictional record content

Incident field	Fictional record content
detection	sampled response linked to obsolete-source identity
containment	topic disabled; employee route activated; change frozen
affected population	release, time, channel, topic and session query; unknowns stated
evidence preservation	request/response references, retrieved source IDs, policy decisions, deployment history
customer/process remediation	legal/conduct-owned notification and redress decision; record correction and complaint linkage
root and contributing causes	source withdrawal failure plus cache invalidation and regression gap
return conditions	rebuilt index, withdrawal drill, targeted regression, operating verification, accountable approval

Reporting duties must be mapped, not improvised

Incident reporting thresholds, clocks, recipients and content differ by jurisdiction, regulated entity and incident type. The product runbook should link to the bank's current regulatory-notification matrix and start legal/regulatory assessment when the relevant facts emerge. It should not embed a possibly stale universal deadline in application code or this book.

Illustrative UK example; legal review required. PRA published PS7/26 on 18 March 2026; its policy implementation date is 18 March 2027. Its operational-incident and third-party reporting arrangements require firm, incident and version-specific analysis, including any applicable existing duties before implementation. The example shows why the bank must identify entity, rule, materiality/threshold, clock start, recipient and update/final-report stages from current primary materials. It does not conclude that the fictional incident is reportable.[2]

Population reconstruction test

Before release, test whether the bank can answer: which customers, employees, cases or transactions encountered this release and dependency state; which received or acted on the problematic output; what downstream records changed; and where evidence is missing. Trace minimization and privacy remain constraints. The goal is not to log everything; it is to preserve the identifiers needed for foreseeable containment and remedy under approved retention and access rules.

The post-incident review updates the product claim, evaluation population, knowledge-withdrawal control, monitoring, runbook and shared platform if the cause is systemic. A lesson is not complete until an owner and evidence of implementation are linked to it.

Canonical incident and customer-remediation loop

The loop is detect, triage, contain, preserve, assess, notify where applicable, remediate, recover, learn, and reapprove. Near misses and silent failures enter through the same evidence route when they reveal a failed assumption. Customer-impact assessment separates exposure, reliance, harm, and remedy; it records unknowns rather than inferring that every exposed person was harmed or that every unobserved person was safe.

Recovery requires a new operating decision linked to the affected release, corrected dependency, regression evidence, residual limitation, customer/record reconciliation, and renewed monitoring. Restoration of availability alone does not close remediation.

Reapproval and remedy closure records

The incident links reporting assessment to entity, applicable rule, fact/clock trigger, recipient, owner and update/final-report decisions; reportability is not assumed. Reapproval binds the repaired release/index/cache, regression and independent findings, limits, approval owner and operating verification. Remedy closure separately records affected cases, exposure/reliance/harm uncertainty, corrections/communication/redress, unresolved obligations and accountable follow-through. Restoring answers or access to an evidence index does not close customer or records remediation.

Synthetic reconstruction PA-INC-01

PA-INC-01 concerns the internal PA-R1 draft-only service, separate from the customer-facing case above. Withdrawn document POL-DOC-01-v1 remains reachable through a POL-8-derived cache. Query the protected event index by PA-R1, that document version and the withdrawal-to-containment window, then reconcile channel receipts and downstream owner records. A corpus snapshot identifies the package; the withdrawal applies to its document member.

Table 23.2 — Population question and constructed result

Population question	Constructed result	What remains unknown
Generated responses	56 distinct response events reference the source	A generation event is not proof of display
Displayed / blocked / unresolved	48 confirmed displays; four blocked; four lack display receipts	Treat the four as potentially exposed, not as unshown
Employee population	22 distinct confirmed viewers	Four unresolved events allow up to four additional viewers: 22–26 distinct viewers assuming one viewer per event; overlap is unverified and shared forwarding is outside this bound
Reliance	Six employee uses confirmed by follow-up owner records	Six known uses do not resolve other reliance, downstream actions or harm; no direct transaction was permitted
Remedy groups	Source correction and employee notification; separately reconcile the six known downstream uses	Policy/conduct owners retain unresolved cases and lawful access limits

A broker-denied send in a separate PA-SUBMIT fixture is a near miss: no prohibited effect commits, but the attempt challenges that workflow. It is not one of the 56 PA-DRAFT incident events. Draft-only forbidden action text and a silently incomplete answer are different failures. Keep their tests and incident records distinct. Repairing the cache does not close unresolved employee reliance, customer remedies in the separate customer case, or records obligations.

23.11 Executive and Practitioner Decisions

Contain the affected use, reconstruct generated/shown/acted-on events and retain unknowns. The remedy owner closes customer or record obligations separately from availability recovery and renewed release permission.

Notes

1. NIST, Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile, SP 800-61 Rev. 3 (B34), final April 2025. It supersedes Rev. 2 and is not an AI-specific banking obligation. Return to text

2. Bank of England/PRA, PS7/26 Operational Resilience: Operational Incident and Third-Party Reporting (B43). UK scope- and implementation-specific material; no fictional event is classified as reportable. Return to text

Chapter

24

Performance, Cost, Reliability, Capacity, and Sustainability

Latency, throughput, reliability, capacity, and cost shape whether an AI product can satisfy its purpose. A slow answer can make review perfunctory. Capacity pressure can trigger truncation or bypass. Cost limits can shift traffic to an unevaluated model. Reliability is therefore connected to conduct and control, not merely infrastructure.

24.1 Treat Nonfunctional Properties as Product Behavior

Requirements should be stated for the user and workflow, not only the model endpoint. End-to-end time includes authentication, retrieval, model calls, validation, tools, human review, and downstream confirmation. Availability should distinguish degraded AI from availability of the critical business service.

24.2 Define Service Objectives by Decision

Service objectives can cover latency, throughput, availability, error, task completion, freshness, queue age, fallback activation, and recovery. The appropriate values are institution and use specific; this chapter supplies no numeric targets.

Table 24.1 — Objective and boundary to define

Objective	Boundary to define	Failure response
Latency	percentile, task, cohort, end-to-end path	degrade, queue, fallback, communicate
Availability	AI feature versus business service	disable feature or continue non-AI path
Throughput	normal, peak, concurrent, batch	admit, prioritize, defer, shed
Freshness	model, source, index, feature, policy	restrict topic, rebuild, stop
Quality under load	truncation, routing, retry, output behavior	preserve hard boundaries; reduce optional work
Recovery	component and service state	reconcile, validate, phased restart

An objective must have measurement, owner, review cadence, and action. A contractual provider target may support but cannot replace the bank's end-to-end objective.

24.3 Model the Full Cost Boundary

AI cost includes more than inference. Consider data acquisition and preparation, model adaptation, retrieval, storage, network, evaluation, security, provider minimums, licenses, platform engineering, human review, exception handling, support, incidents, remediation, and exit.

Unit cost should use a meaningful unit: completed case, approved draft, investigated alert, or served customer journey—not only a token or call. A lower per-call cost can increase total cost if error, retry, review, or downstream rework rises.

Cost allocation should not create unsafe incentives. A product team charged for evaluation but not incident impact may underinvest in evidence. Shared platform funding should reveal consumption while preserving controls required by policy.

24.4 Engineer Capacity and Backpressure

Capacity planning needs expected and stress demand, request size, context, concurrency, tool fan-out, retries, evaluation traffic, provider quotas, and fallback capacity. Long agent loops and large contexts can produce nonlinear resource use.

Use admission control, queues, budgets, rate limits, concurrency limits, caching where safe, circuit breakers, and workload prioritization. Protect critical services from

experimental or batch traffic. Backpressure should propagate visibly rather than creating hidden timeouts and repeated requests.

Cost-abuse and denial-of-service scenarios include adversarially long inputs, tool fan-out, repeated retries, cache busting, and provider-account exhaustion. Security and capacity controls should be coordinated.

24.5 Design Graceful Degradation

Graceful degradation preserves the most important service properties when resources or dependencies fail. A product may shorten optional context, use a smaller approved model, disable a nonessential feature, restrict topics, or fall back to a conventional process. Any alternative must be evaluated for its claim.

Do not silently lower safety, entitlement, or authorization checks to meet latency. The degradation policy should identify inviolable controls and communicate reduced capability. A cheaper model is not a fallback until its behavior and limits are approved.

The continuity plan in §25.5 records which degraded or non-AI route is authorized for the service, its prerequisites, capacity and reassessment trigger. Graceful degradation is an option inside that boundary, not permission to bypass an entitlement or action control. If the approved route loses safety, permission or sufficient capacity, restrict the affected activity and escalate the remaining service impact.

24.6 Measure Reliability Across Dependencies

Reliability analysis should include provider, network, identity, corpus, vector store, policy service, tool, queue, database, observability, and human fallback. Correlated dependencies matter: two models on the same provider or region may not provide meaningful resilience.

Track partial and semantic failures as well as hard outages. A retrieval service can return success with stale results; a model endpoint can return valid JSON with unsupported content. Technical health and product-quality signals must be combined without conflating them.

Error budgets or similar methods can inform the pace of change, but their definitions should include the failures material to the product. They are operating mechanisms, not universal governance requirements.

24.7 Establish a Defensible Sustainability Boundary

Sustainability discussion should define the measured boundary: model development, adaptation, inference, storage, retrieval, network, facilities, hardware lifecycle, or the broader process being changed. Provider estimates may use different methods and regions; comparisons require qualification.

Avoid unsupported energy, water, or emissions figures. Where measurement is available, state source, method, period, allocation, uncertainty, and whether the figure is operational, embodied, or estimated. Efficiency changes may create rebound effects if lower unit cost increases total use.

Sustainability is one decision factor alongside service, risk, cost, and value. A smaller model or shorter context may reduce resource use and latency, but only if it still satisfies the approved claim. The bank should not trade away a material control under an unverified sustainability assertion.

24.8 Worked Capacity Decision at Fictional Bank

The policy assistant experiences peak demand after a policy update. The team models model-service quota, retrieval load, employee concurrency, and fallback capacity. It prioritizes short supported questions, queues document-comparison jobs, caps retries, and displays when the AI path is unavailable.

The service does not remove citations or entitlement checks to reduce latency. If provider quota is exhausted, it routes employees to the existing policy-support process. The bank records wait time, fallback demand, abandonment, and rework to assess whether the service and its alternative remain viable. No performance or savings outcome is asserted.

24.9 Recovery Objectives and Capacity Evidence

Resilience terms must be defined consistently. A **recovery time objective (RTO)** expresses the target time to restore a service or capability after disruption. A **recovery point objective (RPO)** expresses the maximum targeted data-loss interval measured in time for recoverable state. **Maximum tolerable period of disruption (MTPD)** or comparable local terminology concerns the longest disruption the business determines it can tolerate before unacceptable impact. Institutions and regimes may use related terms differently; local resilience policy governs.

For an AI product, these objectives may differ by layer. The business service might continue through a non-AI route while the model service is unavailable. The retrieval index may be rebuilt from source with a longer RTO than the customer channel because

a safe static knowledge path exists. Intentionally disposable conversation memory may have no recovery requirement; that is not RPO zero. RPO zero targets no loss of the recoverable committed state in scope. Confirmed actions, approval receipts and reconciliation records need their own durable recovery and integrity objectives.[1]

Table 24.2 — Component/state and recovery question

Component/state	Recovery question	Evidence
customer or employee channel	can the underlying service continue without AI?	fallback exercise and capacity result
workflow queue	can pending work be identified without duplicate action?	restore and reconciliation test
model/provider	is substitution approved and behaviorally evaluated?	outage scenario and candidate record
corpus/index	can the exact source set be rebuilt and entitlement restored?	reproducible build and withdrawal test
policy/configuration	can the approved version be recovered without mutable alias ambiguity?	manifest and configuration restore
evidence store	can release and action lineage survive component failure?	backup/restore, integrity and access test

Capacity model under degraded operation

Capacity planning should include arrival rate, service time, concurrency, context or feature size, retry behavior, provider quota, queue limits, employee review capacity and fallback throughput. Averages are rarely enough. Peak correlation matters: an incident can increase customer demand precisely when a provider or channel is impaired.

Fictional Bank models the policy assistant’s normal path and employee fallback. The non-AI route has limited specialist capacity, so degradation prioritizes urgent policy topics and communicates expected handling rather than allowing an unbounded queue. The exercise records assumptions and observed throughput; it does not claim universal service targets.

Cost and sustainability measurement boundary

Unit cost should include inference, retrieval, data processing, storage, evaluation, observability, network, review, incident readiness and shared platform allocation where decision-useful. Cost per token alone can reward longer or lower-quality workflows. Define the unit as a business task and pair cost with quality, consequence and fallback.

Environmental measurement likewise requires a declared boundary, method, data source and uncertainty: training versus inference, direct energy versus attributed provider estimates, location/time, embodied infrastructure if included, and avoided or shifted work. Sustainability claims need specialist review. This book supplies no performance or emissions figure.

The acceptance record connects service objectives, load profile, failure/degradation rules, capacity tests, cost definition, recovery objectives and owners. A metric without an action remains observation, not control.

Link these component questions and their capacity assumptions to the business-service continuity exercise in §§25.5–25.6 and the B01–B12 record outline in Appendix H. Record the demand, staffing, queue and dependency conditions under which an alternative was evaluated. A technical recovery target or a single successful component test does not establish that the service can continue within its locally determined tolerance.

Degradation tied to workload and capacity

Table 24.3 — Workload stress and safe-route decision

Workload stress	Safe-route decision	Evidence to test
Policy-support route unavailable or overloaded	Narrow topic/exposure and communicate bounded service; do not improvise unsupported policy	Queue/staffing/admission assumptions, priority and recovery conditions
Alert-review queue grows	Maintain accountable investigation route within approved operating limits; escalate capacity breach	Queue age, severe-case handling, manual workload and affected population
Evidence access unavailable during incident	Use authorized trusted-source/snapshot route or hold affected decisions (§2.6)	Retrieval target, integrity/access check, reconstruction gaps and buffering/replay
Cost/resource budget exhausted	Bound loops/concurrency and stop or degrade the approved task	Budget/iteration limits, state preservation, outstanding work and customer/process effect

Exercises test achievable service outcomes against locally set tolerances. These patterns do not assert available staffing, a recovery time or a universal capacity threshold.

Synthetic capacity and tail-cost observation

In a constructed ten-minute technical stress profile, 100 requests/minute arrive and 80 drafts/minute complete: 1,000 arrivals, 800 completions and 200 outstanding requests if none abandon and no other route completes them. Admission control must route or defer excess demand without retry amplification. Synthetic p95/p99 latency is 4/8 seconds in the normal profile and 12/30 seconds in stress, measured from technical channel ingress to draft availability over the declared profile window. It excludes employee handling; define that separate end-to-end boundary before making a service claim.

The constructed four-week monthly cost is 43,000/9,000 accepted cases = 4.78 (§5.5). The 100-request/minute technical stress profile is a different workload from §25.5's manual exercise of 120 cases/hour demand and 40/hour fallback; no routing conversion is supplied. Count accepted outcomes, checking, refusals and rework within their own declared boundaries. Fund fallback or restrict exposure when demand exceeds its authorized capacity. Meter energy over a specified inference/storage/network boundary or label provider estimates; no energy or emissions saving is asserted.

RTO targets restoration time for a named capability; RPO targets recoverable data loss; MTPD expresses the business's tolerated disruption period. A UK important-business-service impact tolerance also assesses the disruption's effects within its regime. A component can meet its RTO while customer impact still breaches the service tolerance. Test the whole service and its fallback, not only the restarted server.

24.10 Executive and Practitioner Decisions

Evaluate capacity at peak and tail conditions, using accepted completed cases as the cost unit. Service continuity, recoverable data and sustainability claims each need a declared measurement boundary and evidence.

This chapter's objective, cost-boundary, and sustainability framework is author synthesis. No external performance, emissions, energy, water, cost, or capacity figure is used.

Notes

1. NIST recovery-point objective glossary (B59), inspected 8 October 2026. State and service scope, integrity and local resilience rules determine the applied objective. Return to text

Chapter

25 Operational Resilience and Third-Party Dependencies

Operational resilience asks whether the institution can continue or recover the service outcomes that matter when disruption occurs. The analysis should begin with the banking service, customers, obligations, and tolerable disruption—not with the availability of a model endpoint.

25.1 Start With the Critical Service

Basel Committee operational-resilience principles provide an international reference for banks, while the 2025 third-party-risk principles provide a flexible common baseline for managing external dependencies.[1] They are not directly binding in every jurisdiction. The EU's Digital Operational Resilience Act is a jurisdiction-specific legal example and applies within its scope.[2]

25.2 Map the End-to-End Dependency Chain

Map people, processes, facilities, technology, data, models, knowledge sources, providers, subprocessors, connectivity, and manual alternatives needed to deliver the service. Include dependencies that do not look like AI: identity, DNS, certificate, queue, observability, and ticketing services can determine availability and recovery.

For each dependency identify owner, service supported, location, provider, concentration, substitutability, data and authority, recovery assumption, evidence access, and failure coordination. A model-service contract alone cannot reveal the end-to-end chain.

25.3 Assess Concentration and Correlation

Concentration can arise from one provider, region, model family, cloud platform, vector database, open-source library, data source, integration pattern, or specialist team. Superficially different vendors may depend on the same infrastructure or foundation model.

Assess correlation: can one incident, account compromise, regulatory restriction, network failure, or provider policy change affect multiple products? Diversification that shares the same failure domain provides limited resilience.

The decision should consider product materiality, switching time, evidence gaps, fallback, and cost. Concentration may be accepted, but the record should show who accepted it and what monitoring or exit capability supports the decision.

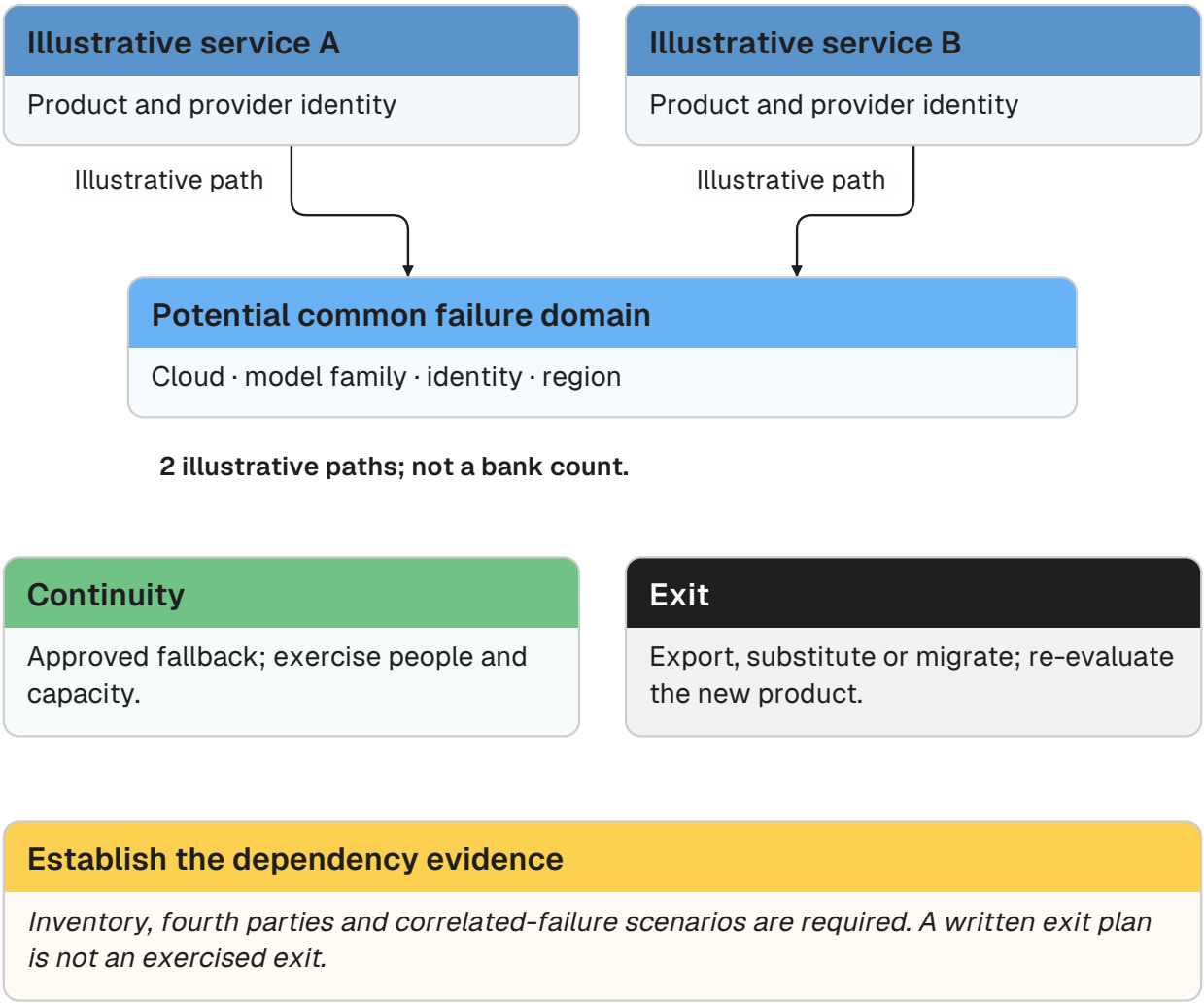
Shared failure-domain record

Table 25.1 — Product route and direct supplier

Product route	Direct supplier	Shared dependency
Policy assistant primary	Provider A	Cloud C / identity I
Proposed model fallback	Provider B	Cloud C / identity I
Approved manual policy route	Internal support	Identity I for protected sources; bounded offline route only where authorized

The two model contracts do not provide independent recovery from Cloud C or identity I. Test those dependencies directly; separately assess whether the offline information, access and staffing actually permit continuity. Unknown fourth-party facts reduce confidence rather than count as diversification. See Figure 25.1.

Figure 25.1 — Different services can share one failure domain



Two illustrative service paths may share one failure domain. Continuity and exit require distinct preparations; no actual bank dependency is asserted.

25.4 Make Third-Party Evidence Decision Relevant

Due diligence should address capability, security, privacy, resilience, incident communication, model and service changes, data handling, subcontracting, audit or evidence access, recovery, business continuity, financial and geopolitical exposure where relevant, termination, deletion, and portability.

Classify evidence by source and strength: contract, independent report, certification within stated scope, provider test, bank test, operational observation, or unresolved assertion. Certifications can support a decision but rarely cover the bank's exact product workflow.

Ongoing monitoring should follow material changes and performance, not merely repeat an annual questionnaire. Provider incidents, service degradation, ownership changes, new subprocessors, model updates, or loss of evidence access may trigger reassessment.

Legal rights, terms and evidence of capability

A provider right matters to a decision only when its scope and practical limits are understood. The matrix below groups seven review themes: availability; data/confidentiality; licenses/portability; oversight/changes; termination/transition; closure/residual duties; and complaints and financial institution rights. It is an unscored author framework with illustrative ownership, not globally mandatory contract clauses or a finding of compliance.

For each theme, identify the actual contract or legal constraint, the entity and service it concerns, who can determine its meaning, and the evidence of what the institution can do. Keep negotiated rights, provider assertions, institution tests and operating observations separate. An export clause does not show that exported state can be interpreted; an assistance promise may have notice, fee, access or cooperation limits. A termination right does not qualify a substitute model. Known constraints, unavailable evidence and work needed to make the option feasible belong in the decision record.

Trace permitted purpose, training reuse, secrecy/confidentiality, locations, subprocessors, transfer and access questions to the actual data flow and qualified assessment. Inventory what can be exported or rebuilt under its license, including institution-controlled sources/configuration and evidence, and what remains provider-only or non-portable. Do not assume access to model weights, internal logs or other proprietary artifacts. The data and customer-protection chapters retain their existing scope.

Customer complaints, contestation and legal challenge need a route to the relevant decision/release, competent review, correction and remedy assessment. The financial institution may also need to defend its conduct or assess a contractual claim or remedy against a provider. The legal, complaints, records and service owners should establish

the relevant facts, terms, procedural constraints and lawful evidence needs. Supplier remedies do not override customer rights or establish fulfilment of customer duties. The book does not decide liability or presume an entitlement to compensation.

Lawful preservation and access should support investigation and claims without uncontrolled disclosure. Refer to the evidence-custody method in §8.7, customer rights in §19.6 and incident/remediation operations in §23.6. Link open matters and owners to the continuity, transition and closure records in §§25.5 and 26.7–26.8. Switching off a model does not settle an outstanding complaint, provider dispute or records duty.

Use Appendix H to connect the seven themes to actual terms, constraints, capability evidence, gaps and owners. The figure is a review guide; enforceability, applicable amended rules, local rights and institutional readiness still require their own evidence and competent decisions. See Figure 25.2.

Figure 25.2 — Legal rights, provider terms and exit capability

Protect customer remedies and the financial institution's lawful rights; test what the financial institution can do.

Review theme	Terms and constraints	Proof of capability	Suggested ownership
Service availability	Notice, suspension and deprecation terms; emergency support limits	Exercise sudden access loss and provider non-cooperation; validate the safe service route	Service owner; procurement; continuity
Data and confidentiality	Permitted purpose, training reuse, locations, subprocessors and lawful transfers	Map data flows; enforce access and purpose limits; test recoverable records	Data owner; privacy; legal
Licences and portability	Rights to use and move code, prompts, outputs and other assets; third-party limits	Inventory assets; test export or rebuild; do not assume transferable model weights	Legal; engineering; records
Oversight and changes	Information, audit and supervisory access; model and subcontractor change terms	Retain usable evidence; reassess material changes and missing access	Risk; assurance; legal
Termination and transition	Exit rights, assistance, fees, notice and realistic transition commitments	Test planned and stressed routes; qualify replacement; authorize cutover	Service owner; operations; legal
Closure and residual duties	Return or deletion, lawful retention, liabilities, disputes and continuing duties	Verify access revocation and data disposition; keep evidence and remedies owned	Records; legal; service owner
Complaints and financial institution rights	Customer complaints, redress and legal challenge; financial institution defence, provider remedies and dispute terms	Trace the decision and release; test complaint handling, lawful evidence preservation and claims support	Complaints owner; legal; records; service owner

Contract rights alone do not prove a feasible fallback or exit. Financial institution defence and provider claims do not override customer rights.

Preservation, retention, disposal and disclosure follow applicable duties and authority.

Privilege is a separate fact- and jurisdiction-dependent protection assessed by competent counsel; lack of privilege does not remove lawful preservation duties.

Legal rights, provider terms and exit capability. Seven unscored review themes separate actual terms, capability evidence and illustrative ownership.

Figure 25.2. Legal rights, provider terms and exit capability. Author synthesis. Seven themes are unscored; ownership is illustrative. Customer remedies and lawful financial institution rights require actual contract, entity, jurisdiction and evidence review.

Privilege, lawful basis, confidentiality and retention are separate legal questions. A privileged communication label does not create a privacy lawful basis; a contract confidentiality clause does not decide privilege or retention. The legal owner records each conclusion with actor, jurisdiction, purpose and evidence access limits. Preserve unknowns rather than treating one label as an answer to all four.

25.5 Design Continuity and Exit as Different Capabilities

Continuity sustains the service during disruption. Exit ends or transfers a dependency through a planned or stressed transition; a stressed exit can begin alongside continuity. A short outage may be handled through fallback; a provider withdrawal or unacceptable contract may require data export, model substitution, architecture change, re-evaluation, and migration.

An exit plan should identify assets to retrieve or delete, formats, dependencies, intellectual-property and license constraints, replacement criteria, migration sequence, dual running where appropriate, evaluation, customer and regulator considerations, and residual records. It should state what cannot be ported.

Test parts of the plan. Exporting configuration without proving that the service can use it is not portability. Switching models requires behavioral re-evaluation even when the API is compatible.

Business Continuity / Contingency Plan

Start with the business service and affected parties, not the failed endpoint. Record the runtime or software-delivery dependence, consequence, locally defined tolerance/objectives and minimum acceptable service. A component recovery plan supports this analysis but does not replace it. The B01–B12 outline in Appendix H links the service to its release, dependencies, controls, capacity, evidence and owners; it is an author record pattern to adapt, not a universal regulatory template.

Name the conditions that activate contingency and where the signals come from. They may include abrupt model-access withdrawal, a legal or contractual access restriction, outage, latency/quota loss, unsafe output/action or changed behavior. The plan should identify the authority to activate, contain and escalate, the service/incident owner and the communication route. Internal activation, supervisory approval or notification, and incident reporting remain distinct; applicable duties and deadlines must be determined locally through §8.4.

An alternative supports continuity only within its approved and lawful envelope. A non-AI, manual or degraded route needs usable source access, skills, permissions, inviolable controls and credible capacity for the priority service. Disabling an optional AI feature must not silently remove entitlement, security or action authorization. Record prerequisites, permitted scope and limitations rather than treating every named alternative as ready.

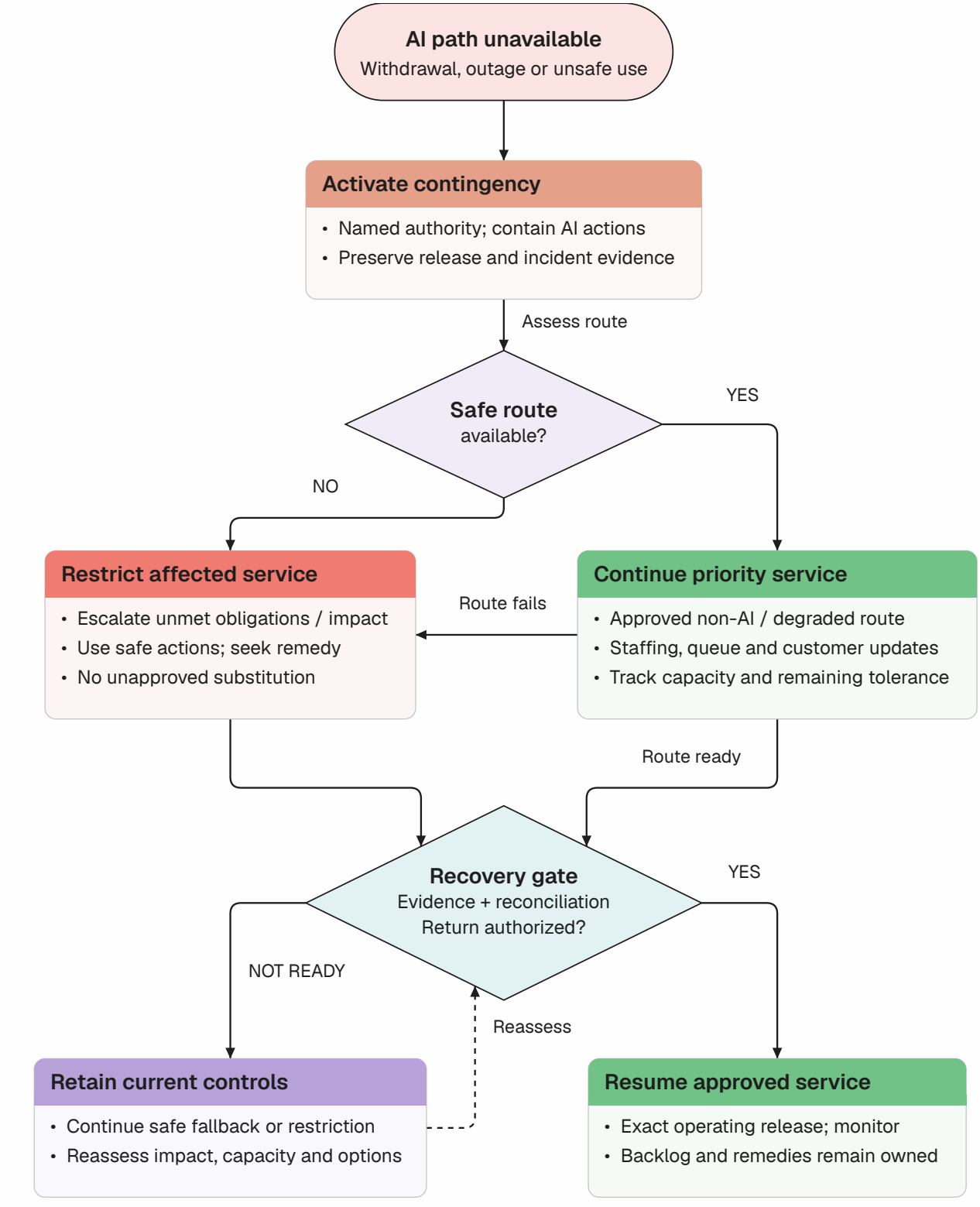
Capacity is part of the operating decision. Assess normal and peak demand, available staff and skills, queue priorities, throughput assumptions, backlog, abandonment and emerging customer/service impact. Observe whether the route is still viable and who reassesses when demand, staffing or control conditions change. A manual option written in a plan is not evidence that it can absorb the actual workload.

Contain new AI actions and preserve the exact release/incident references when safe and lawful. Classify in-flight work as pending, completed, failed or unknown using authoritative business records. A timeout does not prove that a payment, message or record update failed. Reconcile action identity and downstream state before retry or replay; carry affected-customer and record remediation to §23.6. Keep relevant evidence accessible under the custody rules rather than copying all content into the contingency pack.

Monitor the remaining service impact, route controls and capacity during contingency. If the fallback loses permission, safety or sufficient capacity, move to restriction and escalation. Continuity and a stressed exit may run in parallel; continuing a priority service is neither permission to use an unqualified replacement nor proof that every obligation is being met. See Figure 25.3.

Figure 25.3 — AI disruption and business continuity

Protect the banking service; do not silently substitute an unqualified model.



Safe route: lawful, approved and capable within the service tolerance.
Persistent loss may trigger exit alongside continuity; see Figure 25.4.

When the AI path is unavailable, activate contingency and assess a lawful, approved and capable service route. Resume only through the recovery gate and authorization; keep backlog, remedies and any exit decision owned.

Figure 25.3. AI disruption and business continuity. Author synthesis. A safe approved route supports only its evidenced scope and capacity; restriction and unmet impact remain visible when it cannot. The diagram does not report a successful recovery.

Planned and Stressed Exit Plan

A planned exit may follow commercial, performance or strategic decisions. A stressed exit may follow withdrawal, failure, loss of permission or another condition that leaves little notice or provider cooperation. Prepare both before becoming dependent. Identify the authority to start, the affected service, the linked contingency plan and what can actually be done without assuming the departing provider remains available.

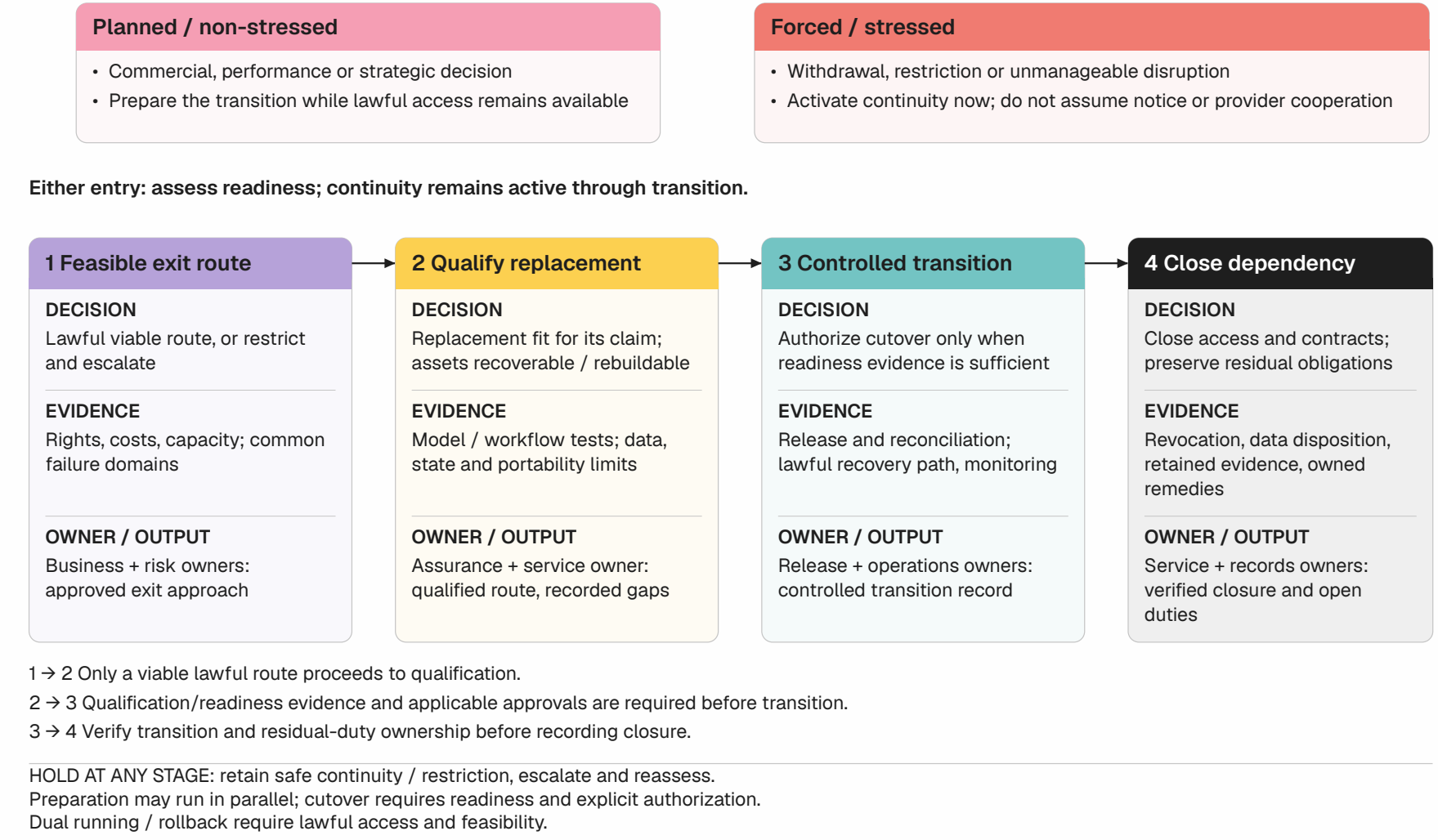
Inventory institution-controlled data and knowledge sources, prompts/configuration, permissions, integration code, release/evaluation records, logs that the institution can lawfully obtain, queues and action state. For each asset, record its custodian, format, permitted use, export/rebuild/deletion rights and known limit. Provider-specific weights, filters, logs or internal state may be unavailable or non-portable. Test export interpretation and source-based rebuild where appropriate; do not fabricate missing evidence to make the register look complete.

Assess feasible alternatives against the actual claim. A second provider, reseller, account, region or model is not proof of independence or capacity. Map shared cloud, identity, network, base model, fourth parties and legal access restrictions; assess alternate quota, staffing, budget and technical prerequisites. A non-AI route or retirement of a discretionary feature may be a better lawful option than substitution. If none is viable, record that constraint and the consequence rather than labeling an unqualified option a recovery route.

The E01–E12 outline in Appendix H connects those facts to replacement criteria, transition sequence, closure and maintenance. Keep preparation, authorization, exercise and actual completion distinguishable. Refresh the plan and qualification when the service scope, provider/model, data, terms, permissions, law, dependencies or operating capacity changes. See Figure 25.4.

Figure 25.4 — Planned and stressed AI exit readiness

Prepare before dependence; activate the applicable route without transferring model approval.



Planned and stressed entry routes lead through feasible exit, replacement qualification, controlled transition and dependency closure. Readiness and applicable authorization govern progression; continuity and residual duties remain owned.

Figure 25.4. Planned and stressed exit from an AI dependency. Author synthesis. Stages identify decisions, evidence and ownership; they do not promise provider cooperation, a qualified substitute or a completed exit.

Qualification, Transition and Return to Service

Treat a replacement model/provider as a candidate. Evaluate the actual task and workflow, behavior and material failure modes, data rights/residency, entitlements, tool authority, security/control evidence, latency and capacity. Apply the existing classification, review and release route to the changed claim. An API-compatible service does not inherit the former model's evaluation or authorization.

Define readiness conditions and the exact release before cutover. Stage exposure and monitor where that is feasible, preserve action identity, reconcile in-flight work and keep customer/record remedies owned. Dual running or rollback is an option only when permissions, technical state and provider access make it lawful and workable; an exit plan cannot assume use of a prohibited or withdrawn endpoint.

For return to the original or a qualified route, the existing authorized owner should assess current identity, control/evidence health, capacity, reconciliation and unresolved impact. Availability alone does not pass the recovery gate. Record the permitted operating scope, conditions, monitoring and backlog/remediation owners. If evidence or authority is insufficient, retain the safe fallback or restriction and reassess through §23.7 and Chapter 26.

When a Safe Route Is Unavailable

Restrict the affected activity, preserve lawful safe actions and escalate customer/service impact and unmet obligations through the actual authority. Assess locally applicable communication, reporting and remedy questions; seek qualified decisions without inventing an emergency waiver of law. Be explicit about the unavailable route, evidence gaps and consequence. Restriction may be necessary harm containment, but it is not successful continuity or a substitute for meeting an obligation.

Revisit the options as facts and evidence change. The decision may fund more capacity, narrow the service, maintain restriction, qualify another design or retire the dependency. A management summary should show that unresolved choice and its owner, not merely mark the continuity plan complete.

25.6 Exercise Disruption Scenarios

Scenarios should include provider outage, region failure, latency or quota degradation, model withdrawal, unannounced behavior change, corrupted index, identity-service failure, data-source outage, subprocessor incident, loss of evidence access, and simultaneous failure of AI and fallback capacity.

Exercises should involve business, technology, risk, provider, communications, and customer-remediation roles as appropriate. Measure decisions and service outcomes, not only technical recovery. Preserve findings, owners, due dates, and retest evidence.

Impact tolerance or similar concepts must be defined under applicable frameworks. This book does not supply a universal time or loss threshold.

Extend the scenario set to sudden withdrawal without notice or cooperation, inaccessible records, scarce alternate quota at peak demand, correlated failure and unknown agent-action outcomes. Include a replacement that is API-compatible but fails a material product claim, and a restored endpoint whose behavior or configuration has changed. The illustrative CE-S01–CE-S07 schedule in Appendix H defines the observation/decision question without claiming a result.

Use risk-proportionate tabletop, technical and business exercises suited to the actual service and uncertainty. State the assumed conditions, locally defined criteria and permitted actions before the exercise; observe activation, safe route or restriction, staffing/queue effects, reconciliation, communications and exit/return decisions. Record what was and was not tested, evidence gaps, owners, due dates and retest. A rehearsal can inform readiness but does not establish uninterrupted BAU or transfer approval to a replacement. No universal tolerance, recovery time or pass threshold is supplied.

25.7 Coordinate Provider Incidents

Contracts and playbooks should define contact routes, severity, notification, evidence preservation, model or configuration identity, containment, status cadence, customer-impact support, and post-incident evidence. The bank retains accountability for its response even when the provider caused the failure.

Provider communication may be delayed or incomplete. The bank needs its own detection and containment where material. If the product cannot operate safely without provider evidence, that limitation should affect architecture and risk classification.

25.8 Worked Resilience Exercise at Fictional Bank

Synthetic continuity and exit exercise PA-RES-01

At 09:00 the primary service fails. In this separate manual workload, demand is constant at 120 cases/hour; fallback starts at 09:15 and completes 40/hour. Assume no abandonment and no other completions. By 09:15, 30 arrivals await service. By 10:00, 120 cases have arrived and 30 have completed, leaving 90 outstanding, including explicitly deferred demand. After activation the shortfall grows by 80/hour. The owner prioritizes authorized urgent topics, communicates deferral and escalates funding or exposure limits. These counts show a capacity gap; they establish no tolerance pass or uninterrupted service.

The proposed alternate model remains off. Its application integration passed a laboratory check, but its provider cannot supply the required export cooperation in the exercise, and both providers rely on the same identity service. A contract clause does not remove either dependency.

Table 25.2 — Observation and constructed evidence

Observation	Constructed evidence	Owner and disposition
Model access lost	Failure injected at 09:00; model route stopped	Operations holds affected route
Fallback capacity shortfall	120/hour arrivals versus 40/hour completions	Service owner restricts scope and assesses staffing
Shared identity failure domain	Provider A and B both depend on identity service I	Architecture withdraws the claim of independent fallback
Export cooperation gap	Requested export incomplete under the exercised route	Supplier/legal owners assess terms and capability separately
Evidence-index outage	Trusted snapshot available; three buffered event references initially unresolved	Custodian preserves sequence and reconciles against authoritative records
Retest	Staged for changed capacity, identity and export assumptions	Resilience owner withholds full-peak readiness until evidence is supplied

Continuity preserves a permitted service route; stressed exit removes an untenable dependency. They can proceed together, but neither approves a replacement model. The record links service tolerances, rights, tested capacity, uncertain in-flight work, owners

and a new decision. Use Appendix H’s fields to retain the result rather than repeating a generic warning at each step.

25.9 Jurisdiction Examples and Exit Evidence

Operational resilience and third-party expectations are not globally interchangeable. The common engineering response is to map critical services, dependencies, tolerances, scenarios, governance and evidence; the legal or supervisory conclusion remains jurisdiction- and entity-specific.

Table 25.3 — Source context and bounded example

Source context	Bounded example	What the architecture should expose
International / Basel	operational resilience focuses on a bank's ability to deliver critical operations through disruption; third-party principles emphasize lifecycle risk and concentration	critical operation, dependency chain, tolerance, scenario, continuity and exit evidence
United Kingdom	PRA/FCA operational-resilience regimes use important business services and impact tolerances for firms within scope; PRA outsourcing/third-party requirements add governance and contract expectations.[3]	service-to-product map, maximum tolerable disruption, board/self-assessment evidence, material outsourcing and provider dependencies
United States	2023 interagency guidance applies a risk-based lifecycle approach to banking-organization third-party relationships and stresses that arrangements vary in risk.[4]	relationship inventory, due diligence, contract, ongoing monitoring, termination and board/management accountability
Singapore	MAS technology-risk and outsourcing/third-party materials provide expectations for financial institutions within their scope; MAS published the Project MindForge AI Risk Management Toolkit and Operationalisation Handbook on 20 March 2026 as practical material preceding the final 7 October 2026 AI-risk guidelines (B56).[5]	technology dependency, availability/security, outsourcing materiality, oversight, continuity and exit
European Union	DORA establishes entity- and scope-specific ICT risk and third-party obligations for covered financial entities	ICT service dependency, contracts, register/reporting route, testing, incident and exit evidence

These rows are navigation aids, not legal summaries. Source currency and applicability must be checked for the relevant entity and date.[6]

Impact tolerance and component objectives

An impact tolerance is a business-service boundary for the maximum tolerable disruption under the applicable framework; it is not simply an infrastructure RTO. A service can breach its customer-impact tolerance even when servers recover “on time,” or remain within tolerance by using an approved manual route while the AI component is unavailable. Component RTO/RPO support—but do not replace—the service-level analysis.

Exit test, not exit document

An exit plan should demonstrate that the bank can obtain and interpret its data and records, revoke provider access, replace or remove technical integration, rebuild critical knowledge or state, continue the service, meet retention/deletion decisions, reconcile in-flight work, and manage customer/employee change. A contractual right can have legal or negotiating value even before an exercise. Enforceability and demonstrated operating capability are different propositions; record each separately.

The synthetic §25.8 exercise leaves continuity and exit gaps open: the manual route handles 40 requests/hour against 120/hour demand, the substitute shares the identity dependency, and record export is incomplete. The service owner restricts priority work; the identity and records owners resolve their gaps before the next capacity and export retest. A substitute model remains a new candidate requiring qualification. Neither uninterrupted operation nor a completed exit is demonstrated.

Concentration and fourth-party evidence

Map concentration across suppliers and the underlying cloud/region, model, identity service, network, packages and specialist teams. Products that appear diversified can fail together. Group the exercise by common failure domain and leave unavailable contractual or technical facts visible; unknown concentration is not verified diversification.

The chapter’s output is a decision-ready third-party record: service supported, criticality, data and authority, dependency/fourth-party map, evidence reviewed, limitations, concentration, continuity, exit, incident coordination, change notice, accountable owner and review trigger.

Dependency and exit manifest

The service register separates legal supplier, product/service, underlying cloud and region, base model, identity provider, network, vector/knowledge store, observability, content filter, evaluation service, open-source package, human-review provider, and shared internal platform. For each it records owner, purpose, data/authority, concentration group, substitute, contract evidence, bank verification, continuity, exit steps, test date/result or evidence gap, and re-evaluation trigger.

Keep contractual assurance, provider attestation, bank testing and observed operation distinct in the manifest; §25.8 supplies the exercise result and remaining gaps.

Scoped continuity and exit sources

The November 2024 PRA SS2/21 describes continuity and planned/stressed exit expectations for material outsourcing within its defined UK firm/arrangement scope. Its version index distinguishes that current edition from the March 2026 edition, effective 18 March 2027.[7] These dates do not make the expectations a global AI approval rule.

The BCBS December 2025 third-party principles connect ongoing monitoring, continuity and planned/unplanned termination for banks and supervisors, with jurisdictional adaptation.[8] The AI-specific workflow, record fields and matrix in this book are author synthesis.

For each actual service, use §8.4 to record the primary source/version, binding or guidance status, entity/activity/date, applicable decision or reporting route, unresolved question and competent owner. EU, US and Singapore examples retain their own applicability limits. A country row or contract statement is not an institution-specific legal conclusion.

Evidence status and maintenance

Keep a proposed plan, an authorized arrangement, an exercise observation and an actual operating or completed-exit outcome distinct. Link criteria, assumptions, observed limitations, gap owners and the disposition rather than reducing them to a ready/not-ready score. Known non-portable assets and missing evidence remain visible even after an internal plan approval. These are descriptive record links within Chapter 2's evidence model, not rated evidence-lineage diagram edges or new evidence classes.

Refresh the manifest's owners, resources, source versions and exercise scope when provider/model, service, data, terms, permissions, law or capacity changes. §§25.4–25.6 and Appendix H link terms, continuity, transition and tests to the affected claim.

25.10 Executive and Practitioner Decisions

The service owner should test demand, dependencies and lawful safe routes through a disruption. A legal right, an enforceable term and exercised capability are distinct; a substitute remains a candidate until qualified.

Notes

1. Basel Committee on Banking Supervision, Principles for Operational Resilience (B11) and Principles for the Sound Management of Third-Party Risk (B13), published 10 December 2025. International principles; implementation is jurisdiction specific. Return to text

2. European Union, Regulation (EU) 2022/2554 on digital operational resilience (DORA) (B36), applicable from 17 January 2025 within its scope. It is an EU/EEA legal example, not a global requirement. Return to text

3. PRA SS1/21 (B41) and SS2/21 (B42), within stated UK firm and activity scope. Return to text

4. Federal Reserve/FDIC/OCC, 2023 Interagency Guidance on Third-Party Relationships (B40), within supervised-institution scope and not AI-specific. Return to text

5. MAS Technology Risk Management Guidelines (B44), Guidelines on Outsourcing (Banks) (B45), and final Guidelines on AI Risk Management for Financial Institutions, 7 October 2026 (B56), each within its own scope. Project MindForge toolkit/Operationalisation Handbook (B51) is consultation-era supporting material, not the final guideline or proof of supervisory compliance. Qualified applicability review remains required. Return to text

6. European Union, Regulation (EU) 2022/2554 on digital operational resilience (DORA) (B36), applicable from 17 January 2025 within its scope. It is an EU/EEA legal example, not a global requirement. Return to text

7. PRA, SS2/21, November 2024, §§1.2 and 10.1–10.2; official version index and November 2024 text, checked 7 October 2026. Defined UK scope; later applicable changes require review. Return to text

8. BCBS, Principles for the Sound Management of Third-Party Risk, 10 December 2025, Principles 7–9; official publication and text, checked 7 October 2026. International banking guidelines; local implementation/applicability is separate. Return to text

Chapter

26 Change, Continuous Improvement, and Retirement

AI products evolve through software, model, data, corpus, prompt, policy, tool, infrastructure, provider, and workflow changes. Improvement is not self-proving. A change is acceptable when evidence shows that the resulting product remains suitable for its approved use or when a new use is explicitly approved.

26.1 Every Improvement Is a Change to a Claim

The change record should state what changed, why, affected claims and dependencies, risk and materiality, regression scope, review route, deployment and recovery, monitoring, and owner. “No code change” is not a reason to skip assessment.

26.2 Classify Change by Effect

Table 26.1 — Change class and example

Change class	Example	Typical consequence
Editorial or administrative	Non-behavioral documentation correction	Record and lightweight review
Bounded configuration	Approved threshold or prompt update within envelope	Targeted regression and release control
Behavioral dependency	New model, index method, feature logic, tool schema	Broader evaluation and domain review
Use or authority	New population, purpose, data, action, jurisdiction	Reclassification and renewed approval
Emergency containment	Disable tool or restrict scope during incident	Immediate authority plus retrospective review
Retirement	End use, revoke access, preserve or delete records	Decommission and residual-risk decision

Map these change categories to existing policy. The useful distinction is which claims must reopen, with what evidence and authority.

A finite test suite supports a conclusion only within its defined cases, assumptions and change envelope. It cannot demonstrate that a prompt edit never changes relevant behavior. Preserve the tested identity, residual uncertainty, cumulative-change history and re-entry obligations; evaluate an envelope breach as a changed claim.

26.3 Define a Change Envelope

A change envelope identifies updates permitted under a standing route and the evidence required. It can specify components, allowed values, exposure, tests, approver, and triggers that force reclassification. The envelope speeds routine work without granting silent expansion.

Examples might include correcting a policy document under an approved corpus process, tuning a latency parameter within tested limits, or updating a prompt phrase with targeted regressions. Adding write authority, a customer population, a new data category, or an unpinned model falls outside a narrow envelope.

The envelope itself requires review and periodic validation. Repeated small changes can accumulate into material drift even when each appears bounded.

26.4 Keep Feedback Loops Controlled

Feedback can identify defects and opportunities, but automatic learning from live interaction can alter behavior without a release decision. Separate collection, interpretation, selection, training or tuning, evaluation, and deployment.

Feedback may be biased, manipulated, sensitive, or weakly related to correctness. Human corrections can reflect policy or personal preference. Complaints can reveal severe failures but not prevalence. Preserve provenance and use an accountable process to decide what becomes a training example or requirement.

Where online learning is proposed, its update rules, data boundary, monitoring, rollback, and approval need specialized review. This book makes no general recommendation to enable it.

26.5 Scope Regression to the Failure Path—and Beyond It

Impact analysis should identify claims directly affected by the change and adjacent failure paths. A new embedding model requires retrieval regression; it may also change latency, capacity, citations, and fairness across language. A prompt repair for refusal may affect helpfulness and tool selection.

Use baseline and new-condition cases, material past defects, security tests, contract tests, and operational exercises. Report improvements and regressions rather than selecting only favorable outcomes. Where the evaluation method changes, avoid interpreting score movement as product movement without calibration.

26.6 Improve Through Evidence, Not Anecdote

Prioritize improvements using customer and employee impacts, incidents, monitoring, evaluation gaps, control failures, provider changes, cost and capacity, and strategic value. A vivid anecdote can reveal a failure class but should not be treated as prevalence evidence.

Improvement backlogs should identify the claim, expected mechanism, evidence needed, risk of change, and decision. Stop low-value experiments and retire controls that produce no decision value only after assessing the risk they addressed.

26.7 Decide to Retire

Retirement can be triggered by low value, unacceptable risk, obsolete technology, provider exit, policy or legal change, inability to validate, replacement, or end of the supported process. The decision should identify the service and affected parties, not merely the model.

Plan user and customer communication where required, migration or fallback, access revocation, endpoint and credential shutdown, queued-work handling, data and model disposition, corpus and index removal, provider termination, monitoring closure, evidence retention, records schedules, and residual dependencies.

Retirement does not erase history. Preserve decisions, releases, incidents, customer remediation, and required records under applicable policy. Delete data and artifacts when required and permitted, with evidence of disposition. Legal holds and investigation needs require qualified determination.

Carry the continuity/exit record in §25.5 and open complaints, claims and customer/record remedies into the retirement decision. Name successor owners and evidence access for residual duties; retiring the technology does not settle a complaint or provider dispute. Replacement qualification and operating acceptance remain separate from the decision to stop using the old dependency.

26.8 Verify Decommissioning

After shutdown, verify that traffic no longer reaches the service, credentials and tools are revoked, scheduled jobs are stopped, indexes and caches are handled, alerts and support routes are updated, provider resources are terminated, and downstream systems no longer depend on outputs.

Watch for orphaned copies: local prompt files, exported datasets, notebooks, model weights, evaluation caches, or documentation that directs users to the retired service. A residual-risk owner should accept unresolved items and completion evidence.

Closure evidence should also identify remaining queues, complaints, claims, remedies and records decisions, with owners and any required follow-up. Link lawful preservation or disposition to the relevant retirement/release and §8.7 custody record. An endpoint being off is evidence of that technical state, not completion of every residual duty.

Retirement closure record

The closure record links disabled application/connectors, revoked identities/credentials, withdrawn indexes/caches, queue and in-flight reconciliation, user/service transition, supplier/contract disposition and retained records/holds. Each residual obligation has an owner and evidence location. Retired service means operating use has closed; it does not mean every lawful record is deleted or every customer obligation is extinguished.

Synthetic retirement closure PA-CLOSE-01

Operations disables the application route and scheduled jobs; identity owners revoke workload credentials; knowledge owners withdraw indexes/caches; the queue owner reconciles two unresolved requests; downstream service owners acknowledge the transition. Records/privacy/legal owners retain the approved event metadata and holds while disposing of eligible payloads. The supplier owner tracks export/deletion evidence. One unresolved employee remedy remains with the conduct owner and due date; closing the service does not close that obligation. Each closure assertion needs a receipt/test or an explicit remaining gap.

26.9 Worked Change and Retirement at Fictional Bank

Fictional Bank proposes adding multilingual policy drafting. The change affects supported users, corpus coverage, evaluation, accessibility, human competence, and fallback. It is not treated as a prompt translation inside the existing envelope. The bank creates a new candidate use boundary and evaluation route.

Later, the original model provider withdraws the pinned version. The bank compares migration, restricted operation, and retirement. If replacement evidence is insufficient, it can retire the AI drafting feature while preserving the policy-support service. The example asserts no migration success; it illustrates that service continuity and model continuity are different.

26.10 Periodic Review and Accumulated Change

Periodic review complements event-triggered review. It asks whether the approved purpose, classification, configuration, evidence, operation and ownership remain valid even when no single change crossed an escalation threshold. The interval should be defined by local policy using consequence, exposure, change rate, outcome delay, dependency volatility, incident history and evidence maturity. This book does not prescribe annual, quarterly or other universal cadence.

Table 26.2 — Review element and question

Review element	Question	Output
use and population	is the product used by the people, channels, purposes and jurisdictions approved?	confirm, narrow, reclassify or stop
release and dependencies	does the operating configuration match the manifest, and what changed upstream?	reconciliation and new candidate where required
outcomes and value	is the value hypothesis still supported, and what customer/operational outcomes emerged?	continue, redesign or retire
evaluation and controls	do severe cases, limitations, findings and control evidence remain adequate?	remediation, renewed challenge or condition
incidents and exceptions	what patterns, overdue items or repeated workarounds exist?	systemic action and accountable deadline
resilience and third parties	do fallback, capacity, concentration and exit assumptions remain credible?	exercise, contract/design change or risk decision
roles and records	are owners, delegations, skills, retention and access still valid?	reassignment, training, records action

Higher-risk reviews may require an independent participant or validation route. Independence should match the claim and local governance; it should not be inferred from a meeting attendee list. The review record states period, scope, release/population, evidence sampled, reviewers, conflicts or exclusions, conclusion, actions and next trigger.

Change accumulation

Several individually bounded changes can collectively invalidate the original evidence. The product maintains a change ledger linked to claims. A review is triggered when accumulated changes affect the same behavior path, consume an approved change budget, alter a sensitive cohort, or make the original evaluation no longer representative. The ledger does not need a universal numeric score; it needs traceable reasoning.

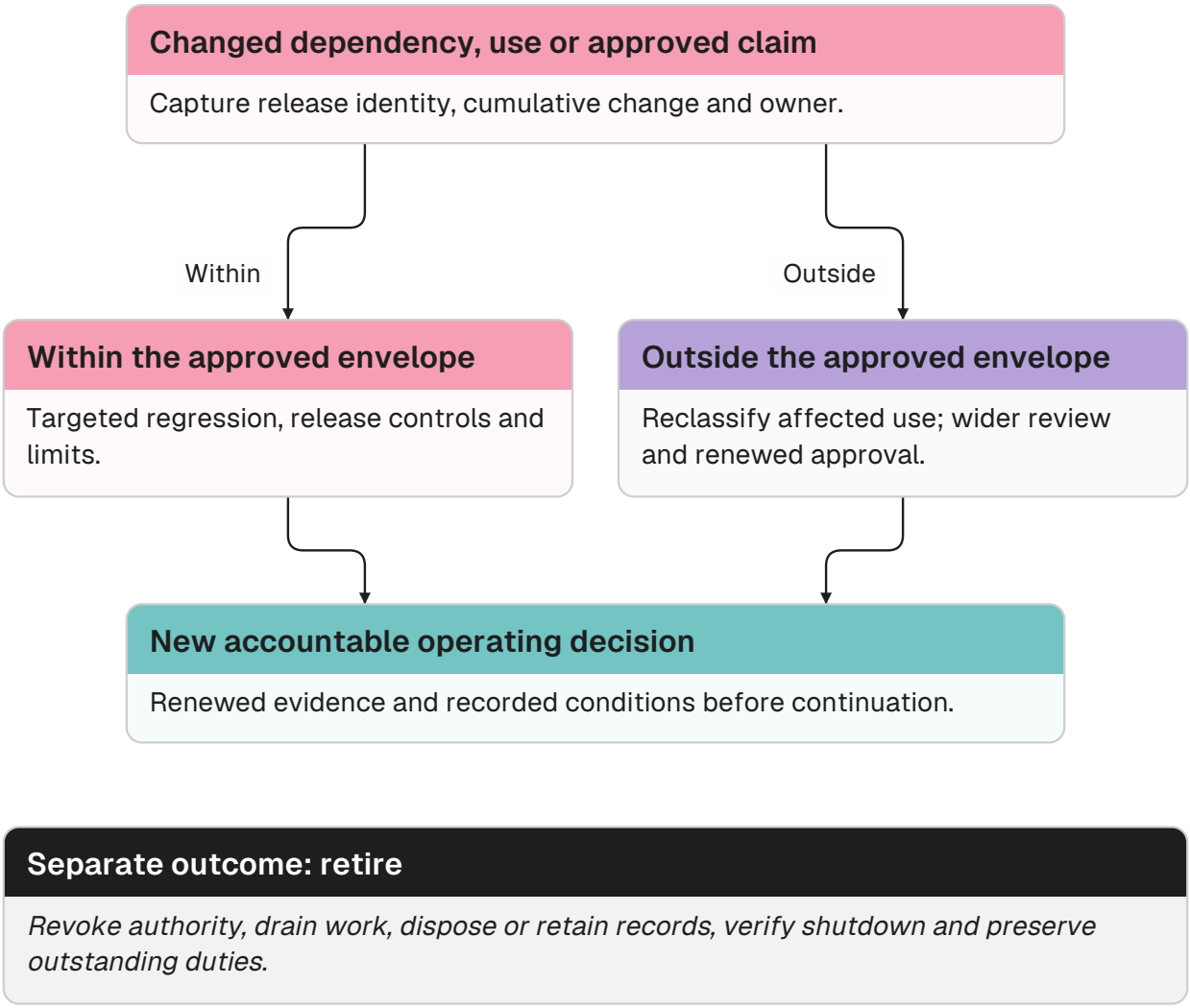
For example, Fictional Bank changes a prompt example, a retrieval ranking parameter and a provider model alias within separately approved envelopes. Each appears small, but all affect how policy exceptions are expressed. The product owner routes the combination for broader regression and approval rather than relying on three isolated low-risk classifications.

Retirement evidence

Retirement closes authority as well as infrastructure. Verify that user and workload access is revoked; scheduled jobs and queues are drained; model/provider, corpus and tool integrations are removed; data and records are retained, returned or deleted under approved obligations; customer or employee communications are completed; dependent processes have a viable route; open incidents and complaints remain owned; and inventory status is updated.

Fictional Bank retires a pilot assistant after the value hypothesis is not supported within the approved period. That is a governance outcome, not a failure to innovate. The bank preserves decision and evaluation records, deletes transient content according to policy, closes provider access and documents lessons. No cost saving or performance outcome is invented. See Figure 26.1.

Figure 26.1 — A change must remain inside an approved envelope



Assess cumulative change against the approved envelope. Continued operation needs a renewed decision; retirement is a separate controlled outcome.

Closest precedents and originality note

The change envelope is an author-developed way to combine ordinary change control, configuration management, regression analysis, model-monitoring triggers, and risk reapproval. It does not create a safe harbour or a universal materiality rule. The bi-temporal evidence pattern—preserving when a fact was effective and when the institution recorded or corrected it—draws on established temporal-data and records concepts; applying it to an AI evidence bundle is this book's synthesis.

Retirement verifies access revocation, queued/in-flight work, data and derived artifacts, embeddings and caches, logs/evidence, credentials, contracts, monitoring, user transition, residual records duties, and replacement dependencies. "Turned off" is not complete decommissioning.

Accumulated change in the policy-assistant thread

Table 26.3 — Change ledger item and claim affected

Change ledger item	Claim affected	Review consequence
Corpus adds regional policy material	Source precedence, jurisdiction and permitted topic/population	Reassess use/source authority and lawfully scoped cases
Prompt changes how limitations appear	Employee understanding and challenge, refusal/support presentation	Evaluate the workflow/oversight task as well as answer content
Successor model changes context/refusal behavior	Exception coverage, source support, capacity/fallback assumptions	Treat as changed candidate and compare representative/hard cases

Assess these together: the combined release may change which exception is retrieved, whether it fits context and whether the employee recognizes a limitation. The ledger records versions, affected claims, individual and combined regression, gaps, decision owner and conditions. Change count is not the trigger; aggregate effect and uncertainty determine targeted or full re-entry.

In a synthetic quarter, three individually small changes broaden topic coverage, extend cache age and reduce review sampling. Each appears inside a separate local threshold; together they change the exception and stale-source claims. The product owner pauses the combined expansion and opens a cumulative impact review. A sequence of small approvals cannot justify a materially different operating boundary.

26.11 Executive and Practitioner Decisions

Inspect combined changes, not only individual tickets. Retirement needs verified decommissioning and named owners for records, unresolved work and remedies; replacement does not close those obligations.

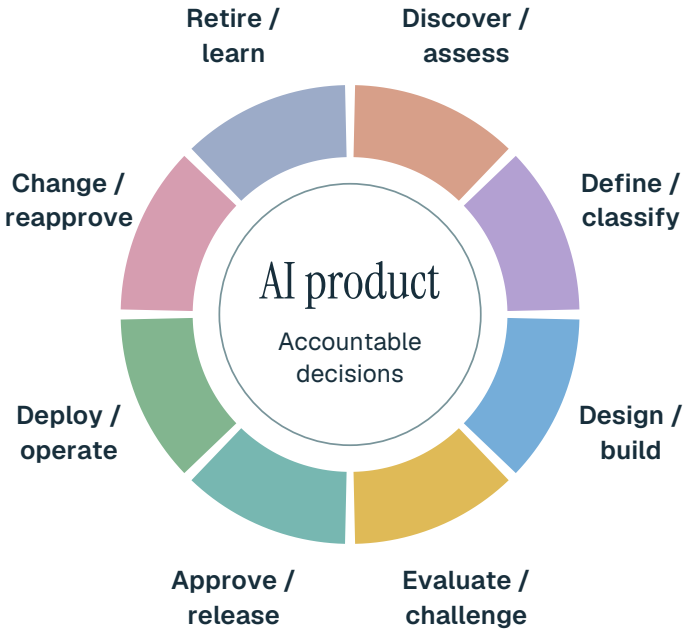
NIST AI RMF (B01), SSDF (B04/B28), and Basel operational-resilience and third-party-risk principles (B11/B13) provide relevant lifecycle context. The change classes, envelope, and decommissioning checklist are author synthesis.

Part

VI

Institutionalization and Domain Use

Defines the operating model, assurance map, transformation path and domain decision patterns. The outcome is repeatable portfolio governance without reducing every product to the same checklist.



Emphasis: Discover / assess; Define / classify; Design / build; Evaluate / challenge; Approve / release; Deploy / operate; Change / reapprove; Retire / learn.

Other phases remain part of the lifecycle.

Re-enter at the affected decision.

Chapter

27

The AI SDLC Operating Model

An operating model turns lifecycle decisions into repeatable work. It should answer who owns the AI product, which capabilities are shared, who provides independent challenge, how evidence moves, and how the institution stops or changes a service.

27.1 Organize Around Products and Capabilities

The model should extend existing software, data, security, model-risk, privacy, resilience, procurement, and audit arrangements. Creating an “AI organization” that duplicates all of them can obscure accountability. Some new specialist capabilities may be necessary, but ownership of the banking service should remain clear.

27.2 Choose a Federated Pattern Deliberately

Centralized and federated models have trade-offs. Central teams can standardize scarce expertise and controls; embedded teams understand products and operate faster. A common pattern combines both: enterprise policy and shared platforms, product-level accountable owners and engineering, domain risk and validation, and independent assurance.

Table 27.1 — Capability and enterprise role

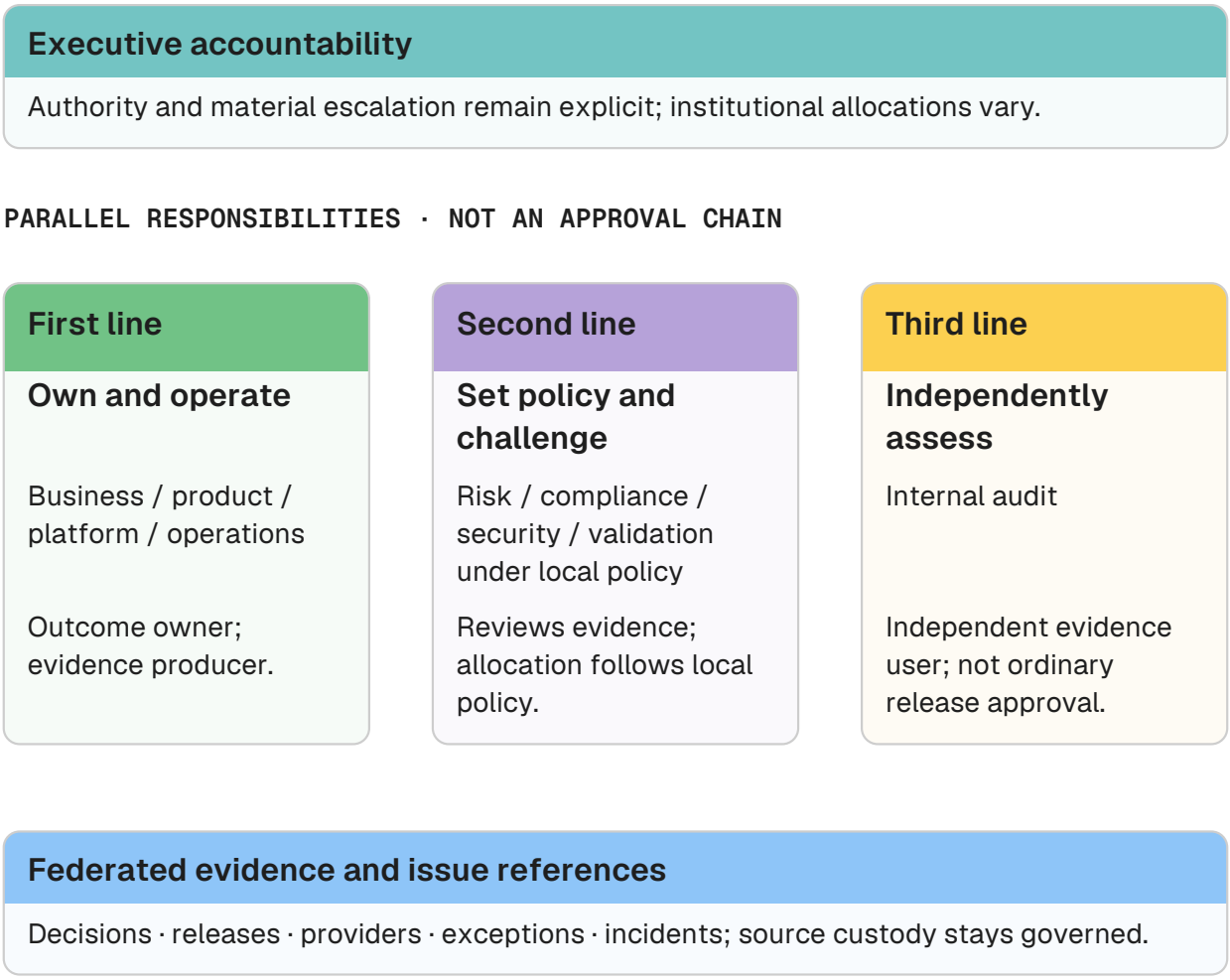
Capability	Enterprise role	Product/domain role
Policy and risk taxonomy	Set principles, routes, minimum controls	Apply to the defined use; escalate ambiguity
Platform	Provide approved services and evidence	Configure and integrate within product claim
Data and knowledge	Set standards and shared tooling	Own sources, quality, rights, and operational use
Evaluation	Provide methods, tooling, specialist pools	Define claims and domain cases; own remediation
Security and privacy	Set architecture and control requirements	Implement, test, operate, and evidence controls
Validation/challenge	Define independence and review criteria	Supply complete evidence and resolve findings
Operations	Provide service practices and incident structures	Own runbooks, fallback, support, and outcomes

The table is a starting pattern, not a universal organization chart.

Choose the operating model on concrete axes: who owns product budget and use, which identity/platform controls are mandatory, who produces domain evidence, who independently challenges it, and who can grant exceptions. Centralization can place delivery and capability funding centrally; federation can give domains those budgets while retaining mandatory shared controls; a hybrid states both explicitly. Those are choices about authority and evidence, not three names for the same arrangement. See Figure 27.1.

27.3 Make Product Accountability Durable

Figure 27.1 — Accountability stays with named roles



Executive accountability sits above parallel ownership, challenge and independent assessment roles. Shared evidence references transfer neither source custody nor decision authority.

Each AI product needs an accountable business owner, product or service owner, technical owner, and named owners for model, data, knowledge, security, operations, and evidence responsibilities as applicable. One person may hold multiple roles for a low-risk use, but the decisions must remain visible.

Accountability should survive project closure. A temporary innovation team cannot remain the only group that understands a service after handover. Funding, service management, support, monitoring, change, incident response, and retirement require durable ownership.

Decision-rights records from Chapter 8 should identify who proposes, challenges, approves, operates, accepts exceptions, and stops the product. Committees support these roles; they do not absorb accountability.

27.4 Build Shared Control Capabilities

High-value shared capabilities include inventory, identity and policy enforcement, approved model access, data and corpus lineage, evaluation harnesses, release manifests, trace and evidence services, incident linkage, provider records, and control reporting. Their purpose is to reduce duplicated risk and engineering.

Each shared service needs a service contract, availability and recovery, control evidence, change policy, and consumer obligations. A centralized control can create concentration and bottlenecks; resilience and capacity should match its enterprise role.

Evidence automation should collect facts from authoritative systems: code and artifact identity, access policy, evaluation results, release approvals, telemetry, and incidents. It should not automate a sufficiency conclusion that requires qualified judgment.

Discover purchased, embedded and unapproved AI

Inventory work includes AI features in purchased services, embedded applications and supplier updates, as well as declared product projects. Reconcile procurement/service catalogues, approved administrative inventories, provider notices and lawfully authorized telemetry. Record discovery source/authority, application/feature and provider identity, owner, enablement state, data/training-reuse terms, permissions, release/use route and disposition. Use proportionate discovery with privacy/security oversight. An unknown feature is investigated and held or restricted where required by its exposure; discovery is not retroactive approval. Supplier feature changes reopen the inventory and affected use/permission decisions.[1]

27.5 Fund the Lifecycle, Not Only the Build

Investment cases should include data and knowledge maintenance, evaluation, security, provider management, monitoring, human review, fallback, incident response, remediation, and retirement. Product funding that ends at deployment creates control debt.

Platforms and independent review need sustainable funding models. Chargeback can create transparency but should not encourage product teams to bypass mandatory controls. Portfolio governance should stop products that cannot justify their operating cost or evidence burden.

Capability development includes engineering, risk, domain, human-factors, legal, and operational skills. Training should be role specific. A board member, model validator, product manager, customer-service employee, and platform engineer need different depth and decisions.

27.6 Design Governance Forums Around Escalation

Forums should have clear scope, inputs, authority, quorum or participation rules where relevant, recorded decisions, and escalation. Possible levels include product review, domain or portfolio governance, enterprise risk, and executive or board oversight. The number of forums should follow decision need, not a desire to display governance.

Routine low-risk decisions can use delegated authority and standard evidence. Material uncertainty, cross-domain conflict, repeated exceptions, high-consequence use, and control failure should escalate. Deadlock and urgent containment routes must be explicit.

27.7 Measure the Operating Model

Useful measures reveal decision and control health: inventory completeness, unowned products, evidence gaps, gate lead time, material findings, exception age, overdue conditions, release mismatch, incident and remediation status, fallback exercises, provider concentration, and retirement completion.

Counts need context. More incidents may reflect more exposure, better detection, or worse control. Faster approval may reflect automation or weaker challenge. Pair measures with definitions, denominators, trends, and decisions.

Avoid maturity scores that imply precision without evidence. Chapter 29 uses qualitative states and proof points.

27.8 Worked Operating Model at Fictional Bank

Fictional Bank assigns the policy assistant to the employee-service portfolio. A product owner holds the use and value decision; a service owner holds operating outcomes; platform teams provide model gateway, identity, evaluation, and evidence services; policy owners govern the corpus; security and privacy provide domain challenge; model validation determines its scope under local policy; internal audit retains independent assurance.

The product forum can approve routine changes inside the envelope. New customer-facing use, write authority, or jurisdiction must escalate. A central register connects the product to releases, providers, exceptions, and incidents without replacing the source systems.

Operating-model choice and record ownership

Table 27.2 — Pattern and shared versus product accountability

Pattern	Shared versus product accountability	Artifact / decision linkage
Centralized capability	Shared policy/IAM/evaluation/index capability; product owner still bounds use and consequences	A4/A5 shared-service records link to product A1/A2/A3, A6/A7 and operating A8
Federated capability	Domain teams produce product evidence; shared standards and challenge preserve comparability	Each artifact has content/control/decision owner and protected challenge route
Hybrid capability	Common platform with domain-specific evaluation, authority and fallback	Shared-control evidence plus local release/operating decisions; exceptions and funding are recorded

Choose by consequence, reusable control semantics, specialist capacity and dependency concentration. A responsibility pattern is not an approval chain, and a shared platform does not inherit every product decision.

27.9 Workforce, Capability and Incentive Design

The operating model requires capacity, not just role names. Product owners need enough technical and risk literacy to own a bounded claim. Engineers need secure AI-product patterns. Data and evaluation teams need domain access and statistical skill. Reviewers need independence, time and evidence access. Operations teams need authority to restrict service. Executives need decision-oriented information rather than a model score.

Table 27.3 — Role group and minimum capability outcome

Role group	Minimum capability outcome	Capacity question
board and executives	understand exposure, authority, evidence limits, concentration and decisions due	can material exceptions and incidents reach the right forum in time?
product/business owner	define use, value, affected parties, acceptance, fallback and residual-risk decision	is ownership durable after project funding ends?
architecture/ engineering	design identities, boundaries, contracts, tests, release and recovery	is there an approved path and specialist support for exceptions?
data/ model/ evaluation	define populations, lineage, methods, uncertainty, monitoring and re-entry	can representative cases and delayed outcomes be maintained?
security/ privacy/ legal/ compliance/ risk	translate domain obligations into product decisions and challenge evidence	are scarce specialists routed by risk rather than every product identically?
validation/audit	independently reconstruct claims, configuration, evidence and operation	does review demand exceed qualified capacity, creating ceremonial approval?
operations/customer remediation	observe, intervene, reconcile, communicate and remediate	is fallback and remediation capacity funded and exercised?

Training should be role- and decision-specific. A universal “responsible AI awareness” course is not enough for a tool-broker engineer, model validator, complaint handler and board risk committee. Evidence of training attendance does not prove competence; scenario performance, supervised work and review quality can provide stronger signals.

Incentives can undermine the control model. Delivery bonuses tied only to launch dates encourage exception debt. Platform adoption targets can encourage products to fit a generic control regardless of need. Reviewer throughput targets can reduce meaningful challenge. Operations targets can suppress incidents or customer escalation. The governance design should pair speed and adoption with quality, unresolved risk, customer outcome, evidence and sustainable capacity.

Reviewer-capacity plan

Portfolio intake should forecast specialist demand by risk route and expected decision dates. It should show required domains, reviewer independence, evidence readiness, queue, aging, rework and bottlenecks. When capacity is unavailable, the honest options are sequencing, narrower scope, additional qualified capacity or stop—not silent approval by attendance.

Federated forum example

Fictional Bank's product forum owns purpose, value, use and operating outcome. A technical control forum maintains shared architecture, security, data and evaluation patterns. Independent risk/validation forums challenge material claims according to delegation. A portfolio forum resolves concentration, investment and cross-product exceptions. Each forum has explicit decision rights, inputs, outputs and escalation; none exists merely to "socialize" a proposal.

The chapter's operating-model artifact therefore combines roles, capabilities, forums, handoffs, service-level expectations for evidence/review, funding, metrics, exceptions and a route for workforce learning. Chapter 8's lines-of-defense distinctions remain applicable and should be read with this model.

Fund and refresh readiness evidence

The role-specific readiness records in §19.5 link workforce planning to product authority and operating tasks. Capability owners fund training, assessors, realistic practice and refresher capacity; product/service owners enforce recorded restrictions. Review triggers include new use, changed authority, interface/workload change, incident and persistent error—not only a calendar reminder.

Synthetic review queue and platform disagreement

Ten initiatives request specialist review this month; the staffed team can complete six at the required depth. Funding two more reviews creates planned capacity only. Those two remain held until competent reviewers, available hours, lead time and conflict checks are confirmed; the other two launches are also held. Thus six can proceed now and four await capacity or reprioritization. Eight may proceed only after the funded capacity actually becomes available. Reclassification does not create expertise.

In the synthetic launch dispute, a team requests an entitlement bypass. The platform owner refuses because revoked-source access cannot be bounded. The product owner narrows topics and funds the fix; the record names the constraint, decision and budget owner. A federated forum cannot waive enforcement.

27.10 Executive and Practitioner Decisions

Fund product ownership, shared controls and specialist capacity together. A domain team may own its delivery priorities while mandatory permissions and independent challenge remain explicit constraints.

NIST AI RMF GOVERN functions (B01), banking model-risk sources (B09–B10), and Basel resilience and third-party-risk principles (B11/B13) provide relevant context. The federated capability matrix and operating measures are author synthesis.

Notes

1. NIST, Cybersecurity Framework 2.0 (B53), ID.AM-02/04/08, PR.AA-01/05 and PR.AT-01/02; AI RMF/Playbook (B01/B03), GOVERN 1.6 and 2.2. Voluntary cross-sector guidance; the AI-specific discovery and record design here are author synthesis. Return to text

Chapter

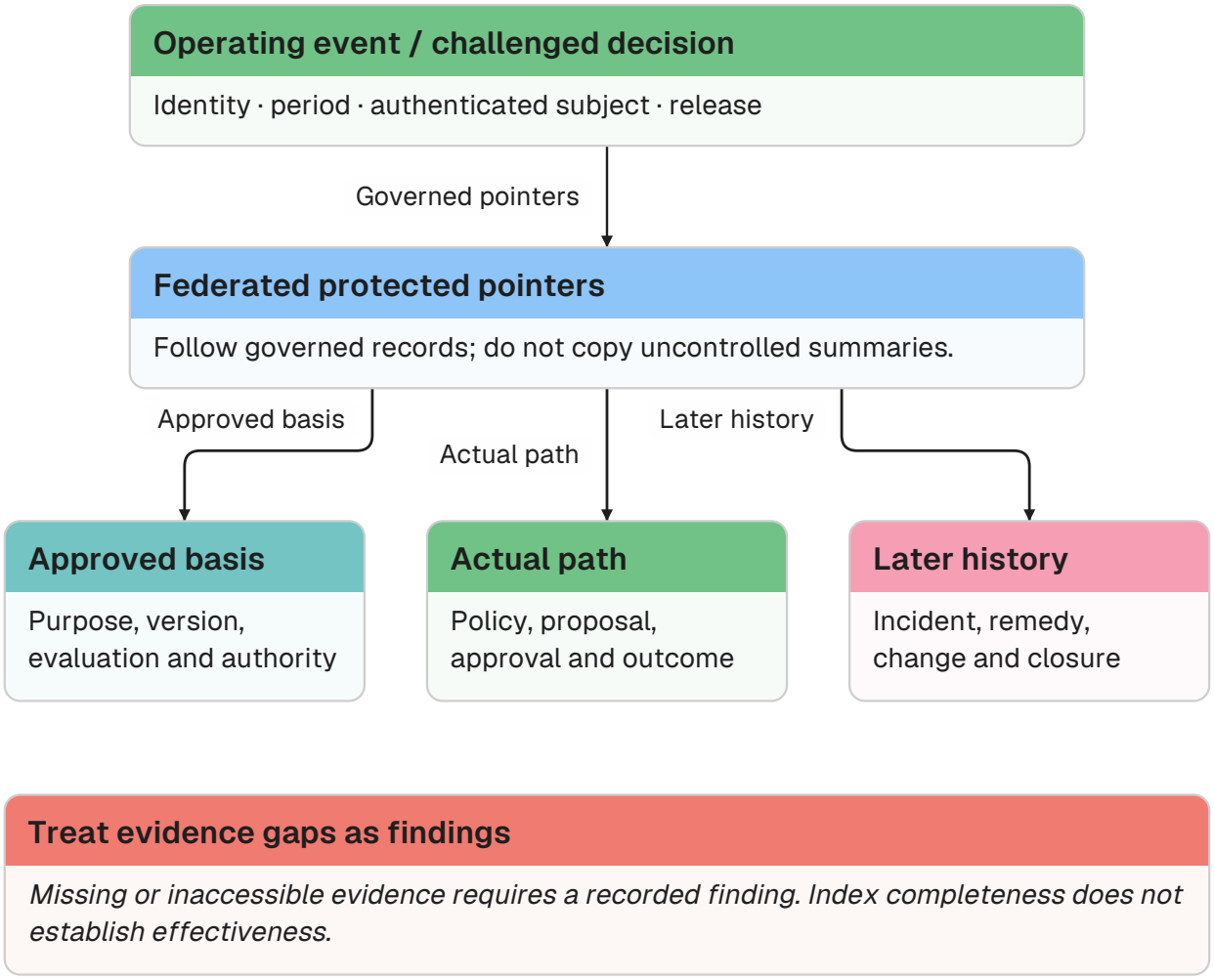
28 Auditability, Assurance, and Executive Oversight

Auditability is the ability to reconstruct a material decision or operating event from protected, interpretable evidence. It does not require every detail in one repository. It requires stable relationships among purpose, versions, controls, evaluation, approval, operation, incidents, and change.

28.1 Design for Reconstruction

The evidence bundle from Chapter 2 is the connecting framework. Auditability should be designed into product and platform interfaces; reconstructing it manually after an incident is slow and uncertain. See Figure 28.1.

Figure 28.1 — Build the dossier from one challenged event



Reconstruct one operating event through protected pointers to approved basis, actual path and later history. Missing evidence remains a finding.

28.2 Distinguish Design, Operation, and Outcome

A control description shows intended design. An execution record shows an activity occurred. Operating-effectiveness evidence shows whether the control performed as intended over a defined period and population. Outcome evidence shows what happened to the service or stakeholders. These are related but not interchangeable.

For example, a policy may require employee review; a click record shows approval; an observed study may show whether reviewers can detect a seeded material error; complaints and corrections may reveal operating failures. None alone establishes the whole control conclusion.

Assurance should state which layer it examined. A documentation audit should not be reported as behavioral validation. A model validation should not imply application-security assurance.

28.3 Preserve Evidence Lineage

Material records should share identifiers or resolvable links for product, use, release, requirement, risk, control, test, finding, decision, deployment, observation, incident, and change. Version and valid time matter: what was approved, what operated, and when?

Corrections should append or preserve history rather than silently overwrite an approved record. Access and integrity protections should match sensitivity. Retention follows applicable policy and law; the book supplies no schedule.

Evidence health itself should be monitored. Missing release identifiers, broken links, inaccessible provider reports, or orphaned approvals can invalidate an assurance conclusion.

28.4 Plan Assurance by Risk and Question

An assurance map connects material questions to first-line testing and operation, second-line challenge or validation, and third-line audit as the institution defines them. It should identify overlap and gaps without assuming one universal three-lines structure.

Table 28.1 — Oversight question and possible evidence

Oversight question	Possible evidence	Typical limitation
Is the use within approved scope?	Intended use, entitlement, runtime events	Hidden workarounds or unregistered use
Did the approved configuration operate?	Manifest, deployment, trace identity	Moving external dependency or missing telemetry
Do controls work?	Tests, samples, exceptions, operating evidence	Limited period or population
Are outcomes acceptable?	Evaluation, complaints, impact measures, remediation	Delayed, biased, or incomplete outcome data
Can the bank recover?	Exercises, incidents, fallback and exit evidence	Scenario and dependency limitations
Is governance effective?	Decisions, findings, conditions, escalation, closure	Formal compliance without meaningful challenge

Independent assurance should have direct access to evidence and authority to report unresolved limitations. Management retains responsibility for operating the product.

The management, risk/compliance and independent internal-audit distinction has a historical precedent in the IIA's 2020 Three Lines Model, updated September 2024 (B58). Its current July 2026 Statement of Position (B60) addresses management accountability, audit objectivity, coordination and safeguards against self-review. The book adapts those relationships to product decisions; it prescribes no compulsory organization chart and does not equate second-line review with independent internal audit. Record the actual mandate, reporting relationship and conflicts for the question reviewed. Neither professional position establishes a universal banking legal requirement.[1]

28.5 Give Executives Decision-Oriented Information

Executive reporting should show portfolio exposure, high-consequence uses, material dependencies, evidence and review status, exceptions, incidents and remediation, changing risk, value, and decisions required. It should distinguish facts, estimates, management judgments, and unknowns.

Useful questions include:

- Which products can affect customers, money, critical services, or regulated records?
- Which uses have expanded authority or population since approval?

- Which material claims lack current evidence?
- Where are provider concentration and exit weakest?
- Which exceptions, conditions, or remediation items are overdue?
- Which incidents reveal a common failure class?
- Which products should be restricted, reinvested in, or retired?

A heat map without definitions and actions can create visual confidence without governance value.

Use the five questions at the end of the Executive Brief as pointers to the eight existing executive decisions. For continuity/exit and legal matters, show the exact service/release, evidence status, underlying record, conditions/gaps, actual owner and decision required. Distinguish a proposed plan, current authorization, exercise findings and operating observations. Include the resource decision when staffing, review, contingency or exit capability is constrained. Keep sensitive complaint/claims material behind lawful access; the leadership view needs decision-relevant references, not unrestricted copies. Appendix I follows the same approach without adding a readiness score.

28.6 Support Sampling and Deep Dives

Auditors and assurance functions may sample by risk, transaction, release, time, change, provider, exception, or incident. The evidence architecture should permit tracing from a selected outcome back to source and approval, and from a selected control forward to operation and findings.

Sampling methods and conclusions need their own scope. A clean sample does not prove universal operation. A targeted adverse sample does not estimate prevalence. State the selection basis.

High-risk deep dives may require source code, configuration, prompts, model and data records, provider evidence, human-work observation, and expert support. Access should be planned before the review.

28.7 Prepare for Supervisory and External Scrutiny

External expectations differ across jurisdictions and products. The institution should maintain an applicability record and qualified interpretations. The EU AI Act’s consolidated text and DORA illustrate different legal scopes; PRA and U.S. model-risk sources illustrate differing model definitions and applicability.[2]

Do not claim compliance from framework alignment alone. Evidence should support the applicable obligation and effective control. Where licensed standards are relevant but

not lawfully available for inspection, record the gap and obtain authorized access rather than infer detailed requirements.

28.8 Worked Reconstruction at Fictional Bank

An auditor selects a policy draft from a prior month. The product trace identifies employee, approved use, release, model endpoint, prompt policy, corpus index, retrieved sources, output, review event, and absence of external sending. The release links to evaluation, security review, approval conditions, deployment, and later corpus changes.

The audit discovers that a provider report referenced at approval is no longer accessible. The product evidence remains available, but the third-party assurance basis is incomplete. The finding is recorded and routed; the bank does not recreate or assume the missing report.

28.9 Worked Assurance Map and Executive View

An assurance map connects an oversight question to evidence sources, accountable first-line operation, second-line challenge, independent assurance and known limitation. It prevents multiple reviews from repeating document collection while leaving an important claim uncovered.

Table 28.2 — Oversight question and first-line evidence

Oversight question	First-line evidence	Second-line challenge	Independent assurance	Limitation / next decision
is the policy assistant within approved use?	entitlement events, topic routing, tool denials, release manifest	sample prohibited-use handling and condition compliance	audit sample of inventory-to-runtime reconciliation	indirect employee workarounds may be under-observed
is the answer support adequate?	retrieval/answer evaluation, runtime sample and correction	challenge case design, severe-failure rules and source withdrawal	audit evidence lineage and closure of findings	sampled evidence does not prove every answer
can the bank stop and recover?	fallback and withdrawal drills, incident/runbook records	review scenario severity and residual gaps	observe selected exercise and action closure	exercise cannot cover every correlated failure
are customer consequences controlled?	no customer-send authority in release; access boundary	verify architecture and monitor proposed scope change	test configuration/permission evidence	expansion would require new use and review

This example is fictional and does not represent completed assurance. The actual map must name systems, periods, populations, reviewers and evidence IDs.

Executive dashboard specification

Table 28.3 — Tile and decision-oriented definition

Tile	Decision-oriented definition	Drill-down
exposure	products and releases by use, authority, consequence, population and jurisdiction	product charter, classification and operating release
decisions due	conditions, exceptions, periodic reviews and provider changes approaching decision dates	owner, evidence outstanding, impact of delay
severe findings/incidents	open material findings and incidents by affected service/population	containment, remediation, customer/record impact, next decision
evidence health	releases missing required identity, lineage, evaluation or operating evidence	exact missing record and responsible owner
third-party concentration	products sharing critical provider/failure domain and untested exits	dependency map and scenario result
value and outcome	status of the approved value hypothesis with cost, service and harm measures	definition cards, denominators, uncertainty and owner
workforce/review capacity	qualified review and remediation demand versus available capacity	queue, aging, conflicts, bottleneck and action

No tile should collapse these dimensions into an unexplained red/amber/green or “trust score.” Color can indicate action state only when the underlying definition and evidence are accessible. Executives should be able to answer: what changed, who or what is exposed, what evidence is missing, who owns the decision, and what happens if no action is taken.

Audit search and sampling design

Evidence must be searchable through stable keys: product, release, decision, dependency, case/transaction where lawfully retained, incident, exception, owner, period and jurisdiction. The central index may point to protected systems rather than copy sensitive content. Search authorization and access logging are themselves controls.

Sampling should reflect the assurance question. Random sampling estimates ordinary operation; risk-based sampling targets high-consequence paths; event sampling follows changes, incidents and overrides; trace sampling reconstructs an end-to-end decision. Each sample records population, selection method, exclusions and limits. A large sample from the wrong population is not stronger assurance.

Executive dashboard and audit reconstruction

The dashboard uses tiles for portfolio exposure; authority/action; exact operating identity; decisions due; severe findings and incidents; evidence health; third-party concentration and untested exit; value/outcome evidence; customer remediation; and reviewer/operations capacity. Each tile exposes definition, population/denominator, period, owner, uncertainty, threshold, action, and drill-through record. No composite trust score is implied.

An auditor starts from one operating event and reconstructs authenticated subject, product/release, input and relevant source identity, policy decision, proposed and actual action, approval, outcome, incident/complaint link, and later change. The exercise records missing or inaccessible evidence as a finding; it does not treat index completeness as proof of control effectiveness.

Board oversight and management authorization

The board asks for exposure, appetite, concentrations, material conditions, remedy and capability evidence; management owns delegated operating and release decisions. An executive dashboard should show the decision needed, severe/open conditions, owner, due/review trigger and evidence limitations before supporting detail. Drill-down preserves the reconstruction records. Aggregate oversight does not replace approval of the exact product/release under Chapter 8.

Filled synthetic dashboard row and deep dive

Use Figure 28.2, the existing executive dashboard, for this view; Figure 27.1 remains the responsibility map.

Figure 28.2 — An executive view should lead to a decision

Tile	Decision-oriented definition	Drill-down
exposure	products and releases by use, authority, consequence, population and jurisdiction	product charter, classification and operating release
decisions due	conditions, exceptions, periodic reviews and provider changes approaching decision dates	owner, evidence outstanding, impact of delay
severe findings/incidents	open material findings and incidents by affected service/population	containment, remediation, customer/record impact, next decision
evidence health	releases missing required identity, lineage, evaluation or operating evidence	exact missing record and responsible owner
third-party concentration	products sharing critical provider/failure domain and untested exits	dependency map and scenario result
value and outcome	status of the approved value hypothesis with cost, service and harm measures	definition cards, denominators, uncertainty and owner
workforce/review capacity	qualified review and remediation demand versus available capacity	queue, aging, conflicts, bottleneck and action

Seven literal tile definitions connect executive attention to underlying evidence. They are specifications, not measured portfolio values or scores.

Table 28.4 — Field and pa-r1 dashboard entry

Field	PA-R1 dashboard entry
Exposure	25 authorized internal employees; draft-only topics
Value	Synthetic monthly 43,000 / 9,000 accepted cases = 4.78; actual value unmeasured
Decision due	PA-INV-02 four-week checkpoint; proposed expansion not supported
Severe/open condition	PA-INC-01 source-withdrawal mismatch; affected topic restricted
Reconstruction	56 generated; 48 shown; four blocked; four uncertain receipts
Capacity/dependency	Fallback 40/hour versus 120/hour stress demand; shared identity l
Owner/action	Product owner holds expansion; knowledge owner repairs withdrawal; conduct owner reconciles six confirmed downstream uses

Start with a displayed response, follow PA-R1 to PA-GATE-01 and PA-EV-03, identify POL-DOC-01-v1 and inspect containment and open remedy records. Four missing receipts remain a finding, rather than zero exposure. The board asks for decisions and resources; management retains delegated release and operating authority.

28.10 Executive and Practitioner Decisions

Ask for the decision needed and drill through one operating event. Evidence gaps, uncertain exposure and capacity shortfalls should reach the accountable owner; a dashboard summary cannot close them.

Notes

1. Historical IIA Three Lines Model, 2020/September 2024 (B58), and current Three Lines Model Statement of Position, 8 July 2026 (B60), Introduction and Independence. The IIA official repository confirms the publication date; date checked 9 October 2026. These are professional governance positions, not universal banking legal mandates. Return to text

2. EU AI Act consolidated text (B07), DORA (B36), PRA SS1/23 (B09), and 2026 U.S. interagency model-risk guidance (B10). Each is used as a bounded example; qualified jurisdictional analysis is required. Return to text

Chapter

29 Maturity and Transformation Roadmap

Maturity should describe what the institution can repeatedly decide, engineer, evidence, and improve. It is not the number of policies, tools, committees, or AI pilots. A bank can have sophisticated models and weak service ownership; another can use modest technology with strong control and recovery.

29.1 Maturity Is Demonstrated Capability

The roadmap should begin with exposure and failure, not an aspiration to reach a numeric level. Identify current products, high-consequence uses, unowned dependencies, evidence gaps, and incident readiness. Then prioritize capabilities that reduce material uncertainty or enable bounded value.

29.2 Assess Across Connected Dimensions

Assess at least eight dimensions:

- strategy and portfolio decisions;
- product ownership and governance;
- architecture and platform controls;
- data, knowledge, and model supply chains;
- engineering, evaluation, and security;
- release, operation, incident, resilience, and retirement;
- evidence, validation, audit, and oversight; and
- people, skills, incentives, and change.

Do not average these into a score unless the method has a defensible purpose. A critical weakness can matter more than a strong average.

29.3 Use Observable States

Table 29.1 — State and observable behavior

State	Observable behavior	Typical risk
Reactive	Products found after deployment; evidence assembled after questions arise	Unknown exposure and inconsistent response
Repeatable	Basic inventory, routes, owners, and common checklists exist	Process can be formal but weakly connected to engineering
Integrated	Controls and evidence are embedded in platforms and delivery	Central dependencies and false automation confidence
Measured	Decisions use defined operating and outcome evidence	Metrics can be gamed or misinterpreted
Adaptive	Lessons, incidents, and change update controls across products	Continuous change can outpace independent challenge

Rate each dimension and product on its evidence. These descriptive states are not a validated industry benchmark and need not advance together.

29.4 Sequence the Foundations

The first horizon should establish visibility and stop capability: product inventory, accountable owners, intended use, risk routing, provider dependencies, release identity, incident contacts, and a path to restrict or retire. This creates a minimum basis for decisions.

The second horizon integrates controls into delivery: approved model and data access, identity and policy enforcement, evaluation harnesses, release manifests, telemetry, evidence links, and predictable review routes. Reuse should target recurring risk.

The third horizon improves operating evidence and portfolio decisions: continuous evaluation, cross-product incident learning, provider concentration management, control-effectiveness testing, value realization, and retirement. Advanced automation should follow reliable underlying processes, not compensate for their absence.

29.5 Prioritize by Risk Reduction and Enablement

Evaluate roadmap items by exposure addressed, decision enabled, dependency, feasibility, time to evidence, and cost. Some controls both reduce risk and accelerate delivery: shared identity, model gateways, release manifests, evaluation utilities, and evidence APIs can prevent repeated manual work.

Avoid funding only visible front ends while data, fallback, and operating ownership remain unresolved. Also avoid designing an enterprise platform before observing enough product patterns. Use bounded pilots to learn about shared needs, then standardize what is stable.

29.6 Address Common Anti-Patterns

- **Policy-first without operating path:** requirements exist, but teams cannot satisfy or evidence them.
- **Tool-first transformation:** a catalog or gateway is purchased before ownership and decisions are defined.
- **Universal high control:** every use receives the same burden, encouraging avoidance and bottlenecks.
- **Innovation exception:** pilots use real data or users without lifecycle ownership.
- **Model-only governance:** application, tools, people, and critical service are outside review.
- **Metric theater:** dashboard counts rise without showing control, value, or customer outcome.
- **Permanent pilot:** a product operates indefinitely without release, service, or retirement decision.

These patterns are diagnostic prompts, not claims about any particular institution.

29.7 Measure Progress Through Proof Points

Proof points can include products with accountable owners and bounded uses, releases with resolvable manifests, material claims with current evaluation, critical dependencies with tested fallback, exceptions closed before expiry, incidents linked to remediated failure classes, and retired services fully decommissioned.

Measure lead time and friction alongside control. A review queue that takes months may drive hidden use; an instant approval may lack challenge. Interview teams and reviewers to understand where evidence is created twice or arrives too late.

Do not claim that a maturity state causes fewer incidents or greater return without empirical evidence. Use local before-and-after observations carefully and state confounders.

29.8 Build a Transformation Portfolio

Assign an executive sponsor, capability owners, product exemplars, milestones, dependencies, evidence of completion, and adoption measures. Treat policy, platform, operating model, and skills as one change portfolio.

Use a small number of representative products: a predictive use, a generative knowledge use, and a tool-using workflow may reveal different needs. Fictional Bank uses the policy assistant as one exemplar, but it does not assume the same design will fit lending or payments.

Review the roadmap when regulation, providers, incidents, or strategy change. The target is not a static end state; it is the ability to govern change without losing accountability.

29.9 Evidence-Based Self-Assessment

Use the complete five-state scale in §29.3 first. The table below gives selected contrasts to illustrate transitions; it is not a three-state rating scale. The progression acknowledges maturity-model precedents, while assessing connected release, authority, evidence, operation and re-entry. No certified level or demonstrated performance effect is claimed.

Table 29.2 — Dimension and reactive evidence

Dimension	Reactive evidence	Integrated evidence	Measured/adaptive evidence
inventory and use	discovery after deployment or survey-only list	product/release inventory linked to intake and deployment	runtime reconciliation, change/retirement and unknown-use investigation
authority and governance	informal owner and generic committee	explicit decision rights, conditions, exceptions and escalation	decision quality, aging and recurring issue analysis update governance
engineering/ platform	bespoke model access and manual control evidence	approved path with identities, policy, evaluation, telemetry and release manifest	platform evidence is tested, exceptions improve capabilities, concentration managed
data/ knowledge/ model	disconnected inventories	lineage and dependency identity tied to release	change and outcome evidence drive re-entry and retirement
evaluation/ validation	demonstration or generic score	claim-based layered evaluation and proportional challenge	uncertainty, operation, incidents and delayed outcomes update methods
operations/ resilience	unclear owner and manual fallback claim	monitoring, runbook, fallback, incident and exit linked to service	exercises and incidents produce portfolio-level control change
customer/impact	benefits asserted; harm handled reactively	affected populations, oversight, complaint and remedy designed	outcome evidence and remediation feed value/risk decisions
people/incentives	volunteer expertise and launch-focused reward	role capability and funded reviewer/operations capacity	workforce metrics, learning and incentive effects inform planning

An institution should not average these rows into a maturity score without an approved method. A high platform capability cannot compensate for absent customer-remedy

capability in a high-consequence product. The self-assessment records evidence, limitation, owner and next proof point for each dimension.

Transformation portfolio

Sequence work by risk reduction and enablement. Common early investments are a product/release inventory, intended-use record, authority taxonomy, identity and tool boundary, evaluation method, incident linkage and a small canonical evidence register. Platform automation should follow clear control semantics; automating an ambiguous approval process makes ambiguity faster.

Fictional Bank selects three proof points: reconcile all operating AI releases to named owners and manifests; demonstrate source withdrawal and customer/record reconstruction for the policy and customer-assistant threads; and conduct a bounded alert-triage evaluation and fallback exercise. These are fictional objectives, not claimed achievements.

Transformation decisions should include what will stop. Retire redundant checklists, duplicate forums, unsearchable evidence copies and unsupported pilots. Maturity is visible when the institution can make a quicker, better-supported “no,” “not yet,” “narrower,” “continue” or “retire” decision—not when it accumulates governance artifacts.

Closest precedents and originality note

The five observable maturity states are author synthesis informed by capability-maturity, control-maturity, product-operating-model, and continuous-improvement traditions. They are not a validated benchmark and do not imply that maximum autonomy, centralization, tooling, or orchestration is the desired endpoint. Evidence should reveal anti-patterns such as committee-heavy, document-heavy, platform-heavy, or automation-heavy programs whose decisions and outcomes remain weak.

Proof without a race to autonomy

A proof point names the capability claim, observed period/population, linked release/records, method/result, limitation, owner and next action. Evidence of reliable source withdrawal, negative authorization or customer-remedy reconstruction can justify capability improvement while action authority remains unchanged. More autonomy, centralization or tooling is not itself a maturity result.

All five states and a failed proof point

Record each dimension as Reactive, Repeatable, Integrated, Measured or Adaptive under §29.3, with evidence for the transition. The selected contrasts above illustrate practices; the complete five-state assessment remains controlling.

Table 29.3 — State and transition evidence to inspect

State	Transition evidence to inspect
Reactive	Product/owner discovery is incomplete and responses are ad hoc
Repeatable	Common intake, routes, owners and records used consistently
Integrated	Those records connect to actual engineering, release and operation
Measured	Defined outcomes, control results and uncertainty inform decisions
Adaptive	Changes to capability follow demonstrated learning with renewed evidence

In a synthetic roadmap, the current gap is unlinked operating manifests; the funded change is runtime reconciliation; the proof is a lawful sample of operating events linked to approved releases; the accountable owner is platform operations. Two of twenty sample events fail to resolve. The owner repairs the identity mapping and repeats the proof rather than declaring Integrated because the inventory tool exists. Source withdrawal and review capacity are dependencies. I would prioritize that failed proof over a maturity slide with no drill-through records.

29.10 Executive and Practitioner Decisions

Fund the next observable proof, with its current gap and dependency. A failed reconciliation or withdrawal exercise should change the plan; installing tooling or increasing autonomy does not establish maturity.

Treat the maturity assessment as a diagnostic for the next decision and investment, with evidence and limitations visible. It supplies no industry percentile or demonstrated maturity-performance relationship.

Chapter

30 Domain Playbooks and Decision Patterns

A playbook should help a team apply the common AI SDLC to a domain without duplicating all thirty chapters. It begins with the service, consequence, authority, data, evidence, fallback, and change triggers. It then highlights domain-specific failure pathways and reviewers.

30.1 Tailor the Common Lifecycle

The patterns below are not approvals, legal classifications, or control checklists. They are decision prompts. Fictional Bank remains the only named institution, and every scenario is a fictional composite with no claimed outcome.

30.2 Customer-Service and Employee Copilots

Purpose pattern: retrieve approved knowledge, summarize, or prepare a draft for an employee.
Principal risks: unsupported or stale content, disclosure, inconsistent treatment, inaccessible communication, over-reliance, and weak fallback.
Authority boundary: distinguish internal draft, employee-approved communication, and direct sending.

Decision questions:

- Which topics, customers, languages, and channels are supported?
- Which source is authoritative, and how are exceptions and withdrawals handled?
- What information may enter context or leave in traces?
- Can the employee inspect support and correct the draft?
- What happens when evidence is missing or the service is unavailable?

The Fictional Bank policy assistant is the longitudinal example. Its proposed boundary is internal drafting from an entitled policy corpus with no customer-record access or send authority. Expansion to direct customer communication is a new use.

30.3 Lending and Credit Decision Support

Purpose pattern: score, rank, verify information, summarize a file, or support an authorized credit process.
Principal risks: unfair or unlawful treatment, invalid data or model use, explanation failure, automation bias, adverse customer consequence, and inability to reproduce the decision.
Authority boundary: distinguish information extraction, recommendation, decision, pricing, and communication.

Decision questions:

- Which decision and population are in scope, and which legal regimes apply?
- What is the model and product validation route?
- Which data, proxies, fairness objectives, and explanation duties are relevant?
- Can a reviewer meaningfully challenge the output and access contrary evidence?
- How are overrides, disputes, corrections, and remediation recorded?

Generative summaries should not be assumed to inherit the validation of an underlying predictive model. They can omit facts or introduce unsupported reasons. Their workflow requires separate evidence.

30.4 Financial-Crime Investigation Support

Purpose pattern: prioritize alerts, link information, summarize evidence, draft investigative material, or recommend next steps.
Principal risks: missed suspicious activity, false implication, sensitive-data disclosure, evasion by adversaries, feedback bias, and contamination of official records.
Authority boundary: distinguish triage, investigation aid, case decision, filing, and account action.

Decision questions:

- How does the design protect investigation confidentiality and access?
- Which adversarial behaviors and changing typologies are tested?
- What evidence supports prioritization and material statements?
- How are model or assistant outputs separated from verified investigator findings?
- What fallback and backlog capacity exists during disruption?

Human investigators retain defined responsibility only when workload, information, and authority make challenge feasible. A reviewer click is not proof.

30.5 Payments, Treasury, Trading, and High-Consequence Automation

Purpose pattern: detect anomaly, support routing or pricing, prepare an instruction, optimize execution, or act within a bounded strategy.
Principal risks: financial loss, market or liquidity impact, unauthorized transaction, rapid propagation, manipulation, latency failure, and difficult reversal.
Authority boundary: separate analysis, proposal, authorization, submission, and settlement or execution.

Decision questions:

- What value, volume, instrument, counterparty, market, and time limits apply?
- Which deterministic policy and pre-trade or pre-execution controls remain outside the model?
- Can the bank stop, revoke, reconcile, and recover within the service need?
- How are model behavior and conventional algorithmic controls separated and validated?
- Which actions are irreversible, and what customer or market remediation is possible?

Higher speed can reduce the feasibility of per-action human approval. That does not remove accountability; it increases the importance of bounded authority, pre-enforced limits, monitoring, and intervention. Applicable trading, payments, prudential, and market rules require specialist analysis.

Table 30.1 — Domain and distinct decision boundary

Domain	Distinct decision boundary	Recovery implication
Payments	Beneficiary, amount, sanctions/fraud route and commit/finality controls	Reconcile committed versus unresolved work; cancellation may be impossible after settlement
Treasury	Liquidity/position exposure, limits and funding timetable	Preserve position and funding obligations; a delayed action can change exposure
Trading	Market exposure, latency, order/venue authority and kill limits	Reconcile orders/fills and positions; restarting software does not unwind market effects

Apply the exact-action trace to those domain facts; do not reuse a policy-drafting approval. AI-supported recommendations and order/payment execution require different authority, evidence and specialist conclusions.

30.6 AI-Assisted Software Delivery

Purpose pattern: explain, generate, review, test, or modify code and infrastructure; triage vulnerabilities; assist operations.
Principal risks: incorrect or insecure code, secret or intellectual-property exposure, license issues, unsafe dependency, excessive agent authority, and review complacency.
Authority boundary: distinguish suggestion, workspace edit, command execution, pull request, deployment, and production change.

Decision questions:

- Which repositories and data may the assistant access?
- What can it execute, and under which identity and environment?
- How are generated dependencies, licenses, tests, and security findings reviewed?
- What change can be merged or deployed only by an authorized person or pipeline?
- Can the evidence distinguish machine proposal, human review, and executed change?

Generated code remains untrusted contribution until it passes the institution's standard engineering controls. Large AI-generated diffs may require different review strategies, not weaker review.

Apply the scoped legal-review method in §8.4 to the actual data, code/license, provider and delegated-action facts. Link dependency and fallback planning to §§25.4–25.5, but distinguish loss of development or review capacity from interruption of an operating financial service. A coding assistant may affect delivery without being in the runtime path; the service consequence and contingency scope must follow the actual dependency. An engineering fallback does not authorize bypassing the institution's release, access or code-review controls.

30.7 Internal Operations and Corporate Functions

Purpose pattern: summarize documents, support HR or procurement, analyze contracts, prepare reports, or automate administrative workflow.
Principal risks: sensitive employee or commercial information, biased employment impact, legal interpretation errors, unauthorized commitments, and shadow deployment.
Authority boundary: distinguish drafting and analysis from decision, communication, approval, and system update.

"Internal" does not mean low risk. Employment, legal, finance, audit, and access-administration uses can have material individual or institutional consequence. Classification follows the use, not the absence of customers.

30.8 Apply a Common Decision Canvas

For any domain, a concise canvas can route the team to the relevant chapters:

Table 30.2 — Question and required decision

Question	Required decision	Primary chapter
What service and value?	Hypothesis and accountable owner	5
What is allowed?	Intended/prohibited use and acceptance	6
What could matter?	Risk, criticality, materiality	7
Who decides?	Governance and decision rights	8
What is assembled?	Architecture, data, knowledge, model, tools	9–14
How is it built and challenged?	Engineering, evaluation, security, impact, validation	15–20
How does it operate and recover?	Release, monitoring, incident, reliability, resilience, change	21–26
How is it institutionalized?	Operating model, assurance, transformation	27–29

The canvas does not replace the evidence. It ensures the team asks the same lifecycle questions while tailoring depth.

One canvas across the existing domain traces

Table 30.3 — Existing trace and bounded authority

Existing trace	Bounded authority	Credible non-AI route	Specialist / evidence emphasis
Internal policy assistant (§30.11 A)	Source-linked internal draft; no customer communication or record action	Policy search and specialist explanation	Knowledge/access; exception/ withdrawal and employee challenge
Fraud/AML triage (§30.11 B)	Prioritize/draft; investigator retains disposition/filing authority	Existing rule queue and accountable investigator review	Financial crime/model risk; severe misses, delayed outcomes and fallback capacity
Customer assistant (§30.11 C)	Bounded answer and request preparation; no unapproved consequential action	Staffed/ asynchronous service and complaint route	Conduct/ legal/ privacy; accessible disclosure, source currency and remedy
Bounded lending (§30.12)	Verified-information summary; underwriter retains the defined decision	Authorized underwriting/rules workflow	Credit/ model/ legal/ fairness; reason fidelity, use classification and challenge feasibility

For each, use the same purpose/population, action/data/permission, consequence, acceptance, owner/challenge, manifest, gate, monitoring, fallback, incident/remedy, change and retirement fields. Stop or narrow when evidence or service capacity cannot support the bounded task. The lending trace remains bounded; no additional longitudinal scenario is introduced.

30.9 Identify Pattern-Based Stop Conditions

Stop or redesign when the bank cannot define the use, source the necessary data lawfully, enforce the authority boundary, construct representative evaluation, provide viable fallback, obtain essential provider evidence, support human challenge, remediate affected customers or records, or operate within resilience needs.

These are decision triggers, not automatic legal conclusions. A gap may lead to narrower scope, more research, a different architecture, or rejection. Recording a stop is evidence of governance, not a failed innovation program.

30.10 Close the Lifecycle

The following material contains one worked synthetic policy-assistant trail and two bounded decision-link traces, not three completed implementation histories. Follow use, configuration, failed evidence, decision, operating event and proposed change without inferring missing receipts, remedies or approvals. The closing lesson appears in §30.13.

30.11 Three Longitudinal Implementation Traces

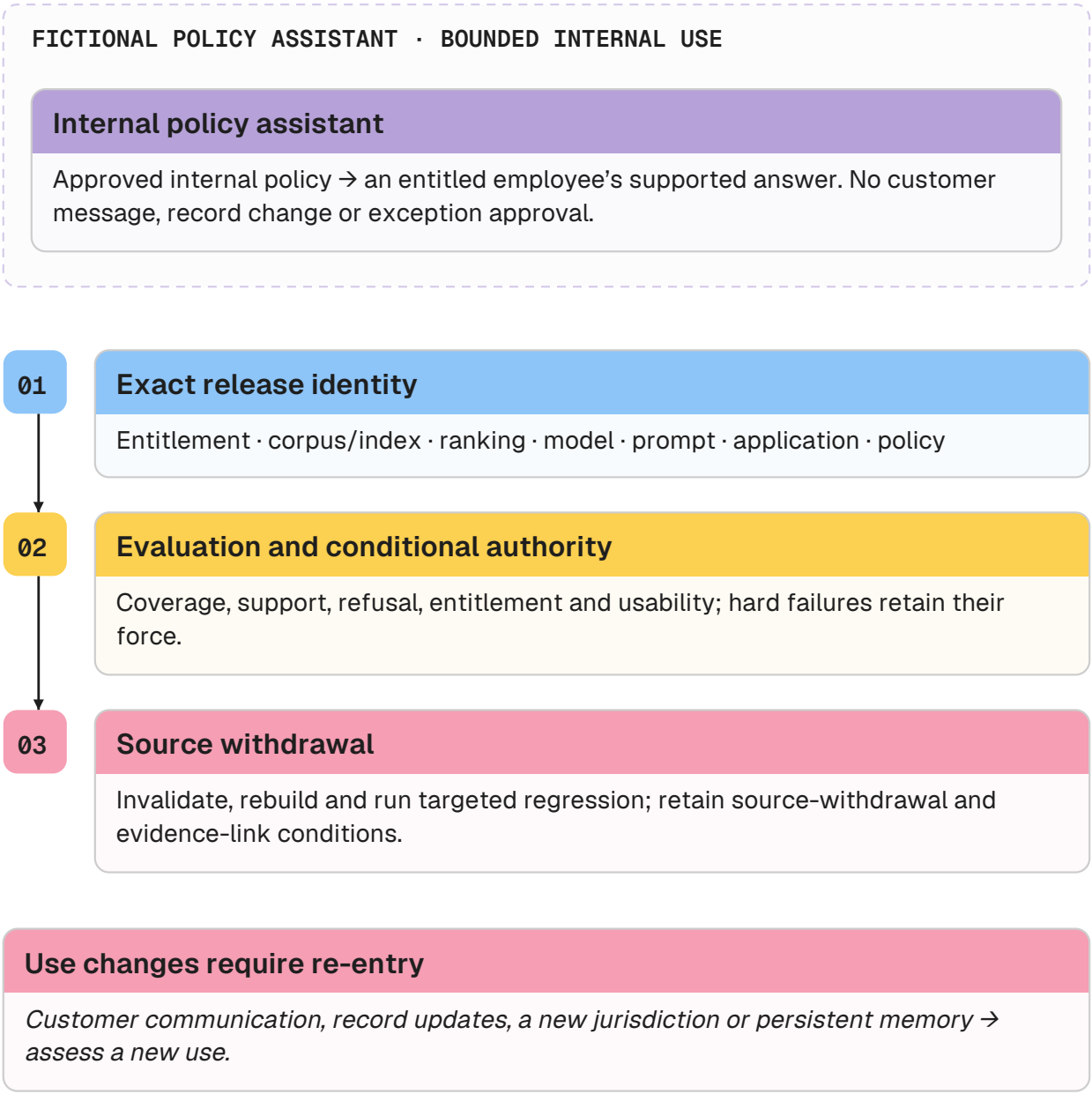
The following fictional traces apply the common lifecycle at different consequence and authority levels. They are not deployment recommendations or evidence that any control works.

Trace A — Internal policy assistant: bounded knowledge support

Purpose and boundary. The product retrieves approved internal policy and drafts an answer for an entitled employee. It cannot send customer communication, alter a record or approve an exception. Unsupported topics route to a policy specialist.

Classification and architecture. Consequence is limited by internal use, evidence display, no action authority and fallback, but sensitive policy content and widespread employee exposure still require access control and monitoring. The release binds user entitlement, corpus/index, ranking, model, prompt, application and policy configuration. Retrieval filters source authority, entity, jurisdiction and effective date before semantic ranking. See Figure 30.1.

Figure 30.1 — Carry the policy assistant's evidence through change



Fictional Trace A illustrates bounded knowledge support and governed change.

Evaluation and gate. Tests separate retrieval coverage, exception retrieval, proposition support, refusal, entitlement and workflow usability. Hard failures include serving a restricted document or presenting a superseded exception as current. Approval is conditional on a source-withdrawal route and evidence-link display. A missing topic is a gap; the model is not invited to improvise.

Operation and change. Runtime sampling covers source support and corrections. A source withdrawal triggers invalidation, rebuild and targeted regression. Direct customer communication, record update, new jurisdiction or persistent memory is a new use requiring re-entry.

Core records. Product charter; use record; classification; architecture/trust-boundary record; corpus/model/prompt manifest; evaluation/acceptance record; release/exception record; operating/change record.

Trace B — Fraud/AML alert triage: high-consequence predictive and operational support

Purpose and boundary. The product prioritizes an existing alert queue and drafts evidence-linked summaries for investigators. It does not decide whether activity is suspicious, file a report, restrict an account or communicate with a customer. Those distinctions are recorded because “human review” alone is too vague.

Data and model. The record distinguishes transaction/event data, rule output, customer-risk attributes, investigator disposition and later confirmed outcomes. Investigator disposition is not assumed to be unbiased ground truth. Feature lineage, label delay, selection effects and adversarial adaptation are explicit limitations. The candidate may combine a predictive ranker with a generative summary; each component and the combined workflow have separate claims.

Evaluation. The ranker is assessed on a defined alert population using decision-relevant ranking, stability and severe-miss analysis; calibration is assessed only if the score is used probabilistically. The summary is tested for factual support, omission of contrary facts, confidentiality and separation of generated text from verified investigative record. Workflow evaluation examines backlog, investigator correction, escalation and fallback capacity. Quantitative design and any regulatory/control-effectiveness conclusion require specialist review.

Gate and authority. High-consequence routing requires independent challenge proportionate to the local classification. Conditions are technically enforceable: pilot population, queue share, no automated case disposition, manual path during model/provider failure, and stop triggers for evidence gaps, anomalous ranking or capacity breach.

Operation and incident. Monitoring combines data/score stability, delayed backtest, subgroup and typology review, investigator overrides, queue age, severe cases and release identity. An incident exercise traces an incorrectly deprioritized population, preserves decision evidence, restores the non-AI route, reviews affected cases and decides whether filings, customer actions or records require correction through applicable procedures. No detection rate, productivity gain or compliance outcome is claimed.

Re-entry triggers. New typology, data source, population, scoring use, disposition authority, threshold meaning, provider/model, label definition or jurisdiction causes targeted or full reassessment.

Synthetic Trace B decision links

FRAUD-USE-01 → FRAUD-DATA-01 bounds investigator support, with no automated disposition, filing or account action. The data record distinguishes §10.6's returning-entity temporal test from its separate unseen-group holdout and records the 30-day labels as of 31 January in the following year. Unknown outcomes remain unknown; a partition is not unbiased ground truth.

FRAUD-EV-01 → FRAUD-GATE-01 records §19.3's one-shift synthetic workload: T1 flags 410 against 300 reviews and is rejected; T2 flags 295 but remains a candidate on hold. Its five-review headroom does not resolve increased misses, label uncertainty or surge risk. A bounded fraud pilot still needs an explicit decision on those consequences, lawful use, funded review and stop/expiry conditions. FRAUD-R1 is a reserved proposed release identity, not an approved service. The PA-R1 decision in §20.9 supplies no fraud authority. The next checkpoint is the missing gate evidence, not an invented pilot result.

FRAUD-CHG-01 → FRAUD-EV-02: a later typology or label-definition change holds the affected population. The product and data owners bind the changed versions and arrange targeted evaluation before a new gate decision. FRAUD-R1 cannot pass its authority to the changed candidate; filing or account action remains with the accountable role. These are constructed minimum records, not a completed pilot or retest.

Trace C — Customer-facing generative assistant: communication and remediation

Purpose and boundary. The assistant answers bounded service questions from approved knowledge, clearly identifies itself where required, and can prepare a service request for customer confirmation. It cannot provide individualized credit, investment or legal decisions, change an account, waive a fee, submit a payment or conceal escalation to an employee.

Affected-party and jurisdiction review. The product identifies supported customers, languages, accessibility needs, channels and locations. Legal and conduct reviewers determine disclosure, recording, privacy, marketing, automated-decision and complaint requirements by entity and jurisdiction. EU AI Act Article 50 transparency guidance is one scope- and date-specific example; it is not a global rule.[1]

Architecture and evaluation. The interface separates sourced answer, account-specific data and proposed action. A tool broker validates customer/session identity and exact request; confirmation expires on material change. Evaluation covers source support, safe handling of account context, accessibility, language, escalation, prohibited advice, misleading certainty, multi-turn state and customer-understanding tasks. Red-team cases include prompt injection, social engineering, cross-session leakage and unauthorized action.

Release and operation. Progressive exposure is defined by channel and topic, not only traffic percentage. The fallback is a staffed or asynchronous route with realistic capacity. Monitoring includes severe unsupported statements, escalation success, complaint/correction, tool denial, identity/trace completeness and customer-impact signals. Direct action or expansion into decisioning requires reclassification.

Incident and remediation. If obsolete knowledge produces a wrong fee statement, the bank disables the topic, reconstructs exposed sessions, distinguishes exposure from reliance and harm, corrects source and records, determines communication/redress under applicable rules, and requires a new release decision. Technical rollback is only the first step.

Synthetic Trace C incident and re-entry links

CX-USE-01/CX-R1 → CX-INC-01: the product owner bounds the assistant to service answers and a prepared request. An obsolete fee statement triggers topic disablement; the incident owner reconstructs exposed sessions while reliance and harm remain uncertain. No PA-INC-01 internal-assistant counts are used as customer case facts.

CX-REMEDY-01 → CX-CHG-01/CX-EV-02: the customer-remedy owner assesses communication, challenge, correction and any redress under the applicable rules. The knowledge owner records the corrected source version; the evaluation owner prepares targeted regression. A corrected source does not show that a customer remedy or regression is complete. Their findings and remaining evidence are the next checkpoint.

CX-GATE-02: the delegated gate owner requires targeted regression and remedy-owner review before topic re-entry, with unresolved evidence and permitted scope recorded. No completed customer remedy, harm assessment or release approval is invented; account changes and fee-waiver execution remain outside CX-R1.

Reconstruction keys for the longitudinal traces

Trace A follows PA-USE-01 → PA-EV-01 rejection → PA-CHG-01/PA-EV-02 hold → PA-EV-03 → PA-GATE-01/PA-R1 → PA-INC-01 → PA-CLOSE-01. The rows in §§2.7, 16.9, 23.10 and 26.8 carry the synthetic result and resulting permission. Trace B uses FRAUD-DATA-01's temporal/entity partitions, §19.3's threshold/capacity tradeoff and §20.9's excluded-population condition; investigation/filing remains with the accountable role. Trace C uses §23.10's customer-facing fee-waiver case and its separate customer-remedy record. Similar record links do not make those authorities interchangeable.

30.12 Bounded Lending Trace

Lending remains a bounded domain trace rather than a fourth longitudinal thread. Fictional Bank considers a product that summarizes verified application information for an authorized underwriter while an existing predictive model and rules produce separate decision inputs. The generative summary cannot create a reason, alter verified data, or make the credit decision.

The product records population and product, data provenance, predictive-model identity, underwriting rules, summary configuration, decision authority, reasons, override and customer communication. U.S. adverse-action requirements and EU automated-decision/data-protection issues are examples requiring jurisdiction-specific legal analysis; neither is generalized globally.[2]

Evaluation checks omitted or distorted facts, decision-relevant subgroup behavior, reason fidelity, automation bias and reconstruction. A human signature is insufficient if workload or interface makes challenge impracticable. Expansion from summary to recommendation, pricing or decision changes the authority and evidence route.

Impact-assessment handoff for the bounded lending trace

Legal screening determines the intended purpose of each component and the assembled use. Where a use is classified as a covered high-risk creditworthiness or specified insurance use, Article 27 screening includes the relevant private-deployer trigger. A summary-only lending label does not settle classification. Link the FRIA/DPIA findings, limitations, review owner and customer/underwriter handoff to the use record in §8.4.

For the bounded lending trace, keep the actual decision factor and communicated reason together (§19.9), with the underwriting owner, legal/rights route, independently reviewed predictive evidence and customer challenge. The policy assistant's synthetic quality result cannot support this use. A faithful explanation can still accompany an unacceptable or unlawful decision; those questions require their own evidence and accountable conclusions.

30.13 Selecting the Minimum Sufficient Artifact Set

The eight canonical artifact families organize the connected records. Appendices A–J provide the minimum field sets in this book; optional institutional extensions can split or combine records without changing their accountable purpose. Count record types, fields and exercise scenarios separately; the minimum set follows the decision and risk route, not a universal record count. The test is whether the bank can retrieve the current decision and supporting evidence by product and release.

Begin with the common fields in Appendices A–J and add specialist records when the domain triggers them. Keep those additions linked to the same product and release so the portfolio can retrieve the decision.

One end-to-end Fictional Bank journey

The policy-assistant thread begins as an assessed internal-use idea, becomes a bounded candidate with prohibited customer and investigation uses, proceeds through architecture and corpus design, reaches an evaluated candidate with explicit severe failures, and becomes an approval candidate linked to an exact manifest. If approved, deployment creates a deployed configuration; operating acceptance confirms the observed release; monitoring and incidents can restrict the service and reopen source, design, evaluation, or approval claims. Provider/model change creates a new candidate rather than inheriting approval. Retirement closes access, indexes, credentials, queues, records, contracts, user transition, and residual evidence obligations.

Closing the lifecycle

Across domains, the governing idea remains consistent: authorize a bounded product, engineer the complete system, evaluate the claims that matter, preserve evidence, operate within explicit authority, learn from failure, and retire responsibly. The model is one dependency. The bank owns the service and its consequences.

The reader should now be able to select a use, route it through the lifecycle, identify the decision-makers and evidence, and explain what would cause progression, restriction, return, or stop. That is the practical promise of an AI SDLC.

The playbooks and decision canvas are teaching designs. Apply legal and supervisory sources within their actual scope; the traces describe no real institution or observed outcome.

Notes

1. European Commission, Article 50 transparency guidelines (B38), published 20 July 2026, with obligations described by the Commission as applying from 2 August 2026. Scope, actor, system and territorial applicability require qualified review. Return to text

2. CFPB Circular 2022-03 (B46), GDPR (B47), and CJEU Case C-634/21 (B48). These are bounded U.S./EU examples requiring current, fact-specific legal analysis. Historical circular withdrawn 12 May 2025; current rule/interpretation is B57, with qualified U.S. review. Return to text

Appendices A–J provide reusable record fields. Complete them for the actual workflow and link the evidence. Filling a form establishes neither approval, compliance nor effectiveness.

Appendix A — AI Product Intake and Value Hypothesis

Record product ID, accountable owner, service problem, affected parties, credible alternative, value mechanism, evidence needed, full cost boundary, material failure paths, feasibility assumptions, risk route, stop/narrow conditions, decision, conditions, owner and expiry. Do not enter a benefit as achieved until a defined measure and population support it.

Minimum reusable record

Copy the record, complete each response cell and link evidence by ID. An empty response is a field to fill, not a passing value. Mark an unavailable fact **unknown**, with an owner and next decision; record not-applicable only with a rationale. Institutional extensions are optional.

Table A.1 — Field and what to enter

Field	What to enter	Response
Record identity	Product/initiative ID, version, date and owner	
Problem and population	Service problem, affected parties, baseline and period	
Alternatives and sourcing	Non-AI comparator; Build/Buy/Partner option and why	
Value hypothesis	Measure, denominator, net-value mechanism and confidence	
Full cost	Delivery, review, support, incident, fallback and exit assumptions	
Five-dimension profile	Impact, feasibility, data, fit and effort/time with evidence confidence	
Prerequisites	Rights, prohibited uses and essential controls outside scoring	
Evidence plan	Decisive question, method, owner and resources	
Verdict	Continue/ Scale/ Pause/ Terminate, scope and rationale	
Checkpoint	Conditions, budget, stop triggers, date/expiry and decision authority	

Appendix B — Intended-Use and Prohibited-Use Specification

Record permitted and prohibited users, populations, tasks, data, knowledge, outputs, communications, tools, actions, channels, locations, jurisdictions, human roles and fallback. Link each acceptance claim and severe failure to evaluation. Changes to purpose, population, authority or jurisdiction normally require re-entry.

Minimum reusable record

Copy the record, complete each response cell and link evidence by ID. An empty response is a field to fill, not a passing value. Mark an unavailable fact **unknown**, with an owner and next decision; record not-applicable only with a rationale. Institutional extensions are optional.

Table B.1 — Field and what to enter

Field	What to enter	Response
Identity	Product, use version and candidate/release reference	
Permitted use	Users, populations, task, language, channel and geography	
Permitted information	Data/source owners, rights, access and effective versions	
Output and authority	Inform/ recommend/ prepare/ decide/ act; precise tools/actions	
Boundary classes	Out-of-scope, disallowed, unsupported and unavailable responses	
Severe failures	Observable condition and required hold/stop/escalation	
Acceptance criteria	Situation, expected behavior, method, decision rule and owner	
Human task	Information, competence, time, authority and alternative route	
Fallback	Trigger, safe route, capacity, owner and communication	
Decision/change	Approved scope, withheld rights, expiry and re-entry triggers	

Appendix C — AI Product Classification and Control-Intensity Worksheet

Assess capability, authority, consequence, exposure, scale and reversibility in plain language. Record criticality, materiality, legal/regulatory routes, uncertainty, selected institutional band, required reviewers, decision authority and reclassification triggers. Institution-specific thresholds remain required.

Minimum reusable record

Copy the record, complete each response cell and link evidence by ID. An empty response is a field to fill, not a passing value. Mark an unavailable fact **unknown**, with an owner and next decision; record not-applicable only with a rationale. Institutional extensions are optional.

Table C.1 — Field and what to enter

Field	What to enter	Response
Assessed use	Product/use version, affected service and scope	
Six factors	Capability, authority, consequence, exposure, scale, reversibility	
Criticality/materiality	Local criteria and rationale; not only color/score	
Legal/rights routes	Actor, entity/use/jurisdiction, sources and unresolved questions	
Institutional route	Local band, mapped review depth and override rationale	
Required evidence	Claims, severe cases and control/assurance requirements	
Owners/conflicts	Decision delegation, specialists, independence and conflicts	
Conditions	Enforceable scope, residual risk, owner and expiry	
Reclassification	New purpose, population, data, authority, dependency or accumulated change	

Appendix D — Architecture and Trust-Boundary Review

Attach context/workflow, data/knowledge flow, identity/trust boundary, tool/action, deployment, failure-domain and evidence-event views. Record policy enforcement outside the model, deployment trade-offs, data residency owner, failure/degradation, rollback/reconciliation, conditions and evidence gaps.

Minimum reusable record

Copy the record, complete each response cell and link evidence by ID. An empty response is a field to fill, not a passing value. Mark an unavailable fact **unknown**, with an owner and next decision; record not-applicable only with a rationale. Institutional extensions are optional.

Table D.1 — Field and what to enter

Field	What to enter	Response
Context and workflow	Actors, service boundary and normal/exception sequence	
Trust transitions	Identity, context assembly, output and privileged receiver	
Data/knowledge	Provenance, entitlement, refresh/withdrawal and privacy	
Policy enforcement	External control, owner, proposed/tested status and evidence	
Dependencies	Code, model, tool, policy, infrastructure and effective versions	
Failure domains	Shared provider/ cloud/ identity/ network/ team and unknowns	
Failure handling	Timeout, denial, safe route, backpressure and containment	
Action semantics	Exact approval, receiver checks, idempotency and reconciliation	
Evidence handling	Event IDs, protected payloads, access, retention and lawful disposal	
Architecture decision	Tradeoff, limitation, approving owner and re-entry condition	

Appendix E — Evaluation Plan and Result Record

Record claim and decision, candidate configuration, target population/cohorts/exclusions, severe failures, cases and sampling logic, layered methods, measures and uncertainty, adjudication and judge validation, baseline/challenger, results with denominators, defects, limitations, conclusion, conditions and re-evaluation triggers. No universal metric or threshold is supplied.

Minimum reusable record

Copy the record, complete each response cell and link evidence by ID. An empty response is a field to fill, not a passing value. Mark an unavailable fact **unknown**, with an owner and next decision; record not-applicable only with a rationale. Institutional extensions are optional.

Table E.1 — Field and what to enter

Field	What to enter	Response
Claim	Proposition and decision supported	
Population	Use, cohorts, conditions, exclusions and target period	
Cases	Sampling/selection, boundary/stress cases and leakage controls	
Measures	Outcome definition, rubric, adjudicators and denominators	
Decision/uncertainty	Hard failures, thresholds, interval method and dependence	
Configuration	Candidate, effective data/knowledge/tools/policy, environment and time	
Results	Per-layer counts, failures, uncertainty and evidence references	
Conclusion/ follow-through	Supported scope, limitations, residual risk, conditions, owner and retest	
Assessor record	Qualification, independence/conflicts and unavailable evidence	

Appendix F — Release Manifest, Gate, and Exception Record

Record immutable identities for bank-controlled code, infrastructure, prompts/policy, corpus/index, tools, evaluation and telemetry. For provider-controlled services record observable identity, notice limits, change envelope and the response to uncertainty; hold uses requiring unavailable guarantees. Link the gate question, independent conclusion where required, approval, enforcement, expiry, exposure, fallback, rollback, reconciliation and operating acceptance.

Where relevant to the use, link the scoped legal disposition in §8.4 and the continuity/exit records in §25.5 and Appendix H to that same release. Identify the competent decisions, permitted scope and unmet conditions without treating legal review, internal release authority and an applicable external step as interchangeable. These are links in the existing record, not new mandatory templates or permission to duplicate sensitive evidence.

Minimum reusable record

Copy the record, complete each response cell and link evidence by ID. An empty response is a field to fill, not a passing value. Mark an unavailable fact **unknown**, with an owner and next decision; record not-applicable only with a rationale. Institutional extensions are optional.

Table F.1 — Field and what to enter

Field	What to enter	Response
Release identity	Product/release/version, exact evaluated configuration and scope	
Dependency manifest	Code/build, model alias/effective revision, prompts, policy, sources/index, tools	
Gate question	Transition, entry evidence and independent conclusions	
Management decision	Delegate, authority, outcome, scope and rationale	
Conditions/ exceptions	Requirement, alternative control, evidence due, owner, expiry and default	
Deployment	Environment, exposure, configuration comparison and denied paths	
Operating acceptance	Verified identity/control/telemetry, owner and initial observations	
Rollback/fallback	Current validity, capacity, state reconciliation and tested limits	
Legal/resilience links	Separate scoped conclusions, notices and continuity/exit records	
Change/retirement	Envelope, incident triggers, cumulative change and residual duties	

Complete lifecycle reference

The following fields are unchanged from the controlled reference; their placement follows the minimum release/gate record. The same decisions should not be documented twice.

Discover and assess

Table F.2 — Crosswalk field and phase record

Crosswalk field	Phase record
Phase	Discover and assess
Decision	Fund a bounded question or stop
State produced	Proposed idea → assessed candidate
Chapter(s)	1,3,5
Artifact family	A1; A2; A3
Evidence classes	Decision evidence; Assurance evidence
Gate / exit condition	Credible problem, alternatives, sponsor and proportionate investigation scope; no operating permission
Accountable role	Business sponsor / product owner within investment delegation
Required challenge	Business/domain, risk and finance input proportionate to consequence
Re-entry trigger	Purpose, value assumptions, affected population or portfolio dependency changes
Related appendix	A;C;J
Visual reference	Figure P.2; Figure P.3; Figure 1.1; Figure 5.1

Define and classify

Table F.3 — Crosswalk field and phase record

Crosswalk field	Phase record
Phase	Define and classify
Decision	Bound permitted use and route authority/risk
State produced	Assessed candidate → bounded candidate
Chapter(s)	4,6–8
Artifact family	A2; A3; A4
Evidence classes	Decision evidence; Implementation evidence; Assurance evidence
Gate / exit condition	Intended/prohibited use, route, rights, controls, owners and acceptance claims sufficiently specified
Accountable role	Accountable product owner; delegated risk/authority decision owner
Required challenge	Legal/privacy/conduct/security/model-risk specialists where triggered
Re-entry trigger	New population, action, data, jurisdiction or changed consequence
Related appendix	B;C;D;J
Visual reference	Figure P.2; Figure P.3; Figure 6.1; Figure 7.1; Figure 8.1; Figure 8.2

Design and build

Table F.4 — Crosswalk field and phase record

Crosswalk field	Phase record
Phase	Design and build
Decision	Construct the bounded candidate and enforce boundaries
State produced	Bounded candidate with identified build/configuration; no new named approved state
Chapter(s)	9–15
Artifact family	A4; A5; A6
Evidence classes	Implementation evidence; Assurance evidence; Decision evidence
Gate / exit condition	Traceable dependencies, authorized data/tools, enforceable contracts, secure build and test target identity
Accountable role	Engineering / architecture owner with product accountability
Required challenge	Architecture, data, security/privacy and relevant supplier challenge
Re-entry trigger	Changed trust boundary, model, prompt, corpus, permission, tool or provider
Related appendix	D;E;H
Visual reference	Figure 4.3; Figure 10.1; Figure 12.1; Figure 13.1; Figure 14.1; Figure 15.1

Evaluate and challenge

Table F.5 — Crosswalk field and phase record

Crosswalk field	Phase record
Phase	Evaluate and challenge
Decision	Decide whether evidence supports defined claims
State produced	Bounded candidate → evaluated candidate → approval candidate when evidence submitted
Chapter(s)	16–20
Artifact family	A3; A5; A6; A7
Evidence classes	Assurance evidence; Implementation evidence; Decision evidence
Gate / exit condition	Layer-specific results, hard failures, uncertainty, independence, limitations and unresolved exceptions visible
Accountable role	Evaluation owner; independent challenger reports own conclusion; product owner submits
Required challenge	Domain/statistical validation, security/red team, privacy/fairness and independent review as required
Re-entry trigger	Failed claim, changed population/configuration, judge issue or challenge finding
Related appendix	C;E;F
Visual reference	Figure 16.1; Figure 18.1; Figure 19.1; Figure 20.1

Approve and release

Table F.6 — Crosswalk field and phase record

Crosswalk field	Phase record
Phase	Approve and release
Decision	Accept, condition, reject or hold an identified release
State produced	Approval candidate → approved release, or recorded hold/rejection
Chapter(s)	8,20–21
Artifact family	A3; A6; A7
Evidence classes	Decision evidence; Assurance evidence; Implementation evidence
Gate / exit condition	Authorized delegate records exact release, scope, conditions, residual risk, expiry and rollback/fallback readiness
Accountable role	Delegated release / risk-acceptance decision owner
Required challenge	Independent review conclusions and unresolved conflicts presented to decision owner
Re-entry trigger	Condition lapse, severe failure, changed manifest/use or unmet prerequisite
Related appendix	F;I
Visual reference	Figure 8.1; Figure 20.1; Figure 21.1

Deploy and operate

Table F.7 — Crosswalk field and phase record

Crosswalk field	Phase record
Phase	Deploy and operate
Decision	Verify deployment and decide continued authorized service
State produced	Approved release → deployed configuration → operating service; restricted service if necessary
Chapter(s)	21–25,28
Artifact family	A5; A7; A8
Evidence classes	Operating evidence; Decision evidence; Assurance evidence; Implementation evidence; Change evidence
Gate / exit condition	Identity and enforceable conditions verified; operating acceptance, observability, capacity and tested safe route
Accountable role	Service owner / incident commander within recorded delegation
Required challenge	Operations, security, conduct, resilience and periodic independent assurance
Re-entry trigger	Incident, drift, complaint, stale evidence, capacity breach, provider or access change
Related appendix	G;H;I
Visual reference	Figure P.3; Figure 21.1; Figure 22.1; Figure 23.1; Figure 25.1; Figure 28.1; Figure 25.3; Figure 25.4; Figure 25.2

Change and reapprove

Table F.8 — Crosswalk field and phase record

Crosswalk field	Phase record
Phase	Change and reapprove
Decision	Assess affected claims and route a changed candidate
State produced	Operating/restricted service → affected candidate state; renewed approval/deployment only after relevant decisions
Chapter(s)	7,12–14,21,23,25–26
Artifact family	A2; A3; A4; A5; A6; A7; A8
Evidence classes	Change evidence; Decision evidence; Implementation evidence; Assurance evidence; Operating evidence
Gate / exit condition	Change envelope, cumulative effect, regression and condition closure assessed; no automatic inherited approval
Accountable role	Change owner with product owner; relevant delegated reapproval owner
Required challenge	Risk/domain/control specialists for changed claims; independent challenge where needed
Re-entry trigger	Accumulated changes, emergency expiry, failed regression, changed supplier capability
Related appendix	C;E;F;G;H
Visual reference	Figure 26.1; Figure 23.1; Figure 12.1; Figure 25.4

Retire and learn

Table F.9 — Crosswalk field and phase record

Crosswalk field	Phase record
Phase	Retire and learn
Decision	Close service and preserve residual obligations
State produced	Operating/restricted service → retired service after verified closure
Chapter(s)	25–30
Artifact family	A1; A5; A7; A8
Evidence classes	Change evidence; Operating evidence; Decision evidence; Assurance evidence
Gate / exit condition	Access/credentials/indexes/queues/contracts closed or transferred; records/holds/customer obligations and learning owned
Accountable role	Product and service owners; records authority owns retention/disposal decisions
Required challenge	Operations/security/privacy/legal and independent sampling proportionate to risk
Re-entry trigger	Failed decommissioning, unresolved harm, retained dependency or evidence duty
Related appendix	G;H;I;J
Visual reference	Figure 26.1; Figure 28.1; Figure 30.1; Figure 25.4

Appendix G — Runtime, Incident, and Remediation Record

Trace detection, classification, release/dependency, containment, safe service route, affected population and unknowns, preserved evidence, investigation, customer/record/process remediation, reporting assessment, recovery gate and change. Each metric uses a definition card with denominator, period, owner, uncertainty, trigger and action.

Link complaint/decision references, scoped preservation/access decisions, claim/remedy assessment and residual ownership where relevant. Reuse the lawful evidence index and uncertainty record from §§8.7 and 23.6. Connect safe-route/restriction and return decisions to §25.5; open matters follow the transition or retirement until the actual owner verifies their disposition.

Minimum reusable record

Copy the record, complete each response cell and link evidence by ID. An empty response is a field to fill, not a passing value. Mark an unavailable fact **unknown**, with an owner and next decision; record not-applicable only with a rationale. Institutional extensions are optional.

Table G.1 — Field and what to enter

Field	What to enter	Response
Event/incident identity	Product/release, time window, detection and classification	
Effective dependency	Source/index/policy/provider versions and trace references	
Containment	Restricted scope, authority, safe route and evidence preservation	
Population reconstruction	Generated/shown/acted-on records, unique people and missing evidence	
Cause and control	Proposed versus demonstrated control, failed assumption and owner	
Remedy	Customer/employee/record groups, communication, redress and uncertainties	
Reporting assessment	Entity/rule/fact clock, recipient, owner and separate conclusion	
Recovery	Changed release, regression, approval and operating verification	
Closure/residuals	Findings, lawful records/holds, unresolved obligations and owners	
Metric card	Definition, denominator, period, uncertainty, trigger, capacity and action	

Appendix H — Third-Party and Exit Assessment

Record supported business service and tolerance, provider and fourth parties, data/model/authority/evidence access, concentration, due diligence, contract/change/incident route, continuity, fallback, substitution, exit, data disposition, scenario result, limitations and residual-risk owner.

Linked continuity and exit plan outlines

Use the following author record outlines to assemble the continuity/contingency and exit decisions in §25.5. B01–B12, E01–E12 and CE-S01–CE-S07 label record fields and exercise scenarios; they are not additional artifact families. Link facts already maintained in the service, release, dependency, authority and incident records. Adapt scope, owners, tolerances, legal applicability and exercise design to the actual institution; no prefilled result establishes readiness.

Continuity / contingency plan: B01–B12

Table H.1 — Field and what to capture

Field	What to capture
B01 Service and consequence	Service, parties, criticality, obligations, runtime/development AI dependence; locally defined tolerance/objectives
B02 Dependency/release	Exact operating identity, model/provider/fourth parties, common failure domains and evidence access
B03 Trigger and authority	Signals, legal/access restrictions, decision owner, activation/escalation rights and emergency containment route
B04 Minimum service and controls	Priority outcomes, disabled features, inviolable entitlements/security/authorization and permitted data use
B05 Approved alternatives	Candidate/approved status, allowed scope, non-AI/manual/degraded options, prerequisites and limitations
B06 Capacity and staffing	Demand/peak assumptions, skills and availability, queue priorities, throughput, backlog and reassessment triggers
B07 In-flight work	Authoritative action state, reconciliation, retry/replay controls, unknown outcomes and remediation ownership
B08 Communication and applicability	Internal/customer/provider routes; locally assessed reporting/notification obligations and status cadence
B09 Restoration/return	Exact route/release, renewed evidence, reconciled work and authorized return-to-service conditions
B10 No safe route	Restriction, impact/unmet-obligation escalation, emergency options, constraints and accountable decisions
B11 Exercises and findings	Scenario, criteria, assumptions, observed outcomes, gaps, owners, retest and limitations
B12 Maintenance and linkage	Review triggers; linked exit plan, change/re-entry, funding, records and residual risk

Planned and stressed exit plan: E01–E12

Table H.2 — Field and what to capture

Field	What to capture
E01 Arrangement and trigger	Affected model/provider/service; planned or stressed/no-notice conditions; activation authority
E02 Service continuity	Linked BCP, customer/business duties, tolerance, minimum lawful service and time/capacity assumptions
E03 Feasible options	Lawful alternative provider, in-house/non-AI route, limited feature retirement; constraints if no viable option
E04 Contract and rights	Termination/transition assistance, access/export/delete/retention rights, licenses and limits; do not assume cooperation
E05 Asset/state inventory	Source data/knowledge, prompts/configuration, logs/evidence, state/queues, credentials, recoverable versus unavailable assets
E06 Portability/rebuild	Formats, validation, source-based rebuild, provider-only artifacts, test results and non-portability
E07 Replacement qualification	Product claims, material failure modes, permissions/residency, behavior/tools, controls, capacity and required approvals
E08 Failure-domain assessment	Supplier/model/cloud/identity/region/nth parties/legal access; alternate quota and correlated failure
E09 Resources and readiness	Owners, skills, staffing, costs/budget, prerequisites, exercises, gaps and decision criteria
E10 Transition and reconciliation	Approved release, staged cutover, monitoring, pending actions, dual-run/rollback only if lawful and feasible
E11 Closure and residual duties	Revoke credentials/access, settle contracts, retain/delete assets per obligations, preserve evidence and own open remedies
E12 Update and disposition	Planned/exercised/completed status, currentness, review triggers, sign-off, residual risk and retest

Exercise questions: CE-S01–CE-S07

Table H.3 — ID and scenario

ID	Scenario	Required observation/decision
CE-S01	Model access disappears without notice or provider cooperation	Detect and restrict; activate approved business fallback; measure queue/staff/control effects; decide whether stressed exit starts immediately
CE-S02	Alternate and primary share identity/cloud/model/legal access exposure	Expose common failure domains and viable options; do not label brand diversity as independent recovery
CE-S03	Fallback demand peaks while alternate-provider quota is scarce	Observe priority-service capacity, backlog, impact, restriction and escalation decisions against locally defined criteria
CE-S04	Required records or proprietary artifacts cannot be exported	Demonstrate recoverable/rebuildable assets, unavailable evidence, obligations and feasibility limits without recreating missing facts
CE-S05	Agent action timed out and its business outcome is unknown	Reconcile with authoritative records before retry; preserve action identity; own customer/record remediation
CE-S06	New model is API-compatible but fails a material product claim	Hold substitution; maintain safe continuity/restriction; remediate/evaluate through existing approval route
CE-S07	Restored original endpoint has changed behavior or configuration	Assess exact restored identity and evidence; authorize return only within an applicable current envelope

Legal and capability review links

Link four blocks from §8.4: scoped entity/use/territory/role/release and unknowns; primary source/version/scope/date and unresolved duties; controls, terms/capability and complaint/rights/evidence references with gaps; and competent owners, distinct dispositions, conditions, restriction and reassessment. For each of the seven themes in Figure 25.2, point to the actual terms and constraints, proof of capability, status/gap and accountable owner. The suggested figure roles do not substitute for local delegations.

Keep negotiated rights, provider assertions, institution tests and operating observations distinct. Link unresolved access, licenses, non-portability, claims and residual duties to their qualified owner and disposition. Assessment, an approved plan, an exercise and a completed exit are different states. Do not reproduce the three Chapter 25 figures here or copy sensitive records into the assessment; refer to their primary locations and controlled evidence.

Minimum reusable record

Copy the record, complete each response cell and link evidence by ID. An empty response is a field to fill, not a passing value. Mark an unavailable fact **unknown**, with an owner and next decision; record not-applicable only with a rationale. Institutional extensions are optional.

Table H.4 — Field and what to enter

Field	What to enter	Response
Assessment identity	Service, supplier/relationship, version, owner and date	
Terms and rights	Actual clause/source, enforceability conclusion and limitations	
Shared dependencies	Fourth parties, correlated domains and unavailable facts	
Continuity	Link B01–B12 fields earlier in this appendix, capacity and safe-route authority	
Exit	Link E01–E12 fields earlier in this appendix, planned/stressed route and residual duties	
Exercise result	CE-S01–CE-S07 scenario, observations, failed assumptions and retest	
Disposition	Permitted route, gaps, funding, accountable owners and next checkpoint	

Appendix I — Executive Oversight and Assurance View

Show exposure; decisions due; severe findings/incidents; evidence health; third-party concentration; value/outcome; and reviewer/operations capacity. Each tile must expose definition, denominator, uncertainty, owner and underlying record. Do not use a composite “trust” score without an approved method.

Refer to the five-question leadership brief at the end of the Executive Brief, retaining its descriptive links to the eight decisions. The underlying record should identify service/release, competent owner, evidence version and status, known limitations and the decision or resource constraint requiring attention. Summarize legal/complaint/claims exposure through lawful references, with uncertainty visible. Distinguish planned, authorized, exercised and observed arrangements; the accepted diagram and its illustrative roles are not evidence of institution readiness.

Minimum reusable record

Copy the record, complete each response cell and link evidence by ID. An empty response is a field to fill, not a passing value. Mark an unavailable fact **unknown**, with an owner and next decision; record not-applicable only with a rationale. Institutional extensions are optional.

Table I.1 — Field and what to enter

Field	What to enter	Response
Portfolio/row identity	Service/product/release, population, jurisdiction and period	
Exposure	Capability/ authority/ consequence and actual permitted scope	
Decision due	Requested decision, delegate, deadline and effect of inaction	
Evidence/findings	Underlying IDs, severe issues, status, uncertainty and limitations	
Value/outcome	Definition, denominator, cost boundary and observed versus assumed	
Capacity/ dependencies	Review/operation queue, concentration, fallback/exit tests and gaps	
Remedy	Affected groups, unresolved cases and accountable follow-through	
Assurance map	Management evidence, specialist challenge, audit question and coverage	
Drill-through	Protected source links, access rules and reconstructed decision trail	

Appendix J — Domain Playbook Canvas

Record domain service/value, affected parties, intended/prohibited use, authority/human role, failure pathways, dependencies, jurisdiction/specialist route, acceptance/severe failures, architecture, release/fallback/operation, remediation, re-entry/retirement triggers and required evidence decisions.

Minimum reusable record

Copy the record, complete each response cell and link evidence by ID. An empty response is a field to fill, not a passing value. Mark an unavailable fact **unknown**, with an owner and next decision; record not-applicable only with a rationale. Institutional extensions are optional.

Table J.1 — Field and what to enter

Field	What to enter	Response
Domain/service	Purpose/value, finality, latency and affected parties	
Use/authority	Permitted/prohibited task, data, action and human decision	
Failure paths	Domain-specific harms and severe stop conditions	
Dependencies/rights	Architecture, concentration, sources, provider limits and scope	
Evaluation	Claim, population, cases, measures, uncertainty and actual configuration	
Release/operation	Delegated permission, operating acceptance, observations and capacity	
Recovery/remedy	Fallback, irreversibility, reconciliation and customer/record duties	
Re-entry/retirement	Changed claims, incident, conditions, closure and residual ownership	

Illustration Descriptions

Figure P.1 — AI SDLC: the leadership decisions

Five leadership questions connect to the eight executive decisions. Roles and ownership are illustrative; local delegations determine authority. No readiness result is claimed. Figure P.1. AI SDLC: the leadership decisions. Author synthesis. Role titles are illustrative; they do not assign authority or establish compliance or readiness.

View Figure P.1

A one-page brief for banking executives and accountable service leaders. Govern the banking product and its consequences. Link every operating release to its purpose, evidence, authority and accountable owner.

CANONICAL LIFECYCLE • TARGETED RE-ENTRY

- Discover and assess
- Define and classify
- Design and build
- Evaluate and challenge
- Approve and release
- Deploy and operate
- Change and reapprove
- Retire and learn

1 Why this product, and within which boundaries?

Define value, a credible alternative, permitted use, customer consequence and authority. Bound data, users, actions and jurisdictions.

Evidence: Purpose, scope and control-intensity assessment.

Accountability: Executive sponsor / business owner

2 What supports an accountable release?

Connect design, evaluation and independent challenge to the exact release. Enforce permissions and approval conditions outside the model.

Evidence: Release-linked evidence, limits and approval record.

Accountability: Engineering / assurance / release authority

3 Can the service operate and recover safely?

Monitor actual outcomes. Exercise AI loss, approved fallback or restriction, capacity, reconciliation and customer remediation.

Evidence: Operating evidence; contingency exercise and gaps.

Accountability: COO / continuity / service owner

4 When must we reapprove, exit or retire?

Name change and stop triggers. Test planned and stressed exit, qualified replacement, controlled cutover and residual-duty ownership.

Evidence: Changed-claim record; exit rehearsal and closure evidence.

Accountability: CIO / risk / service owner

5 Are legal rights and accountability protected?

Map applicable duties. Own customer complaints and redress, bank defence and provider remedies. Preserve evidence lawfully.

Evidence: Duty map; complaints / claims record; decision authority.

Accountability: Legal / complaints / accountable executive

The leadership decision to record

- Name the accountable sponsor, service owner and decision rights.
- Fund evidence, operating capacity, contingency and exit exercises.
- Record remaining risk, affected use and re-entry / stop conditions.

Missing required authority or evidence: hold or restrict the affected use and escalate. A new model or provider needs qualification and applicable approval.

Figure P.2 — AI SDLC in a nutshell

AI SDLC in a nutshell: navigation from assessed candidate to retirement, with targeted re-entry.

View Figure P.2

Long description

Discover / assess

Purpose: Establish the problem and credible alternative.

Chapters: Ch. 1, 3, 5

Define / classify

Purpose: Bound the use, consequence and authority.

Chapters: Ch. 4, 6–8

Design / build

Purpose: Build an identified configuration of the bounded candidate.

Chapters: Ch. 9–15

Evaluate / challenge

Purpose: Test claims and preserve limitations; submit approval evidence.

Chapters: Ch. 16–19

Approve / release

Purpose: Authorize the exact release and its conditions.

Chapters: Ch. 20–21

Deploy / operate

Purpose: Verify deployment identity; operate within authorized exposure.

Chapters: Ch. 21–25

Change / reapprove

Purpose: Return changed work to the affected candidate state.

Chapters: Ch. 23, 26

Retire / learn

Purpose: Verify closure; preserve records, duties and accountability.

Chapters: Ch. 26

Reentry: Reopen affected claims and decisions; navigation is not an automatic gate sequence. Proposed, implemented, tested, approved, deployed and effective remain distinct.

Figure P.3 — AI SDLC: the full lifecycle

The full lifecycle: decisions, evidence handoffs and an applicable request path within Deploy / operate.

View Figure P.3

Long description

Discover / assess

Controlled description: Assessed candidate

Limit: Investigation scope; no operating permission.

Chapters: Ch. 1, 3, 5

Define / classify

Controlled description: Bounded candidate

Limit: Intended use, rights and review route; no automatic permission.

Chapters: Ch. 4, 6–8

Design / build

Controlled description: Bounded candidate; identified build

Limit: An identified configuration; build completion is not approval.

Chapters: Ch. 9–15

Evaluate / challenge

Controlled description: Evaluated candidate

Limit: Scoped results; approval candidate when evidence is submitted.

Chapters: Ch. 16–19

Approve / release

Controlled description: Approved release

Limit: Exact release and conditions; deployment remains separate.

Chapters: Ch. 20–21

Deploy / operate

Controlled description: Operating service

Limit: Verify deployed configuration and continuing conditions.

Chapters: Ch. 21–25

Change / reapprove

Controlled description: Affected candidate state

Limit: Reopen affected decisions; prior approval is not inherited.

Chapters: Ch. 23, 26

Retire / learn

Controlled description: Retired service after closure duties

Limit: Verify closure; retain residual records and duties.

Chapters: Ch. 26

Request path

R1 Receive

Meaning: Bind identity, purpose and workflow state.

R2 Entitlement

Meaning: Apply access and policy outside the model before exposing information.

R3 Bounded assembly

Meaning: Use permitted input and identified model; retrieval and tools only where designed.

R4 Validate and authorize

Meaning: Check output, exact action permission and required human approval before execution.

R5 Return and observe

Meaning: Confirm actual outcome; retain protected minimized observations linked to release.

Handoffs: Evidence links the problem and alternatives, bounded use, architecture and identity, scoped evaluation, release conditions, operating records, change and closure. Evidence does not itself authorize action.

Reentry: Failures route to bounded repair, required review, approved fallback or stop; re-entry reopens affected decisions.

Figure 1.1 — A lifecycle of accountable decisions

A lifecycle of accountable decisions. Each phase has a decision purpose and expected evidence; phase descriptions do not confer permission.

View Figure 1.1

Long description

Discover / assess

Description: Assessed candidate

Permission limit: Investigation scope; no operating permission.

Define / classify

Description: Bounded candidate

Permission limit: Intended use, rights and review route; no automatic permission.

Design / build

Description: Bounded candidate; identified build

Permission limit: An identified configuration; build completion is not approval.

Evaluate / challenge

Description: Evaluated candidate

Permission limit: Scoped results; approval candidate when evidence is submitted.

Approve / release

Description: Approved release

Permission limit: Exact release and conditions; deployment remains separate.

Deploy / operate

Description: Operating service

Permission limit: Verify deployed configuration and continuing conditions.

Change / reapprove

Description: Affected candidate state

Permission limit: Reopen affected decisions; prior approval is not inherited.

Retire / learn

Description: Retired service after closure duties

Permission limit: Verify closure; retain residual records and duties.

Reentry: Incidents, drift, complaints, provider change and accumulated change reopen the affected decision; no automatic permission increase or complete restart is implied.

Figure 2.1 — One release identity, federated evidence

Purpose and use, risk and authority, and evaluation and approval link to an exact release identity. Solid lines show release relationships; dashed lines connect records to the federated evidence index, with governed access, retention and source custody.

View Figure 2.1

Text equivalentPurpose and use, risk and authority, and evaluation and approval feed distinct ports on the identified release manifest. It binds product, model, prompt, corpus, policy, code and configuration. The manifest connects to deployed state, operating evidence, and incident and change records. Dashed connections from each operating group reach a federated index containing governed pointers, access and retention information; the index does not require copying every record. Material incidents and changes can reopen the affected claim and approval. Valid and record time are separate design questions.

Figure 2.2 — Five evidence classes; eight artifact families

The approved five classes and eight family names retain their descriptive crosswalk. No Primary, Supporting or Conditional figure edge has been inferred.

View Figure 2.2

Family: A1

Decision evidence: primary

Implementation evidence: supporting

Assurance evidence: limitation

Operating evidence: outcome hypothesis

Change evidence: purpose change

Family: A2

Decision evidence: primary

Implementation evidence: supporting

Assurance evidence: acceptance

Operating evidence: boundary signal

Change evidence: use change

Family: A3

Decision evidence: primary

Implementation evidence: supporting

Assurance evidence: challenge

Operating evidence: reclassification signal

Change evidence: route change

Family: A4

Decision evidence: supporting

Implementation evidence: primary

Assurance evidence: review

Operating evidence: control health

Change evidence: design change

Family: A5

Decision evidence: supporting

Implementation evidence: primary

Assurance evidence: provenance review

Operating evidence: dependency state

Change evidence: version change

Family: A6

Decision evidence: conclusion

Implementation evidence: test target

Assurance evidence: primary

Operating evidence: production sample

Change evidence: regression

Family: A7

Decision evidence: primary

Implementation evidence: release identity

Assurance evidence: independent conclusion

Operating evidence: condition status

Change evidence: reapproval

Family: A8

Decision evidence: primary

Implementation evidence: operating identity

Assurance evidence: periodic assurance

Operating evidence: primary

Change evidence: primary

Artifact families

- A1 — AI Product Charter
- A2 — Intended and Prohibited Use Record
- A3 — Risk, Criticality, Materiality and Authority Assessment
- A4 — System and Trust-Boundary Architecture Record
- A5 — Data, Knowledge, Model, Prompt, Tool and Dependency Manifest
- A6 — Evaluation and Acceptance Record
- A7 — Approval, Exception and Release Record
- A8 — Operating, Incident, Change and Retirement Record

Figure 4.1 — Where can this product have consequences?

Six independent lenses assess the assembled product. Testing, human authority, monitoring, resilience and escalation depend on the assessed context; no weights or ranking are implied.

View Figure 4.1

Affected parties: Customers, staff, counterparties

Banking services: Payments, lending, advice

Records and data: Identity, transactions, evidence

Legal / regulatory: Duties, permissions, reporting

Critical operations: Continuity, recoverability, impact

Third-party dependencies: Models, platforms, providers

Governed AI product: Boundary · authority · evidence · release

Calibrate governance from the assessed context: Testing, human authority, monitoring, resilience and escalation depend on the product. No weights or ranking are implied.

Reading route

- Governed AI product — Affected parties (association, no arrow)
- Governed AI product — Records and data (association, no arrow)
- Governed AI product — Critical operations (association, no arrow)
- Governed AI product — Banking services (association, no arrow)
- Governed AI product — Legal / regulatory (association, no arrow)
- Governed AI product — Third-party dependencies (association, no arrow)

Figure 4.2 — Six factors that shape control intensity

All six factors, guiding questions, qualitative indicators and design levers remain unchanged. Assess control intensity in context rather than by a universal score.

View Figure 4.2

Factor: Capability

Guiding question: What can the product perceive, infer, generate, retrieve, or do?

Qualitative indicators: Tool use, planning, sensitive inference, open-ended generation

Design levers that may reduce intensity: Narrow the task, remove tools, constrain inputs and outputs

Factor: Authority

Guiding question: What may it materially influence, decide, prepare, or execute?

Qualitative indicators: Formal permission and practical reliance

Design levers that may reduce intensity: Separate recommendation from decision or preparation from execution

Factor: Consequence

Guiding question: What can happen if it is wrong, unavailable, misused, or changed?

Qualitative indicators: Customer, financial, conduct, market, record, or service effects

Design levers that may reduce intensity: Limit eligible cases and require higher-authority routing

Factor: Exposure

Guiding question: Who and what encounters the behavior?

Qualitative indicators: Population, data sensitivity, channels, jurisdictions

Design levers that may reduce intensity: Restrict users, data, environment, or distribution

Factor: Scale

Guiding question: How broadly and quickly can behavior propagate?

Qualitative indicators: Volume, speed, reuse, shared dependency

Design levers that may reduce intensity: Rate and value limits, progressive rollout, segmentation

Factor: Reversibility

Guiding question: Can the effect be detected, stopped, corrected, restored, and remediated?

Qualitative indicators: Recovery time, record correction, customer redress

Design levers that may reduce intensity: Preview, rollback, compensation, fallback, recourse

Figure 4.3 — Put enforcement outside the model

The logical product has conditional service and data dependencies. Enforcement, platform, failure handling and evidence are separate views; actual topology and allocation vary.

View Figure 4.3

Text equivalentThe five elements are Channels and user interaction; AI product and service orchestration; Model, agent, and tool services; Data and knowledge services; Platform and infrastructure. The conceptual solid path leads from channels to orchestration, with two possible dependency calls. Markers 1, 2, 3 locate ingress, material action, and data-source access reviews. Identity and policy must be determined for material actions; a model request is not authorization. Evidence includes decisions, versions, evaluation, and material runtime records linked to their source systems. A dependency fault invokes a selected fallback, recovery, read-only, manual, or stop route. The displayed failure branch is one illustrative dependency, not an exhaustive error-flow map. These are distinct analytical routes and do not specify actual bank/provider topology, actual identities, data classes, implementation locations, or one universal failure outcome.

Figure 5.1 — Evidence must bridge each benefit claim

Behavior, workflow benefit and institutional effect are separate claims. Each requires its own evidence, a credible alternative and quality guardrails.

View Figure 5.1

Text equivalentThe proposed value chain has three distinct claims: observed system behavior, an accepted workflow outcome, and an institutional consequence. Each arrow is a hypothesis requiring its own evidence. The first link observes the task and output; the second measures effort from process entry through accepted result including rework and escalation; the third depends on demand, staffing and scheduling and does not by itself establish a cash saving.Compare with a credible alternative, document confounding changes, and set quality guardrails before seeing results. A bounded decision may stop, repeat, narrow or advance the proposal. Operating evidence later revisits the same claim. This is a proposed author-synthesis map, not an achieved benefit.

Figure 5.2 — Qualified impact and effort matrix

Compare impact and effort only within the stated assumptions, evidence and decision context. Position is a qualified prioritization aid, not an automatic investment approval.

View Figure 5.2

A qualified portfolio discussion A sequencing aid within the existing investment process.

Prerequisites stay outside the comparison

Check permissible scope, data rights, authority, unacceptable consequences and essential controls before the next exposure. A position grants no operating permission.

Business Impact (defined locally)

Discussion and sequencing aid; no automatic verdict.

Quick Wins

High impact / Low effort

Prioritize bounded pilots that meet prerequisites. Demonstrate net value and guardrail performance against a credible alternative before scale.

Strategic Bets

High impact / High effort

Fund staged learning, dependencies and evidence milestones. Test decisive assumptions; define stop or redesign conditions.

Fill-ins / Tactical

Low impact / Low effort

Consider capacity, reusable capability and control/service benefits. Preserve opportunity cost and support burden.

Deprioritize / Drop

Low impact / High effort

Challenge, simplify, defer or terminate when unsupported. Check confidence, obligations, risk reduction, dependencies and alternatives before deciding.

Business impact axis: High / Low

Implementation effort axis: Low / High

Implementation Effort / Complexity (defined locally)

Keep the full five-dimension profile

Business Impact; Technical Feasibility; Data Readiness; Strategic Fit; Implementation Effort / Time-to-Value. Record basis, evidence status, confidence, owner and next evidence. Unknowns remain visible; any numerical rubric and weights are local.

Figure 5.3 — Initiative investment verdicts

An initiative investment disposition depends on its bounded case, evidence and conditions. A verdict is not a product release, legal conclusion or proof of achieved benefit.

View Figure 5.3

At a recorded investment checkpoint Four investment outcomes within the existing lifecycle.

Evidence and decision context

Scope, stage and actual exposure; alternatives and sourcing route; prioritization profile, confidence and limits; proposed resource commitment.

Permissible scope and prerequisites

Check use/data rights, authority, unacceptable consequences and essential controls. Monitoring cannot replace missing pre-exposure controls.

- informs
- constrains

A competent decision owner records one verdict

Scope/version and exposure; evidence and limits; rationale and delegation; conditions/owners; funding/capacity; checkpoint/expiry and escalation.

one verdict Record one of four verdicts; no automatic transition.

Continue and Monitor

Bounded, permissible activity. Name questions, observation period and measures; owner and budget; stop triggers and next checkpoint. Extensions need a recorded basis and progress.

Scale

Define the expansion and its evidence. Fund control, support and fallback capacity. Funding approval is distinct from use/release approval, deployment and operating acceptance.

Pause

Define what stops and what may continue under existing authority. Preserve state/evidence; name restart criteria, owner, funding and review/expiry. Portfolio pause does not implement service containment.

Terminate

Pre-operation: close commitments and disposition assets/records. Operating service: controlled retirement (26.7-26.8), transition and residual duties.

Act on the recorded verdict

- Continue / Scale / Pause: conditions and dated/triggered review; no new operating authority.
- Terminate: closure/retirement, records and residual duties; no automatic return.

Figure 6.1 — A specified use has an explicit boundary

A specified use has an explicit boundary. Four response reasons require distinct handling; material boundary change reopens the affected decision.

View Figure 6.1

Specified use

Population / task

Question: Who may use it, and for what task?

Data / knowledge

Question: Permitted sources, routes, exclusions and freshness.

Decision / authority

Question: What it may influence, decide or do; enforced permissions.

Acceptance / evidence

Question: Claims, tests, failure conditions, limits and decision owner.

Responses

1 · Prohibited use

Response: Stop, record and escalate as required. The use is explicitly excluded.

2 · Lawful out-of-scope use

Response: Assess scope separately. Lawfulness alone does not authorize this product use.

3 · Permitted task; insufficient evidence

Response: State the limitation and use authorized support. Do not silently authorize unsupported work.

4 · Permitted task; temporarily unavailable

Response: Use an authorized contingency or restriction. An outage is not a prohibition.

Reentry: Material population, authority, data or provider change reopens the affected decision before expansion; no response silently extends permission.

Figure 7.1 — Classification determines the review route

Apply institutional review rules to each bounded use. Legal classification remains separate; unresolved findings hold the affected permission or release.

View Figure 7.1

Text equivalentDefine the bounded use. If incomplete, clarify and hold the affected decision.Check customer consequence, sensitive information, critical-service dependency, external communication, action authority and locally approved triggers.With no relevant trigger, apply the local baseline review; with a trigger, retain the baseline and refer to the relevant domain specialists. No preset classification result follows.Record the scoped decision, authority, limits, conditions and revisit triggers.At any stage an unresolved prohibition, authority question or material evidence gap holds the affected permission or release while other work may continue. Legal applicability is separately assessed.

Figure 8.1 — Separate preparation, challenge and authority

Preparation, accountable decision authority and locally scoped challenge remain separate. Role labels are illustrative and require actual institutional delegation.

View Figure 8.1

Decision: Fund a bounded use

Prepares the evidence: Business and product owners

Proposed decision authority: Delegated investment authority

Required challenge to scope locally: Finance, risk and affected operations

Decision: Classify the use and route required reviews

Prepares the evidence: Product and risk representatives

Proposed decision authority: Authority defined by classification policy

Required challenge to scope locally: Legal/regulatory and affected specialists

Decision: Permit data and knowledge use

Prepares the evidence: Data owner with product team

Proposed decision authority: Authority designated by data policy

Required challenge to scope locally: Privacy/legal, security and records

Decision: Set action and tool permissions

Prepares the evidence: System and security owners

Proposed decision authority: Delegated authority for the target service

Required challenge to scope locally: IAM, operational risk and business owner

Decision: Accept evaluation evidence

Prepares the evidence: Evaluation lead and asset owners

Proposed decision authority: Designated assurance or validation authority

Required challenge to scope locally: Independent domain challenge as applicable

Decision: Accept a provider, model or material configuration change

Prepares the evidence: Change owner with product and system owners

Proposed decision authority: Designated change/release authority

Required challenge to scope locally: Evaluation, security, resilience and affected domains

Decision: Release the assembled product

Prepares the evidence: Product and system owners

Proposed decision authority: Authorized release/risk decision holders

Required challenge to scope locally: Unresolved domain findings and conditions

Decision: Decide customer remediation

Prepares the evidence: Conduct/complaints and business owners

Proposed decision authority: Authority defined by remediation policy

Required challenge to scope locally: Legal, operations, finance and risk as applicable

Decision: Grant a bounded exception

Prepares the evidence: Owner of the affected control

Proposed decision authority: Authorized risk-acceptance role

Required challenge to scope locally: Relevant specialist; no self-approved waiver

Decision: Withdraw or restrict operation

Prepares the evidence: Operations with incident/control owners

Proposed decision authority: Predelegated intervention authority

Required challenge to scope locally: Escalation and subsequent accountable review

Decision: Retire the product and dispose of retained material

Prepares the evidence: Product, operations and records owners

Proposed decision authority: Designated retirement authority

Required challenge to scope locally: Legal/privacy, security, data and service owners

Figure 8.2 — Legal review across the AI lifecycle

Define scope, map applicable obligations, demonstrate controls and record the disposition. Unmet conditions require a hold or restriction and escalation; changes reopen affected review. This author-developed workflow does not establish a universal legal approval procedure.

View Figure 8.2

Reading order: Read stages 1–4 down the page. The two lower panels state unmet-condition and reassessment duties that apply across the workflow.

Stage	Required content
1 Define the scope	Bank entity, service and customer impact; jurisdictions, data flows and providers; AI purpose, role and operating release. The output is scope and applicability.
2 Map applicable obligations	Sector duties, records and service criticality; privacy, secrecy and cross-border constraints; customer decisions, remedies and AI classification. Record source version, scope and effective date. The output is applicable duties.
3 Demonstrate the controls	Data and customer-protection evidence; provider terms and tested exit capability; model, security and operational evidence; open gaps, compensating controls and owners. The output is evidence and open gaps.
4 Record the disposition	Named legal, risk and release decision owners; external approval or notification where required; permitted scope, conditions and unresolved gaps. Proceed only within applicable duties and authority.

Cross cutting duties

- If a required condition is unmet: hold or restrict the affected use and escalate the gap. Document the reason, remediation and next review.
- Reassess when model, purpose, data location, terms or law changes, or when an incident, fallback or exit changes the operating facts.
- Review may run in parallel; required evidence and authority still apply. Reassess the affected scope. Emergency containment follows existing authority.

Qualification: Author synthesis of a proposed banking-specific review workflow, not a universal legal approval procedure.

Figure 10.1 — Entitlement must precede context assembly

A source becomes context only after provenance and entitlement checks. Withdrawal must be traced through derived material and affected releases.

View Figure 10.1

Text equivalentAuthoritative source: Owner · effective period · permitted audienceIngest, transform, index: Provenance · release identity · derived copiesRetrieve with entitlement: Authenticate subject and purpose before contextAssemble and generate: Separate untrusted content from instructionDisplay support: Passage, status, conflict and limitsA withdrawn policy must cease influencing new answers across source, chunks, embeddings, caches and citations, with affected indexes and release versions identified. Access is enforced at retrieval for the authenticated subject and approved purpose. Retrieved text is untrusted content, not instruction authority. If authoritative sources conflict, route to the owner or narrow the claim rather than invent a reconciliation. This is a design proposal, not evidence that a control operates.

Figure 12.1 — A manifest for the model-supply decision

Thirteen manifest fields organize the model-supply decision. Field groups aid navigation; no provider values are assumed.

View Figure 12.1

Display index	Literal source field
Identity / acquisition (proposed)	
01	model or service
02	provider
03	version or immutable reference where available
04	acquisition path
05	license and use constraints
Execution boundary (proposed)	
06	execution location
07	data-handling boundary
08	safety or filtering configuration
09	known limitations
Change / continuity (proposed)	
10	update policy
11	vulnerability/incident contact
12	subdependencies available to the bank
13	exit route

Figure 13.1 — Authorize the exact action candidate

Request, proposal, validation, authorization, submission and receiving-system confirmation are separate steps. The model cannot authorize its own proposal.

View Figure 13.1

Text equivalentRequest: User objective; no action authorized.Prepare: Model proposes typed fields and cited support.Validate: Check schema, object, limits and current data.Authorize: Policy or accountable person binds exact candidate.Submit: Identified tool uses an idempotency key.Confirm or reconcile: Receiving system result determines state.The policy service authenticates and authorizes the exact action; human approval is risk triggered when required. Denial, lost entitlement, changed candidate, expiration or failed validation stops execution and routes to repair, escalation, fallback or stop. A tool response, not the model narrative, determines whether an action was confirmed, failed or unresolved. This is a risk-triggered pattern, not a universal per-action approval mandate.

Figure 14.1 — Agent autonomy stays inside granted authority

Planning, permission and execution remain distinct inside granted authority. Memory and takeover require governed state, clear provenance and reconciliation.

View Figure 14.1

Text equivalentObjective: Task and completion condition boundedPlan: Proposal within policy and resource limitsPermission: Separate tool, object, time and value scopeExecution: Validate, record and recover where feasibleMemory is governed data with purpose, source, sensitivity, scope, expiry and correction path. A takeover record distinguishes completed actions, proposed unexecuted actions, locks, valid approvals and uncertain side effects for reconciliation. Pause alone does not revoke credentials or drain queued actions; the institution must design containment for its actual service. No agent can grant another authority it lacks.

Figure 15.1 — Permission bands are separately granted

Each permission band carries its own boundary and evidence. Promotion is separately authorized through normal production controls.

View Figure 15.1

Band: Explain

Capability: read a bounded code selection and produce an explanation

Minimum boundary: approved repository/data policy; no secret or production access

Additional evidence when promoted: tool and model identity where the output informs a material decision

Band: Propose

Capability: generate code, tests or documentation without writing the workspace

Minimum boundary: treat output as untrusted contribution

Additional evidence when promoted: prompt/context provenance, review and test result

Band: Edit

Capability: modify files in an isolated branch or workspace

Minimum boundary: scoped file access; change diff; no merge authority

Additional evidence when promoted: machine-generated change markers where policy requires, reviewer identity

Band: Execute

Capability: run approved commands in an isolated development environment

Minimum boundary: command allowlist or sandbox, network/secret restrictions, resource budget

Additional evidence when promoted: command and result log; dependency changes; security findings

Band: Submit

Capability: open a change request or pull request

Minimum boundary: service identity and branch protection

Additional evidence when promoted: link proposal to reviewed diff and CI evidence

Band: Promote

Capability: merge, deploy or change infrastructure

Minimum boundary: separate release authority and normal production controls

Additional evidence when promoted: approval, artifact identity, environment and rollback evidence

Figure 16.1 — An evaluation conclusion needs an argument

Cases, measures and predefined rules jointly support exact-candidate evidence. The conclusion records limitations, residual risk, an owner and a re-evaluation trigger.

View Figure 16.1

Text equivalentState the exact claim, use, population and conditions.Include ordinary, boundary, rare, adverse and prohibited cases.Predefine measures or rubrics for material outcomes and decision rules for hard failures and uncertainty.Record results for the exact candidate configuration.Conclude with limitations, residual risk, owner and re-evaluation trigger.The source has seven connected elements; the visual groups some of them for reading. A passing average does not erase a hard failure. This is original author synthesis requiring statistical and domain review before institutional use.

Figure 18.1 — Locate the control; record the observed test

These are proposed threat-to-control-to-test links. Record the control's location and the observed result separately; no control effectiveness is asserted.

View Figure 18.1

Threat path	Control / response	Test / evidence
Untrusted policy text or uploaded content	Source approval; provenance and labels	Indirect-injection case; source identity recorded
Restricted retrieval or tool request	Retrieval entitlement; receiving tool policy	Unauthorized arguments; denial/trace inspection
Residual behavior or disclosure	Contain affected path; preserve bounded trace	Exposure search; recovery and retest

Figure 19.1 — Oversight must be capable of changing an outcome

Information, competence, practical power and recourse are separate oversight obligations. Jurisdiction-specific rights require qualified determination.

View Figure 19.1

Design task	Needed capability	Evidence or decision caveat
Meaningful oversight	Competent, authorized person has information, time and practical ability to reject, stop or correct.	Observe skipped review, override and workload; a click is not proof of effectiveness.
Challenge outcome	Preserve decision reference, relevant reasons and human review route for a person contesting an outcome.	Applicable rights and notice route require qualified jurisdiction-specific determination.
Escalate disagreement	Give the reviewer power to escalate or change a consequential outcome.	Record disagreement, decision authority and conditions rather than treating presence as oversight.
Correct and redress	Identify affected downstream messages, cases and records; propagate necessary correction.	Determine notice and remedy under applicable legal and conduct processes; record unknowns.
Assess the whole product	Keep privacy, fairness, explanation and human oversight as separate claims.	An explanation, human review or privacy measure does not establish the other claims.

Figure 20.1 — Say precisely which status the evidence supports

Each status supports a bounded assertion with an explicit inference limit. No later state, broader scope or future effectiveness follows automatically.

View Figure 20.1

Status	What may be asserted	What may not be inferred
designed	control or product behavior is specified	implemented or testable
implemented	mechanism exists in the candidate	correctly configured or effective
tested	scoped method produced a result	complete coverage or independence
independently challenged	qualified reviewer reached a recorded conclusion	management approval or runtime effectiveness
approved	authority permits a bounded release, perhaps with conditions	deployed, operating, safe, compliant, or effective
deployed	configuration is present in an environment	exposed to users or operating as approved
operating	service is processing within a stated exposure	controls effective over an assessed period
effective for assessed period	defined evidence supports a scoped conclusion	future effectiveness or broader scope

Figure 21.1 — Approval, deployment and operation are different states

Candidate, evaluated, approved, deployed and operating remain distinct. Each transition needs evidence and authority. Rollback and fallback are different recovery routes; affected messages, records and downstream actions still require impact assessment and remedy.

View Figure 21.1

Text equivalentA candidate is evaluated for its bounded use.An accountable decision may approve a release with conditions.Deployment installs a configuration, while operation identifies the actual exposed state; none of these states is automatic.Progressive exposure names cohort, owner, criteria and stop route.Rollback restores a prior approved configuration only where each dependency can revert. Fallback is a separately approved alternative service with capacity, communication and reconciliation.Rollback or fallback may stop new harm, but neither corrects already sent messages, changed records or downstream actions. Those require impact assessment and remediation. This diagram proposes no universal rollout percentage.

Figure 22.1 — Make every operating signal actionable

A signal needs interpretation, an accountable owner, a local intervention condition, action and an evidence record. Monitoring alone does not establish effectiveness.

View Figure 22.1

Text equivalentObserve a runtime signal across service, behavior or control.Interpret it using a defined measure tied to the operating release, with privacy limits.Name the accountable owner who can interpret and act.Apply a locally approved threshold, severity or hard event; no universal value is implied.Decide whether to investigate, restrict, stop or fall back.Record intervention, evidence and closure, and reassess on material change or incident.Monitoring alone does not establish control effectiveness. The dashed return is conditional re-entry, not automatic retraining or automatic approval.

Figure 23.1 — Restore service and remedy harm on separate tracks

After containment, technical repair and customer or record remediation proceed on separate tracks. Both inform a new accountable operating decision.

View Figure 23.1

Text equivalentDetect and triage actual release, time, affected population, current exposure and uncertainty.Contain the narrowest effective path, preserve evidence and reconcile initiated or queued actions.In parallel, investigate and correct the technical or provider chain; assess people and records by exposure, reliance, harm and remedy, recording unknowns. Qualified legal and conduct roles decide any notice or redress under applicable jurisdiction.Require a new accountable operating decision linked to corrected dependency, regression evidence, impact reconciliation, conditions and renewed monitoring before return.Learn and update scenarios without overwriting the prior decision record.Availability restoration alone does not close customer or record remediation; this fictional control path does not establish actual effectiveness.

Figure 25.1 — Different services can share one failure domain

Two illustrative service paths may share one failure domain. Continuity and exit require distinct preparations; no actual bank dependency is asserted.

View Figure 25.1

Text equivalentTwo illustrative service paths may appear diversified yet share a provider, cloud, base model, identity service, region, network, package or specialist team. The map asserts no actual bank dependency; inventory and scenario evidence must establish the common failure domain. Continuity sustains the service during disruption through an approved route and exercised capacity. Exit migrates away from a dependency through data and records access, integration change, substitute selection, behavioral re-evaluation and contractual or legal disposition. A written exit plan is not proof of an exercised exit; provider assertions, bank tests and observed operation remain different evidence classes.

Figure 25.2 — Legal rights, provider terms and exit capability

Legal rights, provider terms and exit capability. Seven unscored review themes separate actual terms, capability evidence and illustrative ownership.

View Figure 25.2

Review theme: Service availability

Terms and constraints: Notice, suspension and deprecation terms; emergency support limits

Proof of capability: Exercise sudden access loss and provider non-cooperation; validate the safe service route

Suggested ownership: Service owner; procurement; continuity

Review theme: Data and confidentiality

Terms and constraints: Permitted purpose, training reuse, locations, subprocessors and lawful transfers

Proof of capability: Map data flows; enforce access and purpose limits; test recoverable records

Suggested ownership: Data owner; privacy; legal

Review theme: Licences and portability

Terms and constraints: Rights to use and move code, prompts, outputs and other assets; third-party limits

Proof of capability: Inventory assets; test export or rebuild; do not assume transferable model weights

Suggested ownership: Legal; engineering; records

Review theme: Oversight and changes

Terms and constraints: Information, audit and supervisory access; model and subcontractor change terms

Proof of capability: Retain usable evidence; reassess material changes and missing access

Suggested ownership: Risk; assurance; legal

Review theme: Termination and transition

Terms and constraints: Exit rights, assistance, fees, notice and realistic transition commitments

Proof of capability: Test planned and stressed routes; qualify replacement; authorize cutover

Suggested ownership: Service owner; operations; legal

Review theme: Closure and residual duties

Terms and constraints: Return or deletion, lawful retention, liabilities, disputes and continuing duties

Proof of capability: Verify access revocation and data disposition; keep evidence and remedies owned

Suggested ownership: Records; legal; service owner

Review theme: Complaints and financial institution rights

Terms and constraints: Customer complaints, redress and legal challenge; financial institution defence, provider remedies and dispute terms

Proof of capability: Trace the decision and release; test complaint handling, lawful evidence preservation and claims support

Suggested ownership: Complaints owner; legal; records; service owner

Qualifications

- Contract rights alone do not prove a feasible fallback or exit. Financial institution defence and provider claims do not override customer rights.
- Preservation, retention, disposal and disclosure follow applicable duties and authority.
- Privilege is a separate fact- and jurisdiction-dependent protection assessed by competent counsel; lack of privilege does not remove lawful preservation duties.
- Scope and enforceability depend on actual entity, contract, jurisdiction and evidence. This matrix does not establish compliance or universally mandatory clauses.

Figure 25.3 — AI disruption and business continuity

When the AI path is unavailable, activate contingency and assess a lawful, approved and capable service route. Resume only through the recovery gate and authorization; keep backlog, remedies and any exit decision owned.

View Figure 25.3

Reading order: Start at the unavailable AI path, follow the safe-route branches, then read the recovery gate and its return loop.

Ordered flow

- Trigger: the AI path is unavailable because of withdrawal, outage or unsafe use.
- Activate contingency under named authority: contain AI actions and preserve release and incident evidence. Assess the route.
- Safe route available — YES: continue priority service through an approved non-AI or degraded route. Manage staffing, queue and customer updates; track capacity and remaining tolerance.
- Safe route available — NO, or a continuing route fails: restrict affected service. Escalate unmet obligations and impact; use safe actions and seek remedy. Do not make an unapproved substitution.
- A ready route or the restricted-service route leads to the recovery gate: establish evidence and reconciliation, and decide whether return is authorized.
- Recovery gate — YES: resume the approved service using the exact operating release and monitor it. Backlog and remedies remain owned.
- Recovery gate — NOT READY: retain current controls through safe fallback or restriction. Reassess impact, capacity and options; reassessment returns to the recovery gate.

Qualification: A safe route is lawful, approved and capable within the service tolerance. Persistent loss may trigger exit alongside continuity; see Figure 25.4. Protect the banking service without silently substituting an unqualified model.

Figure 25.4 — Planned and stressed AI exit readiness

Planned and stressed entry routes lead through feasible exit, replacement qualification, controlled transition and dependency closure. Readiness and applicable authorization govern progression; continuity and residual duties remain owned.

View Figure 25.4

Entry routes

- Planned / non-stressed: a commercial, performance or strategic decision; prepare the transition while lawful access remains available.
- Forced / stressed: withdrawal, restriction or unmanageable disruption; activate continuity immediately and do not assume notice or provider cooperation.
- Either entry requires readiness assessment. Continuity remains active through transition.

Stage: 1 Feasible exit route

Decision: Lawful viable route, or restrict and escalate

Evidence: Rights, costs, capacity; common failure domains

Owner / output: Business and risk owners: approved exit approach

Stage: 2 Qualify replacement

Decision: Replacement fit for its claim; assets recoverable / rebuildable

Evidence: Model / workflow tests; data, state and portability limits

Owner / output: Assurance and service owner: qualified route, recorded gaps

Stage: 3 Controlled transition

Decision: Authorize cutover only when readiness evidence is sufficient

Evidence: Release and reconciliation; lawful recovery path, monitoring

Owner / output: Release and operations owners: controlled transition records

Stage: 4 Close dependency

Decision: Close access and contracts; preserve residual obligations

Evidence: Revocation, data disposition, retained evidence, owned remedies

Owner / output: Service and records owners: verified closure and open duties

Transition conditions

- 1 → 2: only a viable lawful route proceeds to qualification.
- 2 → 3: qualification and readiness evidence and applicable approvals are required before transition.
- 3 → 4: verify transition and residual-duty ownership before recording closure.
- Hold at any stage: retain safe continuity or restriction, escalate and reassess.
- Preparation may run in parallel; cutover requires readiness and explicit authorization. Dual running or rollback requires lawful access and feasibility.

Qualification: Prepare before dependence and activate the applicable route without transferring model approval. The workflow does not promise provider cooperation, a qualified substitute or a completed exit.

Figure 26.1 — A change must remain inside an approved envelope

Assess cumulative change against the approved envelope. Continued operation needs a renewed decision; retirement is a separate controlled outcome.

View Figure 26.1

Text equivalentIdentify the changed software, model, data, corpus, prompt, policy, tool, provider or workflow dependency and the affected approved product claim. If inside an actually approved change envelope, run targeted regression, release control and cumulative-change review. If outside, reclassify the affected use or authority and seek wider evaluation and renewed approval. Both routes need an attributable operating decision before continued operation. Alternatively a retirement decision closes access and integrations, handles queued actions and retained or deleted evidence under policy, verifies decommissioning and preserves prior decisions and incident obligations. No small-change label automatically avoids reassessment.

Figure 27.1 — Accountability stays with named roles

Executive accountability sits above parallel ownership, challenge and independent assessment roles. Shared evidence references transfer neither source custody nor decision authority.

View Figure 27.1

Text equivalentExecutive decisions and accountability remain explicit. Business, product, platform, and operations own and operate the product. Risk, compliance, security, and independent validation set policy and challenge as applicable under local policy. Internal audit independently assesses and is not an ordinary release approver. A federated evidence and issue record links decisions, releases, providers, exceptions, and incidents to the systems that hold authoritative records; a central index does not assume custody of every item. The picture does not prescribe one universal organization, independent validation allocation, committee, staffing level, or reporting hierarchy. The first line may supply evidence, while producer, content owner, custodian, challenger, and decision owner remain separately defined roles.

Figure 28.1 — Build the dossier from one challenged event

Reconstruct one operating event through protected pointers to approved basis, actual path and later history. Missing evidence remains a finding.

View Figure 28.1

Text equivalentBegin with a specific operating event, complaint, challenge or decision and resolve the authenticated subject, product and release, input/source identity, policy decision, proposed versus actual action, approval and result. Follow protected federated index pointers backward to intended use, evaluation and approval, then forward to incident, remediation, change and closure. The index can store authorized links rather than copying sensitive source records. Missing or inaccessible evidence becomes a finding. A complete index is not by itself evidence of control effectiveness.

Figure 28.2 — An executive view should lead to a decision

Seven literal tile definitions connect executive attention to underlying evidence. They are specifications, not measured portfolio values or scores.

View Figure 28.2

Tile	Decision-oriented definition	Drill-down
exposure	products and releases by use, authority, consequence, population and jurisdiction	product charter, classification and operating release
decisions due	conditions, exceptions, periodic reviews and provider changes approaching decision dates	owner, evidence outstanding, impact of delay
severe findings/incidents	open material findings and incidents by affected service/population	containment, remediation, customer/record impact, next decision
evidence health	releases missing required identity, lineage, evaluation or operating evidence	exact missing record and responsible owner
third-party concentration	products sharing critical provider/failure domain and untested exits	dependency map and scenario result
value and outcome	status of the approved value hypothesis with cost, service and harm measures	definition cards, denominators, uncertainty and owner
workforce/review capacity	qualified review and remediation demand versus available capacity	queue, aging, conflicts, bottleneck and action

Figure 30.1 — Carry the policy assistant's evidence through change

Fictional Trace A illustrates bounded knowledge support and governed change.

View Figure 30.1

Internal policy assistant: Approved internal policy → an entitled employee's supported answer. No customer message, record change or exception approval.

Exact release identity: Entitlement · corpus/index · ranking · model · prompt · application · policy

Evaluation and conditional authority: Coverage, support, refusal, entitlement and usability; hard failures retain their force.

Source withdrawal: Invalidate, rebuild and run targeted regression; retain source-withdrawal and evidence-link conditions.

Use changes require re-entry: Customer communication, record updates, a new jurisdiction or persistent memory → assess a new use.

Reading route

- Exact release identity → Evaluation and conditional authority
- Evaluation and conditional authority → Source withdrawal

Glossary

Acceptance criterion — Observable condition used to decide whether a stated product claim is supported for a defined use.

Affected population — People, cases, accounts, transactions or services that may experience a product's output or action.

Agentic system — In this book, a system that can pursue a goal through multiple steps, select tools or actions, retain relevant state and exercise bounded delegated discretion.

AI application — Software assembly that integrates one or more AI components with workflow, data, interfaces, tools and controls.

AI product — Governed banking service comprising purpose, users, workflow, software, data, models, tools, people, dependencies, controls, operation and evidence.

AI system — Context-dependent term for an assembled AI-enabled system; this book governs the full product boundary, including workflow, people, software, permissions, providers, operation and evidence. Legal definitions retain their instrument-specific scope.

AI-assisted engineering — Use of AI to explain, generate, review, test or modify software and infrastructure; distinct from engineering a product whose delivered capability includes AI.

Assurance evidence — Evaluation, review, test, challenge or validation evidence used to support a decision.

Authority boundary — Limit on what a user, workload, model, agent, tool or workflow may influence, decide or execute.

Author synthesis — Framework or pattern developed for this book; sources may support constituent concepts without validating the synthesis.

Behavioral dependency — Model, data, prompt, corpus, index, policy, tool or configuration that can alter product behavior.

Bounded automation — Repeated action permitted inside a preapproved, machine-enforced envelope with monitoring, intervention and recovery.

Calibration — For predicted probabilities, agreement with observed event frequencies in a defined population under a specified assessment method. Calibration of measurements or other scores requires its own definition. Fluent or confident generated prose is not itself a calibrated probability.

Candidate release — Identified configuration proposed for evaluation and possible approval.

Change envelope — Preapproved boundary within which defined changes may follow a reduced but explicit evidence and approval route.

Claim — Specific proposition about purpose, behavior, control, quality, operation or outcome that evidence is intended to support.

Component evaluation — Assessment of an individual model or other component under stated conditions.

Condition — Enforceable restriction attached to a decision, with an owner, evidence due and expiry or review trigger.

Control drift — Divergence between approved control design and current implementation or operation.

Control intensity — Depth of evidence, review, constraint, monitoring, recovery and approval proportionate to the product's risk drivers.

Control plane — Logical concern that distributes identity, policy, configuration, approvals and release constraints.

Criticality — Importance of a service, process or dependency to the institution under its own policy and applicable framework.

Data drift — Material change in data distribution, quality, meaning, provenance or use relative to an approved baseline.

Decision evidence — Record of purpose, scope, classification, approval, condition, exception and accountable authority.

Delegated authority — Institutional permission granted to a person, workload or system to make or execute a bounded decision or action.

Deployed configuration — Release installed in an environment; deployment alone does not mean operation is approved or accepted.

Evidence bundle — Connected set of decision, implementation, assurance, operation and change records for a product and release.

Evidence gap — Material information that cannot be supplied responsibly without additional data, source access, decision or expertise.

Evidence plane — Logical concern that connects product/release identity with decisions, versions, tests, runtime events, incidents and changes.

Exception — Explicit, bounded and time-limited deviation from a requirement, with alternative treatment, owner and closure route.

Fallback — Approved alternative service path used when the AI-enabled path cannot or should not continue.

Failure domain — Boundary within which a fault can propagate or create correlated disruption.

Human-in-the-loop — Pattern in which a person is in the path of a specific action; the label does not establish meaningful oversight.

Human-on-the-loop — Pattern in which a person monitors and can intervene in bounded automation; adequacy depends on real authority and operating conditions.

Impact tolerance — Under an applicable operational-resilience framework, a business-service boundary for maximum tolerable disruption; not synonymous with component RTO.

Implementation evidence — Record of architecture, code, data, model, prompt, configuration, tool, build and dependency state.

Independent challenge — Review by a party with sufficient competence, evidence access and freedom from incentives to change an adverse conclusion.

Knowledge drift — Material change in relevance, correctness, currency, coverage or entitlement of knowledge used by a product.

Manifest — Versioned inventory of behavior-shaping components and configuration associated with a candidate or approved release.

Materiality — Institutional or regulatory significance assessed under the applicable context; not a universal numeric threshold in this book.

Meaningful oversight — Human review supported by authority, time, competence, information, usable interface, alternative action and escalation.

Model — In this book, a learned component; the term is not intended as a universal legal or technical definition of AI.

Model drift — Material change in predictive or generative behavior relative to an approved expectation; teams should define method-specific usage.

Non-AI alternative — Credible process or design used as comparator, fallback or substitute rather than assuming AI is necessary.

Operating evidence — Runtime observations, control events, incidents, complaints, outcomes, exercises and service decisions linked to a release.

Operating service — Deployed configuration accepted for a bounded production use with an accountable service owner.

Product plane — Logical concern implementing the user and business workflow.

Prohibited use — Use expressly disallowed by law, institutional policy or the release boundary. A lawful unsupported task can instead be out of scope; missing evidence is unsupported; a failed dependency can make a permitted task temporarily unavailable. The applicable response is recorded separately.

Proposition support — Assessment of whether a cited source passage entails a material statement under the relevant scope and date.

Proposed control — Design option presented for consideration; not evidence that a control is implemented or effective.

Release identity — Stable identifier for the exact approved configuration and its linked evidence.

Re-entry trigger — Change, incident, drift, exception, outcome or time/event condition that returns a product or claim to review.

Retrieval-augmented generation (RAG) — Pattern in which external material is retrieved and supplied as context for generation; it expands source, entitlement and evaluation boundaries.

Risk-triggered control — Control or review required when a defined product characteristic or consequence crosses an institutional condition.

RPO — Recovery point objective: targeted maximum data-loss interval for the recoverable state in scope. Zero targets no loss; intentionally disposable state may have no recovery requirement.

RTO — Recovery time objective: target time to restore a service or capability after disruption.

Severe failure — Outcome defined in advance as release-blocking, stop-triggering or requiring escalation regardless of average performance.

Trust boundary — Point where assumptions about identity, data, control or responsibility change.

Validation — Review of conceptual basis, evidence and use by an appropriately independent function within its defined scope; not synonymous with testing.

Workload identity — Identity assigned to software or automation so receiving services can authorize the actual caller rather than trusting model text.

Bibliography

B01. National Institute of Standards and Technology. Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST AI 100-1, 26 January 2023. https://doi.org/10.6028/NIST.AI.100-1. Voluntary cross-sector framework.

B02. National Institute of Standards and Technology. *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile.* NIST AI 600-1, July 2024. https://doi.org/10.6028/NIST.AI.600-1. Voluntary profile; not a certification or banking rule.

B03. National Institute of Standards and Technology. *AI RMF Playbook.* https://airc.nist.gov/airmf-resources/playbook/. Live voluntary resource current as at 22 September 2026; not a certification or banking rule.

B04. National Institute of Standards and Technology. *Secure Software Development Framework Version 1.1.* NIST SP 800-218, February 2022. https://csrc.nist.gov/pubs/sp/800/218/final. Final publication; cross-sector and not a complete banking AI control system.

B05. National Institute of Standards and Technology. *Secure Software Development Framework Version 1.2.* NIST SP 800-218 Rev. 1 Initial Public Draft, 17 December 2025. https://csrc.nist.gov/pubs/sp/800/218/r1/ipd. Draft only; comment period closed 30 January 2026.

B06. European Union. *Regulation (EU) 2024/1689*, original Official Journal text, 13 June 2024. https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng. Retained for historical provenance; use B07 for current consolidated-text references.

B07. European Union. Consolidated text: Regulation (EU) 2024/1689, consolidation date 27 July 2026. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:02024R1689-20260727. Documentary consolidation with no independent legal effect; underlying regulations are binding within their phased actor/system/territorial scope.

B08. European Commission. AI Act: regulatory framework. https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai. Official implementation and timing context inspected 8 October 2026; not a substitute for the controlling legal acts or applicability review.

B09. Bank of England, Prudential Regulation Authority. *Model risk management principles for banks (SS1/23).* Current version published and effective 23 April 2026. https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss. Applies only within its stated firm and model scope.

B10. Board of Governors of the Federal Reserve System, Federal Deposit Insurance Corporation, and Office of the Comptroller of the Currency. *Model Risk Management: Revised Guidance.* 17 April 2026; OCC Bulletin 2026-13. https://www.occ.gov/news-issuances/bulletins/2026/bulletin-2026-13.html. Risk-based, non-enforceable guidance; expressly excludes generative and agentic AI.

B11. Basel Committee on Banking Supervision. *Principles for Operational Resilience.* 31 March 2021. https://www.bis.org/publications/202103-guidelines-principles-operational-resilience. Current international principles; not AI-specific and not directly binding in every jurisdiction.

B12. Basel Committee on Banking Supervision. *Digitalisation of finance.* 16 May 2024. https://www.bis.org/publications/digitalisation-finance. International analysis; not AI-specific in every proposition and not binding law.

B13. Basel Committee on Banking Supervision. *Principles for the sound management of third-party risk.* 10 December 2025. https://www.bis.org/publications/202512-guidelines-principles-sound-management-third-party-risk. Current international baseline allowing jurisdictional flexibility.

B14. Financial Stability Board. *The Financial Stability Implications of Artificial Intelligence.* 14 November 2024. https://www.fsb.org/2024/11/the-financial-stability-implications-of-artificial-intelligence/. Non-binding system-level analysis.

B15. Financial Stability Board. *Monitoring Adoption of Artificial Intelligence and Related Vulnerabilities in the Financial Sector.* 10 October 2025. https://www.fsb.org/2025/10/monitoring-adoption-of-artificial-intelligence-and-related-vulnerabilities-in-the-financial-sector/. Non-binding financial-sector monitoring perspective.

B16. U.S. Department of the Treasury. “Treasury Releases Two New Resources to Guide AI Use in the Financial Sector.” 19 February 2026. https://home.treasury.gov/news/press-releases/sb0401. Public-private practical-resource context; not law or supervisory guidance. Optional background; no substantive chapter claim relies on this entry.

B17. National Institute of Standards and Technology, National Cybersecurity Center of Excellence. *Software and AI Agent Identity and Authorization.* https://www.nccoe.nist.gov/projects/software-and-ai-agent-identity-and-authorization. Emerging project current as at 22 September 2026; not final guidance or a standard.

B18. Organisation for Economic Co-operation and Development. *Framework for the Classification of AI Systems.* 22 February 2022. https://doi.org/10.1787/cb6d9eca-en. Policy framework; not a banking control standard and not the book’s taxonomy.

B19. Sculley, D., et al. “Hidden Technical Debt in Machine Learning Systems.” *Advances in Neural Information Processing Systems 28* (2015). https://proceedings.neurips.cc/paper/2015/hash/86df7dcfd896fcaf2674f757a2463eba-Abstract.html. Peer reviewed; not banking-specific and predates foundation-model applications.

B20. Lewis, Patrick, et al. “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks.” *Advances in Neural Information Processing Systems 33* (2020). https://proceedings.neurips.cc/paper/2020/hash/6b493230205f780e1bc26945df7481e5-Abstract.html. Peer reviewed; does not define a complete enterprise governance architecture.

B21. Schick, Timo, et al. “Toolformer: Language Models Can Teach Themselves to Use Tools.” *Advances in Neural Information Processing Systems 36* (2023). https://papers.nips.cc/paper_files/paper/2023/hash/d842425e4bf79ba039352da0f658a906-Abstract-Conference.html. Peer reviewed; not a banking control standard.

B22. Holtzman, Ari, et al. “The Curious Case of Neural Text Degeneration.” *International Conference on Learning Representations* (2020). https://arxiv.org/abs/1904.09751. Peer-reviewed paper; research result, not a banking control standard.

B23. Yao, Shunyu, et al. “ReAct: Synergizing Reasoning and Acting in Language Models.” *International Conference on Learning Representations* (2023). https://arxiv.org/abs/2210.03629. Peer-reviewed paper; research results do not establish production controls.

B24. Mitchell, Margaret, et al. “Model Cards for Model Reporting.” *Conference on Fairness, Accountability, and Transparency* (2019). https://research.google/pubs/model-cards-for-model-reporting/. Peer reviewed; model-centered documentation does not assure a complete product.

B25. Parasuraman, Raja, and Victor Riley. “Humans and Automation: Use, Misuse, Disuse, Abuse.” Human Factors 39, no. 2 (1997). https://doi.org/10.1518/001872097778543886. Peer-reviewed historical source; no claim of a universal banking threshold. Optional background; no substantive chapter claim relies on this entry.

B26. Sterz, Sarah, et al. “On the Quest for Effectiveness in Human Oversight: Interdisciplinary Perspectives.” *ACM FAccT* (2024). https://arxiv.org/abs/2404.04059. Peer-reviewed work; accessible author preprint inspected; not banking-specific or a legal test.

B27. Goddard, Kate, Abdul Roudsari, and Jeremy C. Wyatt. “Automation Bias: A Systematic Review of Frequency, Effect Mediators, and Mitigators.” *Journal of the American Medical Informatics Association* (2012). https://doi.org/10.1136/amiajnl-2011-000089. Publisher abstract inspected; healthcare context and no universal banking threshold.

B28. National Institute of Standards and Technology. *Secure Software Development Practices for Generative AI and Dual-Use Foundation Models: An SSDF Community Profile.* NIST SP 800-218A, July 2024. https://doi.org/10.6028/NIST.SP.800-218A. Final official publication; augments SSDF v1.1 for producers of covered AI models and does not replace system-level, institution-specific controls.

B29. Monetary Authority of Singapore. “MAS Proposes Guidelines to Strengthen AI Risk Management in the Financial Sector.” 13 November 2025. https://www.mas.gov.sg/news/media-releases/2025/mas-guidelines-for-artificial-intelligence-risk-management. Historical 2025 consultation announcement; final guidelines issued 7 October 2026 are separately registered as B56.

B30. Parasuraman, Raja, Thomas B. Sheridan, and Christopher D. Wickens. “A Model for Types and Levels of Human Interaction with Automation.” *IEEE Transactions on Systems, Man, and Cybernetics—Part A* 30, no. 3 (2000): 286–297. https://doi.org/10.1109/3468.844354. Peer-reviewed human-automation framework; the book’s banking authority ladder is an adaptation, not a reproduction or validated consequence scale.

B31. National Institute of Standards and Technology. *Zero Trust Architecture.* NIST SP 800-207, August 2020. https://doi.org/10.6028/NIST.SP.800-207. Final cross-sector architecture publication; it does not prescribe the book’s AI planes or a bank-specific topology.

B32. National Institute of Standards and Technology. NIST Privacy Framework: A Tool for Improving Privacy through Enterprise Risk Management, Version 1.0. January 2020. https://www.nist.gov/privacy-framework. Voluntary final framework.

B33. National Institute of Standards and Technology. *Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations.* NIST AI 100-2 E2025, March 2025. https://doi.org/10.6028/NIST.AI.100-2e2025. Final cross-sector taxonomy with an official errata notice; not a bank control standard or claim of control effectiveness.

B34. National Institute of Standards and Technology. *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile.* NIST SP 800-61 Rev. 3, April 2025. https://doi.org/10.6028/NIST.SP.800-61r3. Final publication that supersedes Rev. 2; cybersecurity context, not an AI-specific banking rule.

B36. European Union. *Regulation (EU) 2022/2554 on Digital Operational Resilience for the Financial Sector (DORA).* Official Journal text. https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng. In force and applicable from 17 January 2025 within its scope; EU/EEA legal example, not a global requirement.

B38. European Commission. *Guidelines on transparency obligations for providers and deployers of certain AI systems under Article 50 of the AI Act.* Published 20 July 2026. https://digital-strategy.ec.europa.eu/en/library/guidelines-transparency-obligations-providers-and-deployers-ai-systems. Official implementation guidance with scope- and date-dependent obligations; not used to infer requirements outside Article 50.

B39. OWASP Foundation. *OWASP Top 10 for LLMs and GenAI Applications, 2025.* https://genai.owasp.org/llm-top-10/. Community-developed security guidance; not a regulator, formal standard or evidence that a control is effective.

B40. Board of Governors of the Federal Reserve System, Federal Deposit Insurance Corporation, and Office of the Comptroller of the Currency. *Interagency Guidance on Third-Party Relationships: Risk Management.* 6 June 2023. https://www.federalreserve.gov/frrs/guidance/interagency-guidance-on-third-party-relationships.htm. U.S. banking guidance within agency and institution scope; risk-based and not AI-specific.

B41. Bank of England, Prudential Regulation Authority. *SS1/21 Operational Resilience: Impact Tolerances for Important Business Services.* First published 29 March 2021, as updated. https://www.bankofengland.co.uk/prudential-regulation/publication/2021/march/operational-resilience-impact-tolerances-for-important-business-services-ss. UK scope-specific supervisory statement; not a global resilience definition.

B42. Bank of England, Prudential Regulation Authority. *SS2/21 Outsourcing and Third Party Risk Management.* First published 29 March 2021, as updated. https://www.bankofengland.co.uk/prudential-regulation/publication/2021/march/outsourcing-and-third-party-risk-management-ss. Applies to firms within its scope; requires current-source verification.

B43. Bank of England, Prudential Regulation Authority. *PS7/26 Operational Resilience: Operational Incident and Third-Party Reporting.* 18 March 2026. https://www.bankofengland.co.uk/prudential-regulation/publication/2026/march/operational-incident-and-third-party-reporting-policy-statement. UK scope- and implementation-specific reporting material; not a conclusion that any fictional incident is reportable.

B44. Monetary Authority of Singapore. *Technology Risk Management Guidelines.* January 2021. https://www.mas.gov.sg/-/media/MAS/Regulations-and-Financial-Stability/Regulatory-and-Supervisory-Framework/Risk-Management/TRM-Guidelines-18-January-2021.pdf. Singapore financial-sector guidance; current status and applicability require qualified confirmation.

B45. Monetary Authority of Singapore. *Guidelines on Outsourcing (Banks).* https://www.mas.gov.sg/regulation/guidelines/guidelines-on-outsourcing-banks. Singapore scope-specific guidance; current version and applicability require qualified confirmation.

B46. Consumer Financial Protection Bureau. *Consumer Financial Protection Circular 2022-03: Adverse Action Notification Requirements in Connection with Credit Decisions Based on Complex Algorithms.* 19 May 2022. https://www.consumerfinance.gov/compliance/circulars/circular-2022-03-adverse-action-notification-requirements-in-connection-with-credit-decisions-based-on-complex-algorithms/. Historical guidance withdrawn by CFPB on 12 May 2025. Withdrawal does not repeal Regulation B; use B57 for current adverse-action rule/interpretation and qualified U.S. applicability review.

B47. European Union. *Regulation (EU) 2016/679 (General Data Protection Regulation).* Official Journal text. https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng. Binding within its scope; applicability and national interaction require qualified legal analysis.

B48. Court of Justice of the European Union. *OQ v Land Hessen*, Case C-634/21, judgment of 7 December 2023. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=celex:62021CJ0634. Fact- and law-specific Article 22/scoring judgment; not a universal conclusion about all scoring.

B49. MITRE. *MITRE ATLAS.* https://atlas.mitre.org/. Living knowledge base for adversarial tactics and techniques involving AI-enabled systems; not a regulator or complete banking test standard.

B50. OWASP Foundation. *OWASP Top 10 for Agentic Applications 2026.* https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/. Community-developed, evolving security guidance; not a binding standard or evidence of effectiveness.

B51. Monetary Authority of Singapore. *AI Risk Management Toolkit: Operationalisation Handbook.* Project MindForge, published 20 March 2026. https://www.mas.gov.sg/-/media/mas-media-library/schemes-and-initiatives/ftig/project-mindforge/mindforge-ai-risk-management-operationalisation-handbook.pdf. Practical toolkit published during the consultation period; distinguish the later final guidelines B56 and their phased expectations.

B52. European Commission. AI Act — Regulatory Framework and Implementation Timeline. https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai. Alias of B08 for the same official page, retained to preserve existing citations. Explanation inspected 8 October 2026; B61/B07 distinguish controlling acts from documentary consolidation. Actual applicability requires legal review.

B53. National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0.* NIST CSWP 29, 26 February 2024. https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf. Voluntary cross-sector outcome framework; AI-specific workflows in this book are author synthesis, not a conformity certification.

B54. European Commission. *AI Act Service Desk: Articles 4, 26, 27 and 50.* https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-4; https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-26; https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-27; https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-50. Official presentation inspected on 7 October 2026, based on the 27 July 2026 consolidation. Authentic legal text and qualified applicability/commencement review control; neither a global rule nor legal signoff.

B55. National Institute of Standards and Technology. *NIST/SEMATECH e-Handbook of Statistical Methods, §7.2.4.1: Confidence intervals*, and *Dataplot: Exact Binomial.* https://www.itl.nist.gov/div898/handbook/prc/section2/prc241.htm; https://itl.nist.gov/div898/software/dataplot/refman2/auxillar/exacbino.htm. Technical reference inspected on 7 October 2026; one- and two-sided interval constructions differ. Coverage, independence and the use of uncertainty in a release decision require statistical/domain review.

B56. Monetary Authority of Singapore. *Guidelines on Artificial Intelligence Risk Management for Financial Institutions*, issued 7 October 2026, and accompanying release. https://www.mas.gov.sg/regulation/guidelines/guidelines-on-artificial-intelligence-risk-management-for-financial-institutions; https://www.mas.gov.sg/news/media-releases/2026/mas-sets-out-supervisory-expectations-on-responsible-ai-adoption-by-financial-institutions. Final supervisory guidelines: Sections 3–4 expectations from 7 October 2027, Sections 5–6 by 7 October 2028; jurisdiction/entity/use review required.

B57. Consumer Financial Protection Bureau. *Regulation B, 12 CFR §1002.9 Notifications*, including official interpretation, and *Withdrawn Guidance*. https://www.consumerfinance.gov/rules-policy/regulations/1002/9/; https://www.consumerfinance.gov/compliance/guidance/withdrawn-guidance/. Current rule/interpretation inspected 8 October 2026; Circular 2022-03 withdrawn 12 May 2025. U.S. scope and exceptions require qualified legal review.

B58. Institute of Internal Auditors. The IIA's Three Lines Model, 2020; updated September 2024. https://www.theiia.org/en/content/position-papers/2020/the-iias-three-lines-model-an-update-of-the-three-lines-of-defense/. Historical governance precedent, superseded by the 8 July 2026 Statement of Position (B60); not a mandatory banking organization chart.

B59. National Institute of Standards and Technology. *CSRC Glossary: Recovery Point Objective*. https://csrc.nist.gov/glossary/term/recovery_point_objective. Technical definition with source-specific context; applied recovery scope and local resilience rules remain institutional decisions.

B60. Institute of Internal Auditors. Three Lines Model: Assurance and Advice in Support of Effective Governance. Statement of Position, 8 July 2026. https://www.theiia.org/globalassets/site/resources/statements-of-position/tlm_assurance_advice_support_effective_gov_en.pdf. Introduction and Independence inspected 8 October 2026; professional governance position, not a universal legal mandate.

B61. European Union. Regulation (EU) 2026/1744 of 8 July 2026 amending Regulation (EU) 2024/1689; Official Journal, 24 July 2026. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32026R1744. Article 1(5), (39), (40) and Article 4: literacy wording, transition, high-risk dates and entry into force. Official HTML inspected 8 October 2026; authenticated OJ PDF/e-signature not independently verified; entity/use applicability remains open.

Index

Acceptance criterion

Definition — 471

Acceptance and failure conditions — 129, 132, 134

Affected population

Definition — 471

Incident reconstruction — 309, 310

Agentic system

Definition — 471

Delegation and consequential actions — 216, 217

Memory and coordination — 216

Objectives, plans, permission and execution — 215

Agentic systems — see Agentic system

AI application

Definition — 471

AI product

Definition — 471

Product and component boundaries — 25, 27, 48

AI system

Definition — 471

AI-assisted engineering

Definition — 471

Governed workflow and worked task — 230, 234

Assurance evidence

Definition — 471

Evidence classes — 50

Auditability

Design, operation and outcome — 359

Reconstruction and assurance — 357, 359

Author synthesis

Definition — 471

Authority boundary

Definition — 471

Governance and decision rights — 147, 151

Tools and external enforcement — 92, 207

Backpressure

Capacity and admission control — 313

Banking consequences

Critical services and accountability — 80, 81

Customers, conduct and financial consequences — 74

Behavioral dependency

Definition — 471

Behavioral assembly — 205, 209

Bounded automation

Definition — 471

Business continuity

Contingency plan — 325, 412

Continuity and exit — 325

Unavailable safe route — 330

Calibration

Definition — 471

Candidate release

Definition — 472

Release states and package — 286, 288

Capacity

Degraded operation — 316, 317

Worked capacity decision — 315, 318

Change

Accumulation and periodic review — 342, 343, 345

Controlled feedback and regression — 339

Requirements and product claims — 134, 338

Change envelope

Definition — 472

Boundary and classification — 338, 339

Claim

Definition — 472

Component evaluation

Definition — 472

Concentration

Correlated dependencies and fourth parties — 319, 335

Condition

Definition — 472

Conditional approval

Conditions and revalidation — 277, 278

Control drift

Definition — 472

Control intensity

Definition — 472

Control plane

Definition — 472

Cost

Product cost boundary — 313, 317

Criticality

Definition — 472

Customer remediation

Customers and records — 305, 409

Technical rollback and remedy — 292, 310

Customer rights

Provider disputes and preservation — 322, 323

Data drift

Definition — 472

Four drift forms — 295, 301

Data governance

Contracts and leakage prevention — 177

Provenance, quality and purpose — 175, 176

Decision evidence

Definition — 472

Evidence classes — 50

Decommissioning — see Retirement

Delegated authority

Definition — 472

Minimum useful authority — 216

Deployed configuration

Definition — 472

Operating-state verification — 290

Domain playbooks

Common decision canvas — 375, 379

Copilots and credit support — 375, 376

Financial crime and consequential automation — 376, 377

Evidence bundle

Definition — 472

Contents and connected records — 49, 50, 67

Roles and degraded access — 58, 62, 63

Security and resilience — 60

Evidence gap

Definition — 472

Evidence lineage

Lifecycle and durable history — 52, 55, 359

Evidence ownership

Ownership, retention and roles — 57, 58

Evidence plane

Definition — 472

Five classes and eight families — 58

Relationship key and runtime dependencies — 63

Exception

Definition — 473

Exit

Dependency and exit manifest — 336

Planned and stressed exit — 328, 413

Provider terms and tested capability — 322, 324, 415

Qualification and transition — 330

Readiness and exercises — 335, 414

Explainability

Audience, action and bounded examples — 267, 271

Failure domain

Definition — 473

End-to-end dependencies — 319, 320

Fairness

Decision and affected population — 264

Fallback

Definition — 473

Approved service and contract — 289, 292

Safe continuity route — 327

Feature flags

Emergency changes — 290

Governance

Ownership and policy-position record — 147, 148

Human oversight

Practical intervention and redress — 267, 268, 270

Human-in-the-loop

Definition — 473

Human-on-the-loop

Definition — 473

Impact tolerance

Definition — 473

Implementation evidence

Definition — 473

Evidence classes — 50

Incidents

Customer-impact example and reporting — 308, 309

Detection, containment and investigation — 304

Remedy and reapproval — 305, 310

Independent challenge

Definition — 473

Evidence and decision distinctions — 55, 359

Independence and validation scope — 277

Intended use

Specification and decision boundaries — 124, 126

Knowledge drift

Definition — 473

Four drift forms — 295, 301

Knowledge governance

Authority, precedence and entitlement — 184, 185, 186

Lending

Bounded trace and impact-assessment handoff — 386

Lifecycle

Accountable phases and re-entry — 22, 23, 39, 41, 42

Manifest

Definition — 473

Materiality

Definition — 473

Maturity

Demonstrated capability and observable states — 368, 369

Meaningful oversight

Definition — 473

Governed software and action boundaries — 92, 217

Model

Definition — 473

Model drift

Definition — 473

Model supply chain

Identity and supplier evidence — 197, 198

Provider changes — 199, 200, 202

Monitoring

Continuous evaluation and feedback — 296, 297

Measurement and executive dashboards — 300, 301

Signals, owners and action — 295, 297, 298

Non-AI alternative

Definition — 473

Observability — see Monitoring

Operating evidence

Definition — 473

Evidence classes and effectiveness — 50, 55

Operating model

Capability, incentives and reviewer capacity — 354, 355

Federated structure and durable accountability — 348, 349, 350

Operating service

Definition — 474

Release-state and identity checks — 286, 293

Performance

Service objectives — 312

Preservation

Lawful evidence and residual duties — 55, 323, 343

Privacy

Engineering across the flow — 263

Privilege, lawful basis, confidentiality and retention — 325

Product plane

Definition — 474

Progressive exposure

Evidence collection — 288

Prohibited use

Definition — 474

Observable boundaries — 126

Proposed control

Definition — 474

Proposition support

Definition — 474

Provider dependencies

Concentration and shared failure domains — 319, 335

Evidence and provider incidents — 322, 331

Quality gates

Decision and matched evidence — 276

RAG — see Retrieval-augmented generation (RAG)

Re-entry trigger

Definition — 474

Changed claims and controlled feedback — 338, 339

Recovery

Incident recovery decision — 305

Objectives and capacity evidence — 315

Red teaming

Coverage and independence — 249, 250

Structured challenge and scenario records — 246, 247

Release

Package and operating verification — 288, 290

Topology, reconciliation and customer experience — 291

Release identity

Definition — 474

Lineage and exact release — 52, 54, 296

Reliability

Dependencies and degradation — 314

Retirement

Closure record and worked example — 341

Decision and decommissioning — 340, 341

Evidence and residual duties — 343

Retrieval-augmented generation (RAG)

Definition — 474

Retrieval and answer quality — 187

Risk

Control intensity and risk questions — 83, 359

Risk classification

Criticality, materiality and assembled use — 136, 137

Local and legal routes — 138, 140

Risk-triggered control

Definition — 474

Rollback

Customer remediation distinction — 292

Dependency and refusal conditions — 288, 289

RPO

Definition — 474

RTO

Definition — 474

Security

Evidence-index controls — 60

Severe failure

Definition — 474

State machines

Explicit workflow and output handling — 209, 210, 211

Sustainability

Defensible measurement boundary — 315, 317

Synthetic examples

Evaluation and acceptance — 134, 240

Incidents, capacity and resilience — 310, 318, 332

Longitudinal policy-assistant trace — 381, 382

Telemetry

Release identity — 296

Termination

Containment and protected attribution — 217

Third-party dependencies — see Provider dependencies

Threat modeling

Canonical product threat model — 257, 258

Flows and enforcement — 254, 255

Tools

Privileged interfaces and contracts — 207, 212

Transformation

Portfolio and self-assessment — 371

Risk reduction and proof points — 370

Trust boundary

Definition — 474

Validation

Definition — 474

Evaluation under uncertainty — 242

Value hypothesis

Credible alternative and observable mechanism — 102, 103

Investment dispositions — 118, 121

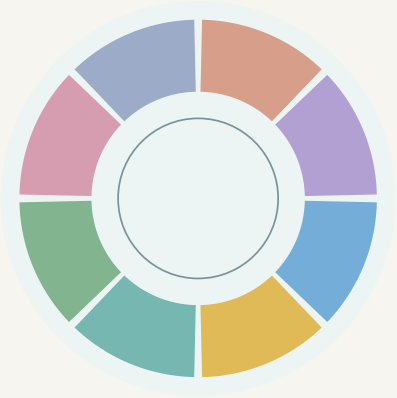
Workflow

State, tools and behavioral assembly — 205, 209, 211

Workload identity

Definition — 474

The AI Software Development Lifecycle for Banking



About the Author

Imitiyaz Basha K M is a technology engineering leader with more than 18 years of experience in banking. He has delivered digital banking, cloud, API and DevSecOps initiatives for Standard Chartered, Citi, Credit Suisse, DBS and Affin Bank.

His background spans software delivery, architecture, security, project and vendor management, and leading cross-functional teams. This book draws on that experience to offer a practical approach to engineering and governing AI products in banking.

He holds a master's degree in Computer Applications from Anna University, India. His professional certifications include PMP, TOGAF Enterprise Architecture Practitioner, CCSP and AWS Certified AI Business Strategist.

Governed · Secure · Resilient · Auditable

https://github.com/Imitiyaz/ai-sdlc

https://www.linkedin.com/in/imitiyaz

Imitiyaz Basha K M

© 2026 Imitiyaz Basha K M. All rights reserved.